Министерство науки и высшего образования Российской Федерации
Федеральное государственное бюджетное образовательное учреждение высшего образования
«Воронежский государственный технический университет»
(ФГБОУ ВО «ВГТУ», ВГТУ)

Факультет Информационных технологий и компьютерной безопасности
Кафедра Систем информационной безопасности
Направление подготовки (специальность) 10.05.03 Информационная безопасность автоматизированных систем
(код и наименование направления подготовки)
Профиль/программа/направленность Обеспечение информационной безопасности распределённых информационных систем

ВЫПУСКНАЯ КВАЛИФИКАЦИОННАЯ РАБОТА

Дипломная работа
(вид выпускной квалификационной работы – бакалаврская работа, дипломная работа (проект), магистерская диссертация)
Есауленко Виктории Витальевны
(фамилия, имя, отчество обучающегося)

Тема: Оценка и регулирование рисков успешности реализации в АИС кибератак класса «Злоупотребление механизмами обработки данных»

Состав выпускной квалификационной работы:

Расчетно-пояснительная записка на 239 страницах
Графическая часть на _____ листах

Расчетно-пояснительная записка к выпускной квалификационной работе:

Заведующий кафедрой _____ (А.Г. Остапенко)
(подпись) *(инициалы, фамилия)*

Руководитель _____ (Л.В.Паринова)
(подпись) *(инициалы, фамилия)*

Консультанты:
по _____ (_____)
(наименование раздела, подпись) *(инициалы, фамилия)*

по _____ (_____)
(наименование раздела, подпись) *(инициалы, фамилия)*

по _____ (_____)
(наименование раздела, подпись) *(инициалы, фамилия)*

Обучающийся _____ В.В.Есауленко
(подпись) *(инициалы, фамилия)*

«02» 07 2025 г.

Министерство науки и высшего образования Российской Федерации
Федеральное государственное бюджетное образовательное учреждение высшего образования
«ВОРОНЕЖСКИЙ ГОСУДАРСТВЕННЫЙ ТЕХНИЧЕСКИЙ УНИВЕРСИТЕТ»
(ФГБОУ ВО «ВГТУ», ВГТУ)

Факультет Информационных технологий и компьютерной безопасности
Кафедра Систем информационной безопасности
Направление подготовки (специальность) 10.05.03 Информационная безопасность автоматизированных систем
(код и наименование направления подготовки)
Профиль/программа/направленность Обеспечение информационной безопасности распределённых информационных систем

Утверждаю _____
(дата)
Зав.кафедрой _____
(подпись)

ЗАДАНИЕ
ПО ПОДГОТОВКЕ ВЫПУСКНОЙ КВАЛИФИКАЦИОННОЙ РАБОТЫ

Дипломная работа
дипломная работа (проект), бакалаврская работа, магистерская диссертация

Обучающемуся Есауленко Виктории Витальевны
фамилия, имя, отчество

1. Тема: Оценка и регулирование рисков успешности реализации в АИС кибератак класса «Злоупотребление механизмами обработки данных»

по заданию какой организации выполняется работа
ФГБОУ ВО «ВГТУ», ВГТУ

приказ № 01-1-10/3-2979 от 25.06.2025
утверждена приказом по университету

2. Срок сдачи обучающимся выпускной квалификационной работы 02.07.25

3. Исходные данные

4. Краткое содержание выпускной квалификационной работы
Раздел 1. Исследование баз данных угроз и инструментов для оценки кибератак
Раздел 2. Определение взаимосвязей между техниками атак и уязвимостями для построения графовой модели рисков
Раздел 3. Моделирование рисков и оценка вероятности успешной реализации кибератак
Раздел 4. Разработка организационных мер по снижению рисков реализации выявленных сценариев атак

5. Перечень графического материала (с точным указанием обязательных чертежей по разделам

6. Консультанты (с указанием относящихся к ним разделов)

График выполнения выпускной квалификационной работы

№ п/п	Наименование разделов выпускной квалификационной работы	Срок выполнения этапов работы
1	Введение	22.03.2025-22.05.2025
2	Исследование баз данных угроз и инструментов для оценки кибератак	22.03.2025-22.05.2025
3	Определение взаимосвязей между техниками атак и уязвимостями для построения графовой модели рисков	23.05.2025-31.05.2025
4	Моделирование рисков и оценка вероятности успешной реализации кибератак	01.06.2025-12.06.2025
5	Разработка организационных мер по снижению рисков реализации выявленных сценариев атак	13.06.2025-24.06.2025
6	Заключение	25.06.2025-02.07.2025

Руководитель _____ (подпись)

Дата выдачи задания 22.03.25

Задание принял к исполнению 22.03.25 (дата)

Подпись обучающегося _____

Министерство науки и высшего образования Российской Федерации
Федеральное государственное бюджетное образовательное учреждение высшего образования
«Воронежский государственный технический университет»

АННОТАЦИЯ
выпускной квалификационной работы

Обучающейся Есауленко Виктории Витальевны

Тема ВКР: Оценка и регулирование рисков успешности реализации в АИС кибератак класса «Злоупотребление механизмами обработки данных»

Характеристика выпускной квалификационной работы

Актуальность исследования

Исследование обусловлено необходимостью разработки эффективных методов оценки и регулирования рисков успешной реализации кибератак класса «Злоупотребление механизмами обработки данных».

Задачи, решаемые в ВКР

- организация, сбор открытых интернет-источников и суммаризации данных относительно пар «атака – уязвимость» в отношении автоматизированных информационных систем;
- установление соответствия между кибератаками класса «Злоупотребление механизмами обработки данных» и уязвимостями в автоматизированных информационных системах, включая их сценарное описание;
- оценка рисков нарушения информационной безопасности посредством кибератак класса «Злоупотребление механизмами обработки данных» на уязвимости в автоматизированных информационных системах;
- формирование регламентов реагирования и ликвидации последствий в отношении кибератак класса «Злоупотребление механизмами обработки данных» на уязвимости в автоматизированных информационных системах.

Структура ВКР

Введение – 8 страниц;

Глава 1. Исследование баз данных угроз и инструментов для оценки кибератак – 24 страницы;

Глава 2. Определение взаимосвязей между техниками атак и уязвимостями для построения графовой модели рисков – 36 страниц;

Глава 3. Моделирование рисков и оценка вероятности успешной реализации кибератак – 71 страница;

Глава 4. Разработка организационных мер по снижению рисков реализации выявленных сценариев атак – 5 страниц;

Заключение –2 страницы;

Список литературы – 10 страниц;

Приложение А – 65 страниц;

Приложение Б – 11 страниц.

Краткая характеристика полученных результатов *(по разделам ВКР)*

Раздел 1. Исследование баз данных угроз и инструментов для оценки кибератак.

Изучена структурированная база данных кибератак класса «Злоупотребление механизмами обработки данных» на АИС, аккумулирующая статистические и экспертные метрики, извлечённые из открытых интернет-источников.

Раздел 2. Определение взаимосвязей между техниками атак и уязвимостями для построения графовой модели рисков.

Представлено векторное представление пар «атака – уязвимость» на основе анализа стандартов CAPEC, CWE и CVE, отражающее динамику развития атак злоумышленника в ходе взаимодействия с АИС.

Раздел 3. Моделирование рисков и оценка вероятности успешной реализации кибератак.

Проведена методика оценки рисков нарушения информационной безопасности АИС в результате реализации кибератак класса «Злоупотребление механизмами обработки данных», с учётом специфики используемых злоумышленников сценариев.

Раздел 4. Разработка организационных мер по снижению рисков реализации выявленных сценариев атак

Сформирован комплекс регламентов реагирования и ликвидации последствий в отношении кибератак класса «Злоупотребление механизмами обработки данных» на уязвимости АИС.

Автор ВКР _____ Есауленко Виктория Витальевна
(подпись)

СОДЕРЖАНИЕ

Введение 7
1 Исследование баз данных угроз и инструментов для оценки кибератак 15
1.1 Исследование существующих баз данных CAPEC, MITRE ATT&CK, NVD, БДУ ФСТЭК России и нормативных документов в области кибератак 15
1.2 Изучение характеристик риск-калькуляторов 28
2 Определение взаимосвязей между техниками атак и уязвимостями для построения графовой модели рисков 39
2.1 Установление соответствий между CAPEC-шаблонами атак и эксплуатируемыми ими уязвимостями 39
2.2 Разработка последовательностей реализации MITRE-техник 63
3 Моделирование рисков и оценка вероятности успешной реализации кибератак 75
3.1 Определение оценки критичности эксплуатируемых уязвимостей 75
3.2 Создание алгоритмов для расчета вероятности успеха каждой техники в рамках сценария атак 92
3.3 Расчет и анализ рисков успешной реализации сценариев атак 136
4 Разработка организационных мер по снижению рисков реализации выявленных сценариев атак 146
4.1 Меры реагирования и ликвидации последствий реализации сценариев атак 146
Заключение 151
Список литературы 153
Приложение А 163
Приложение Б 228

ВВЕДЕНИЕ

Проблема безопасности киберпространства [1-8] неуклонно возрастает по своей актуальности, так, как только в Российской Федерации:

- 22% компании сталкиваются с угрозой утечки информации, из них 15% понесли серьезные ущербы в этой связи;

- 70% компаний испытали заражение вредоносным ПО;

-73% компаний сталкиваются с несанкционированным доступом к информации;

- 62% компаний испытывают на себе DDoS-атаки.

При этом, реализовались следующие угрозы для:

- 37% компаний – это компрометация учетных записей;

- 37% компаний – это программы-шифровальщики;

- 25% компаний – это эксплуатация уязвимостей;

- 32% компаний – это подбор паролей;

- 16% компаний – это инсайдеры;

- 7% компаний – это подмена интерфейсов.

В 54% инцидентов ущерб наносился по вине внешних нарушителей, а в 30% - из-за внутренних злоумышленников. В 15% случаев установить источник угроз не удалось.

Однако только 40% крупных компаний имеют отделы, обеспечивающих кибербезопасность, а в 55% компаний за информационную безопасность отвечают IT-службы. При этом 83% компаний хотят перейти на обслуживание во внешний центр мониторинга кибербезопасности.

При таком подходе не приходится надеяться на кардинальные улучшения защищенности киберпространства и поэтому компаниям предлагаются разнообразные базы данных [1-14] и калькуляторы [15-26], позволяющие компаниям самостоятельно оценивать критичность возникающих у них угроз.

Однако разноплановость и неполнота информационных возможностей вышеупомянутого инструментария обуславливают необходимость уточняющих и систематизирующих исследований в этом направлении [27-50].

Перечисленные работы ориентированы на различные объекты: предприятия [27-30], корпоративные сети [31-33] и иные объекты информатизации [35-40], а также сетевое киберпространство [36-47] в отношении противодействия разнообразным кибератакам [48-50] и уязвимостям [36, 38, 39, 41], в том числе с использованием средств искусственного интеллекта [43, 44]. Однако общим предметом исследования в них выступают оценка и регулирование информационных рисков, чему, собственно, и посвящена настоящая работа.

Атаки класса «Злоупотребление механизмами обработки данных» представляют серьезную угрозу для современных информационных систем. Злоумышленники, использующие этот тип атак, не обходят системы безопасности напрямую, защиты, а используют законные способы обработки информации для совершения неразрешенных действий. Это может включать в себя изменение данных, обход контроля доступа, выполнение произвольного кода и другие вредоносные действия. В данной работе будет изучено деструктивное воздействие таких атак на информационные системы, обеспечивающие работу критически важных сервисов, а также предложены методы повышения их защиты к данному классу угроз.

В последнее время наблюдается стремительный рост кибератак, которые связанны с «Злоупотреблением механизмами обработки данных», особенно в контексте API. Отчет Wallarm API ThreatStats 2025 раскрывает беспрецедентную тенденцию: количество атак на API неуклонно растет, которое обусловлено активным внедрением искусственного интеллекта. Количество уязвимостей, связанных с ИИ, увеличилось на 1205% по сравнению с прошлым годом, достигнув 439 зафиксированных случаев. Кроме того, впервые выявлен новый вид атак - Memory Corruption and Overflow, напрямую связанный с некорректной обработкой памяти и потенциально ведущий к утечкам данных, сбоям и запуску произвольного кода. Анализ каталога KEV от CISA

демонстрирует рост на 30% доли атак на API, которые теперь составляют больше половины всех эксплуатируемых уязвимостей, превзойдя традиционные векторы атак. Частота API-инцидентов также заметно выросла: с одного раза в квартал в 2023 году до 3-5 атак в месяц в 2024 году, при этом особенно подвержены риску финансовый, медицинский и транспортный секторы. DDoS-атаки на API также показывают двукратный рост в России в IV квартале 2024 года по сравнению с аналогичным периодом 2023 года, причем 70% атак направлены на розничную торговлю и банковский сектор [51-53].

Изложенное выше имеет непосредственное отношение к рассматриваемому в настоящей работе множеству шаблонов кибератак класса «злоупотребление механизмами обработки данных». Аналоги [54-58], описывающие это множество атак данного вида, свидетельствуют о росте активности использования злоумышленниками данного типа атак.

«Злоупотребление механизмами обработки данных» набирает обороты среди киберпреступников. Исследования Symantec демонстрируют, что хакеры, включая APT28, Red Stinger и OilRig, активно задействуют Microsoft Graph API для скрытого управления своими командными серверами в облачной среде Microsoft, искусно обходя системы защиты. Вредоносные программы, такие как Graphon (обнаружен в июне 2021) и BirdyClient (применялся в недавних атаках на Украине), показывают, как злоумышленники могут использовать легитимные API, например, OneDrive, для передачи данных и управления зараженными системами. Более того, исследования Permiso указывают на возможность злоупотребления административными командами облачных платформ для манипуляций с виртуальными машинами, особенно при наличии взломанных учетных записей подрядчиков или сторонних лиц с привилегированным доступом. Такие методы делают атаки особенно опасными, поскольку использование популярных облачных сервисов, таких как OneDrive, зачастую не вызывает подозрений у служб безопасности [59].

Несмотря на разнообразие методов оценки киберугроз в современных информационных системах, их адаптация для эффективной защиты от атак класса «Злоупотребление механизмами обработки данных» остаётся недостаточной. Часто не используются современные фреймворки, к примеру, матрица MITRE ATT&CK, для подробного анализа тактик и техник злоумышленников. Это приводит к ограниченному пониманию сценариев атак и снижает эффективность защитных мер. В данной работе предложены вероятностные сценарии на базе MITRE ATT&CK, которые дают специалистам более полное представление о действиях злоумышленника на каждом шаге. Разработанные регламенты содержат конкретные рекомендации по реагированию и ликвидации последствий, учитывая специфику данного класса атак и превосходя обобщённые подходы из аналогичных исследований.

Проведенное исследование аналогов [54-58] позволяет предложить следующее целеполагание настоящего исследования.

Объектом исследования выступают автоматизированные информационные системы, подвергающиеся атакам класса «Злоупотребление механизмами обработки данных».

Предметом исследования являются процессы обеспечения информационной безопасности автоматизированных информационных систем при воздействии кибератак класса «Злоупотребление механизмами обработки данных», включающие анализ взаимосвязей между шаблонами атак, техниками и эксплуатируемыми уязвимостями, моделирование сценариев атак, оценку рисков с использованием различных метрик, а также разработку рекомендаций по противодействию подобным инцидентам на основе анализа вероятности эксплуатации уязвимостей и потенциального ущерба.

Цель исследования состоит в повышение защищенности автоматизированных информационных систем от атак класса «Злоупотребление механизмами обработки данных».

Исследование аналогов показало наличие ряда **противоречий** между:

– необходимостью наличия достаточного объема данных и иных актуальных сведений относительно пар «атака - уязвимость» для атакуемых автоматизированных информационных систем и отсутствием такового для атак класса «Злоупотребление механизмами обработки данных»;

– потребностью установления соответствия элементов множества рассматриваемого класса атак и уязвимостей, обусловленных отсутствием таковых в проектном пространстве обеспечения безопасности защищенных автоматизированных информационных систем;

– существующей методологией вероятностной оценки опасности кибератак класса «Злоупотребление механизмами обработки данных» использующей калькуляторы CVSS, EPSS, OWASP и необходимостью риск-анализа вторжений в автоматизированную информационную систему, которая отсутствует в сложившихся подходах;

– несовершенством процедур регламентации противодействия кибератакам класса «Злоупотребление механизмами обработки данных» и необходимостью осуществлять такую проектную деятельность в соответствии с этапом реализации вторжения злоумышленника в автоматизированные информационные системы.

Для разрешения перечисленных противоречий и достижения поставленной цели необходимо решить следующие **задачи**:

– организация, сбор открытых интернет-источников и суммаризации данных относительно пар «атака – уязвимость» в отношении автоматизированных информационных систем;

– установление соответствия между кибератаками класса «Злоупотребление механизмами обработки данных» и уязвимостями в автоматизированных информационных системах, включая их сценарное описание;

– оценка рисков нарушения информационной безопасности посредством кибератак класса «Злоупотребление механизмами обработки данных» на уязвимости в автоматизированных информационных системах;

– формирование регламентов реагирования и ликвидации последствий в отношении кибератак класса «Злоупотребление механизмами обработки данных» на уязвимости в автоматизированных информационных системах.

На защиту будут вынесены следующие **результаты**:

– структурированная база данных кибератак класса «Злоупотребление механизмами обработки данных» на АИС, аккумулирующая статистические и экспертные метрики, извлечённые из открытых интернет-источников;

– векторное представление пар «атака – уязвимость» на основе анализа стандартов CAPEC, CWE и CVE, отражающее динамику развития атак злоумышленника в ходе взаимодействия с АИС;

– методика оценки рисков нарушения информационной безопасности АИС в результате реализации кибератак класса «Злоупотребление механизмами обработки данных», с учётом специфики используемых злоумышленников сценариев;

– комплекс регламентов реагирования и ликвидации последствий в отношении кибератак класса «Злоупотребление механизмами обработки данных» на уязвимости АИС.

Новизна полученных результатов состоит в следующем:

– в отличие от аналогов, собранные данные с помощью предложенных выражений могут являться основой для вероятностного моделирования процесса реализации класса кибератак «Злоупотребление механизмами обработки данных», используемых в автоматизированных информационных системах, что обеспечивает основу для комплексной оценки и регулирования рисков в сфере обеспечения кибербезопасности АИС;

– впервые для класса кибератак «Злоупотребление механизмами обработки данных» была предложена обобщённая графическая модель сценариев атак, которая может быть использована злоумышленником для вторжения в АИС;

– в отличии от аналогов предложена методика оценки рисков сценариев нарушения информационной безопасности АИС при реализации кибератак класса «Злоупотребление механизмами обработки данных», а также определены наиболее

вероятные сценарии вторжения и сценарии максимального и минимального риска вторжения в АИС;

– для выявленных сценариев впервые предложены актуальные регламенты и методики противодействия кибератакам класса «Злоупотребление механизмами обработки данных».

Практическая ценность полученных результатов видится в том, что:

− созданная база данных метрик кибератак класса «Злоупотребление механизмами обработки данных» и уязвимостей АИС, является практической основой для риск-анализа единичных вторжений и имеет практическую возможность её расширения для соответствующих проектных ситуаций;

− сформированное множество сценариев и их риск-анализ отражает практику реализации проектной деятельности защиты АИС от атак класса «Злоупотребление механизмами обработки данных»;

− предоставленные оценки рисков представляют собой базу для их рецензирования при нарушении информационной безопасности АИС посредством кибератак класса «Злоупотребление механизмами обработки данных», в том числе путём закрытия эксплуатируемых уязвимостей АИС;

− предложенная регламентация является инструментом практического управления риск-ландшафтом успешности кибератак класса «Злоупотребление механизмами обработки данных» на защищаемые АИС.

Теоретическая значимость полученных результатов видится в том, что:

− сформированная база риск-метрик открыта для ее расширения на другие разновидности кибератак и прочие информационные системы, подверженные вторжению;

− разработанные сценарии атак класса «Злоупотребление механизмами обработки данных» в ходе проектной деятельности могут быть расширены на другие используемые тактики, либо сужены до непосредственных уязвимостей конкретно защищаемой АИС;

− представленные оценки рисков нарушения информационной безопасности посредством кибератак класса «Злоупотребление механизмами обработки данных», могут быть развиты для описания рисков многократных, поточных, множественных и лавинных сетевых вторжений при соответствующей модернизации методического обеспечения риск-анализа;

− в ходе развития методологии управления риск-ландшафтом успешности кибератак класса «Злоупотребление механизмами обработки данных» на уязвимости защищаемых АИС предоставляется возможным формирование соответствующих инструкций для специалистов по защите информации, обеспечивающих безопасность конкретных АИС.

1 Исследование баз данных угроз и инструментов для оценки кибератак

1.1 Исследование существующих баз данных CAPEC, MITRE ATT&CK, NVD, БДУ ФСТЭК России и нормативных документов в области кибератак

Информационные системы подвергаются постоянным рискам кибератак различного характера, среди которых атаки класса «Злоупотребление механизмами обработки данных» представляют серьезную опасность. Подобные атаки нацелены на эксплуатацию уязвимостей в механизмах обработки данных, таких как неправильное управление доступом, ненадлежащая проверка ввода и выходящие за рамки допустимых операций манипуляции с файлами и базами данных. Эти угрозы требуют особого подхода к обеспечению информационной безопасности.

Автоматизированные информационные системы являются основой функционирования многих организаций и предприятий. Их защита требует непрерывного улучшения подходов и методик. Одним из важных аспектов является использование стандартов и нормативных документов, регулирующих требования к безопасности информационных технологий. Среди них особенное внимание уделяется государственным стандартам (ГОСТ).

Для улучшения уровня защиты автоматизированных информационных систем от атак класса «Злоупотребление механизмами обработки данных» осуществлён анализ применимости ряда действующих государственных стандартов (ГОСТ), регламентирующих информационную безопасность. Рассмотрены следующие нормативные документы [60-65]:

1) ГОСТ Р ИСО/МЭК 15408-2-2013 «Информационная технология. Методы и средства обеспечения безопасности. Критерии оценки безопасности информационных технологий. Часть 2. Функциональные компоненты безопасности», как часть международных общих критериев (Common Criteria), ориентирован на оценку безопасности информационных технологий.

Стандарт охватывает широкий спектр мер, включая мониторинг, контроль доступа, идентификацию, криптографию и реагирование на инциденты. Однако, анализ

атак класса «Злоупотребление механизмами обработки данных» показывает, что стандарт может быть недостаточно конкретным в отношении этой категории угроз:

− недостаточная детализация механизмов обработки данных: ГОСТ Р ИСО/МЭК 15408-2-2013 не содержит конкретных рекомендаций по защите от атак, направленных на некорректное использование механизмов обработки данных;

− SQL-инъекции: стандарт не предоставляет прямых указаний по предотвращению SQL-инъекций, требующих специальных проверок входных данных;

− некорректное использование API: стандарт не содержит явных требований к проверке входных данных при взаимодействии с API;

− некорректная обработка файлов: недостаточно внимания уделено проверке целостности и типа данных при чтении и записи файлов;

− переполнение буфера: недостаточно конкретных мер, адресованных этому распространенному типу уязвимостей;

− фокус на общем уровне безопасности: стандарт больше ориентирован на общие принципы безопасности, чем на конкретные уязвимости, связанные с обработкой данных. Это может привести к тому, что при разработке мер безопасности, уязвимости в обработке данных останутся незамеченными;

− отсутствие конкретных методик защиты от атак: стандарт не предлагает конкретных методик или алгоритмов для анализа и устранения уязвимостей, связанных со спецификой обработки данных [60].

2) ГОСТ Р ИСО/МЭК 27001-2021 «Информационная технология. Методы и средства обеспечения безопасности. Системы менеджмента информационной безопасности. Требования», ориентирован на установление, внедрение и поддержание СУИБ, обеспечивая уверенность в управление рисками. Вместе с тем, анализ демонстрирует, что его прямое применение к злоупотреблению механизмами обработки данных, как отдельному классу атак, может быть ограничен.

Стандарт описывает общие принципы управления рисками и процессами реагирования, но не даёт конкретных, детальных рекомендаций по защите от атак, нацеленных на некорректное использование механизмов обработки данных. Вот основные недостатки:

− отсутствие прямого фокуса на обработку данных: стандарт фокусируется на управлении рисками в целом, а не на специфических уязвимостях обработки данных, таких как SQL-инъекции, переполнение буфера или неверное применение API. Он не предоставляет конкретных методик, как проверять данные на соответствие, или предотвращать уязвимости, связанных с определенными типами обработки;

− недостаточная детализация контроля входящих данных: хотя стандарт затрагивает контроль доступа, он не уделяет должного внимания проверке данных на входе. Этот аспект важен для предотвращения атак класса «Злоупотребление механизмами обработки данных», которые, по сути, вводят в систему некорректные данные;

− общее реагирование на инциденты: стандарт предлагает общие процедуры реагирования на инциденты, но не предоставляет конкретных шагов для определения, реагирования или восстановления после атаки, связанной с некорректной обработкой данных;

− управление рисками, а не уязвимостями: стандарт фокусируется на управлении рисками, связанными с обрабатываемыми данными, но не детализирует методы анализа, понимания и устранения конкретных уязвимостей в механизмах обработки, которые открывают путь для атак [61].

3) ГОСТ Р 59710-2022 «Защита информации. Управление компьютерными инцидентами. Общие положения», уделяющий внимание регулированию компьютерными инцидентами, представляет собой стандарт, нацеленный на общую систему управления кибербезопасностью.

ГОСТ Р 59710-2022, являясь общим стандартом, имеет определенные ограничения в отношении класса атак «Злоупотребление механизмами обработки данных:

− недостаточная детализация обработки данных: стандарт не содержит определенных рекомендаций по защите от атак, нацеленных на некорректное использование механизмов обработки. К примеру, он не подробно описывает методы валидации входных данных, проверки типов данных или предотвращения SQL-инъекций [62];

− акцент на реагировании, а не на предотвращении: стандарт акцентирует внимание на реагировании инцидентов, а не на профилактических мерах. Хотя реагирование важно, превентивные меры по предотвращению уязвимостей в обработке данных (например, проверка данных на входе) имеют решающее значение;

− общее управление доступом: стандарт затрагивает управление доступом, но не предоставляет конкретных рекомендаций по настройке систем для пресечения злоупотребления доступа к данным и системам обработки данных. Конкретные политики контроля доступа и ролей пользователей, необходимые для защиты от подобных атак, не детализированы;

Отсутствие конкретных методик проверки: стандарт не предлагает конкретных методик для анализа уязвимостей в процессах обработки данных или разработки специализированных систем мониторинга данных, которые могут быть уязвимы для атак.

4) ГОСТ Р 59711-2022 «Защита информации. Управление компьютерными инцидентами. Организация деятельности по управлению компьютерными инцидентами», описывает организацию и процессы, необходимые для эффективного реагирования на инциденты. Однако его прямая применимость к злоупотреблению механизмами обработки данных может быть ограничена.

Стандарт, сфокусированный на управлении инцидентами, не предоставляет достаточно детальных рекомендаций по предотвращению самих атак класса «Злоупотребление механизмами обработки данных»:

− акцент на реагировании, а не на предотвращении: ГОСТ Р 59711-2022 акцентирует внимание на реагировании на инциденты, а не на профилактических мерах. Для защиты от атак, нацеленных на уязвимости в обработке данных, критически важно предотвращать эти уязвимости, а не только реагировать на них [63];

− отсутствие конкретных рекомендаций по валидации данных: стандарт не содержит конкретных рекомендаций по проверке входных данных, валидации типов данных или предотвращению атак типа SQL-инъекции;

− недостаточная детализация анализа уязвимостей: хотя стандарт предусматривает анализ причин инцидентов, он не предлагает конкретных методов анализа уязвимостей в обработке данных, которые могут быть использованы для атак;

− ограниченное внимание к специфике обработки информации: стандарт акцентирует внимание на общих процедурах, не уделяя достаточного внимания специфике различных механизмов обработки информации (SQL, API, файловые системы).

5) ГОСТ Р 59547-2021 «Защита информации. Мониторинг информационной безопасности. Общие положения», описывает процессы мониторинга и управления рисками, предназначенные для обеспечения информационной безопасности, включая конфиденциальность, целостность и доступность информации. Однако, разбор показывает, что прямой упор на класс атаки: «Злоупотребление механизмами обработки данных» ограничен.

Хотя стандарт содержит важные элементы, такие как мониторинг и управление изменениями, его прямое применение к атакам, применяющим уязвимости в обработке информации, имеет ограничения:

− недостаточная детализация проверки входных данных: стандарт не предоставляет конкретных рекомендаций по проверке входных данных, валидации типов данных, предотвращению SQL-инъекций, переполнению буфера или другим видам атак, использующим неверную обработку данных;

− упор на обнаружении, а не на предотвращении: стандарт акцентирует внимание на обнаружении атак после их начала, а не на предотвращении уязвимостей, используемых злоумышленниками. Предотвращение – более эффективная стратегия;

− отсутствие конкретных методик анализа уязвимостей в обработке: стандарт не предлагает методик для анализа уязвимостей в конкретных механизмах обработки информации (SQL, API, файловые системы);

− недостаточная детализация мониторинга данных: стандарт охватывает мониторинг информационных систем в целом, но не указывает на конкретные метрики и методы мониторинга, которые должны применяться для обнаружения атак, связанных с обработкой информации [64].

6) ИСО/МЭК 13335-1:2006. «Информационная технология. Методы обеспечения безопасности. Управление безопасностью информационных и телекоммуникационных технологий. Часть 1. Концепция и модели управления безопасностью информационных и телекоммуникационных технологий».

Сложности применимости к атакам типа «Злоупотребление механизмами обработки данных»:

− нехватка конкретных мер по защите от уязвимостей в обработке данных: стандарт не содержит методов валидации входных данных, предотвращения инъекций, переполнения буфера и иных типов атак, применяющих некорректную обработку данных;

− акцент на общих принципах, а не на конкретных способах: стандарт описывает общие принципы безопасности, такие как контроль доступа и мониторинг, но не предлагает практичных рекомендаций по защите от уязвимостей в обработке данных;

− недостаточная детализация мониторинга обработки данных: хотя стандарт затрагивает мониторинг, он не детализирует, как конкретно мониторить и анализировать события, связанные с обработкой данных для выявления подозрительной активности;

− Общий характер контроля доступа: контроль доступа, описанный в стандарте, не гарантирует конкретных мер по защите от злоупотреблений механизмами обработки данных, например, от атак SQL-инъекций, где необходим строгий контроль типов данных и валидации входных параметров [65].

Рассмотренные стандарты описывают общие принципы создания системы информационной безопасности и противодействия киберугрозам. Однако, в отношении

класса атак «Злоупотребление механизмами обработки данных» они оказываются недостаточными. Стандарты фокусируются на обнаружении и управлении инцидентами, уделяя мало внимания разработке профилактических мер.

Для эффективной защиты от таких атак, как SQL-инъекции, некорректное использование API или ошибки обработки файлов, необходимы дополнительные методики. Это включает строгий контроль и фильтрацию вводимых данных, применение специализированных решений для защиты баз данных и веб-приложений, шифрование данных и регулярное тестирование на уязвимости.

Данный недостаток стандартов подчёркивает необходимость использования дополнительных источников информации, постоянно обновляемых баз знаний, которые отслеживают появление новых типов атак и предоставляют актуальные способы защиты от них.

1) CAPEC (Common Attack Pattern Enumeration and Classification), каталог известных шаблонов атак в кибербезопасности. Созданный в 2007 году Министерством внутренней безопасности США (как инициатива Управления кибербезопасности и коммуникаций), CAPEC сейчас поддерживается и управляется некоммерческой организацией MITRE, которая также заведует рядом исследовательских центров, спонсируемых федеральным правительством [66].

CAPEC − это не просто перечень уязвимостей, а всеобъемлющий словарь и таксономия известных моделей атак. Он предоставляет структурированное представление о враждебных действиях, охватывающее весь процесс атаки − от разведки до исполнения. В отличие от традиционных каталогов уязвимостей, фокусирующихся на технических аспектах, CAPEC описывает схемы атак, включая их цели, механизмы и возможные способы защиты [9]. Каждая запись содержит информацию о сложности реализации атаки, что позволяет точнее оценить уровень риска. Этот общий стандарт терминологии для моделей кибератак используется специалистами в области кибербезопасности для предотвращения атак и повышения общего понимания угроз.

CAPEC призван создать общедоступный, интуитивно понятный каталог распространенных образцов атак и обеспечить единую схему для описания и обмена информацией о них. Его ценность подтверждается практическим применением: например, команда IBM X-Force использовала CAPEC для группировки методов атак, обнаруженных в 2016 году, при составлении Индекса анализа угроз за 2017 год. Благодаря CAPEC, аналитики, разработчики и тестировщики получают более полное представление о современных атаках и способах их предотвращения [67].

Однако, несмотря на широкое применение и значительную ценность CAPEC, этот каталог имеет два основных противоречия, которые ограничивают его эффективность.

Во-первых, существует необходимость в получении полной и достаточной информации о шаблонах атак для результативного использования, но при этом отсутствует полноценный и актуальный перевод материалов на русский язык, что усложняет применение CAPEC специалистами, не владеющими английским языком.

Во-вторых, хотя CAPEC предоставляет описание различных мер противодействия каждой атаке на своём официальном сайте, но для большинства шаблонов такие рекомендации отсутствуют или представлены недостаточно детально. Это создает трудности при практическом внедрении защитных мер и понижает полезность каталога как инструмента комплексного анализа и предотвращения кибератак.

2) MITRE ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge) − общедоступная база знаний о тактиках и методиках злоумышленников, основанная на реальных наблюдениях. Разработанная MITRE в 2013 году, ATT&CK использует опыт профессионалов по кибербезопасности для документирования конкретных техник, тактик и процедур (TTP), применяемых киберпреступниками [68].

ATT&CK служит фундаментом для разработки моделей угроз и методологий, используемых в частном секторе, правительстве, а также сообществом разработчиков продуктов и сервисов в сфере кибербезопасности. Она позволяет аналитикам и специалистам по безопасности не только классифицировать атаки, но и глубже понимать методы взаимодействия злоумышленников с целевыми системами, их подходы на

каждом этапе атаки и способы противодействия этим действиям. По мере обнаружения новых уязвимостей и векторов атак, они добавляются в структуру ATT&CK, обеспечивая ее постоянное развитие и актуальность.

Основываясь на реальных данных о произошедших инцидентах безопасности, MITRE ATT&CK стала отраслевым стандартом для знаний и инструментов предотвращения кибератак. Её структура разделена на секции, отражающие тактические и технические действия, характерные для кибератак. Используя MITRE ATT&CK, специалисты могут не только исследовать произошедшие атаки, но и разрабатывать эффективные стратегии для предотвращения потенциальных угроз. ATT&CK является открытой и доступной для бесплатного использования любым человеком или организацией [10-11].

MITRE ATT&CK предоставляет уникальную возможность глубокого анализа деяний злоумышленников, позволяя специалистам по безопасности улучшить эффективность обороны на всех фазах кибератаки.

Несмотря на широкое признание и значительную ценность MITRE ATT&CK как базы знаний о тактиках, техниках и процедурах (TTP) злоумышленников он обладает рядом недостатков, ограничивающих его практическое применение:

− основной проблемой считается неполнота сведений. В базу данных включаются лишь те техники, которые уже были зафиксированы в реальных атаках. Это подразумевает, что новые, еще не обнаруженные методы атак, не представлены в ATT&CK. Более того, он не всегда адекватно отражает угрозы от внутренних злоумышленников, нередко игнорируя специфику атак, исходящих изнутри организации;

− обширный объем информации в ATT&CK может осложнять анализ и понимание. Большое количество тактик и приемов требует значительных усилий для освоения и эффективного использования. Постоянное обновление матрицы, необходимое для учета новых методов атак, также представляет трудности для организаций с ограниченными ресурсами. Кроме того, корреляция данных из разных источников (мобильные устройства, конечные точки, облачные сервисы) может быть затруднена;

- несмотря на регулярные обновления, ATT&CK не всегда способен отражать реальную последовательность действий злоумышленников в современных атаках. Новые векторы атак, связанные с развитием технологий (например, облачных технологий), могут оставаться незамеченными или недостаточно подробно описанными. В итоге, несмотря на свою полезность, MITRE ATT&CK требует критического осмысления и использования в сочетании с другими методами анализа угроз.

3) NVD (National Vulnerability Database) – государственное хранилище США, управляемое Национальным институтом стандартов и технологий (NIST).

NVD – это централизованная база данных, включающая стандартизированные сведения об управлении уязвимостями, представленные в формате, совместимом с протоколом автоматизации управления контентом безопасности (SCAP), что позволяет автоматизировать управление уязвимостями, оценивание безопасности и соблюдение нормативных требований [14]. База данных была отключена в 2013 году из-за взлома правительственных сайтов через уязвимость Adobe ColdFusion.

В отличие от CAPEC и ATT&CK, ориентированных на атакующие паттерны или техники, NVD сосредоточена на систематизации информации об известных уязвимостях в программном обеспечении. NVD содержит базы данных с контрольными списками безопасности, уязвимостями программного обеспечения, связанными с безопасностью, неверными настройками, названиями продуктов и показателями воздействия. NVD поддерживает программу автоматизации информационной безопасности (ISAP).

Информация об уязвимостях включает описания, рекомендации по исправлению и рейтинг серьезности, основанный на общей системе оценки уязвимостей (CVSS), которая учитывает сложность доступа, наличие решения и другие факторы. Несмотря на то, что, по данным Recorded Future, большинство уязвимостей публикуются неофициально до попадания в NVD (со средним сроком публикации 7 дней), NVD остается важным ресурсом для анализа и оценки рисков и тесно интегрируется с другими базами данных, такими как MITRE ATT&CK и CAPEC, а также с инструментами управления уязвимостями и SIEM-системами, что позволяет специалистам

разрабатывать комплексные стратегии защиты и быстро реагировать на новые угрозы. Интеграция NVD с автоматизированными системами помогает компаниям, работающим с большими объёмами данных, улучшить процессы обнаружения инцидентов и реагирования на них.

В августе 2023 года вспыхнул спор вокруг бреши переполнения целых чисел в устаревших версиях cURL. NVD (National Vulnerability Database) сначала оценила её как критическую, присвоив рейтинг 9,8 из 10. Но, ведущий разработчик cURL, Дэниел Стенберг, не согласился с данной оценкой, заявив, что проблема была устранена четыре года назад, и обвинил NVD в нагнетании ажиотажа. Он потребовал отклонить CVE (Common Vulnerabilities and Exposures).

Несмотря на возражения Стенберга, MITRE, организация, присваивающая CVE, отклонила его просьбу, подтвердив наличие реальной уязвимости, способной привести к серьёзным последствиям для безопасности.

Впоследствии, в сентябре 2023 года, NVD пересмотрела свою оценку, понизив рейтинг до 3,3 («низкий»). NVD отметила, что уязвимость теоретически может привести к отказу в обслуживании (DoS), но посчитала этот сценарий маловероятным. Этот случай подчёркивает трудность оценки уязвимостей и различия в подходах к определению их серьёзности.

NVD является важным ресурсом в области кибербезопасности, предоставляя стандартизированные данные об управлении уязвимостями, основанные на стандартах правительства США и представленные в формате SCAP (Security Content Automation Protocol). Эти данные позволяют автоматизировать процессы управления уязвимостями, оценки безопасности и соблюдения нормативных требований. NVD содержит базы данных с информацией об уязвимостях, связанных с безопасностью, контрольных списках, названиях продуктов и показателях воздействия [69].

Несмотря на полезные качества, NVD имеет определённые минусы:

− NVD фиксирует только официально зарегистрированные уязвимости, получившие номера CVE. Многие скрытые либо частные уязвимости не фиксируются в базе данных, создавая информационную пробуксовку;

− между моментом обнаружения новой уязвимости и официальным добавлением её в реестр NVD иногда возникает временной разрыв, даже если сама уязвимость известна уже давно. Из-за этого организации могут столкнуться с рисками эксплуатации ранее официальной регистрации;

− ограничения в оценке критичности уязвимостей. Хотя оценки CVSS предоставляют общую оценку критичности каждой уязвимости, настоящая критичность может изменяться от одной организации к другой в зависимости от факторов, например, от того, находится ли затронутое приложение в тестировании или производстве, а также от специфики конфигурации приложения;

− отсутствие покрытия для вредоносных пакетов. Технически вредоносный пакет с открытым исходным кодом не является уязвимостью - он намеренно забит. Поскольку этим пакетам не присвоены CVE, NVD не предоставляет способа для их отслеживания и обнаружения с помощью только базы данных.

4) БДУ ФСТЭК России сосредотачивает внимание на систематизации угроз, уязвимостей и методов защиты, соответствующих российским стандартам, нормативным предписаниям и законодательству в сфере информационной безопасности. Таким образом, база данных предоставляет сведения, адаптированные под российский контекст и специфику.

БДУ ФСТЭК России является необходимым ресурсом для специалистов, работающих в государственных структурах и российских компаниях, обязанных соблюдать национальные стандарты защиты данных, такие как ГОСТ и требования регуляторов. База данных охватывает широкий спектр вопросов безопасности, включая уязвимости в операционных системах, приложениях, сетевых устройствах, а также угрозы, связанные с кибератаками и другими нарушениями безопасности. Она содержит информацию об уязвимостях программного обеспечения, классифицированных по степени критичности и возможному ущербу [13].

Важной особенностью БДУ ФСТЭК России является её интеграция с другими отечественными и международными источниками информации о безопасности. Это

обеспечивает формирование более полной и точной картины текущих угроз и уязвимостей, позволяя выявлять взаимосвязи и закономерности в киберпространстве. Кроме того, база данных включает практические рекомендации по устранению уязвимостей и предотвращению инцидентов, что позволяет специалистам по безопасности оперативно реагировать на возникающие угрозы и эффективно оберегать информационные системы.

Несмотря на значимую роль Банка данных угроз (БДУ) ФСТЭК России в обеспечении информационной безопасности и его приспособление под национальные стандарты и законодательство, данный ресурс обладает рядом существенных недостатков:

− тексты в БДУ изложены техническим языком с обилием канцеляризмов, свойственных для государственных документов, что затрудняет их понимание и снижает эффективность использования базы специалистами, особенно теми, кто не обладает глубокими техническими познаниями;

− в БДУ меры безопасности подбираются в зависимости от класса информационной системы или необходимого уровня защищенности, а не исходя из конкретных угроз. Это усложняет разработку целенаправленных и эффективных мер противодействия;

− ранее использовавшаяся в БДУ ФСТЭК России классификация нарушителей по потенциалу (низкий, средний, высокий) не соответствует актуальным методикам моделирования угроз, принятым ФСТЭК России в 2021 году, что вызывает путаницу и уменьшает практическую применимость данных;

−в БДУ учитываются лишь три типа последствий — нарушение конфиденциальности, доступности и целостности. Между тем, современные методики безопасности рассматривают более широкий спектр свойств и эффектов, которые не отражены в базе;

− по сравнению с крупными международными реестрами, такими как CVE, БДУ ФСТЭК содержит значительно меньше данных об уязвимостях, что ограничивает полноту анализа и возможности оперативного реагирования на новые угрозы.

Эти ограничения подчёркивают необходимость в дополнительном мониторинге за независимыми источниками и активном изучении нынешних тынденций в кибербезопасности.

1.2 Изучение характеристик риск-калькуляторов

Одним из основных элементов эффективного управления рисками информационной безопасности является точное определение уровня опасности обнаруженных уязвимостей. Современные организации сталкиваются с огромным количеством уязвимостей ежедневно, и без чёткого механизма оценивания невозможно установить приоритеты для устранения угроз. Для решения этой задачи, применяются следующие системы оценки уязвимостей:

1) Система оценки уязвимостей CVSS (Common Vulnerability Scoring System) представляет собой универсальный подход, разработанный для количественного анализа уязвимостей в информационной системе. Она помогает оценить, какое воздействие может оказать конкретная уязвимость на безопасность системы. Оценки вычисляются по специально разработанным формулам, основываясь на нескольких показателях, и дают примерную оценку легкости эксплуатации уязвимости и ее потенциальных последствий для системы. Результаты расчета включают три числовых оценочных показателя: Base Score, Temporal Score и Environmental Score, каждая из которых может иметь значение от 0 до 10, где 10 указывает на наивысший уровень опасности.

CVSS был разработан Национальным советом по инфраструктуре (NIAC) в США, и над его созданием работали коммерческие организации, такие как Microsoft и Cisco. Поддержка стандарта осуществляется Форумом FIRST [16,70].

Согласно CVSS, уязвимости оцениваются на основе нескольких метрик, которые можно разделить на три основные группы:

1) базовые метрики - эти метрики описывают саму уязвимость и не зависят от времени или конкретного окружения. Они включают две подкатегории:

− метрики эксплуатации: Оценивают легкость эксплуатации уязвимости. Например, некоторые уязвимости можно использовать через Интернет, в то время как другие требуют физического доступа к устройству, затрудняя их эксплуатацию для случайного злоумышленника. Также учитываются сложность атаки, необходимость действий со стороны пользователя и уровень привилегий, необходимых для реализации атаки;

− метрики воздействия: Оценивают последствия, которые могут возникнуть в результате эксплуатации, включая возможность вывода системы из строя, доступа к конфиденциальной информации и модификации данных.

2) временные метрики -описывают внешние факторы, которые могут изменяться со временем, такие как наличие эксплойтов или обновлений безопасности;

3) метрики окружения - эти метрики не меняют основную оценку уязвимости, но помогают определить ее риск для конкретной IT-среды. Включают базовые метрики с учетом специфических условий. Например, если для эксплуатации в целом нужны минимальные привилегии, в организации доступ к уязвимой системе могут иметь только администраторы. Кроме того, эти метрики описывают потенциальные последствия эксплуатации для бизнеса, такие как влияние отключения сервера на операционную деятельность компании и наличие резервных систем [71].

Последней обновленной версией стандарта является CVSS 3.1, выпущенная в июне 2019 года. Разные компании по различным причинам могут применять как более старую версию CVSSv2, так и более новую CVSSv3, а некоторые даже комбинируют оба стандарта.

CVSS 3.1 содержит три основных набора метрик [17]:

1) базовые метрики (Base Metrics) − отражают главные свойства уязвимости;

2) временные метрики (Temporal Metrics) − показывают, как меняется опасность с течением времени;

3) контекстные метрики (Environmental Metrics) − учитывают конкретные условия среды.

Процесс оценивания осуществляется в несколько стадий: сначала вычисляется базовая метрика, которая потом конкретизируется посредством временных и контекстуальных метрик. Поставщики данных предоставляют только базовые и временные метрики, в то время как аналитики либо владельцы систем должны сами подстраивать оценки, применяя метрики окружения. Для временных метрик по умолчанию используются значения, которые отражают худший сценарий (например, если доступен рабочий эксплойт) [72].

Базовые метрики фиксируют «внутренние» стороны уязвимости, которые остаются неизменными и не зависят от характеристик конкретной организации. Они разделяются на:

1) характеристики эксплуатации (Exploitability) − оценивают простоту применения уязвимости злоумышленниками;

2) влияние на систему (Impact) − измеряют возможный ущерб, который может быть нанесен системе при успешной эксплуатации уязвимости.

Итоговая базовая оценка по шкале CVSS 3.1 колеблется от наименьшего значения 0.0 (незначительная угроза) до наибольшего 10.0 (крайне критичная уязвимость). Оценочные интервалы разбиты таким образом:

− низкий уровень риска: от 0.1 до 3.9 баллов - уязвимости незначительной степени критичности;

− средний уровень риска: от 4.0 до 6.9 баллов - средняя опасность;

− высокий уровень риска: от 7.0 до 8.9 баллов - высокая степень опасности;

− крайне критический уровень риска: от 9.0 до 10.0 баллов - крайне критичные уязвимости.

Такой подход позволяет быстро ориентироваться в уровне опасности обнаруженных дефектов и грамотно расставлять приоритеты в работе по увеличению уровня информационной безопасности.

Временные метрики анализируют изменяющиеся факторы, вроде наличия эксплойтов или патчей, и включают [17]:

1) доступность эксплойтов (Exploit Code Maturity) − насколько просто получить доступ к эксплойту;

2) степень исправления (Remediation Level) − показывает наличие патча для уязвимости;

3) достоверность отчета (Report Confidence) − оценивает надежность источников информации о наличии уязвимости.

Контекстные метрики позволяют учитывать специфику среды, в которой функционирует конкретная система. В данном контексте могут быть задействованы защитные механизмы или политики, которые помогают частично или полностью нивелировать потенциальный риск. Контекстная группа метрик включает:

1) требования к конфиденциальности, целостности и доступности − эти параметры позволяют адаптировать оценку уязвимости в зависимости от важности затронутого IT-актива для бизнеса. К примеру, система электронной очереди может требовать высокой целостности и доступности, но иметь низкие требования к конфиденциальности;

2) измененные базовые метрики − эта группа содержит те же параметры, что и базовые метрики (Base), и позволяет пользователю пересмотреть отдельные метрики на основе особенностей конкретной среды. К примеру, наличие определенных защитных механизмов или политик может изменить уровень сложности атаки. В случае, если измененная базовая метрика не указана (обозначение X), в расчете будет использовано значение исходных базовых метрик. Если же значение задано, оно заменяет базовую метрику.

Для лучшего понимания процесса оценки уязвимостей рассмотрим более детально контекстные метрики:

− Modified Attack Vector (MAV) − определяет расстояние (как логическое, так и физическое) от злоумышленника до уязвимости, необходимое для ее эксплуатации;

− Modified Attack Complexity (MAC) − описывает условия, не зависящие от злоумышленника, которые могут потребовать дополнительных усилий для успешного осуществления атаки;

− Modified Privileges Required (MPR) − обозначает уровень привилегий, необходимых злоумышленнику для успешной эксплуатации уязвимости;

− Modified User Interaction (MUI) − указывает на необходимость вмешательства пользователя для успешного выполнения атаки;

− Modified Scope (MS) − определяет способность атаки воздействовать на безопасность смежных компонентов, выходящих за рамки непосредственно уязвимого элемента.

Что касается метрик воздействия, они включают:

− Modified Confidentiality (MC) − влияет на конфиденциальность информации, которой управляет уязвимый компонент;

− Modified Integrity (MI) − учитывает воздействие на целостность данных, контролируемых уязвимым элементом;

− Modified Availability (MA) − отражает влияние на доступность информации, связанной с уязвимым компонентом;

− Modified Security Requirements (CR, IR, AR) − позволяют адаптировать оценку CVSS, исходя из значимости затронутого IT-актива для организации и требований к конфиденциальности, целостности и доступности конкретной информационной системы [72].

Стандарт CVSS 3.1 постепенно теряет свою актуальность с появлением CVSS 4.0. Новая версия заметно расширила возможности оценивания, принимая во внимание нынешние угрозы и эксплуатационные обстоятельства.

В июне 2023 года на 35-й ежегодной международной конференции, устроенной Форумом групп реагирования на компьютерные инциденты (FIRST) в Монреале, была презентована новая версия стандарта оценки уязвимостей − CVSS 4.0. После двух месяцев общественного обсуждения и дополнительного рассмотрения комментариев FIRST официально объявила о публикации обновлённого стандарта [73].

CVSS 4.0 представляет собой значительный прогресс по сравнению с предыдущими версиями, предлагая улучшенные механизмы оценивания рисков кибербезопасности. Система включает адаптивную структуру, учитывающую трудность атак с

точки зрения возможностей злоумышленников, а также детально рассматривает аспекты воздействия на конфиденциальность, целостность и доступность данных. Это повышает эффективность процессов управления рисками, приоритизации угроз и реагирования на инциденты. Тем не менее, для полноценного применения CVSS 4.0 рекомендуется совмещать его с другими методами оценки рисков и информации. Регулярный мониторинг ландшафта угроз и адаптация стратегий защиты являются ключевыми факторами успеха в борьбе с современными киберугрозами [74].

CVSS 4.0 содержит три группы метрик: базовые, временные и экологические.

Базовые метрики оценивают серьезность уязвимости без учета конкретных условий и контекста. Они охватывают такие параметры как:

- вектор атаки (AV) − метод, которым злоумышленник способен воспользоваться уязвимостью;

− сложность атаки (AC) − уровень сложности эксплуатации уязвимости;

− требуемые привилегии (PR) − необходимые привилегии для применения уязвимости;

− воздействие на конфиденциальность (CI) − степень воздействия на конфиденциальность данных;

− воздействие на целостность (II) − степень влияния на целостность данных;

− воздействие на доступность (AI) − воздействие на доступность данных.

Временные метрики учитывают изменения серьезности уязвимости со временем, в зависимости от доступности сведений и инструментов. В данную группу входят:

− эксплуатируемость (E) − насколько легко обнаружить и применить эксплойт;

− уровень оповещения (RL) − насколько широко известна уязвимость.

Экологические метрики отражают влияние уязвимости с учетом специфических условий и особенностей среды, в которой она обнаружена. Они включают:

− воздействие на безопасность (SI) − воздействие на общую безопасность системы либо сети;

− воздействие на целостность (II) − влияние на целостность системы либо сети;

− воздействие на доступность (AI) − влияние на доступность системы либо сети.

Каждая метрика располагает набором возможных значений. Например, метрика «Вектор атаки» может принимать следующие значения:

− локальный (L) − злоумышленник обязан иметь локальный доступ к системе;

− сетевой (N) − атака возможна через сеть;

− смешанный (A) − возможна как локальная, так и сетевая эксплуатация;

− физический (P) − нужен физический доступ к системе.

Значения метрик применяются для вычисления итоговой оценки CVSS, которая варьируется от 0 до 10: 0 обозначает отсутствие серьезной угрозы, а 10 − максимальную критичность уязвимости.

Гибкая структура CVSS 4.0 дает возможность организациям адаптировать систему под свои нужды − добавлять новые метрики или изменять существующие, дабы точнее отражать внутренние риски и приоритеты [73].

Оценка CVSS 4.0 создается на основе трёх групп метрик: базовых, временных и экологических. Показатели данных метрик непосредственно воздействуют на конечный рейтинг уязвимости − чем выше значения, тем серьёзнее оценка. В системе выделено четыре уровня риска:

− низкий (Low): 0.1–3.9;

− средний (Medium): 4.0–6.9;

− высокий (High): 7.0–8.9;

− критический (Critical): 9.0–10.0.

2) Система оценки уязвимостей EPSS (Exploit Prediction Scoring System) впервые была представлена на конференции Black Hat в 2019 году и разработана организацией First.org. EPSS представляет собой статистическую модель, основанную на анализе данных об опубликованных CVE, фактах эксплуатации уязвимостей и связанных с ними событиях. В отличие от традиционных систем оценки, таких как CVSS и

SSVC, EPSS не использует номинальные компоненты и причинно-следственные модели, а опирается на фактические данные и вероятностные методы, преимущественно байесовские модели.

Основная задача EPSS − предсказать вероятность эксплуатации уязвимости в течение ближайших 30 дней, выдавая численную оценку от 0 до 1, где 1 соответствует наибольшему риску. Для этого система анализирует множество факторов, включая тип уязвимости, наличие информации об эксплойтах в открытых источниках, активность злоумышленников, данные о патчах, а также популярность и производителя программного обеспечения (например, Microsoft). Среди ключевых параметров, влияющих на оценку, выделяются уязвимый код, записи в базе Exploit, количество ссылок в Национальной базе уязвимостей и наличие эксплойтов в Metasploit [75].

EPSS оценивает эффективность процесса защиты двумя основными метриками:

− эффективность − отношение количества устранённых эксплуатируемых уязвимостей (True Positives, TP) к сумме TP и ложных срабатываний (False Positives, FP);

− охват − отношение TP к сумме TP и пропущенных уязвимостей (False Negatives, FN).

Несмотря на преимущества, EPSS имеет ряд ограничений.

Во-первых, она зависит от качества и полноты доступных сведений, что снижает точность для редких или новых уязвимостей.

Во-вторых, система не учитывает специфические особенности инфраструктуры конкретных организаций, что может влиять на применимость оценки в некоторых случаях.

В-третьих, EPSS оценивает только вероятность эксплуатации, не затрагивая потенциальные последствия, поэтому её результаты следует использовать в сочетании с другими методами оценки риска, например, CVSS. Кроме того, интеграция EPSS с популярными инструментами безопасности пока ограничена [76].

Таким образом, EPSS является мощным инструментом для прогнозирования риска эксплуатации уязвимостей, основанных на реальных данных и вероятностных

моделях, которые дополнительно повышают качество оценки безопасности при комплексном использовании с другими системами.

3) Современная цифровая среда развивается стремительно, что увеличивает требования к безопасности веб-приложений. В данной ситуации важным инструментом для оценки и управления рисками уязвимостей стал калькулятор рисков, разработанный проектом OWASP. Он широко применяется специалистами в области информационной безопасности для стандартизированной оценки угроз и помогает определить приоритеты в устранении обнаруженных уязвимостей.

Данный инструмент учитывает как технические, так и бизнес-факторы, разделяя оценку риска на две основные категории: вероятность эксплуатации уязвимости и возможный ущерб. Каждая категория разбивается на отдельные метрики, которые оцениваются по шкале от низкого до высокого риска. По итогам всех оценок калькулятор формирует общую степень риска, позволяя классифицировать уязвимости по уровням − низкий, средний или высокий. Такой подход помогает специалистам принимать обоснованные решения о том, какие проблемы требуют первостепенного внимания.

Калькулятор OWASP Risk Rating Calculator пользуется популярностью среди организаций благодаря своей доступности и универсальности. Его часто комбинируют с другими стандартами OWASP, например, OWASP Top 10 и ASVS, для более комплексного анализа безопасности веб-приложений.

Однако инструмент имеет и ограничения. Во-первых, он даёт обобщенные оценки, которые могут не учитывать специфику сложных архитектур и уникальных требований отдельных организаций.

Во-вторых, калькулятор не всегда отражает современные методы атак и новые угрозы из-за редких обновлений.

Наконец, оценка метрик во многом зависит от субъективного опыта эксперта, что может приводить к различным результатам при анализе одной и той же уязвимости.

OWASP Risk Rating Calculator оценивает риск, применяя несколько важнейших параметров, которые распределяются по группам, связанных с особенностями злоумышленника и характеристиками уязвимости [76].

Особенности злоумышленника включают:

− уровень навыков: от отсутствия технических познаний (1 балл) до высокого мастерства в области сетей и программирования, включая опыт взлома систем (до 9 баллов);

− мотивы: от отсутствия или незначительной заинтересованности (1 балл) до существенной выгоды или вознаграждения (9 баллов);

− возможности доступа: от необходимости полного контроля либо дорогостоящих ресурсов (0 баллов) до отсутствия нужды в специальном доступе (9 баллов);

− аудитория: от узкой группы разработчиков и администраторов (2 балла) до анонимных пользователей интернета (9 баллов).

Параметры, описывающие уязвимость, включают:

− сложность обнаружения: от практически невозможного выявления (1 балл) до наличия автоматизированных средств выявления (9 баллов);

− удобство эксплуатации: от теоретической возможности (1 балл) до автоматизированных инструментов, облегчающих эксплуатацию (9 баллов);

− степень осведомлённости: от неизвестной уязвимости (1 балл) до широко доступной информации в открытых источниках (9 баллов);

− наличие механизмов обнаружения атак: от активного мониторинга и предотвращения (1 балл) до отсутствия регистрации попыток эксплуатации (9 баллов).

Технические последствия воздействия оцениваются по степени потери конфиденциальности:

− раскрытие незначительных, нечувствительных данных (2 балла);

− утечка минимально важных сведений (6 баллов);

− обнародование большого объёма некритичной информации (6 баллов);

− раскрытие значимых и критически важных данных (7 баллов);

- полное раскрытие всей информации (9 баллов).

Для эффективного управления рисками безопасности необходимо принимать во внимание не только технические характеристики уязвимостей, но и мотивацию и возможности потенциальных злоумышленников. Такой всесторонний анализ помогает точнее определить, какие угрозы представляют наибольшую опасность, и как они могут повлиять на систему в целом.

Разные инструменты оценки рисков, такие как CVSS, EPSS и OWASP, выполняют свои уникальные функции, дополняя друг друга. CVSS сосредотачивается на определении серьезности уязвимости, EPSS оценивает вероятность её реального применения, а OWASP уделяет внимание бизнес-рискам и последствиям. В совокупности эти методы позволяют принимать более обоснованные решения, минимизируя затраты на устранение уязвимостей, которые не представляют значительной угрозы.

2 Определение взаимосвязей между техниками атак и уязвимостями для построения графовой модели рисков

2.1 Установление соответствий между CAPEC-шаблонами атак и эксплуатируемыми ими уязвимостями

Каталог CAPEC (Перечень и Классификация Общих Шаблонов Атаки) представляет собой исчерпывающую базу данных, содержащую сведения о всех важных способах проникновения и нарушения информационных систем. Главная задача CAPEC заключается в помощи специалистам по защите информации результативно выявлять вероятные угрозы, определять пути вторжения злоумышленников и разрабатывать эффективные стратегии защиты.

Применение CAPEC играет ключевую роль в этом исследовании, так как данный ресурс обеспечивает всестороннее понимание атак, использующих разные вероятностные методы. На основе представленных сведений возможно формирование ясной классификации существующих угроз, характерных конкретно для изучаемого направления, а также разработка соответствующих нормативных актов и инструкций.

Структура каталога построена на многоуровневой модели шаблонов атак, позволяющей разделять общие типы атак на подгруппы, объединённые общими признаками и характеристиками. Эта архитектура облегчает проведение анализа потенциальных опасностей, начиная с общей картины и заканчивая рассмотрением конкретных примеров атак. Такой подход даёт возможность построить целостную систему защиты, учитывающую рисковые факторы на разных уровнях, и использовать эффективные контрмеры против любых категорий атак [9,66-67].

Шаблоны атак представляют собой формализованное отображение свойств и методик, которые хакеры применяют для обнаружения и использования уязвимостей в различных цифровых системах. Данные шаблоны основаны на глубоком исследовании практических примеров взломов и предназначены для комплексного анализа потенциально вредоносных действий.

Процесс формирования каждого шаблона включает детальное изучение стадий подготовки и выполнения атаки, а также рекомендации по минимизации их влияния. Подобные шаблоны помогают разработчикам программного обеспечения и системным администраторам подробно разбираться в особенностях атак и результативнее предотвращать их реализацию.

В системе CAPEC (Common Attack Pattern Enumeration and Classification) для описания уровня атак используется определённая терминология, которая помогает классифицировать и оценивать методы и сложность атак. Вот основные термины и понятия, применяемые при этом [9]:

1) шаблон атаки (Attack Pattern) − это стандартное описание конкретного типа нападения, включающее описание способов её осуществления, цели, условия и результаты. Каждый шаблон служит примером определённого метода злоумышленника;

2) вектор атаки (Attack Vector) − обозначает путь или способ, через который злоумышленник совершает нападение. Вектор может быть разным: через сеть, физический доступ к оборудованию, социальную инженерию, использование уязвимостей программного обеспечения и т.д. Важной частью описания является то, каким способом атакующий проникает в систему;

3) техника атаки (Attack Technique) − это конкретный метод или способ, который использует злоумышленник для достижения поставленных целей. В CAPEC техника нападения включает описание конкретных шагов, инструментов и приемов, таких как использование SQL-инъекций, фишинг, эксплойты, социальная инженерия и прочие. Техника нападения должна детально описывать, как именно осуществляется проникновение или нарушение, какие инструменты и уязвимости применяют злоумышленники;

4) механизм защиты (Mitigation) − это меры, стратегии и средства, которые предназначены для предотвращения либо уменьшения последствий нападения. В CAPEC описывается, какие защитные меры могут быть применены для снижения риска реализации данной техники нападения. Это могут быть технические решения,

такие как внедрение фильтров, шифрование, аутентификация, а также организационные меры, например, обучение персонала;

5) целевая уязвимость (Targeted Weakness) − это конкретная слабость или уязвимость системы, которая эксплуатируется при реализации техники нападения. В CAPEC уязвимость может быть описана как конкретная уязвимость программного обеспечения, конфигурационная ошибка, слабая политика безопасности или любой другой изъян, позволяющий атаке быть успешной;

6) последствия (Impact) − это описание вероятных либо фактических результатов атаки. В CAPEC последствия включают в себя влияние на целевую систему, данные, бизнес-процессы или репутацию организации. Они могут быть разными по степени серьезности − от незначительных до критических;

7) предварительные условия (Prerequisites) − условия, которые должны быть выполнены для начала атаки. Например, наличие у злоумышленника определённого уровня доступа, знания о системе или наличие уязвимости;

8) сложность обнаружения (Detection Difficulty) − характеристика, описывающая, насколько трудно обнаружить или зафиксировать факт атаки. Атаки с высокой сложностью обнаружения требуют специальных средств и методов мониторинга;

9) сложность атаки (Attack Complexity) − это показатель, оценивающий уровень сложности выполнения атаки [9].

Обычно выделяют два уровня:

- низкий уровень сложности − атака легко реализуема, требует минимальных знаний и ресурсов;

- средний уровень сложности − требует определённых навыков и ресурсов, выполнение атаки возможно при наличии соответствующих условий;

- высокий уровень сложности − атака сложна в реализации, требует глубоких технических знаний, специальных инструментов и/или значительных ресурсов.

Разбор кибератак, осуществляемых главным образом посредством эксплуатации брешей в программных изделиях, подразумевает тщательное изучение обширного спектра угроз и сценариев их воплощения. Ограничиваться простым перечнем

существующих шаблонов атак не довольно для адекватной оценки общей картины угроз.

Система CAPEC предлагает эффективный инструмент, позволяющий устанавливать корреляционные связи между различными атаковыми моделями как на разных уровнях детализации, так и среди однотипных атак на одном уровне. Применение подобного подхода даёт возможность изучить взаимодействие атак между собой, понять, как одни типы угроз служат предпосылками для других, и объективно измерить величину рисков, сопряжённых с такими ситуациями.

В рамках общего анализа рассматриваемой сложности целесообразно осуществить углублённое описание категории угроз, а также создать модель в виде древовидных структур, основанных на объединённых подходах CAPEC, CWE и CVE. Такой подход позволяет систематизировать и визуализировать взаимосвязи между различными уязвимостями и методами атак, а также дополнить их соответствующими характеристиками и паспортами, отражающими ключевые моменты. В данном изыскании особое значение имеют угрозы, относящиеся к категории «злоупотребление механизмами обработки данных», поскольку именно эти атаки представляют значительную опасность для безопасности информационных систем и требуют особого внимания при оценке рисков.

Название класса атак «Злоупотребление механизмами обработки данных» отображает суть угроз, которые построены на применении штатных, предусмотренных разработчиком, механизмов обработки данных в информационных системах, но не по прямому назначению, а для достижения вредоносных целей. Вместо эксплуатации уязвимостей на уровне кода или протоколов, злоумышленники применяют существующие функции и возможности системы, вводя ее в заблуждение и вынуждая выполнять нежелательные действия. Четыре приведенных CAPEC отлично иллюстрируют данный принцип [9]:

- CAPEC-465: Прозрачное злоупотребление прокси-серверами;
- CAPEC-44: Переполнение двоичного файла ресурсов;
- CAPEC-42: преобразование MIME;

- CAPEC-71: использование кодировки Unicode для обхода логики проверки.

Можно представить выбранные шаблоны атак в виде древовидной структуры, изображенной на рисунке 1 ниже.

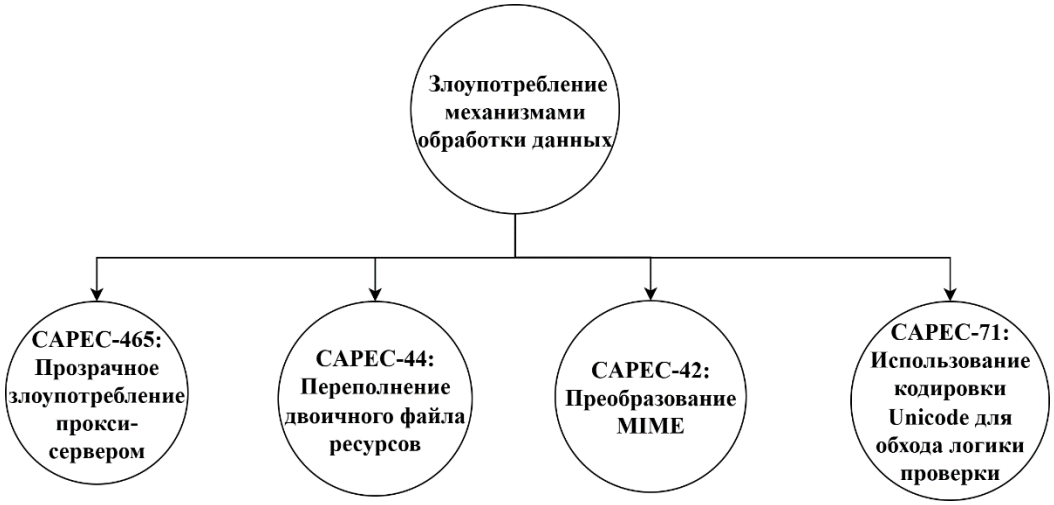

Рисунок 1 – Древовидный граф векторов атаки CAPEC

Основываясь на сведениях, содержащихся в сопровождающих документах по профилям векторов атак, можно систематизировать и распределить по категориям техники и тактики, используемые злоумышленниками при осуществлении киберпреступлений в отношении АИС. Результаты проделанной работы совместно с последующим исследованием списка общераспространённых уязвимостей (Common Weakness Enumeration, CWE) позволят сформировать полный реестр уязвимостей, сопряженный с CAPEC. Анализируя полученные сведения о разнообразии векторов атак и уязвимостей, используемых этими векторами, можно разработать реалистичные сценарии кибератак, попадающих в класс «Злоупотребление механизмами обработки данных».

Стоит отметить, что IBM X-Force Threat Research официально интегрировала стандарт CAPEC для систематизации видов атак, поскольку он был разработан с использованием похожих подходов, аналогично принятым в хорошо зарекомендовавших себя стандартах терминологии в сфере кибербезопасности, таких как Common Vulnerabilities and Exposures (CVE). Специалисты по информационной безопасности

давно привыкли обращаться к справочнику CVE, который фиксирует стандартные наименования публично раскрытых уязвимостей.

Еще одним известным проектом в среде разработчиков и специалистов кибербезопасности является Common Weakness Enumeration (CWE) − перечень наиболее часто встречающихся недостатков в программном обеспечении, сформированный коллективно. Он служит универсальным языком общения для инструментов мониторинга безопасности ПО и является нормативным ориентиром для идентификации, ликвидации и предупреждения слабых мест в программах [67].

Для формирования перечня уязвимостей, соответствующих каждому шаблону CAPEC, станут применяться данные из разных источников. Среди них − Национальный институт стандартов и технологий (NIST), который курирует базу данных CVE (Common Vulnerabilities and Exposures), и банк данных уязвимостей, разработанный ФСТЭК России, представленный в формате BDU.

Теперь перейдем к подробному рассмотрению каждого шаблона CAPEC из набора выше.

CAPEC-465: Прозрачное злоупотребление прокси-серверами.

Компании и интернет-провайдеры часто применяют прозрачные прокси-серверы, задача которых заключается в обнаружении конечного адреса пакетов данных, порождаемых клиентами. Для выполнения этой цели используется один из двух методов: определение места назначения по IP-адресу сетевого уровня или по данным HTTP-заголовка уровня приложений. Нынешние браузеры подчиняются политике единых источников, по которой сценарии, загруженные с конкретного домена, не имеют права направлять запросы на другие веб-сайты, не относящиеся к этому источнику. Не взирая на данный механизм защиты, некоторые вредоносные компоненты, например, Flash-программы или Java-апплеты, могут создавать междоменные соединения, исполняясь непосредственно в браузере пользователя. Когда такое событие происходит, прозрачный прокси проверяет HTTP-заголовок запроса и перенаправляет его на удаленный веб-сайт, этим самым уменьшая воздействие политики ограничений браузера относительно источника. Причина подобной уязвимости заключается в том,

что адресуется трафик не по IP-адресу на сетевом уровне, а по информации, находящейся в HTTP-заголовке Host. Следствием становятся возможные угрозы информационной безопасности, поскольку такая схема позволяет вредоносному коду отправлять запросы к любому хосту, доступному через прокси-сервер [9].

Применение прокси-серверов продолжает увеличиваться и становится необходимой частью современных сетевых инфраструктур. Они позволяют значительно увеличить безопасность, скрывая подлинный IP-адрес пользователя, а также ускорить доступ к ресурсам, управлять трафиком и обеспечивать фильтрацию информации.

В корпоративных и образовательных сетях распространенными решениями являются именно прозрачные прокси, которые не требуют дополнительных конфигураций у пользователей, что облегчает их внедрение и эксплуатацию. В то же время злоумышленники используют уязвимости подобных систем для организации атак, обхода блокировок и распространения вредоносных программ, что делает важным непрерывное улучшение механизмов защиты и мониторинга сетевого трафика [77].

В последние годы наблюдается увеличение применения прокси-серверов злоумышленниками для обхода блокировок и организации DDoS-атак. В отчётах компании Qrator Labs за 2023 год подчёркивается, что злоумышленники активно используют уязвимые IoT-устройства и сетевые маршрутизаторы для организации мусорного трафика и DDoS-атак, арендуя серверы у хостинг-провайдеров на подставных лиц. Среди государств по количеству источников таких атак лидирует Россия, где в IV квартале 2023 года было заблокировано свыше 22 миллионов IP-адресов — больше 42% от общего числа. Также активность DDoS-атак высока в США и Китае.

Наибольшие убытки от подобных атак понесли финансовые учреждения (36,88%) и сфера электронной коммерции (24,95%). При этом количество прикладных атак 7-го уровня (L7) выросло почти на 19%, хотя их доля в общем объёме DDoS-инцидентов остаётся небольшой. Злоумышленники тщательно подбирают цели и проводят подготовительные работы, а продолжительность атак в среднем составляет примерно 1,3 часа. Самая продолжительная атака в сегменте «Аэропорты» длилась около трёх дней и включала разнородные виды флуда (UDP, SYN, TCP). Также отмечается

рост активности ботов, автоматизированных атак и объёмов мусорных запросов, особенно в области ритейла, где много контента, привлекающего ботов, вооружённых искусственным интеллектом [78].

Таблица 1 показывает паспорт шаблона атаки CAPEC-465 совместно с сопутствующими ошибками типа CWE и актуальным статусом каждой из них.

Таблица 1 – Паспорт шаблона атаки CAPEC-465

Идентификатор системы CAPEC	CAPEC-465: Прозрачное злоупотребление прокси-сервером	
Описание шаблона атаки	Прозрачный прокси-сервер служит посредником между клиентом и Интернетом в целом. Он перехватывает все запросы, поступающие от клиента, и перенаправляет их в нужное место. Прокси-сервер также перехватывает все ответы, поступающие от клиента, и перенаправляет их клиенту. Все это делается незаметно для клиента.	
Соотношение типа ошибки CWE и статуса типа ошибки CWE	CWE-441: Непреднамеренный прокси-сервер или посредник («Заблудившийся заместитель»)	Разрешен для использования с реальными уязвимостями в ограниченных ситуациях, требующих тщательного анализа

На основе базы данных БДУ ФСТЭК России были установлены соответствующие ошибкам типа CWE уязвимости CVE. Полученная информация была использована для построения и разбора древовидной структуры графа шаблона атаки CAPEC-465, представленного на рисунке 2.

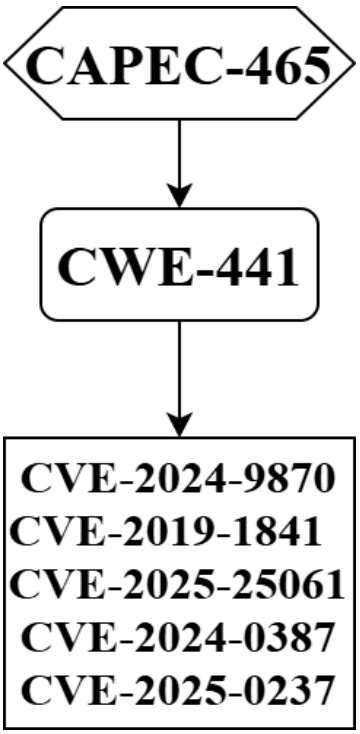

Рисунок 2 – Древовидный граф шаблона атаки CAPEC-465

Ниже в таблице 2, представлен шаблон атаки CAPEC-465, включающий виды ошибок и соответствующие им уязвимости.

Таблица 2 – Соотношение CAPEC-465 типа «атака – уязвимость»

Шаблон атаки	Наименование шаблона атаки	Связанные типы ошибок	Связанные уязвимости
1	2	3	4
CAPEC-465	Прозрачное злоупотребление прокси-сервером	CWE-441	CVE-2024-9870
			CVE-2019-1841
			CVE-2025-25061
			CVE-2024-0387
			CVE-2025-0237

Используя созданную таблицу, выделим уязвимости CAPEC-465 и подготовим для них паспорта. Образец паспорта представлен в таблице 3. Остальные паспорта уязвимостей приведены в приложении А.

Таблица 3 - Паспорт уязвимости CVE-2024-9870

Идентификатор уязвимости	CVE-2024-9870 Уязвимость программной платформы на базе git для совместной работы над кодом GitLab, связанная с возможностью обхода механизмов контроля доступа, позволяющая нарушителю отправлять запросы к уязвимому устройству
Идентификатор типа ошибки	CWE-441
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:S/C:P/I:N/A:N
	CVSS 3.0: AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 4,3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

CAPEC-44: Переполнение двоичного файла ресурсов.

Проблема переполнения буфера продолжает оставаться одной из основных в обеспечении безопасности ПО. Вероятность использовать такие атаки для дистанционной установки вредоносного кода постоянно провоцирует дискуссии и приковывает внимание экспертов. Способы осуществления атак на переполнение давно известны и детально описаны, но важность освещения вопроса сохраняется. Со временем появились новые виды атак, возникли новаторские подходы, потому данный шаблон служит основой для изучения сложных техник атак на переполнение буферов [79].

Рассматриваемый образец атаки базируется на традиционной схеме переполнения буфера, но отличается необычным способом доставки вредоносного эле-

мента − использованием бинарных файлов. Суть метода состоит в следующем: злоумышленник передает жертве двоичный файл напрямую или размещает его в публичном хранилище, к примеру, сервисе обмена музыкой (MP3), откуда жертва сможет скачать его самостоятельно. После успешного получения файла злоумышленник получает подтверждение факта загрузки или иным образом фиксирует возникновение критической ситуации, связанной с переполнением буфера, позволяющей продолжить атаку [9].

По статистике, зафиксированной исследователями и специализированными организациями, атаки на переполнение буфера составляют ощутимую часть от суммарного числа уязвимостей. Согласно официальным докладам, лишь за 2017 год было зарегистрировано свыше 2000 инцидентов, связанных с подобными атаками. По состоянию на сентябрь 2023-го года количество зарегистрированных уязвимостей переполнения буфера превысило 22 989 за всё время.

Примерно 15–20% от всех известных кибератак сопряжено с проблемами переполнения буфера. Это ставит данный вид уязвимостей на одно из первых мест по востребованности среди злоумышленников [80].

Таблица 4 показывает паспорт шаблона атаки CAPEC-44 совместно с сопутствующими ошибками типа CWE и актуальным статусом каждой из них.

Таблица 4 – Паспорт шаблона атаки CAPEC-44

Идентификатор системы CAPEC	CAPEC-44: Переполнение двоичного файла ресурсов
Описание шаблона атаки	Атака этого типа использует уязвимость переполнения буфера при обработке двоичных ресурсов. Двоичные ресурсы могут включать музыкальные файлы, такие как MP3, файлы изображений, такие как JPEG, и любые другие двоичные файлы. Эти атаки могут пройти незамеченными для клиентского компьютера при обычном использовании файлов, например, при загрузке браузером, казалось бы, невинного файла JPEG. Это может позволить злоумышленнику получить доступ к стеку выполнения и выполнить произвольный код в целевом процессе.

Продолжение таблицы 4

Идентификатор системы CAPEC	CAPEC-44: Переполнение двоичного файла ресурсов	
Соотношение типа ошибки CWE и статуса типа ошибки CWE	CWE-120: Копирование буфера без проверки размера входных данных («классическое переполнение буфера»)	Разрешен для использования с реальными уязвимостями в ограниченных ситуациях, требующих тщательного анализа
	CWE-119: Неправильное ограничение операций в пределах буфера памяти	Не рекомендован для использования с реальными уязвимостями
	CWE-697: Некорректное сравнение	Не рекомендован для использования с реальными уязвимостями

Используя базу данных БДУ ФСТЭК России были установлены соответствующие ошибкам типа CWE уязвимости CVE. Полученная информация была использована для построения и разбора древовидной структуры графа шаблона атаки CAPEC-44, представленного на рисунке 3.

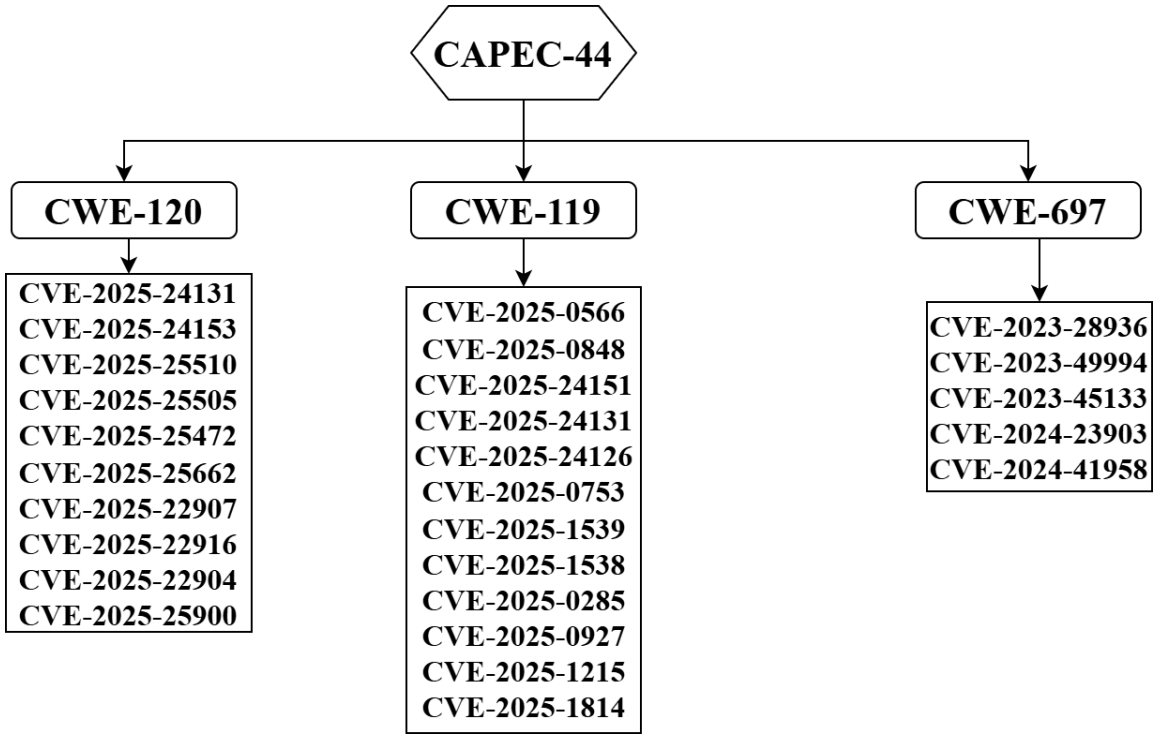

Рисунок 3 – Древовидный граф шаблона атаки CAPEC-44

Ниже в таблице 5, представлен шаблон атаки CAPEC-44, включающий виды ошибок и соответствующие им уязвимости.

Таблица 5 - Соотношение CAPEC-44 типа «атака – уязвимость»

Шаблон атаки	Наименование шаблона атаки	Связанные типы ошибок	Связанные уязвимости
1	2		4
CAPEC-44	Переполнение двоичного файла ресурсов	CWE-120	CVE-2025-24131
			CVE-2025-24153
			CVE-2025-25510
			CVE-2025-25505
			CVE-2025-25472
			CVE-2025-25662
			CVE-2025-22907
			CVE-2025-22916
			CVE-2025-22904
			CVE-2025-25900
		CWE-119	CVE-2025-0566
			CVE-2025-0848
			CVE-2025-24151
			CVE-2025-24131
			CVE-2025-24126
			CVE-2025-0753
			CVE-2025-1539
			CVE-2025-1538
			CVE-2025-0285
			CVE-2025-0927
			CVE-2025-1215
			CVE-2025-1814
		CWE-697	CVE-2023-28936
			CVE-2023-49994
			CVE-2023-45133
			CVE-2024-23903
			CVE-2024-41958

Используя созданную таблицу, выделим уязвимости CAPEC-44 и подготовим для них паспорта. Образец паспорта представлен в таблице 6.

Таблица 6 - Паспорт уязвимости CVE-2025-24131

Идентификатор уязвимости	CVE-2025-24131 Уязвимость реализации технологии AirPlay операционных систем macOS, iOS, iPadOS, watchOS, tvOS и visionOS связана с выходом операции за границы буфера в памяти. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-120
	CWE-119
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:S/C:N/I:N/A:C
	CVSS 3.0: AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,8)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Исчерпание ресурсов, Манипулирование структурами данных
Участие в инцидентах	Нет

CAPEC-42: преобразование MIME.

Механизм MIME (Multipurpose Internet Mail Extensions, произносится как «майм») является стандартом, обеспечивающим поддержку разнообразных форматов данных при передаче электронных писем. Этот протокол описывает методы кодирования информации и форматирования сообщений, что позволяет передавать помимо обычного текста и прочие типы данных, такие как изображения, звук, видео и программное обеспечение [81].

Формат MIME изначально разработан для поддержки многообразия данных, включая тексты на языках с нестандартными символами и мультимедийные вложения. Он интегрируется с базовыми правилами формирования электронного письма, установленными в стандарте RFC 5322 (предшественник RFC 2822 и RFC 822), и добавляет важные расширения, позволяющие включать дополнительную информацию о содержимом письма.

Однако реализация MIME сопряжена с угрозой безопасности. Преобразование данных в MIME-совместимый формат и последующая распаковка данных порой сопровождаются техническими недочетами, создающими условия для потенциальных

атак. Одним из распространенных вариантов эксплуатации таких уязвимостей является переполнение буфера. Хакеры могут воспользоваться этой ситуацией, провоцируя переполнение при обработке данных MIME, что позволяет захватить контроль над почтовым сервером [9].

Согласно открытым данным, атаки на преобразование MIME составляют примерно 10–15% от общего количества киберинцидентов, связанных с электронными сообщениями. Однако конкретные количественные значения меняются в зависимости от региона и отрасли.

Анализ статистики демонстрирует устойчивый рост частоты подобных атак с конца 2020-х годов. В среднем ежегодный прирост достигает порядка 15–20%. Главными факторами роста являются несовершенство стандартов MIME и повсеместное применение HTML-вставок в почтовых клиентах.

Большая часть атак нацелена на крупный государственный и коммерческий сектор. В 2025 году Россия столкнулась с рекордным количеством подобных инцидентов, особенно на сайтах государственных учреждений и крупных корпораций, таких как «РЖД» и «Госуслуги».

Банковский сектор стал особенно привлекательной целью для злоумышленников. Подтвержденный показатель атак на банковские сервисы составляет около 20% от общего количества инцидентов, связанных с MIME-конверсиями.

Международные эксперты отмечают глобальное распространение подобных атак. Согласно исследованию, за 2025 год, средняя вероятность инцидента составляет примерно 1 случай на каждые 1000 писем, доставленных крупными сервисами [82].

Таблица 7 показывает паспорт шаблона атаки CAPEC-42 совместно с сопутствующими ошибками типа CWE и актуальным статусом каждой из них.

Таблица 7 - Паспорт шаблона атаки CAPEC-42

Идентификатор системы CAPEC	CAPEC-42: Преобразование MIME	
Описание шаблона атаки	Злоумышленник использует слабое место в процедуре преобразования MIME, чтобы вызвать переполнение буфера и получить контроль над почтовым сервером. Система MIME предназначена для интерпретации и отправки по электронной почте различных форматов информации. Точки атаки существуют, когда данные преобразуются в формат, совместимый с MIME, и обратно.	
Соотношение типа ошибки CWE и статуса типа ошибки CWE	CWE-120: Копирование буфера без проверки размера входных данных («классическое переполнение буфера»)	Разрешен для использования с реальными уязвимостями в ограниченных ситуациях, требующих тщательного анализа
	CWE-119: Неправильное ограничение операций в пределах буфера памяти	Не рекомендован для использования с реальными уязвимостями
	CWE-74: Неправильная нейтрализация специальных элементов на выходе, используемых нижестоящим компонентом («инъекция»)	Не рекомендован для использования с реальными уязвимостями
	CWE-20: Неправильная проверка входных данных	Не рекомендован для использования с реальными уязвимостями

Используя базу данных БДУ ФСТЭК России были установлены соответствующие ошибкам типа CWE уязвимости CVE. Полученная информация была использована для построения и разбора древовидной структуры графа шаблона атаки CAPEC-42, представленного на рисунке 4.

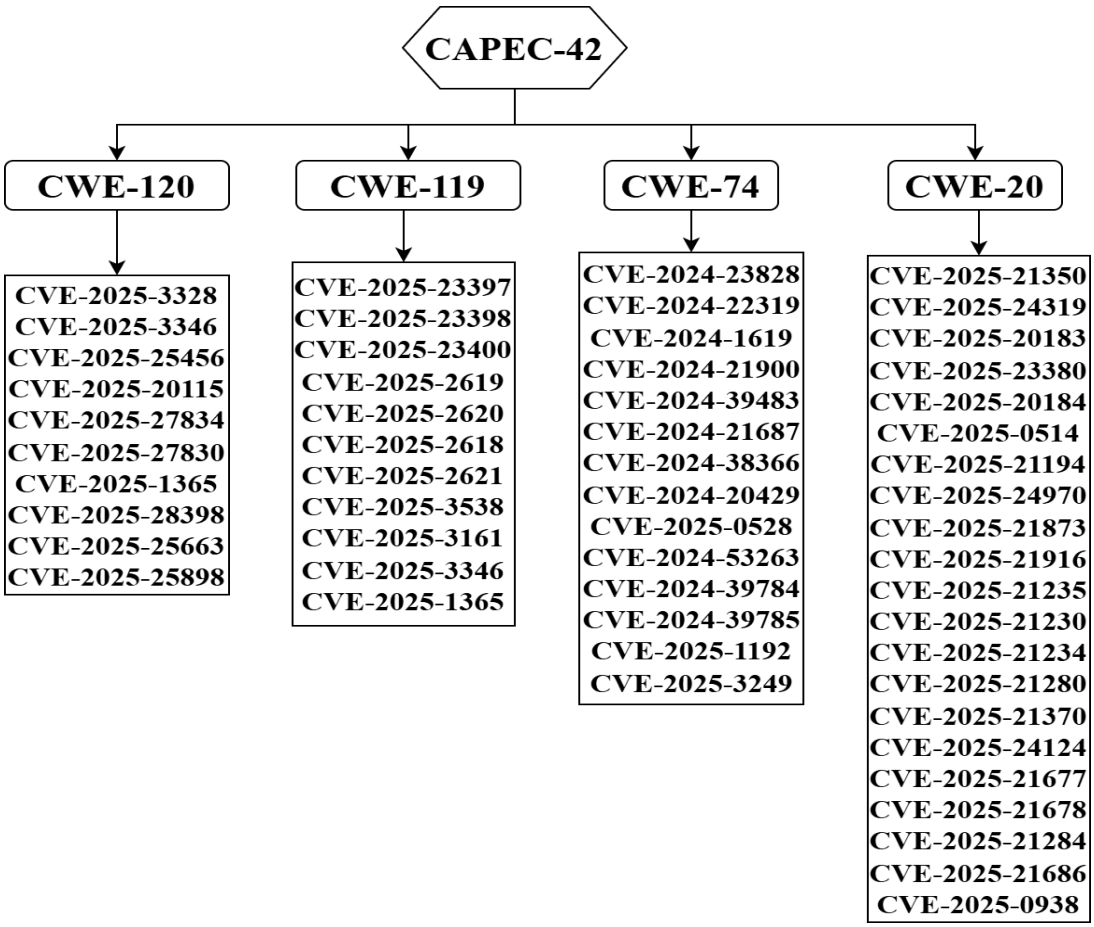

Рисунок 4 – Древовидный граф шаблона атаки CAPEC-42

Ниже в таблице 8, представлен шаблон атаки CAPEC-42, включающий виды ошибок и соответствующие им уязвимости.

Таблица 8 - Соотношение CAPEC-42 типа «атака – уязвимость»

Шаблон атаки	Наименование шаблона атаки	Связанные типы ошибок	Связанные уязвимости
1	2	3	4
CAPEC-42	Преобразование MIME	CWE-120	CVE-2025-3328
			CVE-2025-3346
			CVE-2025-25456
			CVE-2025-20115
			CVE-2025-27834
			CVE-2025-27830
			CVE-2025-25898
			CVE-2025-1365
			CVE-2025-28398
			CVE-2025-25663

Продолжение таблицы 8

Шаблон атаки	Наименование шаблона атаки	Связанные типы ошибок	Связанные уязвимости
1	2	3	4
CAPEC-42	Преобразование MIME	CWE-119	CVE-2025-23397
			CVE-2025-23398
			CVE-2025-23400
			CVE-2025-2619
			CVE-2025-2620
			CVE-2025-2618
			CVE-2025-2621
			CVE-2025-3538
			CVE-2025-3161
			CVE-2025-3346
			CVE-2025-1365
		CWE-74	CVE-2024-23828
			CVE-2024-22319
			CVE-2024-1619
			CVE-2024-21900
			CVE-2024-39483
			CVE-2024-21687
			CVE-2024-38366
			CVE-2024-20429
			CVE-2025-0528
			CVE-2024-53263
			CVE-2024-39784
			CVE-2024-39785
			CVE-2025-1192
			CVE-2025-3249
		CWE-20	CVE-2025-21350
			CVE-2025-24319
			CVE-2025-20183
			CVE-2025-23380
			CVE-2025-20184
			CVE-2025-0514
			CVE-2025-21194
			CVE-2025-24970
			CVE-2025-21873
			CVE-2025-21916

Продолжение таблицы 8

Шаблон атаки	Наименование шаблона атаки	Связанные типы ошибок	Связанные уязвимости
1	2	3	4
CAPEC-42	Преобразование MIME		CVE-2025-21235
			CVE-2025-21230
			CVE-2025-21234
			CVE-2025-21280
			CVE-2025-21370
			CVE-2025-24124
			CVE-2025-21677
			CVE-2025-21678
			CVE-2025-21284
			CVE-2025-21686
			CVE-2025-0938

Используя данные из таблицы, выделим уязвимости CAPEC-42 и подготовим для них паспорта. Образец паспорта представлен в таблице 9.

Таблица 9 - Паспорт уязвимости CVE-2025-3328

Идентификатор уязвимости	CVE-2025-3328 Уязвимость функции form_fast_setting_wifi_set микропрограммного обеспечения маршрутизаторов Tenda AC1206 связана с копированием буфера без проверки размера входных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, выполнить произвольный код путем отправки специально сформированного POST-запроса
Идентификатор типа ошибки	CWE-120
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:S/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 9)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 8,8)
Статус уязвимости	Потенциальная уязвимость
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Данные уточняются
Участие в инцидентах	Нет

CAPEC-71: использование кодировки Unicode для обхода логики проверки.

Злоумышленник может предоставить строку, закодированную в формате Unicode, компоненту системы, который не поддерживает данную кодировку. Такое деяние способно ввести в заблуждение защитные фильтры и повлиять на верное распознавание запроса механизмом классификации. В итоге злоумышленник может успешно обойти меры фильтрации контента и направить запрос приложения по непредназначенному маршруту [9].

Использование кодировки Unicode является ключевой особенностью систем Windows, позволяющей упростить визуализацию информации на разных языках. Приложения Windows, включая Проводник, умеют обрабатывать символы Unicode и корректно представлять их пользователю. Однако эта функциональная особенность также может быть применена злоумышленниками для маскировки вредоносного ПО.

Microsoft заявляет, что Unicode является международным стандартом кодирования символов, облегчающим адаптацию программного обеспечения и улучшающим обработку многоязычных текстов. Наличие широкого спектра доступных кодировок позволяет интегрировать множество алфавитов, языков и научных символов. Пользовательские интерфейсы, воспринимающие и отображающие Unicode, предоставляют обширные возможности, но одновременно создают риск злоупотребления этими возможностями.

Главная слабость системы, обусловленная работой с кодировкой Unicode, заключается в том, что компьютер воспринимает любую информацию исключительно в виде единиц и нулей, не принимая решений о ее важности или опасности. Этим обстоятельством пользуются злоумышленники, замещая визуально безопасные символы вредоносными элементами. Зачастую поверхностный осмотр не выявляет признаков опасности, что заставляет пользователей доверять сомнительным элементам, не подозревая о настоящей угрозе [83].

Атаки с применением кодировки Unicode не представлены отдельной группой в исследованиях по кибербезопасности. Но они рассматриваются частным случаем бо-

лее широких категорий атак, таких как фишинг и инъекционные атаки. Средняя частота подобных атак оценивается в диапазоне 5–10% от общего числа киберинцидентов.

Подобные атаки осуществляются через включение специальных символов Unicode в текстовые поля, что позволяет обходить традиционные методы фильтрации и проверки. Метод может применяться как самостоятельный способ атаки или как вспомогательный инструмент для внедрения вредоносного кода.

Универсальность метода делает его привлекательным для злоумышленников по всему миру. Наиболее уязвимыми остаются государства с низким уровнем информационной грамотности и малыми тратами на защиту инфраструктуры. Применительно к России, атаки с использованием Unicode встречаются сравнительно редко, однако сохраняются риски для небольших компаний и государственных учреждений.

Символьные атаки с использованием Unicode характеризуются низкой стоимостью и высокой степенью скрытности. Атаки такого типа сложно зафиксировать стандартными средствами защиты, что повышает привлекательность их использования среди киберпреступников.

Рост атак с использованием Unicode замедлился в последние годы. Причины этого явления включают повышение уровня безопасности инфраструктуры и введение обязательных требований к проверке и очистке входных данных.

Таблица 10 показывает паспорт шаблона атаки CAPEC-71 совместно с сопутствующими ошибками типа CWE и актуальным статусом каждой из них.

Таблица 10 - Паспорт шаблона атаки CAPEC-71

Идентификатор системы CAPEC	CAPEC-71: Использование кодировки Unicode для обхода логики проверки
Описание шаблона атаки	Злоумышленник может предоставить строку Unicode системному компоненту, который не поддерживает Unicode, и использовать это для обхода фильтра или вызвать сбой механизма классификации при правильном понимании запроса. Это может позволить злоумышленнику пропустить вредоносные данные через фильтр содержимого и / или,

Продолжение таблицы 10

Идентификатор системы CAPEC	CAPEC-71: Использование кодировки Unicode для обхода логики проверки	
	возможно, привести к тому, что приложение неправильно перенаправит запрос.	
Соотношение типа ошибки CWE и статуса типа ошибки CWE	CWE-74: Неправильная нейтрализация специальных элементов на выходе, используемых нижестоящим компонентом («инъекция»)	Не рекомендован для использования с реальными уязвимостями
	CWE-20: Неправильная проверка входных данных	Не рекомендован для использования с реальными уязвимостями
	CWE-176: Неправильная обработка кодировки Unicode	Разрешен для использования с реальными уязвимостями
	CWE-180: Неправильный порядок действий: проверка перед канонизацией	Разрешен для использования с реальными уязвимостями
	CWE-173: Неправильное использование альтернативного кодирования	Разрешен для использования с реальными уязвимостями
	CWE-172: Ошибка кодирования	Разрешен для использования с реальными уязвимостями в ограниченных ситуациях, требующих тщательного анализа
	CWE-184: Неполный список запрещенных входных данных	Разрешен для использования с реальными уязвимостями
	CWE-183: Разрешительный список разрешенных входных данных	Разрешен для использования с реальными уязвимостями
	CWE-697: Некорректное сравнение	Не рекомендован для использования с реальными уязвимостями

Используя базу данных БДУ ФСТЭК России были установлены соответствующие ошибкам типа CWE уязвимости CVE. Полученная информация была использована для построения и разбора древовидной структуры графа шаблона атаки CAPEC-71, представленного на рисунке 5.

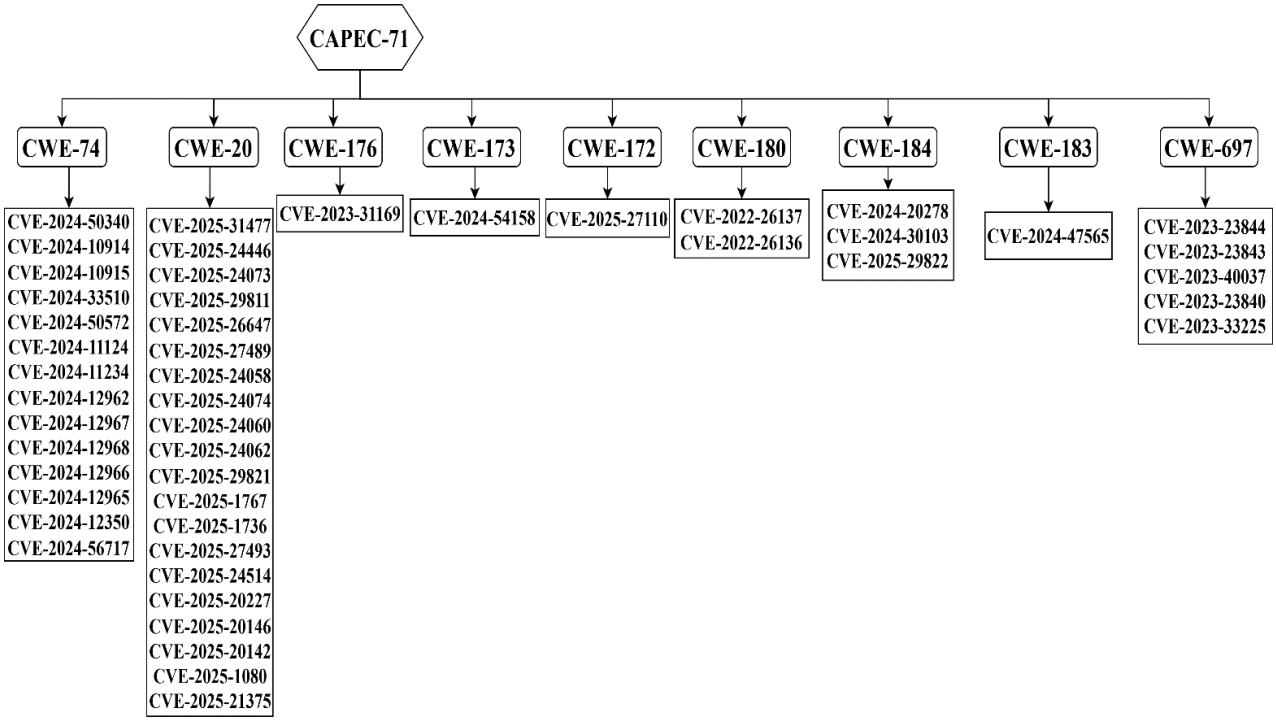

Рисунок 5 – Древовидный граф шаблона атаки CAPEC-71

Ниже в таблице 11, представлен шаблон атаки CAPEC-71, включающий виды ошибок и соответствующие им уязвимости.

Таблица 11 - Соотношение CAPEC-71 типа «атака – уязвимость»

Шаблон атаки	Наименование шаблона атаки	Связанные типы ошибок	Связанные уязвимости
1	2	3	4
CAPEC-71	Использование кодировки Unicode для обхода логики проверки	CWE-74	CVE-2024-50340
			CVE-2024-10914
			CVE-2024-10915
			CVE-2024-33510
			CVE-2024-50572
			CVE-2024-11124
			CVE-2024-11234
			CVE-2024-12962
			CVE-2024-12967
			CVE-2024-12968
			CVE-2024-12966
			CVE-2024-12965
			CVE-2024-12350

Продолжение таблицы 11

Шаблон атаки	Наименование шаблона атаки	Связанные типы ошибок	Связанные уязвимости
1	2	3	4
			CVE-2024-56717
		CWE-20	CVE-2025-31477
			CVE-2025-24446
			CVE-2025-24073
			CVE-2025-29811
			CVE-2025-26647
			CVE-2025-27489
			CVE-2025-24058
			CVE-2025-24074
			CVE-2025-24060
			CVE-2025-24062
			CVE-2025-29821
			CVE-2025-1767
			CVE-2025-1736
			CVE-2025-27493
			CVE-2025-24514
			CVE-2025-20227
			CVE-2025-20146
			CVE-2025-20142
			CVE-2025-1080
			CVE-2025-21375
		CWE-176	CVE-2023-31169
		CWE-173	CVE-2024-54158
		CWE-172	CVE-2025-27110
		CWE-180	CVE-2022-26137
			CVE-2022-26136
		CWE-184	CVE-2024-20278
			CVE-2024-30103
			CVE-2025-29822
		CWE-183	CVE-2024-47565
		CWE-697	CVE-2023-23844
			CVE-2023-23843
			CVE-2023-40037
			CVE-2023-23840
			CVE-2023-33225

Используя данные из таблицы, выделим уязвимости CAPEC-71 и подготовим для них паспорта. Образец паспорта представлен в таблице 12.

Таблица 12 - Паспорт уязвимости CVE-2024-50340

Идентификатор уязвимости	CVE-2024-50340 Уязвимость программной платформы для разработки и управления веб-приложениями Symfony существует из-за непринятия мер по нейтрализации специальных элементов. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, выполнить произвольный код
Идентификатор типа ошибки	CWE-74
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:N/C:P/I:P/A:P
	CVSS 3.0: AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,5)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Инъекция
Участие в инцидентах	Нет

Исследование, проведенное на основе сведений из разных источников, позволило возможность выявить и детально описать широкий спектр векторов атак, связанных с классом «Злоупотреблением механизмами обработки данных» и сопутствующими уязвимостями.

2.2 Разработка последовательностей реализации MITRE-техник

В дальнейшем целесообразно выполнить моделирование сценариев последовательных операций злоумышленников при использовании набора уязвимостей для каждого типа атаки. Предлагаемый метод ориентирован на создание детализированных моделей, воспроизводящих различные варианты применения обнаруженных уязвимостей в рамках имеющихся шаблонов атак. Это обеспечивает инструмент для глубокого анализа каждой фазы − от начального проникновения до закрепления позиций либо сокрытия следов.

Особое внимание уделяется разработке наглядных моделей сценариев атак посредством построения схем. Такой подход позволяет наглядно отображать последовательность этапов, что облегчает понимание логики развития атаки и восприятие динамики действий злоумышленников.

Важную роль играет применение ресурсов базы данных MITRE ATT&CK, которая содержит сведения о практиках злоумышленников на каждом этапе киберинцидентов. Интеграция с этой базой обеспечивает точную классификацию ситуаций и перенос результатов на практику защиты информационных инфраструктур.

При моделировании особое значение имеет учёт связей между действиями злоумышленника, то есть зависимость последующих шагов от предыдущих решений. Это повышает достоверность моделей и помогает выявлять новые точки риска и слабые места систем безопасности.

Также важно рассматривать уровень детализации сценариев, который предполагает разложение атак на последовательность техник.

Сценарии шаблонов атак − это структурированные последовательности действий, направленные на достижение целей злоумышленников, включая вариации техник и тактик. Они помогают моделировать реальные угрозы и лучше подготовиться к ним.

Тактики − это стратегические цели злоумышленников, описывающие их главные намерения во время атаки.

Для шаблона атаки CAPEC-465: Прозрачное злоупотребление прокси-сервером были выбраны определённые тактики и техники, исходя из целей злоумышленника и характера нападения, а также из доступных уязвимостей и способов их эксплуатации. Обоснование данного выбора заключается в необходимости обеспечить наиболее эффективное и скрытое выполнение злоумышленником последовательности действий, начиная с получения доступа, продолжая исполнением команд, повышением привилегий, организацией управления и заканчивая возможным деструктивным воздействием [9].

Конкретно, тактика TA0001: Первоначальный доступ включает технику T1190: Недостатки в общедоступном приложении, которая позволяет злоумышленнику использовать уязвимости в публичных приложениях для проникновения в систему. Это обусловлено тем, что именно через подобные уязвимости зачастую осуществляется первичный вход в инфраструктуру. Далее, для повышения эффективности скрытности и контроля злоумышленник использует тактику TA0004: Повышение привилегий, реализуемую техникой T1068: Эксплуатация уязвимостей для повышения привилегий, что даёт возможность управлять системой с более широкими правами.

Для изучения системы и поиска потенциальных точек входа или слабых мест, применяется тактика TA0007: Обнаружение с техникой T1082: Изучение системы. Это позволяет злоумышленнику адаптировать свои действия под конкретную инфраструктуру и повысить результативность атаки.

Организация управления осуществляется через использование прокси-сервера (T1090) что обеспечивает канал связи и управление командой злоумышленника, а также способствует маскировке своих действий. В случае необходимости, злоумышленник может применить техники деструктивного воздействия, такие как T1529: Завершение работы или перезагрузка системы, T1499: Точечный отказ в обслуживании, T1485: Уничтожение данных − все эти меры позволяют нанести ущерб инфраструктуре, усложнить восстановление и усилить эффект атаки [11].

Этот набор тактик и техник был выбран исходя из анализа типичных сценариев эксплуатации уязвимостей в публичных приложениях, а также для обеспечения максимальной эффективности и скрытности злоумышленника в рамках реализации шаблона атаки.

В таблице 13 ниже представлено соотношение техник и тактик с уязвимостями для CAPEC-465.

Таблица 13 – Соотнесение техник и тактик с уязвимостями CAPEC-465

CAPEC-465: Прозрачное злоупотребление прокси-сервером		
Тактика	Техника	Уязвимости, эксплуатация которых приводит к технике
TA0001:Первоначальный доступ	T1190: Недостатки в общедоступном приложении	CVE-2024-9870, CVE-2019-1841
TA0004:Повышение привилегий	T1068: Эксплуатация уязвимостей для повышения привилегий	CVE-2024-0387, CVE-2025-0237
TA0007:Обнаружение	T1082: Изучение системы	CVE-2024-9870
TA0011:Организация управления	T1090: Прокси-сервер	CVE-2024-9870, CVE-2024-0387
TA0040:Деструктивное воздействие	T1529: Завершение работы или перезагрузка системы	CVE-2019-1841
	T1499: Точечный отказ в обслуживании	CVE-2019-1841,CVE-2024-0387
	T1485: Уничтожение данных	CVE-2025-25061

Для шаблона атаки CAPEC-44: Переполнение двоичного файла ресурсов были выбраны определённые тактики и методы, исходя из целей злоумышленника и особенностей реализации данной угрозы. Обоснование выбора связано с последовательностью действий, необходимой для успешного проведения атаки, а также с уязвимостями и способами, которые позволяют максимально эффективно реализовать задуманную схему [9].

Например, для получения первоначального доступа используют тактику TA0001: Первоначальный доступ, где применяется метод T1190: Недостатки в общедоступном приложении. Этот метод основан на применении уязвимостей в публичных приложениях, что является распространённым способом проникновения в системы злоумышленников.

После получения доступа злоумышленник реализует выполнение (TA0002), применяя различные техники, такие как T1059.007: JavaScript, T1059: Интерпрета-

торы командной строки и сценариев, а также T1203: Эксплуатация уязвимостей в клиентском ПО. Эти методы позволяют запускать вредоносные компоненты, скрипты или эксплойты, что способствует выполнению кода в целевой системе и создание условий для дальнейших действий.

Для повышения своих возможностей злоумышленник использует тактику TA0004: Повышение привилегий, с техникой T1068: Эксплуатация уязвимостей для повышения привилегий. Это обеспечивает более глубокий контроль над системой и позволяет обходить механизмы защиты.

Для сокрытия своей деятельности и предотвращения обнаружения злоумышленник применяет тактику TA0005: Предотвращение обнаружения, используя техники T1574: Перехват потока исполнения, T1211: Эксплуатация уязвимостей для предотвращения обнаружения и T1078: Существующие учетные записи. Эти методы помогают снизить вероятность выявления злоумышленника средствами мониторинга и аналитики.

Кроме того, злоумышленник использует тактику TA0008: Перемещение внутри периметра с техникой T1210: Эксплуатация уязвимостей в удаленных службах, что даёт возможность злоумышленнику перемещаться по сети организации, получая доступ к другим системам и ресурсам через уязвимые удаленные сервисы, что способствует расширению контроля и скрытности внутри инфраструктуры.

Наконец, в случае необходимости, злоумышленник может применить деструктивные меры, такие как T1499: Точечный отказ в обслуживании, T1489: Остановка службы, а также T1498: Сетевой отказ в обслуживании. Эти действия позволяют нанести ущерб системе, усложнить восстановление и усилить эффект атаки [11].

Выбор именно этих тактик и техник обусловлен их эффективностью в реализации сценария переполнения двоичного файла ресурсов, а также соответствием типичным уязвимостям и эксплойтам, используемым злоумышленниками. Эти методы позволяют обеспечить скрытность, контроль, а также максимальную эффективность атаки.

В таблице 14 ниже представлено соотношение техник и тактик с уязвимостями для CAPEC-44.

Таблица 14 – Соотнесение техник и тактик с уязвимостями CAPEC-44

CAPEC-44: Переполнение двоичного файла ресурсов		
Тактика	Техника	Уязвимости, эксплуатация которых приводит к технике
TA0001:Первоначальный доступ	T1190: Недостатки в общедоступном приложении	CVE-2025-1814, CVE-2025-0848, CVE-2025-0566
TA0002:Выполнение	T1059: Интерпретаторы командной строки и сценариев	CVE-2025-24153
	T1059.007: JavaScript	CVE-2023-45133
	T1203: Эксплуатация уязвимостей в клиентском ПО	CVE-2025-0753, CVE-2025-1539, CVE-2025-1538
TA0004:Повышение привилегий	T1068: Эксплуатация уязвимостей для повышения привилегий	CVE-2025-22907, CVE-2025-22916, CVE-2025-22904
TA0005:Предотвращение обнаружения	T1574: Перехват потока исполнения	CVE-2025-1215, CVE-2023-28936
	T1211: Эксплуатация уязвимостей для предотвращения обнаружения	CVE-2025-0285, CVE-2025-0927
	T1078: Существующие учетные записи	CVE-2024-23903, CVE-2024-41958
TA0008: Перемещение внутри периметра	T1210: Эксплуатация уязвимостей в удаленных службах	CVE-2025-25510, CVE-2025-25505
TA0040:Деструктивное воздействие	T1499: Точечный отказ в обслуживании	CVE-2025-24131, CVE-2025-25472, CVE-2025-25900
	T1489: Остановка службы	CVE-2025-24131, CVE-2025-24151, CVE-2025-24126
	T1498: Сетевой отказ в обслуживании	CVE-2025-25662,CVE-2023-49994

Для разработки сценария атаки CAPEC-42: преобразование MIME был подобран комплекс определённых тактик и техник, поскольку они максимально отражают возможные фазы и способы злоумышленников при реализации данной угрозы.

Во-первых, тактика TA0043: Разведка включает технику T1595: Активное сканирование. Данная методика позволяет злоумышленнику собирать сведения о целевой системе или сети, выявляя уязвимости и доступные точки входа для последующих атак.

Далее, тактика TA0001: Первоначальный доступ охватывает технику T1190: Недостатки в общедоступном приложении, которая позволяет атакующим получить доступ к системе или сети, что особенно актуально при эксплуатации уязвимостей веб-приложений и сервисов.

Тактика TA0002: Выполнение реализуется с помощью нескольких техник T1610: Развёртывание контейнера, T1204: Выполнение с участием пользователя, T1059: Интерпретаторы командной строки и сценариев, а также T1203: Эксплуатация уязвимостей в клиентском ПО. Эти методики дают злоумышленнику возможность запускать вредоносный код на целевой системе после успешной атаки.

В рамках тактики TA0004: Повышение привилегий применяется техника T1068: Эксплуатация уязвимостей для повышения привилегий. Она позволяет злоумышленнику расширить свои полномочия в системе, укрепив контроль после первоначального проникновения.

Тактика TA0005: Предотвращение обнаружения включает техники T1562: Ослабление защиты, T1548: Обход механизмов контроля привилегий, T1574: Перехват потока исполнения и T1620: Отраженная загрузка кода. Данные методы используются для сокрытия вредоносной активности и затруднения её выявления системами безопасности.

Перемещение внутри периметра, описываемое тактикой TA0008, осуществляется с помощью техники T1210: Эксплуатация уязвимостей в удаленных службах, что позволяет злоумышленнику перемещаться по сети и расширять своё влияние.

Организация управления, тактика TA0011, реализуется через технику T1071: Протокол прикладного уровня используется для передачи команд и управления вредоносным кодом, обеспечивая скрытность и устойчивость управления.

Наконец, тактика TA0040: Деструктивное воздействие включает техники T1565: Манипуляции с данными, T1499: Точечный отказ в обслуживании, T1485: Уничтожение данных и T1495: Повреждение прошивки. Эти методы позволяют злоумышленнику наносить значительный ущерб системе или сети, например, вызывая сбои, уничтожая данные или повреждая критические компоненты оборудования [11].

Выбор именно этих тактик и техник обусловлен их эффективностью в реализации сценария маскировки и обхода защитных механизмов с помощью манипуляции MIME-типами, внедрения вредоносных файлов и команд, а также скрытной эксплуатации уязвимостей.

В таблице 15 ниже представлено соотношение техник и тактик с уязвимостями для CAPEC-42.

Таблица 15 – Соотнесение техник и тактик с уязвимостями CAPEC-42

CAPEC-42: преобразование MIME		
Тактика	Техника	Уязвимости, эксплуатация, которых приводит к технике
TA0043:Разведка	T1595: Активное сканирование	CVE-2025-24124, CVE-2025-0938
TA0001:Первоначальный доступ	T1190: Недостатки в общедоступном приложении	CVE-2025-3538, CVE-2025-3161, CVE-2024-23828, CVE-2024-22319
TA0002:Выполнение	T1610: Развертывание контейнера	CVE-2025-21677, CVE-2025-21678, CVE-2025-20184
	T1204: Выполнение с участием пользователя	CVE-2024-1619, CVE-2025-1365, CVE-2025-25663,
	T1059: Интерпретаторы командной строки и сценариев	CVE-2025-3346,CVE-2024-21687, CVE-2024-38366
	T1203: Эксплуатация уязвимостей в клиентском ПО	CVE-2025-23397, CVE-2025-23398, CVE-2025-23400
TA0004:Повышение привилегий	T1068: Эксплуатация уязвимостей для повышения привилегий	CVE-2025-1365, CVE-2024-21900,CVE-2024-39483, CVE-2024-20429
TA0005:Предотвращение обнаружения	T1562: Ослабление защиты	CVE-2025-21230, CVE-2025-21280, CVE-2025-21284

Продолжение таблицы 15

CAPEC-42: преобразование MIME		
Техника	Техника	Техника
	T1548: Обход механизмов контроля привилегий	CVE-2025-21194, CVE-2025-21235, CVE-2025-21234 CVE-2025-21686
	T1574: Перехват потока исполнения	CVE-2025-27834, CVE-2025-27830, CVE-2025-28398, CVE-2025-25898
	T1620: Отраженная загрузка кода	CVE-2025-0514, CVE-2025-20183
TA0008: Перемещение внутри периметра	T1210: Эксплуатация уязвимостей в удаленных службах	CVE-2025-2619, CVE-2025-2620, CVE-2025-2618, CVE-2025-2621
TA0011:Организация управления	T1071: Протокол прикладного уровня	CVE-2025-0528, CVE-2025-1192, CVE-2025-3249
TA0040:Деструктивное воздействие	T1565: Манипуляции с данными	CVE-2024-53263, CVE-2025-21370, CVE-2024-39784,CVE-2024-39785
	T1499: Точечный отказ в обслуживании	CVE-2025-3328,CVE-2025-3346, CVE-2025-25456, CVE-2025-20115
	T1485: Уничтожение данных	CVE-2025-21350, CVE-2025-24319, CVE-2025-24970
	T1495: Повреждение прошивки	CVE-2025-23380, CVE-2025-21873, CVE-2025-21916

Для воплощения сценария атаки CAPEC-71, связанного с применением кодировки Unicode для обхода логики проверки, были выбраны конкретные тактики и техники, потому что они наиболее полно отражают возможные этапы и методы злоумышленников при проведении такой атаки.

Во-первых, тактика TA0001: Первоначальный доступ включает техники T1133: Внешние службы удалённого доступа, T1566:Фишинг и T1190:Недостатки в общедоступном приложении, которые позволяют злоумышленнику получить доступ ко входу в систему или сеть.

Далее, тактика TA0002: Выполнение включает техники T1569:Системные службы, T1204:Выполнение с участием пользователя и T1059: Интерпретаторы командной строки и сценариев. Эти способы позволяют злоумышленнику запускать вредоносные команды и скрипты на целевой системе.

Тактика TA0004: Повышение привилегий включает техники T1548: Обход механизмов контроля привилегий, T1546: Выполнение по событию и T1543: Создание или изменение системных процессов, которые позволяют злоумышленнику расширить свои права и возможности на целевой системе, обходя ограничения и применяя системные механизмы для запуска вредоносного кода с повышенными привилегиями.

Тактика TA0005: Предотвращение обнаружения включает техники T1562: Ослабление защиты, T1574: Перехват потока исполнения и T1620: Отражённая загрузка кода. Они направлены на сокрытие вредоносной активности, обход средств защиты и маскировку действий злоумышленника.

Тактика TA0006: Получение учётных данных реализуется через технику T1552: Незащищённые учётные данные, которая позволяет злоумышленнику получить или использовать ненадёжно защищённые учётные данные для дальнейшего проникновения и распространения.

Тактика TA0009: Сбор данных включает технику T1005: Данные из локальной системы, что помогает собрать важную информацию о системе и окружении, необходимого для дальнейших атак.

Тактика TA0011: Организация управления включает технику T1071: Протокол прикладного уровня, который позволяет злоумышленнику управлять вредоносным кодом и коммуникациями с использованием легитимных протоколов, оставаясь незаметным.

Наконец, тактика TA0040: Деструктивное воздействие включает технику T1499: Точечный отказ в обслуживании, позволяющий злоумышленнику вызвать отказ работы системы или перегрузку ресурсов, нанося ущерб инфраструктуре [11].

Выбор именно этих тактик и техник обусловлен их эффективностью в воплощении сценария использования кодировки Unicode для обхода логики контроля, а также их частотой при подобных атаках, подтвержденной в открытых источниках. Эти методы позволяют злоумышленнику маскировать вредоносный код, обходить системы фильтрации и проверки, а также сохранять управление над системами в условиях активной обороны.

В таблице 16 ниже представлено соотношение техник и тактик с уязвимостями для CAPEC-71.

Таблица 16 – Соотнесение техник и тактик с уязвимостями CAPEC-71

CAPEC-71: использование кодировки Unicode для обхода логики проверки		
Тактика	Техника	Уязвимости, эксплуатация которых приводит к технике
TA0001:Первоначальный доступ	T1133: Внешние службы удаленного доступа	CVE-2025-1767, CVE-2025-27493, CVE-2023-23840
	T1566: Фишинг	CVE-2024-33510, CVE-2022-26137, CVE-2022-26136
	T1190: Недостатки в общедоступном приложении	CVE-2024-12962, CVE-2024-12967, CVE-2024-12968
TA0002:Выполнение	T1569: Системные службы	CVE-2025-21375, CVE-2023-40037, CVE-2023-33225
	T1204: Выполнение с участием пользователя	CVE-2025-1080, CVE-2023-31169, CVE-2024-30103
	T1059: Интерпретаторы командной строки и сценариев	CVE-2024-10914, CVE-2024-10915, CVE-2024-50572
TA0004:Повышение привилегий	T1548: Обход механизмов контроля привилегий	CVE-2025-24073, CVE-2025-29811, CVE-2025-26647
	T1546: Выполнение по событию	CVE-2024-54158, CVE-2024-20278, CVE-2024-47565
	T1543: Создание или изменение системных процессов	CVE-2024-12350, CVE-2025-24446, CVE-2025-27489
TA0005:Предотвращение обнаружения	T1562: Ослабление защиты	CVE-2024-50340, CVE-2024-11124, CVE-2024-11234
	T1574: Перехват потока исполнения	CVE-2025-24074, CVE-2025-24060, CVE-2025-24062
	T1620: Отраженная загрузка кода	CVE-2025-31477,CVE-2025-1736, CVE-2023-23843

Продолжение таблицы 16

CAPEC-71: использование кодировки Unicode для обхода логики проверки		
Техника	Техника	Уязвимости, эксплуатация которых приводит к технике
TA0006:Получение учетных данных	T1552: Незащищенные учетные данные	CVE-2025-24058, CVE-2025-27110, CVE-2025-29822
TA0009:Сбор данных	T1005: Данные из локальной системы	CVE-2025-29821, CVE-2025-24514, CVE-2025-20227
TA0011:Организация управления	T1071: Протокол прикладного уровня	CVE-2024-12966, CVE-2024-12965, CVE-2023-23844
TA0040:Деструктивное воздействие	T1499: Точечный отказ в обслуживании	CVE-2024-56717, CVE-2025-20146, CVE-2025-20142

Создание моделей атак, основанных на конкретных шаблонах и последовательностях техник MITRE, представляет собой эффективный метод для изучения и предсказания действий злоумышленников. Разработанные сценарии дают возможность формировать базу для создания детализированных микромоделей, которые отражают конкретные реализации техник сценариев. Эти модели учитывают вероятные риски и возможные последствия атак, что способствует более точной оценке угроз и выработке мер защиты.

3 Моделирование рисков и оценка вероятности успешной реализации кибератак

3.1 Определение оценки критичности эксплуатируемых уязвимостей

В этом разделе рассматривается методика определения оценки критичности каждой обнаруженной уязвимости посредством комплексного подхода, включающего различные системы измерения риска.

Для последующих расчетов производилось вычисление среднеквадратичного значения и среднеквадратичного отклонения [76].

Сначала был осуществлён сравнительный анализ результатов, полученных с использованием нескольких известных калькуляторов оценки рисков, включая CVSS версий 3.1 и 4.0, EPSS и OWASP, который представлен в таблице 17 для шаблона атаки CAPEC-465 класса «Злоупотребление механизмами обработки данных».

Таблица 17 – Расчёт калькуляторов уязвимостей шаблона атаки CAPEC-465

Уязвимости	Оценка CVSS 3.1	Оценка CVSS 4.0	Оценка EPSS	Оценка OWASP
CVE-2024-9870	4.3	5.3	0.16	6.625
CVE-2019-1841	6.5	8.3	0.1214	6.125
CVE-2025-25061	5.8	6.9	0.32	5.250
CVE-2024-0387	9.0	9.4	0.164	6.250
CVE-2025-0237	6.8	6.9	0.74	5.75

Для шаблона атаки CAPEC-44, проведен расчет оценки рисков по калькуляторам, который представлен в таблице 18.

Таблица 18 – Расчёт калькуляторов уязвимостей шаблона атаки CAPEC-44

Уязвимости	Оценка CVSS 3.1	Оценка CVSS 4.0	Оценка EPSS	Оценка OWASP
CVE-2025-1814	8.8	8.7	0.23	4.25
CVE-2025-0848	6.5	7.1	0.07	3.5
CVE-2025-0566	8.8	8.7	0.08	4.25
CVE-2025-24153	6.7	8.4	0.02	5.625
CVE-2023-45133	8.8	8.7	0.67	4.25

Продолжение таблицы 18

Уязвимости	Оценка CVSS 3.1	Оценка CVSS 4.0	Оценка EPSS	Оценка OWASP
CVE-2025-0753	6.5	6.9	0.41	5.5
CVE-2025-1539	8.8	9.4	0.94	6.25
CVE-2025-1538	8.8	8.2	0.28	6.5
CVE-2025-22907	9.8	9.3	0.64	6.25
CVE-2025-22916	9.8	9.3	0.155	6.25
CVE-2025-22904	9.8	9.3	0.07	6.25
CVE-2025-1215	2.8	4.6	0.174	3.5
CVE-2023-28936	5.3	6.3	0.19	5.5
CVE-2025-0285	7.8	8.5	0.547	5.125
CVE-2025-0927	7.8	8.5	0.07	5.125
CVE-2024-23903	5.3	4.8	0.08	4.5
CVE-2024-41958	6.6	6.7	0.295	3.375
CVE-2025-25510	5.5	6.7	0.169	3.5
CVE-2025-25505	6.5	6.9	0.174	4.25
CVE-2025-24131	6.5	6.9	0.27	4.0
CVE-2025-25472	5.3	4.8	0.16	4.5
CVE-2025-25900	5.5	6.9	0.18	3.675
CVE-2025-24151	9.8	9.4	0.25	5.5
CVE-2025-24126	9.8	9.4	0.109	5.25
CVE-2025-25662	9.8	9.4	0.17	6.75
CVE-2023-49994	5.5	6.9	0.44	4.25

Анализ оценки рисков для шаблона атаки CAPEC-42, представлен в таблице 19.

Таблица 19 – Расчёт калькуляторов уязвимостей шаблона атаки CAPEC-42

Уязвимости	Оценка CVSS 3.1	Оценка CVSS 4.0	Оценка EPSS	Оценка OWASP
CVE-2025-24124	9.8	9.3	0.26	6.125
CVE-2025-0938	6.8	7.1	0.27	5.5
CVE-2025-3538	8.8	8.7	0.69	5.625
CVE-2025-3161	8.8	8.7	0.79	5.625

Продолжение таблицы 19

Уязвимости	Оценка CVSS 3.1	Оценка CVSS 4.0	Оценка EPSS	Оценка OWASP
CVE-2024-23828	8.8	8.7	0.138	5.625
CVE-2024-22319	8.1	8.7	0.28	5.75
CVE-2025-21677	5.5	6.8	0.36	5.125
CVE-2025-21678	5.5	6.8	0.94	5.125
CVE-2025-20184	6.5	6.9	0.97	5.375
CVE-2024-1619	4.8	5.3	0.328	3.5
CVE-2025-1365	5.3	4.8	0.34	4.5
CVE-2025-25663	9.8	9.3	0.58	6.125
CVE-2025-3346	8.8	8.7	0.154	5.625
CVE-2024-21687	8.1	8.7	0.24	5.625
CVE-2024-38366	10	10	0.325	6.375
CVE-2025-23397	7.8	7.3	0.307	5.375
CVE-2025-23398	7.8	7.3	0.307	5.375
CVE-2025-23400	7.8	7.3	0.307	5.375
CVE-2024-21900	4.3	5.8	0.09	3.5
CVE-2024-39483	5.5	6.9	0.33	5.125
CVE-2024-20429	6.5	6.9	0.81	5.375
CVE-2025-21230	7.5	6.9	0.182	5.375
CVE-2025-21280	5.5	6.9	0.182	5.125
CVE-2025-21284	5.5	6.9	0.72	5.125
CVE-2025-21194	7.1	8.7	0.18	5.5
CVE-2025-21235	7.8	7.3	0.55	5.375
CVE-2025-21234	7.8	7.3	0.118	5.375
CVE-2025-21686	5.5	6.9	0.943	5.125
CVE-2025-27834	7.8	8.5	0.78	5.375
CVE-2025-27830	7.8	8.5	0.65	5.375
CVE-2025-28398	9.8	9.3	0.993	6.125
CVE-2025-25898	7.5	8.1	0.788	5.25
CVE-2025-0514	7.6	8.3	0.99	5.25
CVE-2025-20183	5.8	6.9	0.135	5.125
CVE-2025-2619	9.8	9.3	0.99	6.125

Продолжение таблицы 19

Уязвимости	Оценка CVSS 3.1	Оценка CVSS 4.0	Оценка EPSS	Оценка OWASP
CVE-2025-2620	9.8	9.3	0.58	6.125
CVE-2025-2618	9.8	9.3	0.125	6.125
CVE-2025-2621	9.8	9.3	0.33	6.125
CVE-2025-0528	7.2	8.6	0.236	5.5
CVE-2025-1192	6.3	5.3	0.163	5.125
CVE-2025-3249	6.3	5.3	0.371	5.125
CVE-2024-53263	8.8	8.5	0.431	5.625
CVE-2025-21370	7.8	7.1	0.148	5.5
CVE-2024-39784	9.1	9.3	0.28	6.0
CVE-2024-39785	9.1	9.3	0.77	6.0
CVE-2025-3328	8.8	8.5	0.124	5.625
CVE-2025-25456	9.8	9.3	0.53	6.125
CVE-2025-20115	8.6	9.1	0.28	5.75
CVE-2025-21350	5.9	6.8	0.28	5.25
CVE-2025-24319	6.5	7.1	0.71	5.5
CVE-2025-24970	7.5	6.3	0.103	5.25
CVE-2025-21873	4.6	5.3	0.22	5.25
CVE-2025-21916	5.5	6.3	0.38	5.25
CVE-2025-23380	4.6	5.3	0.41	3.25

Полученные результаты оценки рисков для шаблона атаки CAPEC-71, представлены в таблице 20.

Таблица 20 – Расчёт калькуляторов уязвимостей шаблона атаки CAPEC-71

Уязвимости	Оценка CVSS 3.1	Оценка CVSS 4.0	Оценка EPSS	Оценка OWASP
CVE-2025-1767	6.5	6.9	0.36	4.875
CVE-2025-27493	8.2	9.3	0.26	5.875
CVE-2023-23840	7.2	7.6	0.291	5.125
CVE-2024-33510	4.3	5.4	0.74	3.125
CVE-2022-26137	7.3	6.9	0.82	5.5

Продолжение таблицы 20

Уязвимости	Оценка CVSS 3.1	Оценка CVSS 4.0	Оценка EPSS	Оценка OWASP
CVE-2022-26136	5.3	4.8	0.183	4.125
CVE-2024-12962	7.3	6.9	0.34	5.5
CVE-2024-12967	7.3	6.9	0.04	5.5
CVE-2024-12968	7.3	6.9	0.44	5.5
CVE-2025-21375	9.8	9.3	0.132	5.25
CVE-2023-40037	6.5	6.9	0.141	4.875
CVE-2023-33225	7.2	8.6	0.206	5.125
CVE-2025-1080	7.6	7.2	0.51	5.125
CVE-2023-31169	4.8	5.3	0.56	3.5
CVE-2024-30103	8.8	8.7	0.192	5.375
CVE-2024-10914	8.1	8.3	0.934	5.375
CVE-2024-10915	9.8	9.3	0.925	6.25
CVE-2024-50572	7.2	8.6	0.372	5.125
CVE-2025-24073	7.8	8.5	0.98	5.375
CVE-2025-29811	7.8	8.5	0.98	5.375
CVE-2025-26647	8.1	8.3	0.129	5.375
CVE-2024-54158	3.5	4.8	0.19	3.0
CVE-2024-20278	6.5	6.9	0.48	5.625
CVE-2024-47565	4.3	5.8	0.88	3.5
CVE-2024-12350	8.8	5.3	0.794	4.675
CVE-2025-24446	9.1	9.4	0.117	6.5
CVE-2025-27489	7.8	8.5	0.98	5.375
CVE-2024-50340	7.3	6.9	0.855	5.5
CVE-2024-11124	7.2	5.1	0.51	5.0
CVE-2024-11234	4.8	5.3	0.39	3.5
CVE-2025-24074	7.8	8.5	0.98	5.75
CVE-2025-24060	7.8	8.5	0.98	5.75
CVE-2025-24062	7.8	8.5	0.98	5.75
CVE-2025-31477	9.8	9.3	0.747	6.25
CVE-2025-1736	4.3	5.8	0.158	3.5
CVE-2023-23843	7.2	5.1	0.206	5.0

Продолжение таблицы 20

Уязвимости	Оценка CVSS 3.1	Оценка CVSS 4.0	Оценка EPSS	Оценка OWASP
CVE-2025-24058	7.8	8.5	0.98	5.375
CVE-2025-27110	7.5	8.7	0.44	5.5
CVE-2025-29822	7.8	8.5	0.608	5.375
CVE-2025-29821	5.5	5.3	0.83	4.5
CVE-2025-24514	8.8	5.3	0.308	4.675
CVE-2025-20227	4.3	5.8	0.06	3.5
CVE-2024-12966	7.1	6.9	0.44	5.5
CVE-2024-12965	7.3	6.9	0.04	5.5
CVE-2023-23844	7.2	5.1	0.209	5.0
CVE-2024-56717	5.5	5.3	0.27	4.5
CVE-2025-20146	8.6	9.2	0.157	5.125
CVE-2025-20142	8.6	9.2	0.113	5.125

Стоит подчеркнуть, что перед вычислением критичности важно свести все оценки к единому масштабу, так как применяемые калькуляторы оценивают риски в различных используемых шкалах. Чтобы гарантировать корректность последующего анализа, нужно провести нормализацию оценок. Эту процедуру выполним, используя формулу (1):

$$S_{norm} = \frac{S - S_{min}}{S_{max} - S_{min}}, \quad (1)$$

где: S_{norm} – нормализованная оценка калькулятора;

S – оценка калькулятора;

S_{max} – максимальная возможная оценка калькулятора;

S_{min} – минимальная возможная оценка калькулятора.

Таблицы 21 содержит результаты нормализации оценок критичности выявленных уязвимостей для шаблона атаки CAPEC-465.

Таблица 21 – Расчёт нормализованных значений калькуляторов уязвимостей шаблона атаки CAPEC-465

Уязвимости	S_{norm},$CVSS$3.1	S_{norm},$CVSS$4.0	S_{norm},$EPSS$	S_{norm},$OWASP$
CVE-2024-9870	0.43	0.56	0.14	0.6625
CVE-2019-1841	0.65	0.83	0.1214	0.6125
CVE-2025-25061	0.58	0.69	0.32	0.525
CVE-2024-0387	0.90	0.94	0.164	0.625
CVE-2025-0237	0.68	0.69	0.74	0.575

Для шаблона атаки CAPEC-44 представлены данные нормализации оценок критичности выявленных уязвимостей в таблице 22.

Таблица 22 – Расчёт нормализованных значений калькуляторов уязвимостей шаблона атаки CAPEC-44

Уязвимости	Оценка CVSS 3.1	Оценка CVSS 4.0	Оценка EPSS	Оценка OWASP
CVE-2025-1814	0.88	0.87	0.23	0.425
CVE-2025-0848	0.65	0.71	0.07	0.35
CVE-2025-0566	0.88	0.87	0.08	0.425
CVE-2025-24153	0.67	0.84	0.02	0.5625
CVE-2023-45133	0.88	0.87	0.67	0.425
CVE-2025-0753	0.65	0.69	0.41	0.55
CVE-2025-1539	0.88	0.94	0.94	0.625
CVE-2025-1538	0.88	0.82	0.28	0.65
CVE-2025-22907	0.98	0.93	0.64	0.625
CVE-2025-22916	0.98	0.93	0.155	0.625
CVE-2025-22904	0.98	0.93	0.07	0.625
CVE-2025-1215	0.28	0.46	0.174	0.35
CVE-2023-28936	0.53	0.63	0.19	0.55
CVE-2025-0285	0.78	0.85	0.547	0.5125
CVE-2025-0927	0.78	0.85	0.07	0.5125
CVE-2024-23903	0.53	0.48	0.08	0.45
CVE-2024-41958	0.66	0.67	0.295	0.3375

Продолжение таблицы 22

Уязвимости	Оценка CVSS 3.1	Оценка CVSS 4.0	Оценка EPSS	Оценка OWASP
CVE-2025-25510	0.55	0.67	0.169	0.35
CVE-2025-25505	0.65	0.69	0.174	0.425
CVE-2025-24131	0.65	0.69	0.27	0.4
CVE-2025-25472	0.53	0.48	0.16	0.45
CVE-2025-25900	0.55	0.69	0.18	0.3675
CVE-2025-24151	0.98	0.94	0.25	0.55
CVE-2025-24126	0.98	0.94	0.109	0.525
CVE-2025-25662	0.98	0.94	0.17	0.675
CVE-2023-49994	0.55	0.69	0.44	0.425

Нормализованная оценка критичности выявленных уязвимостей для шаблона атаки CAPEC-42, представлена в таблице 23.

Таблица 23 – Расчёт нормализованных значений калькуляторов уязвимостей шаблона атаки CAPEC-42

Уязвимости	Оценка CVSS 3.1	Оценка CVSS 4.0	Оценка EPSS	Оценка OWASP
CVE-2025-24124	0.98	0.93	0.26	0.6125
CVE-2025-0938	0.68	0.71	0.27	0.55
CVE-2025-3538	0.88	0.87	0.69	0.5625
CVE-2025-3161	0.88	0.87	0.79	0.5625
CVE-2024-23828	0.88	0.87	0.138	0.5625
CVE-2024-22319	0.81	0.87	0.28	0.575
CVE-2025-21677	0.55	0.68	0.36	0.5125
CVE-2025-21678	0.55	0.68	0.94	0.5125
CVE-2025-20184	0.65	0.69	0.97	0.5375
CVE-2024-1619	0.48	0.53	0.328	0.35
CVE-2025-1365	0.53	0.48	0.34	0.45
CVE-2025-25663	0.98	0.93	0.58	0.6125
CVE-2025-3346	0.88	0.87	0.154	0.5625
CVE-2024-21687	0.81	0.87	0.24	0.5625

Продолжение таблицы 23

Уязвимости	Оценка CVSS 3.1	Оценка CVSS 4.0	Оценка EPSS	Оценка OWASP
CVE-2024-38366	1	1	0.325	0.6375
CVE-2025-23397	0.78	0.73	0.307	0.5375
CVE-2025-23398	0.78	0.73	0.307	0.5375
CVE-2025-23400	0.78	0.73	0.307	0.5375
CVE-2024-21900	0.43	0.58	0.09	0.35
CVE-2024-39483	0.55	0.69	0.33	0.5125
CVE-2024-20429	0.65	0.69	0.81	0.5375
CVE-2025-21230	0.75	0.69	0.182	0.5375
CVE-2025-21280	0.55	0.69	0.182	0.5125
CVE-2025-21284	0.55	0.69	0.72	0.5125
CVE-2025-21194	0.71	0.87	0.18	0.55
CVE-2025-21235	0.78	0.73	0.55	0.5375
CVE-2025-21234	0.78	0.73	0.118	0.5375
CVE-2025-21686	0.55	0.69	0.943	0.5125
CVE-2025-27834	0.78	0.85	0.78	0.5375
CVE-2025-27830	0.78	0.85	0.65	0.5375
CVE-2025-28398	0.98	0.93	0.993	0.6125
CVE-2025-25898	0.75	0.81	0.788	0.525
CVE-2025-0514	0.76	0.83	0.99	0.525
CVE-2025-20183	0.58	0.69	0.135	0.5125
CVE-2025-2619	0.98	0.93	0.99	0.6125
CVE-2025-2620	0.98	0.93	0.58	0.6125
CVE-2025-2618	0.98	0.93	0.125	0.6125
CVE-2025-2621	0.98	0.93	0.33	0.6125
CVE-2025-0528	0.72	0.86	0.236	0.55
CVE-2025-1192	0.63	0.53	0.163	0.5125
CVE-2025-3249	0.63	0.53	0.371	0.5125
CVE-2024-53263	0.88	0.85	0.431	0.5625
CVE-2025-21370	0.78	0.71	0.148	0.55
CVE-2024-39784	0.91	0.93	0.28	0.6
CVE-2024-39785	0.91	0.93	0.77	0.6

Продолжение таблицы 23

Уязвимости	Оценка CVSS 3.1	Оценка CVSS 4.0	Оценка EPSS	Оценка OWASP
CVE-2025-3328	0.88	0.85	0.124	0.5625
CVE-2025-25456	0.98	0.93	0.53	0.6125
CVE-2025-20115	0.86	0.91	0.28	0.575
CVE-2025-21350	0.59	0.68	0.28	0.525
CVE-2025-24319	0.65	0.71	0.371	0.55
CVE-2025-24970	0.75	0.63	0.103	0.525
CVE-2025-21873	0.46	0.53	0.22	0.525
CVE-2025-21916	0.55	0.63	0.38	0.525
CVE-2025-23380	0.46	0.53	0.41	0.325

Результаты нормализации оценки критичности выявленных уязвимостей для шаблона атаки CAPEC-71, представлена в таблице 24.

Таблица 24 – Расчёт нормализованных значений калькуляторов уязвимостей шаблона атаки CAPEC-71

Уязвимости	Оценка CVSS 3.1	Оценка CVSS 4.0	Оценка EPSS	Оценка OWASP
CVE-2025-1767	0.65	0.69	0.36	0.4875
CVE-2025-27493	0.82	0.93	0.26	0.5875
CVE-2023-23840	0.72	0.76	0.291	0.5125
CVE-2024-33510	0.43	0.54	0.74	0.3125
CVE-2022-26137	0.73	0.69	0.82	0.55
CVE-2022-26136	0.53	0.48	0.183	0.4125
CVE-2024-12962	0.73	0.69	0.34	0.55
CVE-2024-12967	0.73	0.69	0.04	0.55
CVE-2024-12968	0.73	0.69	0.44	0.55
CVE-2025-21375	0.98	0.93	0.132	0.525
CVE-2023-40037	0.65	0.69	0.141	0.4875
CVE-2023-33225	0.72	0.86	0.206	0.5125
CVE-2025-1080	0.76	0.72	0.51	0.5125
CVE-2023-31169	0.48	0.53	0.56	0.35

Продолжение таблицы 24

Уязвимости	Оценка CVSS 3.1	Оценка CVSS 4.0	Оценка EPSS	Оценка OWASP
CVE-2024-30103	0.88	0.87	0.192	0.5375
CVE-2024-10914	0.81	0.83	0.934	0.5375
CVE-2024-10915	0.98	0.93	0.925	0.625
CVE-2024-50572	0.72	0.86	0.372	0.5125
CVE-2025-24073	0.78	0.85	0.98	0.5375
CVE-2025-29811	0.78	0.85	0.98	0.5375
CVE-2025-26647	0.81	0.83	0.129	0.5375
CVE-2024-54158	0.35	0.48	0.19	0.3
CVE-2024-20278	0.65	0.69	0.48	0.5625
CVE-2024-47565	0.43	0.58	0.88	0.35
CVE-2024-12350	0.88	0.53	0.794	0.4675
CVE-2025-24446	0.91	0.94	0117	0.65
CVE-2025-27489	0.78	0.85	0.98	0.5375
CVE-2024-50340	0.73	0.69	0.855	0.55
CVE-2024-11124	0.72	0.51	0.51	0.5
CVE-2024-11234	0.48	0.53	0.39	0.35
CVE-2025-24074	0.78	0.85	0.98	0.575
CVE-2025-24060	0.78	0.85	0.98	0.575
CVE-2025-24062	0.78	0.85	0.98	0.575
CVE-2025-31477	0.98	0.93	0.747	0.625
CVE-2025-1736	0.43	0.58	0.158	0.35
CVE-2023-23843	0.72	0.51	0.206	0.5
CVE-2025-24058	0.78	0.85	0.98	0.5375
CVE-2025-27110	0.75	0.87	0.44	0.55
CVE-2025-29822	0.78	0.85	0.608	0.5375
CVE-2025-29821	0.55	0.53	0.83	0.45
CVE-2025-24514	0.88	0.53	0.308	0.4675
CVE-2025-20227	0.43	0.58	0.06	0.35
CVE-2024-12966	0.71	0.69	0.44	0.55
CVE-2024-12965	0.73	0.69	0.04	0.55
CVE-2023-23844	0.72	0.51	0.209	0.5

Продолжение таблицы 24

Уязвимости	Оценка CVSS 3.1	Оценка CVSS 4.0	Оценка EPSS	Оценка OWASP
CVE-2024-56717	0.55	0.53	0.27	0.45
CVE-2025-20146	0.86	0.92	0.157	0.5125
CVE-2025-20142	0.86	0.92	0.113	0.5125

Применение методики вычисления среднеквадратичного значения предполагает определение среднего значения. Используя формулу (2), были рассчитаны средние оценки для каждой отдельно взятой уязвимости:

$$S_{final} = \sqrt{\frac{1}{n}\sum_{i=1}^{n} S_{norm,i.}^{2}} \quad (2)$$

где: S_{final} – среднеквадратическая оценка критичности уязвимости;

$S_{norm,i}$- нормализованная оценка калькулятора;

n – количество используемых калькуляторов.

Следующим этапом, станет подсчет среднеквадратичной оценки уязвимостей шаблона атаки CAPEC-465, который представлен в таблице 25.

Таблица 25 - Итоговая среднеквадратичная оценка шаблона атаки CAPEC-465

Уязвимости	Среднеквадратичная оценка
CVE-2024-9870	0.4891
CVE-2019-1841	0.6126
CVE-2025-25061	0.5456
CVE-2024-0387	0.7265
CVE-2025-0237	0.6276

Затем, выполним расчет среднеквадратичной оценки уязвимостей шаблона атаки CAPEC-44, который представлен в таблице 26.

Таблица 26 - Итоговая среднеквадратичная оценка шаблона атаки CAPEC-44

Уязвимости	Среднеквадратичная оценка
CVE-2025-1814	0.6642
CVE-2025-0848	0.5133
CVE-2025-0566	0.6554
CVE-2025-24153	0.6065
CVE-2023-45133	0.7350
CVE-2025-0753	0.5851
CVE-2025-1539	0.8217
CVE-2025-1538	0.6316
CVE-2025-22907	0.7706
CVE-2025-22916	0.6606
CVE-2025-22904	0.5133
CVE-2025-1215	0.6827
CVE-2023-28936	0.5041
CVE-2025-0285	0.6945
CVE-2025-0927	0.6322
CVE-2024-23903	0.4243
CVE-2024-41958	0.5209
CVE-2025-25510	0.6485
CVE-2025-25505	0.6933
CVE-2025-24131	0.3037
CVE-2025-25472	0.6669
CVE-2025-25900	0.6120
CVE-2025-24151	0.7431
CVE-2025-24126	0.6565
CVE-2025-25662	0.6797
CVE-2023-49994	0.5368

Далее, перейдем к расчету среднеквадратичной оценки уязвимостей шаблона атаки CAPEC-42, который представлен в таблице 27.

Таблица 27 - Итоговая среднеквадратичная оценка шаблона атаки CAPEC-42

Уязвимости	Среднеквадратичная оценка
CVE-2025-24124	0.7530
CVE-2025-0938	0.5792
CVE-2025-3538	0.7622
CVE-2025-3161	0.7861
CVE-2024-23828	0.6831
CVE-2024-22319	0.6749
CVE-2025-21677	0.5379
CVE-2025-21678	0.6912
CVE-2025-20184	0.7295
CVE-2024-1619	0.4305
CVE-2025-1365	0.4554
CVE-2025-25663	0.7964
CVE-2025-3346	0.6840
CVE-2024-21687	0.6684
CVE-2024-38366	0.7925
CVE-2025-23397	0.6173
CVE-2025-23398	0.6173
CVE-2025-23400	0.6173
CVE-2024-21900	0.4037
CVE-2024-39483	0.5362
CVE-2024-20429	0.6789
CVE-2025-21230	0.5524
CVE-2025-21280	0.5183
CVE-2025-21284	0.6244
CVE-2025-21194	0.6316
CVE-2025-21235	0.6582
CVE-2025-21234	0.6009
CVE-2025-21686	0.6947
CVE-2025-27834	0.7464
CVE-2025-27830	0.7145
CVE-2025-28398	0.8925

Продолжение таблицы 27

Уязвимости	Среднеквадратичная оценка
CVE-2025-25898	0.7272
CVE-2025-0514	0.7941
CVE-2025-20183	0.5228
CVE-2025-2619	0.8917
CVE-2025-2620	0.7964
CVE-2025-2618	0.7443
CVE-2025-2621	0.7598
CVE-2025-0528	0.6356
CVE-2025-1192	0.4917
CVE-2025-3249	0.5192
CVE-2024-53263	0.7069
CVE-2025-21370	0.5994
CVE-2024-39784	0.7300
CVE-2024-39785	0.8133
CVE-2025-3328	0.6761
CVE-2025-25456	0.7876
CVE-2025-20115	0.7030
CVE-2025-21350	0.5396
CVE-2025-24319	0.5845
CVE-2025-24970	0.4964
CVE-2025-21873	0.5058
CVE-2025-21916	0.5290
CVE-2025-23380	0.4377

Наконец, осуществим подсчет среднеквадратичной оценки уязвимостей шаблона атаки CAPEC-71, который представлен в таблице 28.

Таблица 28 - Итоговая среднеквадратичная оценка шаблона атаки CAPEC-71

Уязвимости	Среднеквадратичная оценка
CVE-2025-1767	0.5626
CVE-2025-27493	0.6982
CVE-2023-23840	0.6007
CVE-2024-33510	0.5296
CVE-2022-26137	0.7043
CVE-2022-26136	0.4228
CVE-2024-12962	0.5973
CVE-2024-12967	0.5730
CVE-2024-12968	0.6134
CVE-2025-21375	0.5988
CVE-2023-40037	0.5376
CVE-2023-33225	0.6251
CVE-2025-1080	0.6362
CVE-2023-31169	0.4867
CVE-2024-30103	0.6814
CVE-2024-10914	0.7916
CVE-2024-10915	0.8763
CVE-2024-50572	0.6440
CVE-2025-24073	0.8032
CVE-2025-29811	0.8032
CVE-2025-26647	0.6424
CVE-2024-54158	0.3460
CVE-2024-20278	0.6011
CVE-2024-47565	0.5954
CVE-2024-12350	0.6900
CVE-2025-24446	0.7328
CVE-2025-27489	0.8032
CVE-2024-50340	0.7146
CVE-2024-11124	0.5676
CVE-2024-11234	0.4433
CVE-2025-24074	0.8096

Продолжение таблицы 28

Уязвимости	Среднеквадратичная оценка
CVE-2025-24060	0.8096
CVE-2025-24062	0.8096
CVE-2025-31477	0.8328
CVE-2025-1736	0.4089
CVE-2023-23843	0.5174
CVE-2025-24058	0.8032
CVE-2025-27110	0.6737
CVE-2025-29822	0.7052
CVE-2025-29821	0.6072
CVE-2025-24514	0.5850
CVE-2025-20227	0.4023
CVE-2024-12966	0.6134
CVE-2024-12965	0.5730
CVE-2023-23844	0.5177
CVE-2024-56717	0.4634
CVE-2025-20146	0.6843
CVE-2025-20142	0.6822

Проведённый анализ дал возможность выявить уровень критичности выявленных уязвимостей. Оценка производилась с применением актуальных методов и подходов, включая широко используемые калькуляторы CVSS версий 3.0 и 4.0, систему прогнозирования эксплуатаций уязвимостей EPSS, а также методологию OWASP.

Данный подход позволил комплексно проанализировать уязвимости с разных точек зрения, учитывая возможности каждой системы оценки. Полученные результаты создают основу для дальнейших исследований и разработки эффективных мер по снижению рисков.

3.2 Создание алгоритмов для расчета вероятности успеха каждой техники в рамках сценария атак

В ходе анализа основное внимание уделяется установлению возможных последствий реализации атак, что позволяет своевременно определять наиболее опасные направления развития событий. Этот подход значительно упрощает процедуру оценки рисков и дает возможность сосредоточиться на действительно важных элементах угроз.

Задача расчета вероятности успешного завершения атак является важным аспектом информационной безопасности. Она включает создание специализированных алгоритмов, позволяющих объективно оценивать шансы злоумышленников успешно реализовать отдельные техники в рамках комплексного сценария атаки. Рассмотрим подробнее ключевые характеристики, связанные с решением этой задачи.

Вероятность успешной атаки p_i определяется возможностью злоумышленника использовать хотя бы одну из выявленных уязвимостей. Она зависит от критичности каждой i-ой уязвимости и считается равной наибольшей критичности среди всех обнаруженных, так как для успешной атаки достаточно одной успешно используемой уязвимости [76]. Расчет вероятности осуществляется по формуле (3):

$$p_i = \frac{K_i}{\sum_{i=1}^{n} K_i}, \tag{3}$$

где K_i - среднеквадратичная оценка критичности i-ой уязвимости.

Параметр «ущерб» [84] используется для количественной оценки негативных последствий, которые возникают в результате эксплуатации уязвимостей, с учетом основных аспектов информационной безопасности - конфиденциальности, целостности и доступности, известных как модель CIA.

Этот показатель задаётся раздельно для каждого критерия информационной безопасности и формируется на основе следующей общепринятой шкалы, применяемой международными организациями и широко используемой в информационной безопасности:

- нулевое значение (0) свидетельствует об отсутствии какого-либо существенного ущерба или минимальном влиянии на объект безопасности. К примеру, если нарушение связано с небольшими задержками обработки запросов, практически незаметными пользователям, то этот случай соответствует нулевому уровню ущерба;

- минимальное значение (0,2) указывает на слабый негативный ущерб или ограниченную угрозу. Такое повреждение незначительно воздействует на работу системы и не вызывает серьезных сбоев. Примером может служить временная утрата небольшого объёма данных, восстановление которых возможно без значительных затрат ресурсов;

- среднее значение (0,5) характеризует ситуацию, при которой нарушаются важные аспекты информационной безопасности, вызывая существенное снижение качества функционирования системы или её сервисов. К примеру, частичная потеря контроля над доступностью сервиса или серьезное нарушение целостности данных могут привести к такому среднему уровню ущерба [85].

Данный параметр ущерба рассчитывается по следующей формуле (4):

$$U = 1 - (1 - U_k)\,(1 - U_д)\,(1 - U_ц). \qquad (4)$$

где U_k, $U_д$, $U_ц$ – показатели ущерба по трем аспектам: конфиденциальность, доступность и целостность.

Анализ сценариев атаки CAPEC-465 основан на результатах расчётов, приведённых в таблице 29. В ней содержатся значения вероятностей единичных атак и ущерб. Эта информация служит отправной точкой для дальнейшего анализа и принятия решений.

Таблица 29 - Соответствие параметров вероятных сценариев реализации шаблона кибератаки CAPEC-465

Шаблон атаки на защищаемую систему	Техники эксплуатации уязвимостей атакуемой системы	Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Критичности эксплуатируемых уязвимостей атакуемой системы	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб эксплуатации уязвимостей атакуемой системы
CAPEC-465	T1190	CVE-2024-9870	0.4823	0.438	0.2
		CVE-2019-1841	0.6195	0.562	0.75
	T1068	CVE-2024-0387	0.5822	0.453	0.875
		CVE-2025-0237	0.7016	0.547	0.75
	T1082	CVE-2024-9870	0.4823	1	0.2
	T1090	CVE-2024-9870	0.4823	0.453	0.2
		CVE-2024-0387	0.5822	0.547	0.875
	T1485	CVE-2025-25061	0.568	1	0.2
	ИЛИ				
	T1499	CVE-2019-1841	0.6195	0.516	0.75
		CVE-2024-0387	0.5822	0.484	0.875
	ИЛИ				
	T1529	CVE-2019-1841	0.6195	1	0.75

Граф на рисунке 6 показывает взаимосвязи между техниками эксплуатации уязвимостей и их критичностью. Эта модель позволяет визуализировать и анализировать наиболее опасные пути проникновения в систему.

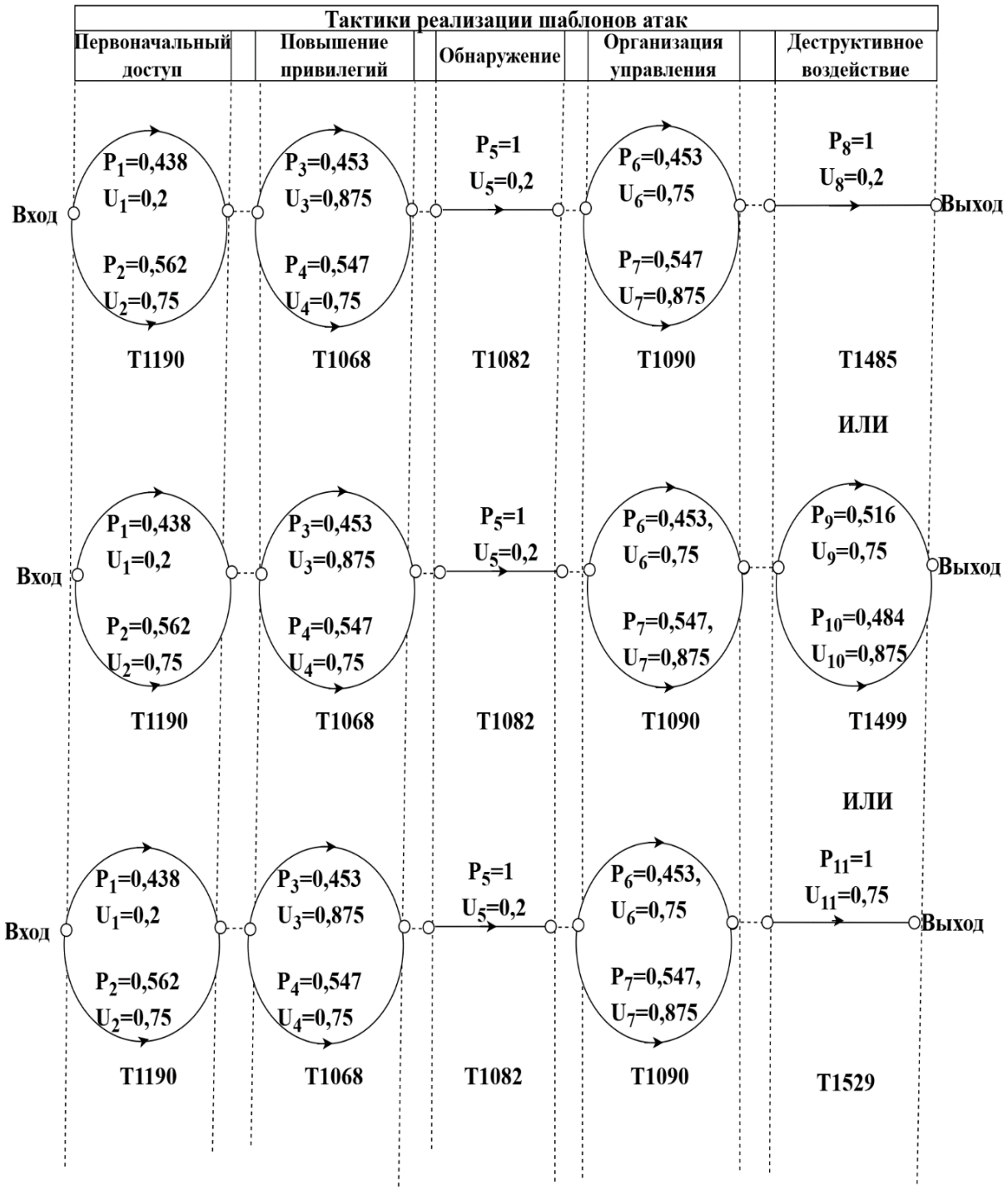

Рисунок 6. Графовая модель вероятных сценариев реализации шаблона кибератаки CAPEC-465

Анализ сценариев атак CAPEC-44 осуществляется на основе результатов, приведенных в таблице 29.

Таблица 29 - Соответствие параметров вероятных сценариев реализации шаблона кибератаки CAPEC-44

Шаблон атаки на защищаемую систему	Техники эксплуатации уязвимостей атакуемой системы	Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Критичности эксплуатируемых уязвимостей атакуемой системы	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб эксплуатации уязвимостей атакуемой системы
CAPEC-44	T1190	CVE-2025-1814	0.6642	0.362	0.875
		CVE-2025-0848	0.5133	0.280	0.5
		CVE-2025-0566	0.6554	0.358	0.875
	T1059	CVE-2025-24153	0.6065	1	0.875
	ИЛИ				
	T1059.007	CVE-2023-45133	0.7350	1	0.875
	ИЛИ				
	T1203	CVE-2025-0753	0.5851	0.287	0.5
		CVE-2025-1539	0.8217	0.403	0.875
		CVE-2025-1538	0.6316	0.310	0.875
	T1068	CVE-2025-22907	0.7706	0.396	0.875
		CVE-2025-22916	0.6606	0.340	0.875
		CVE-2025-22904	0.5133	0.264	0.875
	T1574	CVE-2025-1215	0.6827	0.575	0.2
		CVE-2023-28936	0.5041	0.425	0.2
	ИЛИ				
	T1211	CVE-2025-0285	0.6945	0.523	0.875
		CVE-2025-0927	0.6322	0.477	0.875
	ИЛИ				
	T1078	CVE-2024-23903	0.4243	0.449	0.2
		CVE-2024-41958	0.5209	0.551	0.875
	T1210	CVE-2025-25510	0.6485	0.483	0.2
		CVE-2025-25505	0.6933	0.517	0.2
	T1499	CVE-2025-24131	0.3037	0.192	0.5
		CVE-2025-25472	0.6669	0.421	0.875
		CVE-2025-25900	0.6120	0.387	0.5
	ИЛИ				
	T1489	CVE-2025-24131	0.3037	0.179	0.5
		CVE-2025-24151	0.7431	0.436	0.5
		CVE-2025-24126	0.6565	0.385	0.75
	ИЛИ				
	T1498	CVE-2025-25662	0.6797	0.559	0.875
		CVE-2023-49994	0.5368	0.441	0.5

Граф, представленный на рисунках 7-11 демонстрирует взаимосвязи между техниками эксплуатации уязвимостей и их уровнем критичности для шаблона атаки CAPEC-44, который помогает наглядно представить и детально проанализировать основные сценарии атак, представляющие наибольший риск для информационной безопасности системы.

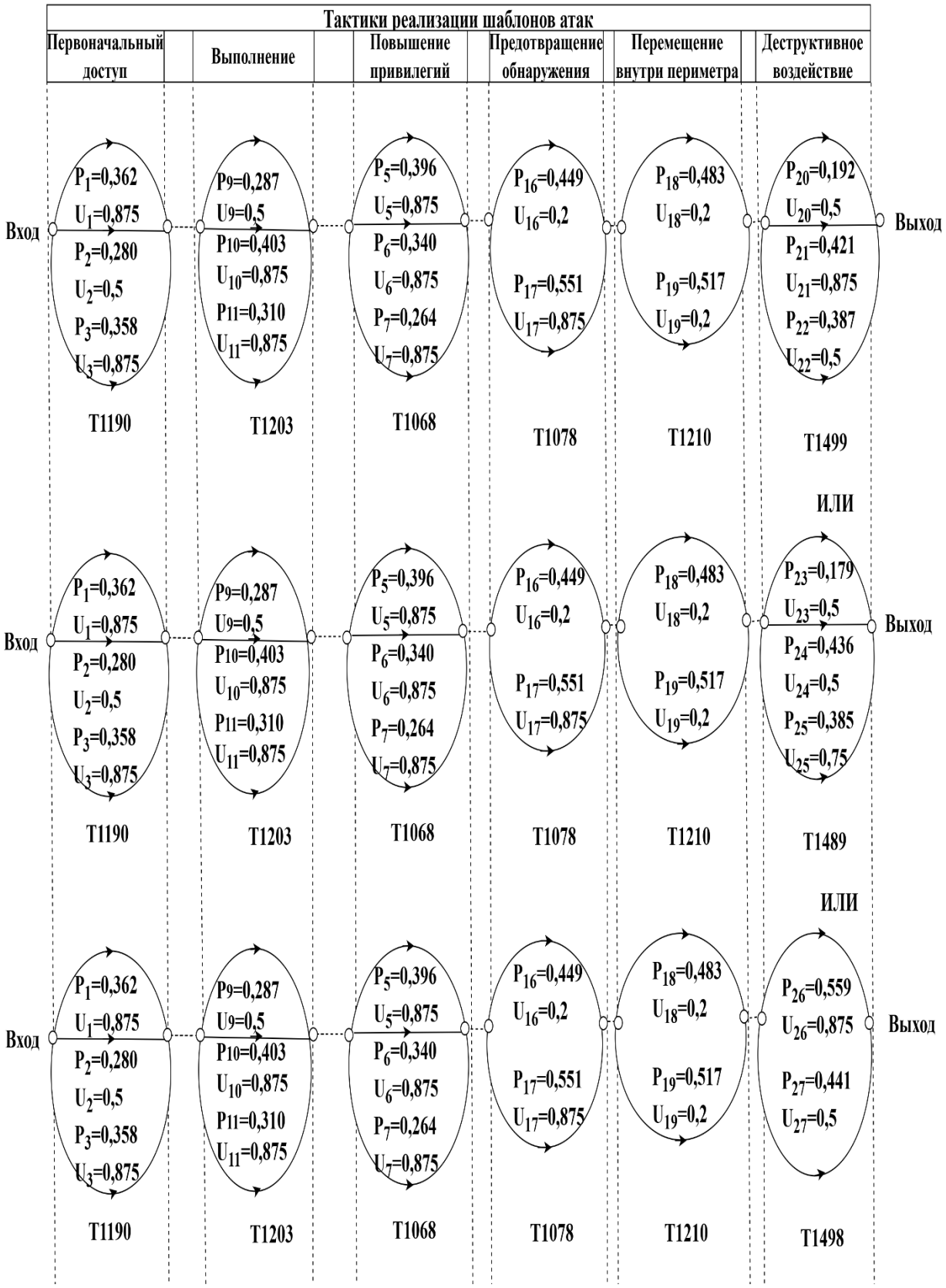

Рисунок 7. Графовая модель вероятных сценариев реализации шаблона кибератаки CAPEC-44 (часть 1)

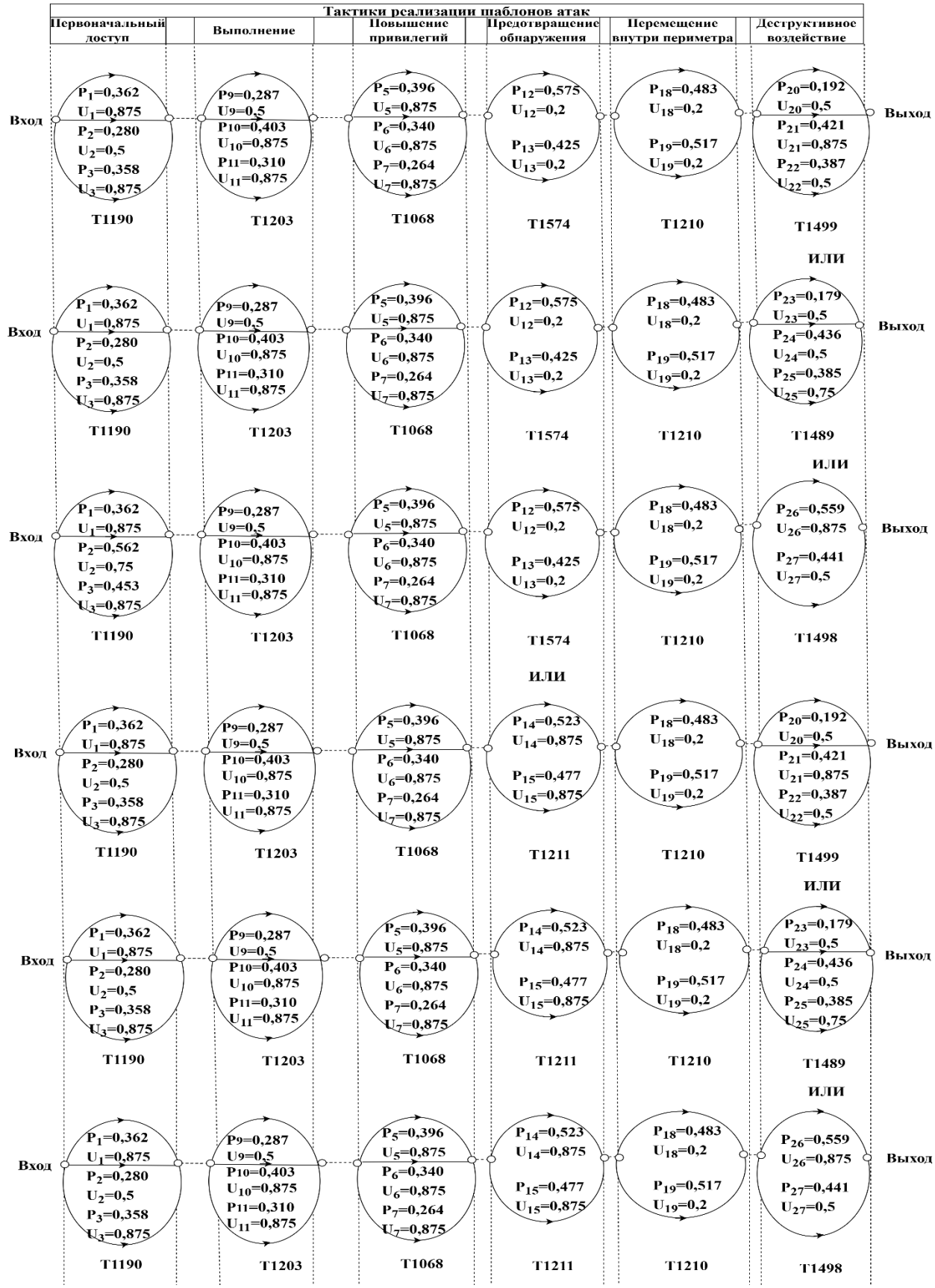

Рисунок 8. Графовая модель вероятных сценариев реализации шаблона кибератаки CAPEC-44 (часть 2)

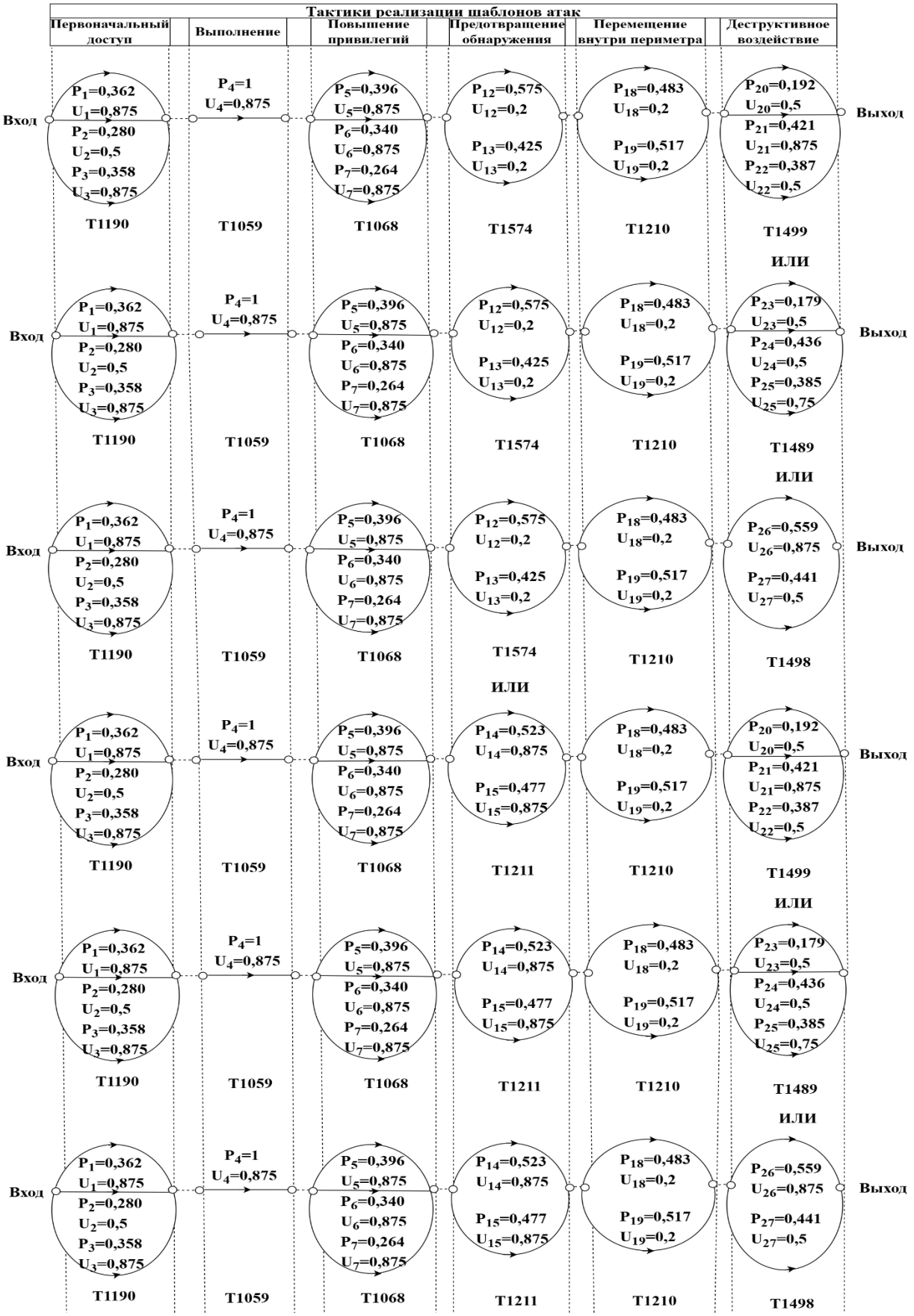

Рисунок 9. Графовая модель вероятных сценариев реализации шаблона кибератаки CAPEC-44 (часть 3)

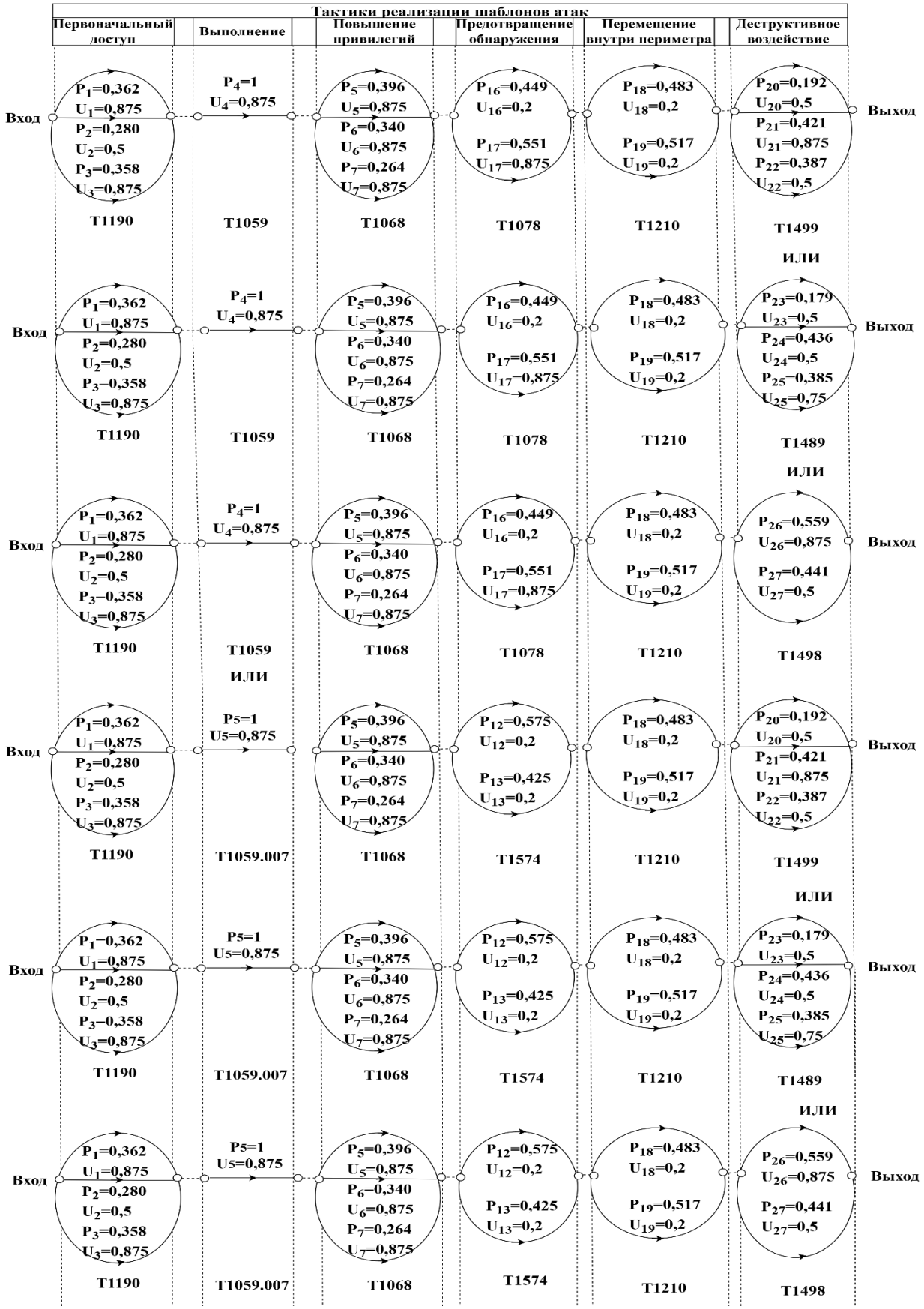

Рисунок 10. Графовая модель вероятных сценариев реализации шаблона кибератаки CAPEC-44 (часть 4)

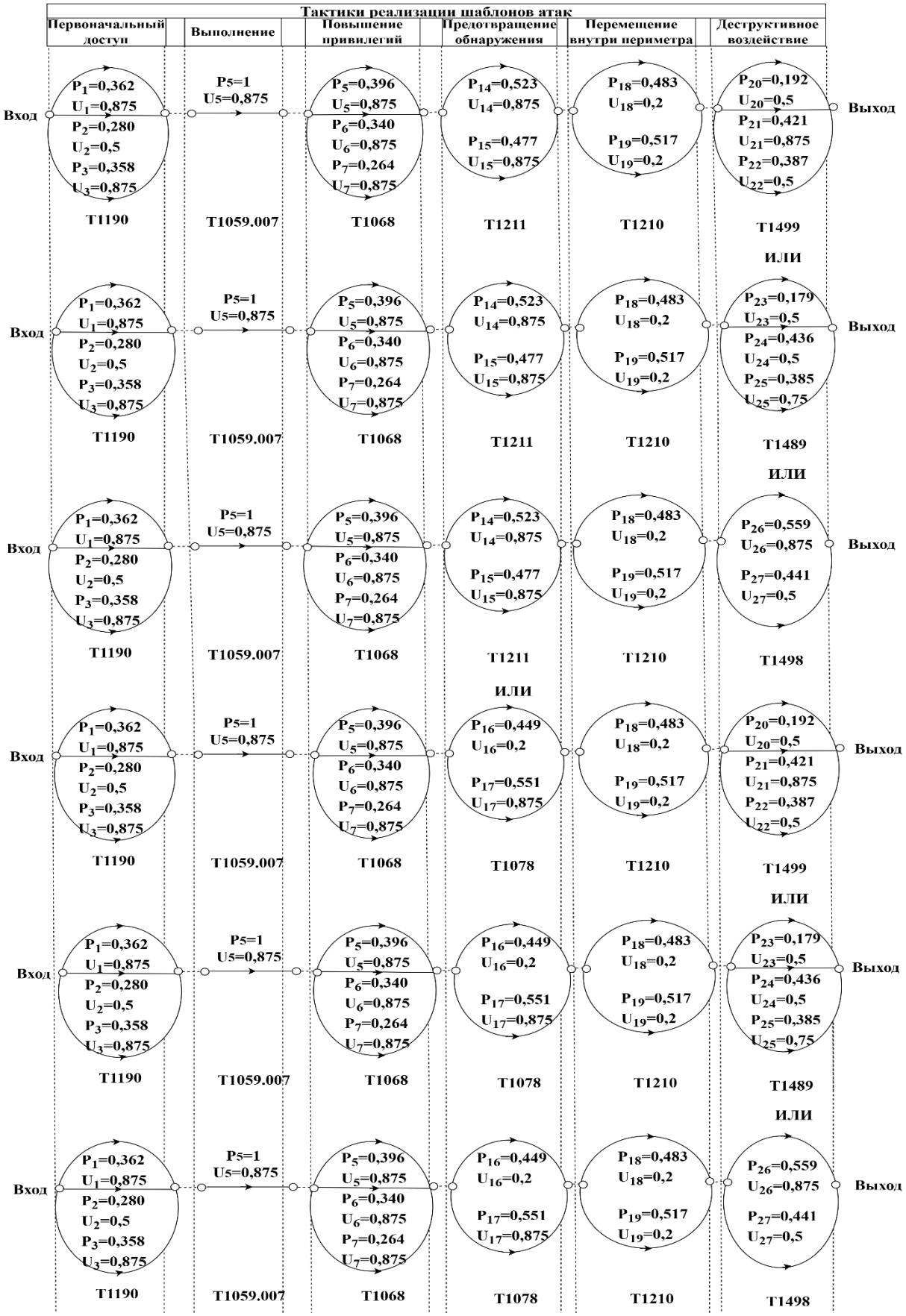

Рисунок 11. Графовая модель вероятных сценариев реализации шаблона кибератаки CAPEC-44 (часть 5)

Анализ сценариев атак CAPEC-42 осуществляется на основе результатов расчета вероятности эксплуатации уязвимостей и ущерба, приведенных в таблице 30.

Таблица 30 - Соответствие параметров вероятных сценариев реализации шаблона кибератаки CAPEC-42

Шаблон атаки на защищаемую систему	Техники эксплуатации уязвимостей атакуемой системы	Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Критичности эксплуатируемых уязвимостей атакуемой системы	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб эксплуатации уязвимостей атакуемой системы
CAPEC-42	T1595	CVE-2025-24124	0.7530	0.565	0.5
		CVE-2025-0938	0.5792	0.435	0.5
	T1190	CVE-2025-3538	0.7622	0.262	0.875
		CVE-2025-3161	0.7861	0.271	0.875
		CVE-2024-23828	0.6831	0.235	0.875
		CVE-2024-22319	0.6749	0.242	0.875
	T1610	CVE-2025-21677	0.5379	0.275	0.5
		CVE-2025-21678	0.6912	0.353	0.5
		CVE-2025-20184	0.7295	0.372	0.75
	ИЛИ				
	T1204	CVE-2024-1619	0.4305	0.256	0.5
		CVE-2025-1365	0.4555	0.271	0.488
		CVE-2025-25663	0.7964	0.473	0.875
	ИЛИ				
	T1059	CVE-2025-3346	0.6840	0.319	0.875
		CVE-2024-21687	0.6684	0.312	0.75
		CVE-2024-38366	0.7925	0.369	0.875
	ИЛИ				
	T1203	CVE-2025-23397	0.6173	0.333	0.875
		CVE-2025-23398	0.6173	0.333	0.875
		CVE-2025-23400	0.6173	0.333	0.875
	T1068	CVE-2025-1365	0.4555	0.220	0.488
		CVE-2024-21900	0.4037	0.195	0.2
		CVE-2024-39483	0.5362	0.258	0.5
		CVE-2024-20429	0.5524	0.327	0.5
	T1562	CVE-2025-21230	0.5183	0.326	0.5
		CVE-2025-21280	0.6244	0.306	0.5
		CVE-2025-21284	0.6316	0.368	0.5
	ИЛИ				
	T1548	CVE-2025-21194	0.6316	0.244	0.875
		CVE-2025-21235	0.6582	0.255	0.875
		CVE-2025-21234	0.6009	0.232	0.875
		CVE-2025-21686	0.6947	0.269	0.5
	ИЛИ				
	T1574	CVE-2025-27834	0.7464	0.242	0.875
		CVE-2025-27830	0.7154	0.232	0.875
		CVE-2025-28398	0.8925	0.290	0.875
		CVE-2025-25898	0.7272	0.236	0.5

Продолжение таблицы 30

Шаблон атаки на защищаемую систему	Техники эксплуатации уязвимостей атакуемой системы	Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Критичности эксплуатируемых уязвимостей атакуемой системы	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб эксплуатации уязвимостей атакуемой системы
CAPEC-42	T1620	CVE-2025-0514	0.7941	0.603	0.8
		CVE-2025-20183	0.5228	0.397	0.2
	T1210	CVE-2025-2619	0.8917	0.279	0.875
		CVE-2025-2620	0.7964	0.249	0.875
		CVE-2025-2618	0.7443	0.233	0.875
		CVE-2025-2621	0.7598	0.238	0.875
	T1071	CVE-2025-0528	0.6356	0.386	0.875
		CVE-2025-1192	0.4917	0.299	0.488
		CVE-2025-3249	0.5192	0.315	0.488
	T1565	CVE-2024-53263	0.7069	0.248	0.875
		CVE-2025-21370	0.5994	0.210	0.875
		CVE-2024-39784	0.5760	0.256	0.875
		CVE-2024-39785	0.7300	0.285	0.875
	ИЛИ				
	T1499	CVE-2025-3328	0.8133	0.237	0.875
		CVE-2025-3346	0.6761	0.240	0.875
		CVE-2025-25456	0.7876	0.276	0.875
		CVE-2025-20115	0.7030	0.247	0.5
	ИЛИ				
	T1485	CVE-2025-21350	0.5396	0.333	0.5
		CVE-2025-24319	0.5845	0.361	0.5
		CVE-2025-24970	0.4964	0.306	0.5
	ИЛИ				
	T1495	CVE-2025-21873	0.5058	0.344	0.5
		CVE-2025-21916	0.5290	0.359	0.5
		CVE-2025-23380	0.4377	0.297	0.6

Представленный граф на рисунке 12-27 отображает взаимосвязь техник эксплуатации уязвимостей и критичности, основываясь на классификации CAPEC-42. Это даёт возможность ясно увидеть и оценить возможные риски, исходящие от разных способов атак, нацеленных на нарушение защиты информационных ресурсов.

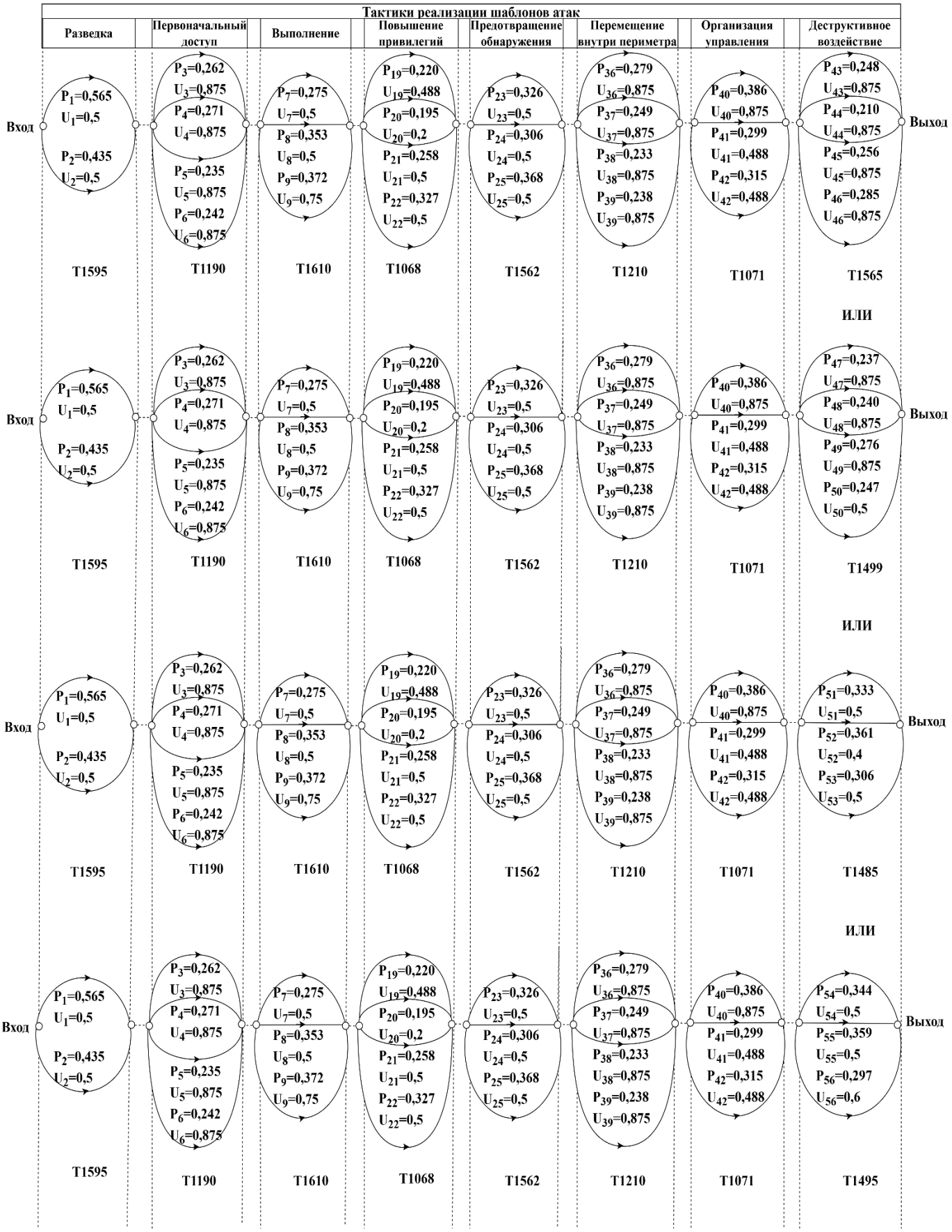

Рисунок 12. Графовая модель вероятных сценариев реализации шаблона кибератаки CAPEC-42 (часть 1)

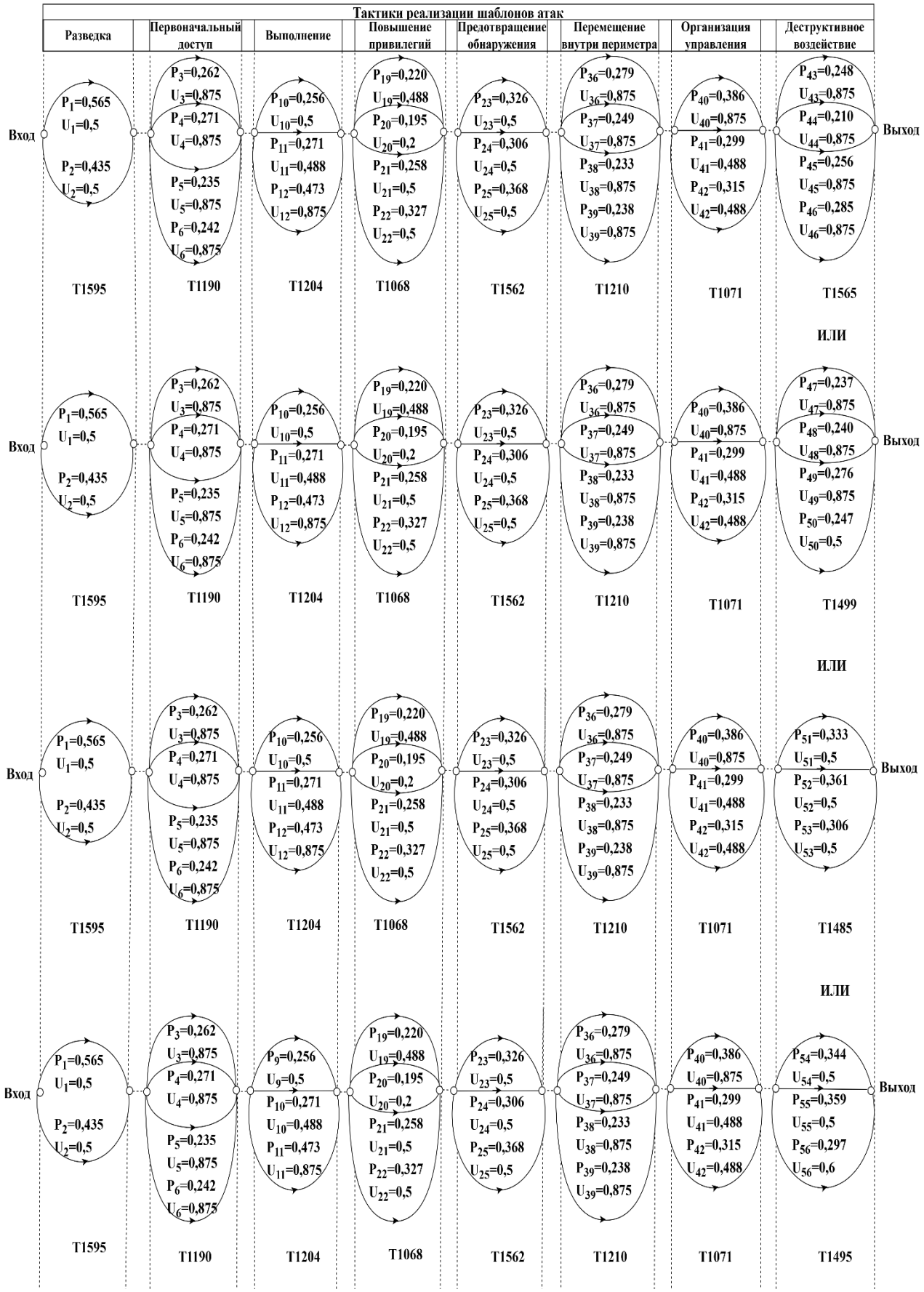

Рисунок 13. Графовая модель вероятных сценариев реализации шаблона кибератаки CAPEC-42 (часть 2)

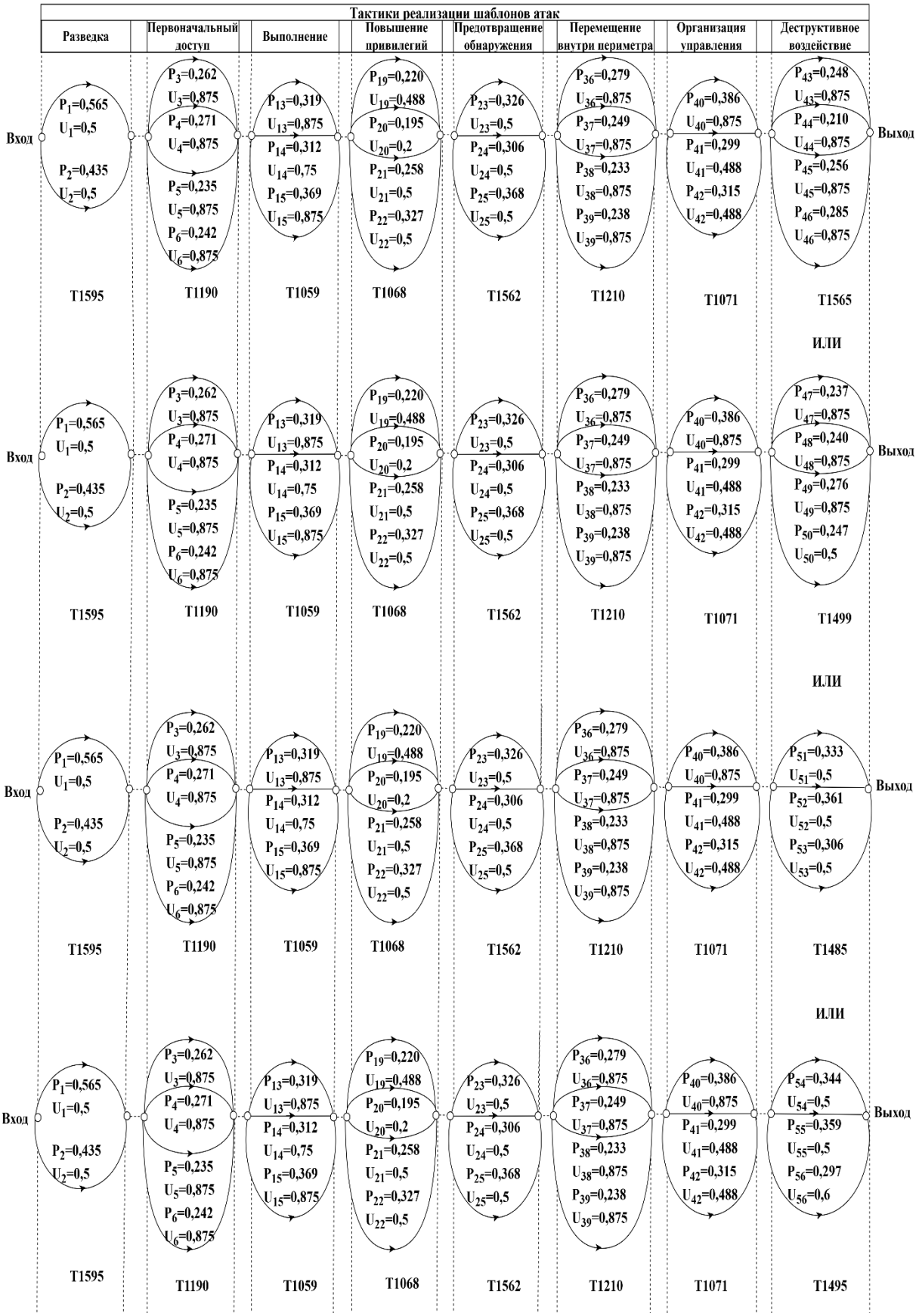

Рисунок 14. Графовая модель вероятных сценариев реализации шаблона кибератаки CAPEC-42 (часть 3)

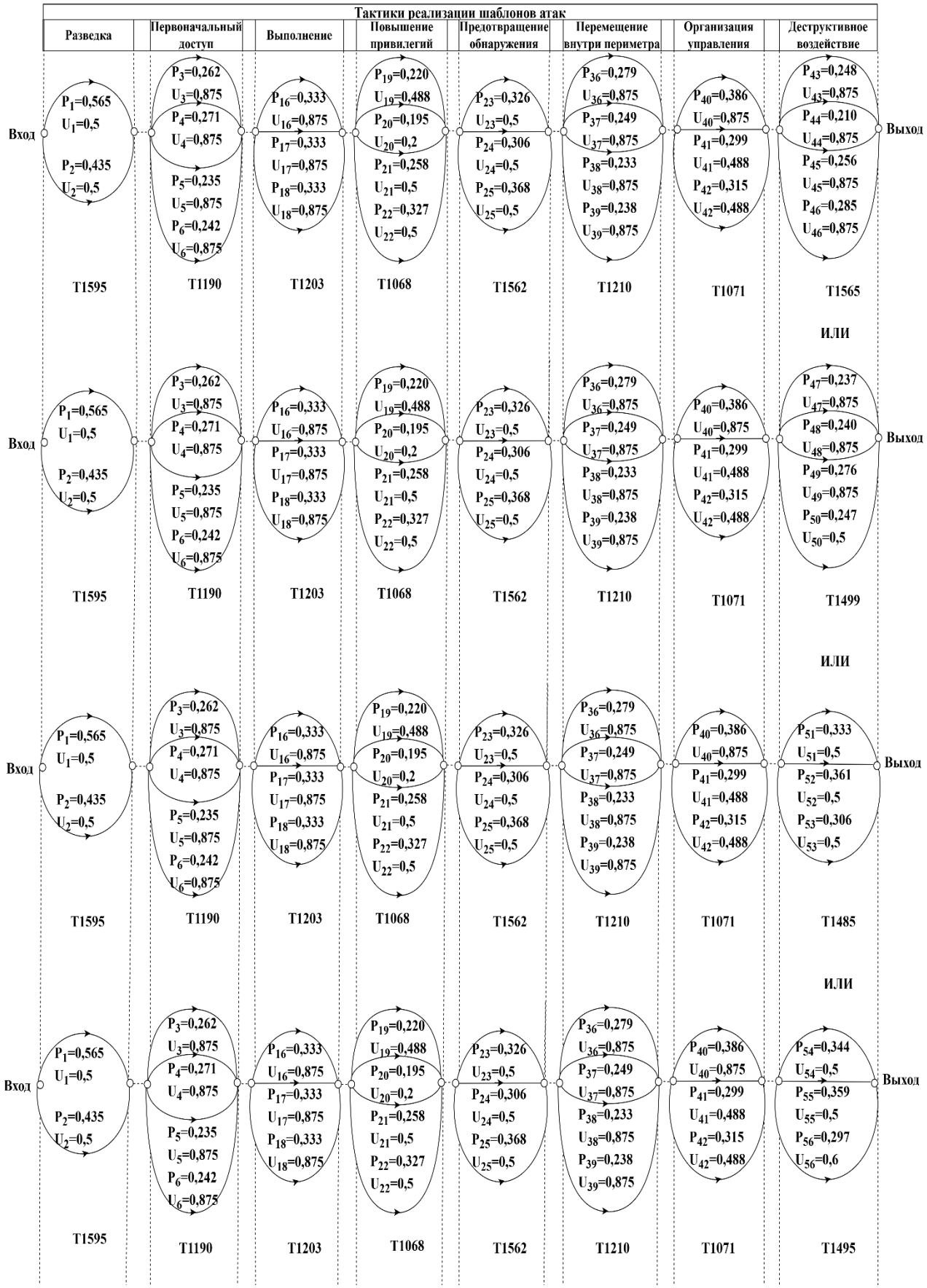

Рисунок 15. Графовая модель вероятных сценариев реализации шаблона кибератаки CAPEC-42 (часть 4)

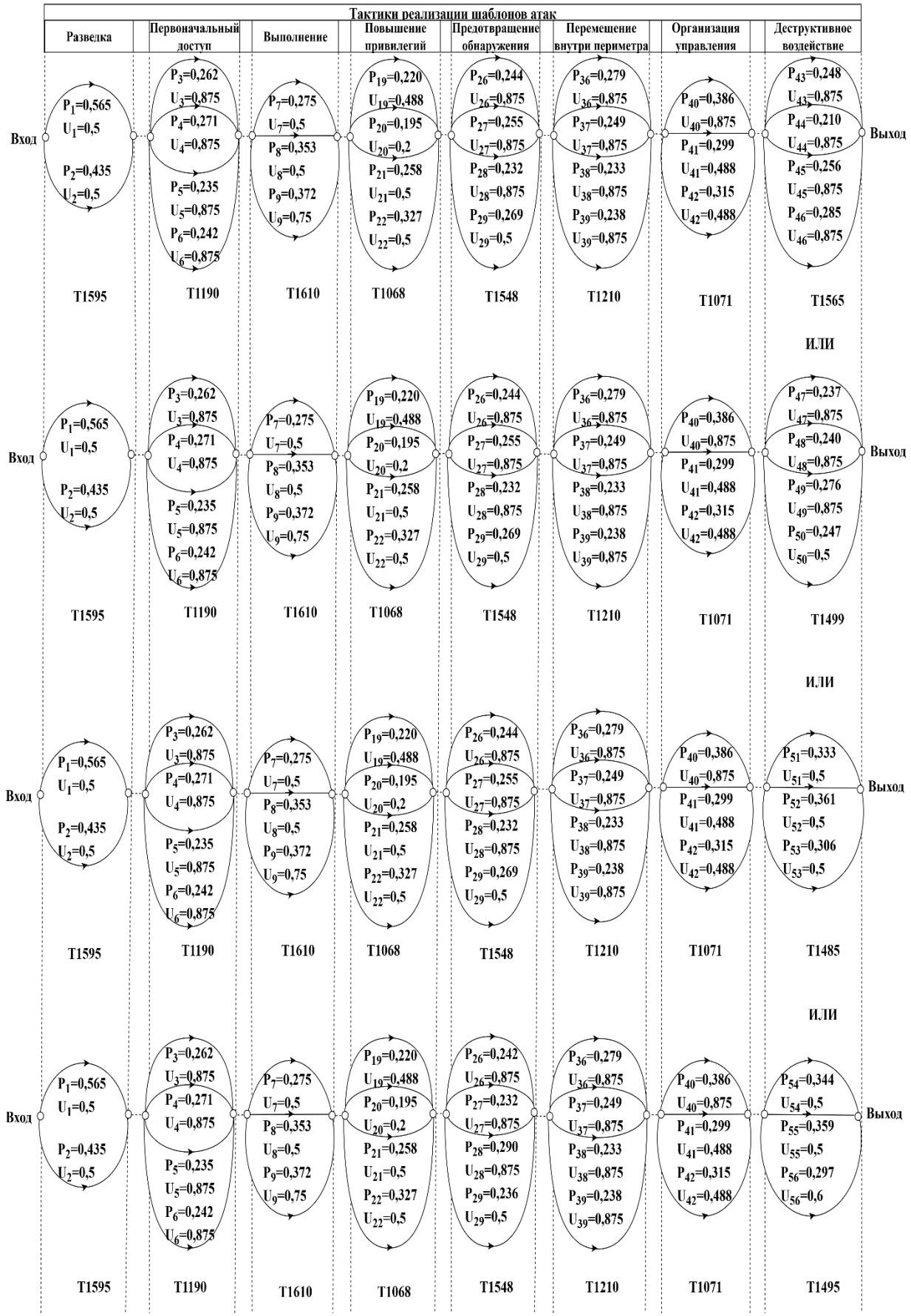

Рисунок 16. Графовая модель вероятных сценариев реализации шаблона кибератаки CAPEC-42 (часть 5)

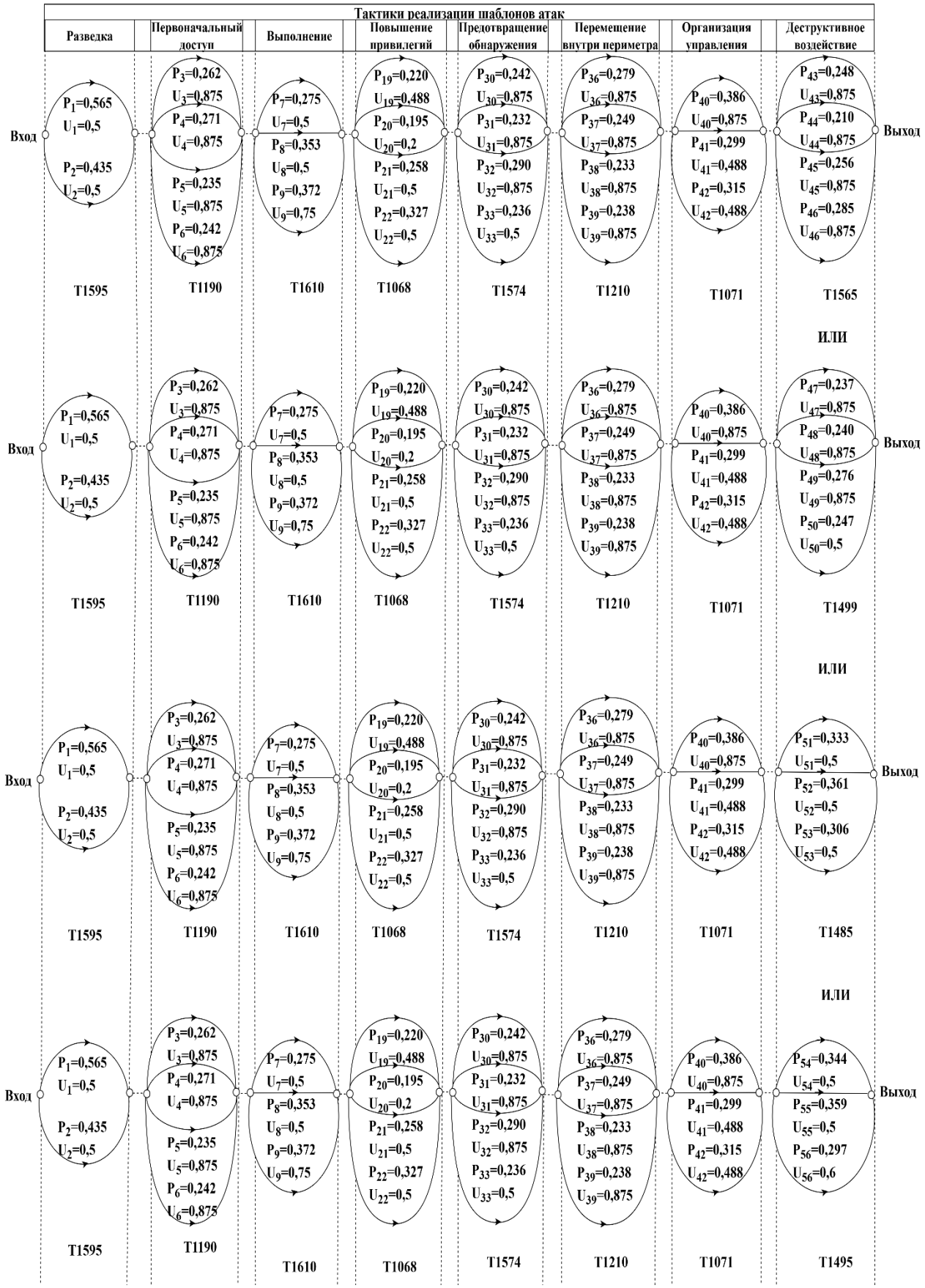

Рисунок 17. Графовая модель вероятных сценариев реализации шаблона кибератаки CAPEC-42 (часть 6)

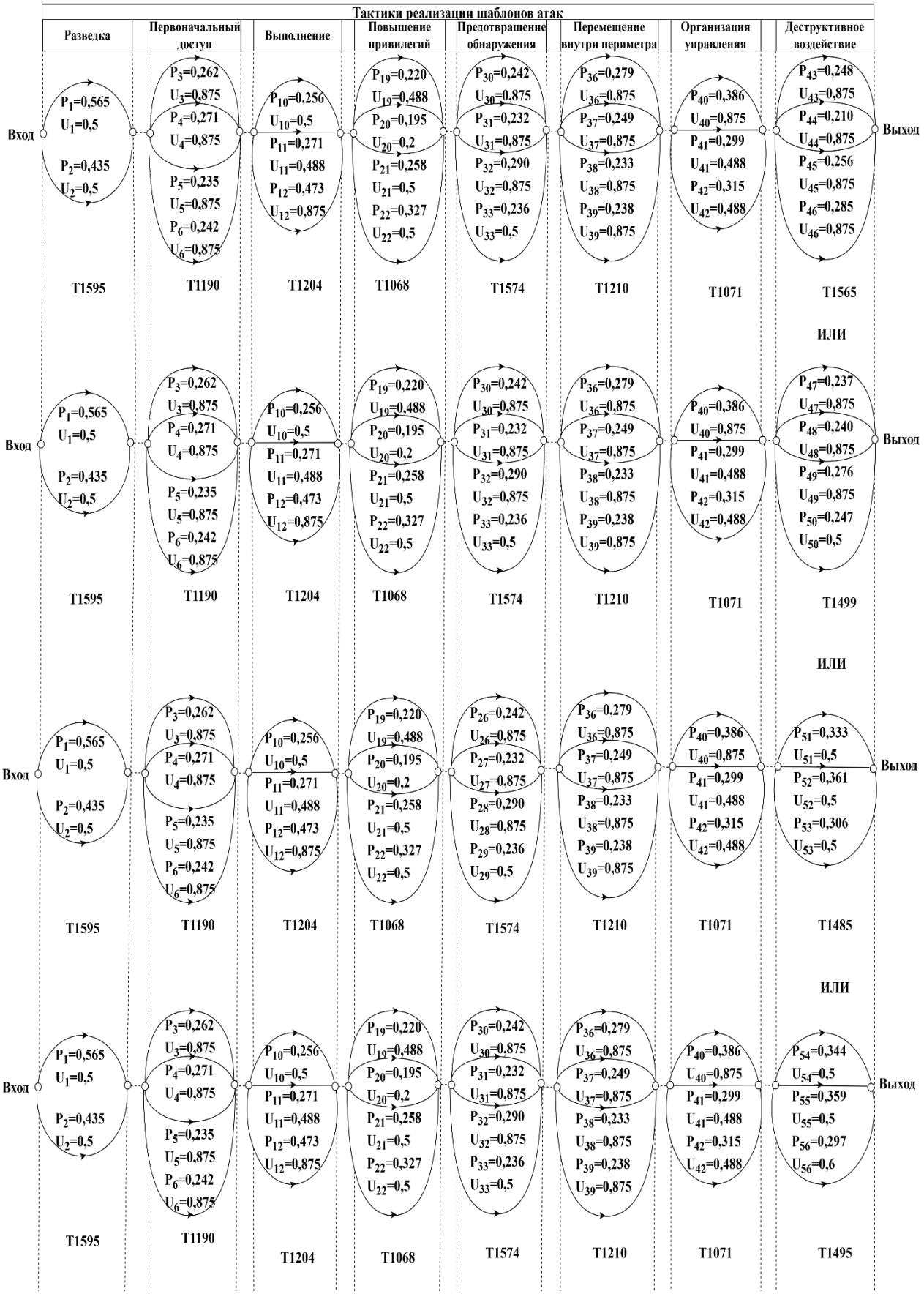

Рисунок 18. Графовая модель вероятных сценариев реализации шаблона кибератаки CAPEC-42 (часть 7)

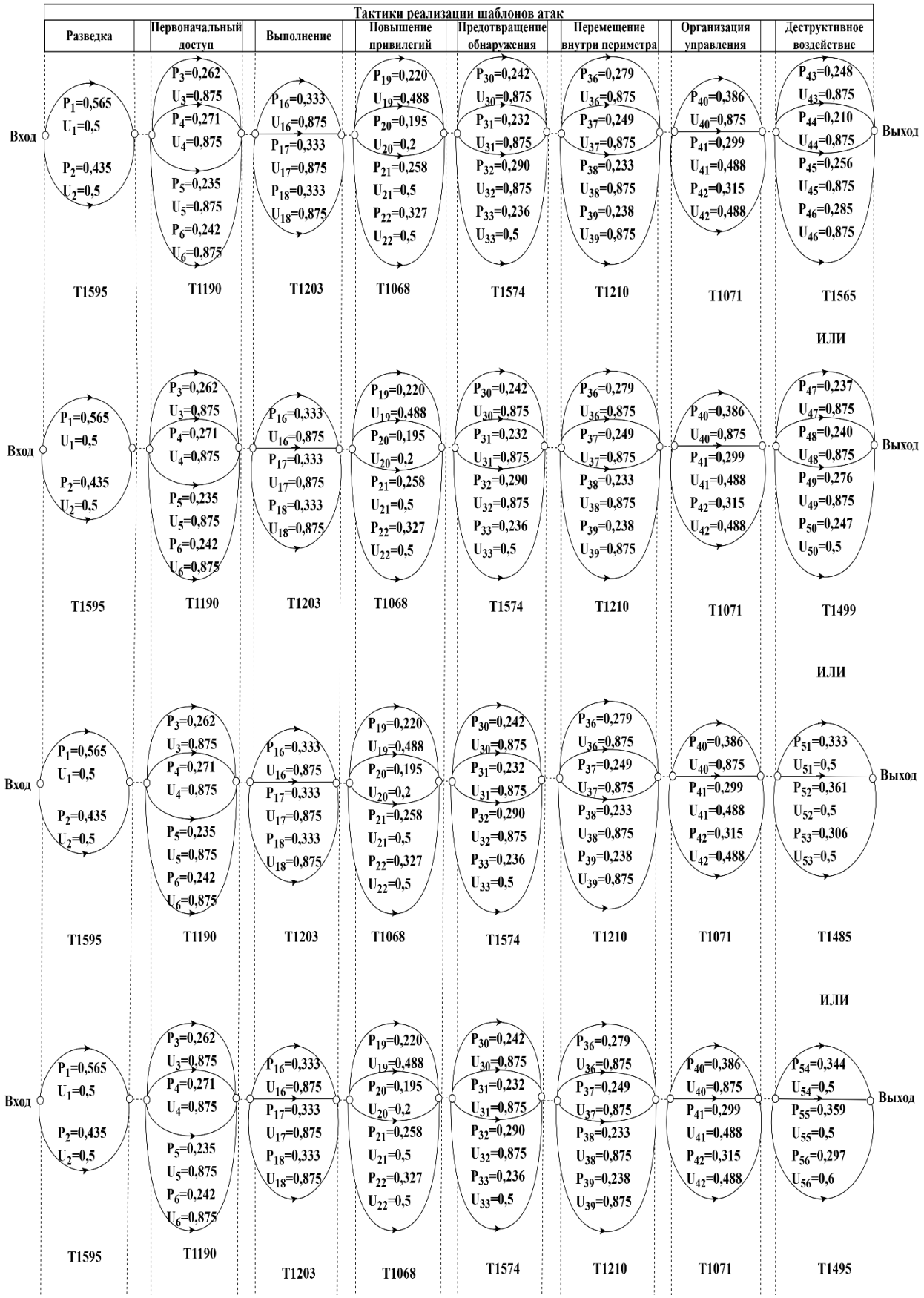

Рисунок 19. Графовая модель вероятных сценариев реализации шаблона кибератаки CAPEC-42 (часть 8)

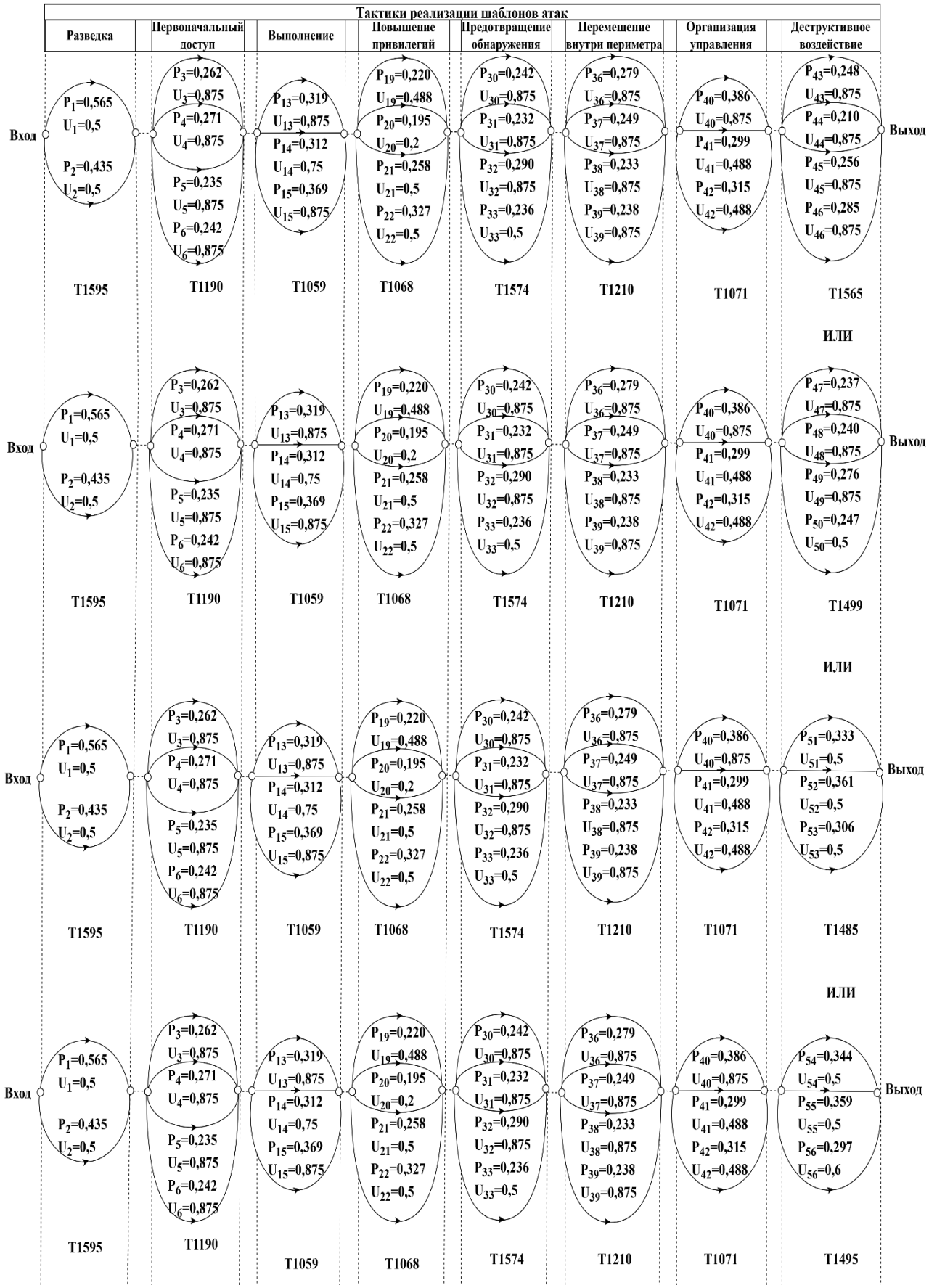

Рисунок 20. Графовая модель вероятных сценариев реализации шаблона кибератаки CAPEC-42 (часть 9)

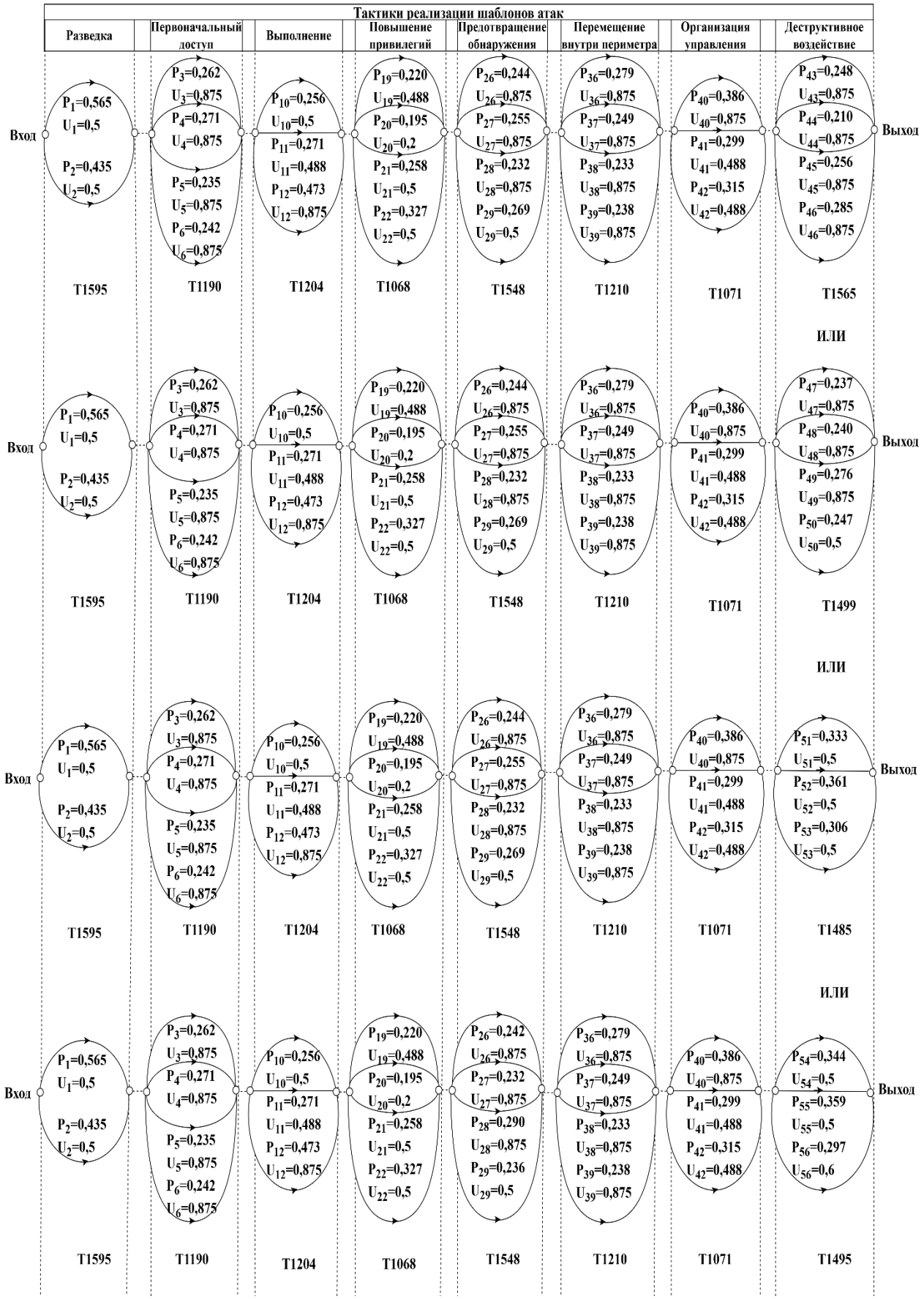

Рисунок 21. Графовая модель вероятных сценариев реализации шаблона кибератаки CAPEC-42 (часть 10)

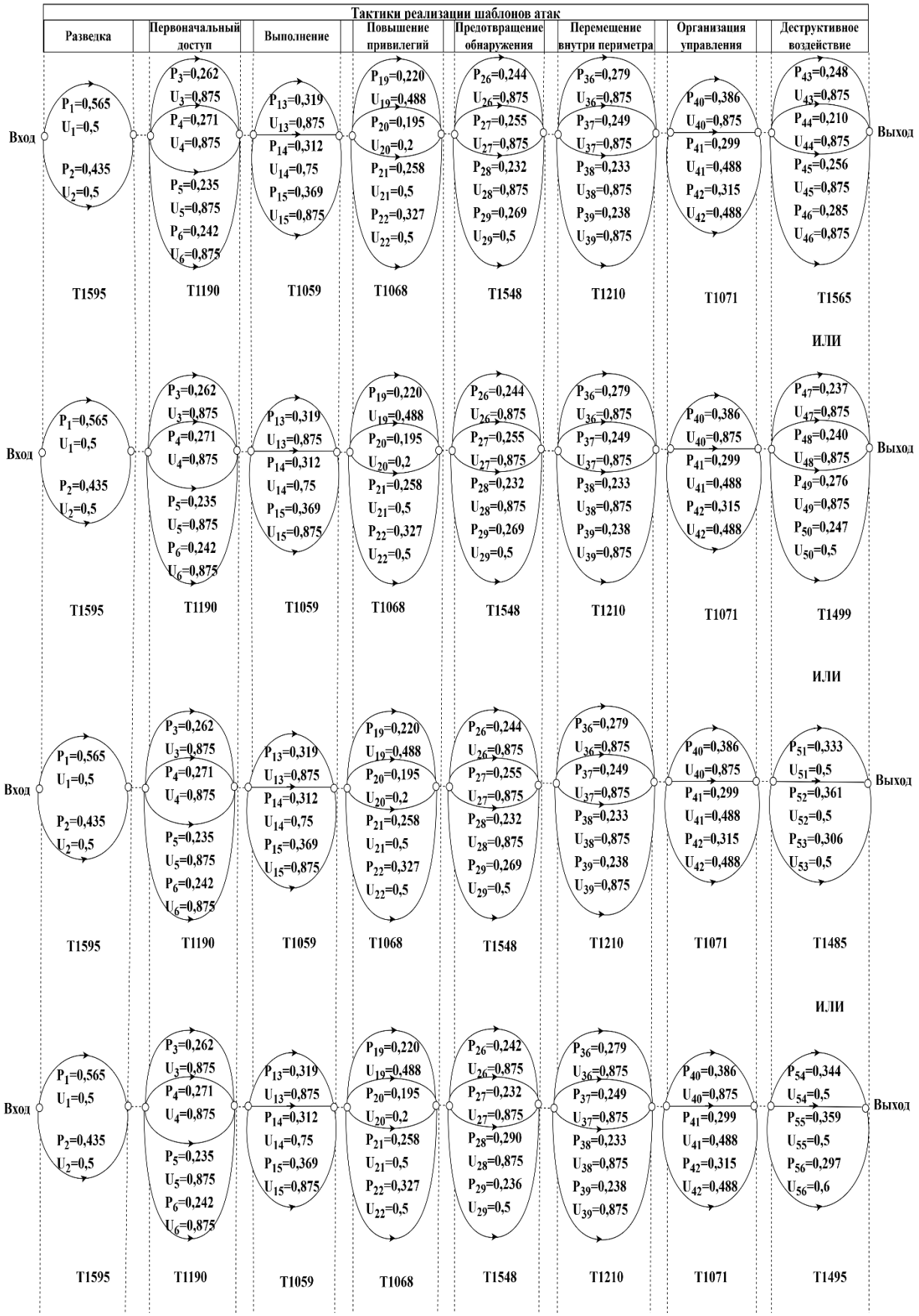

Рисунок 22. Графовая модель вероятных сценариев реализации шаблона кибератаки CAPEC-42 (часть 11)

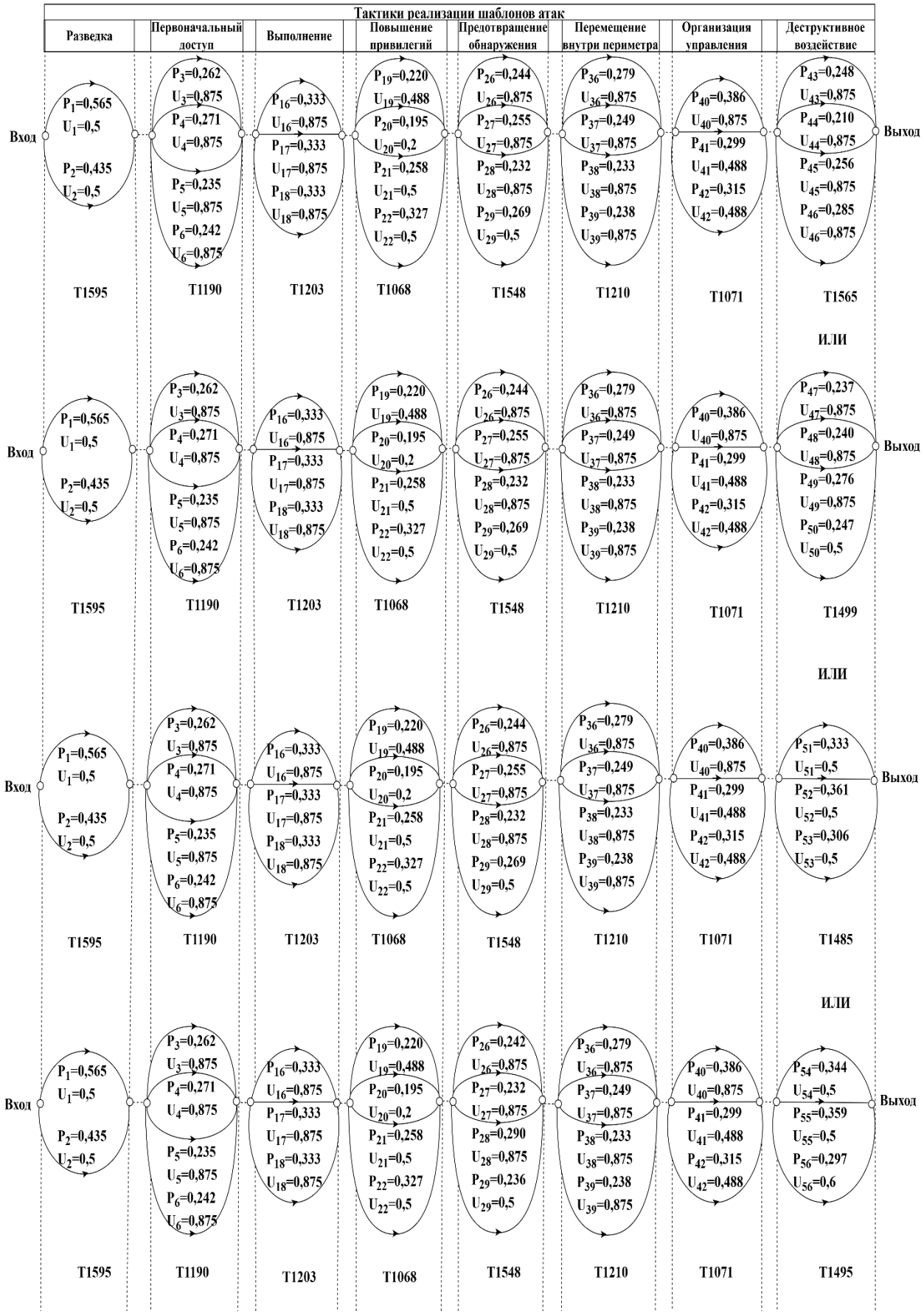

Рисунок 23. Графовая модель вероятных сценариев реализации шаблона кибератаки CAPEC-42 (часть 12)

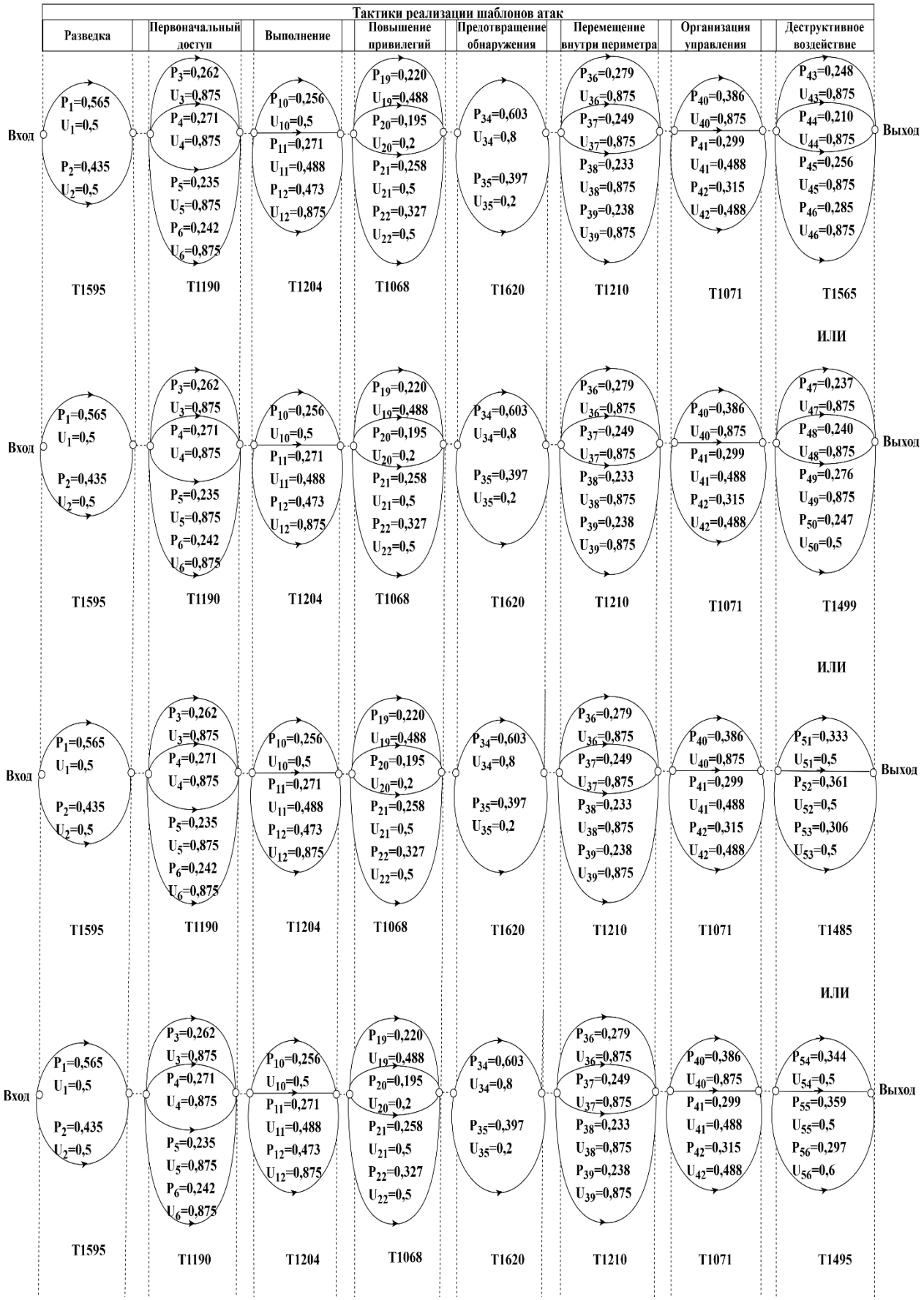

Рисунок 24. Графовая модель вероятных сценариев реализации шаблона кибератаки CAPEC-42 (часть 13)

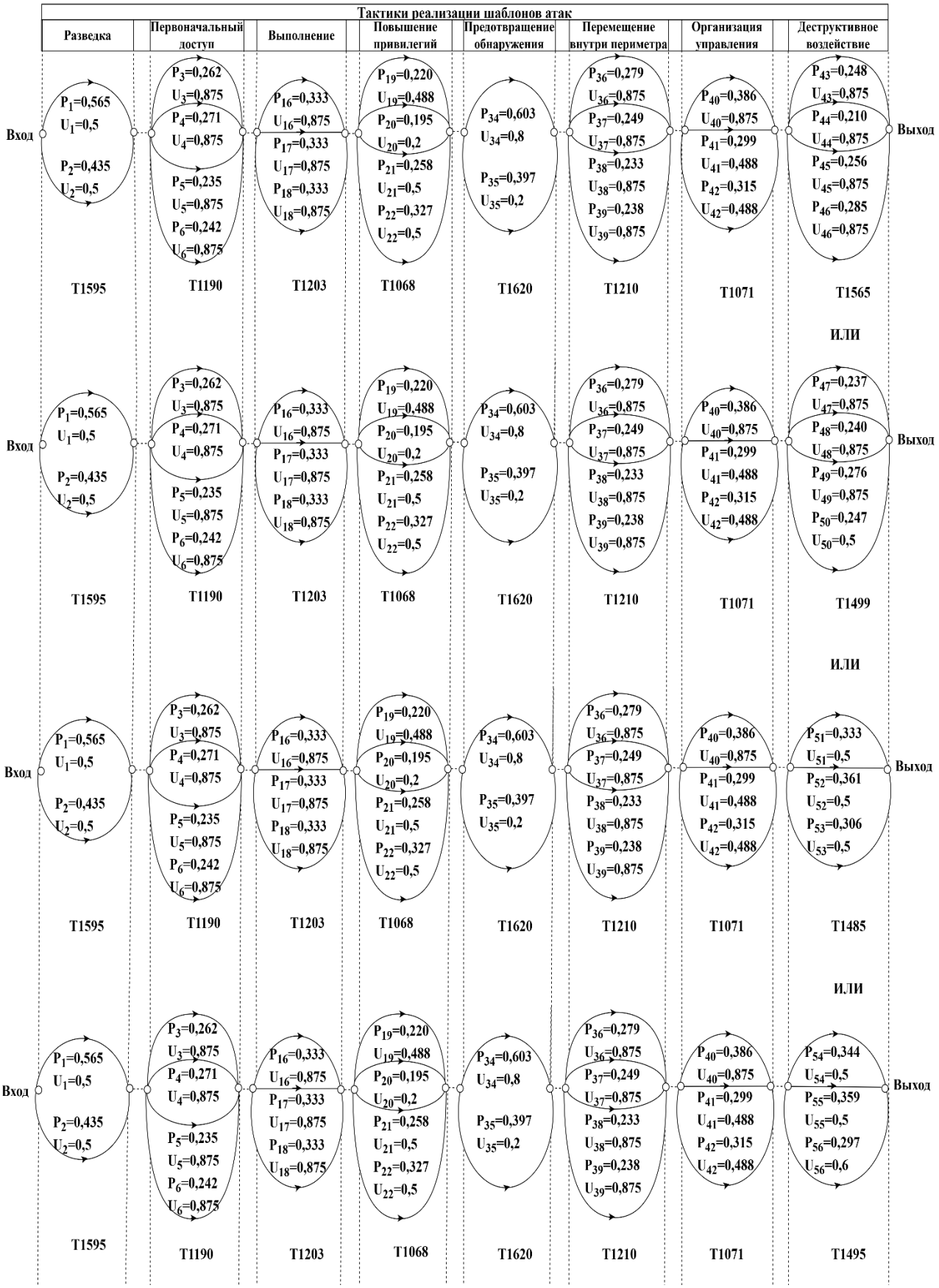

Рисунок 25. Графовая модель вероятных сценариев реализации шаблона кибератаки CAPEC-42 (часть 14)

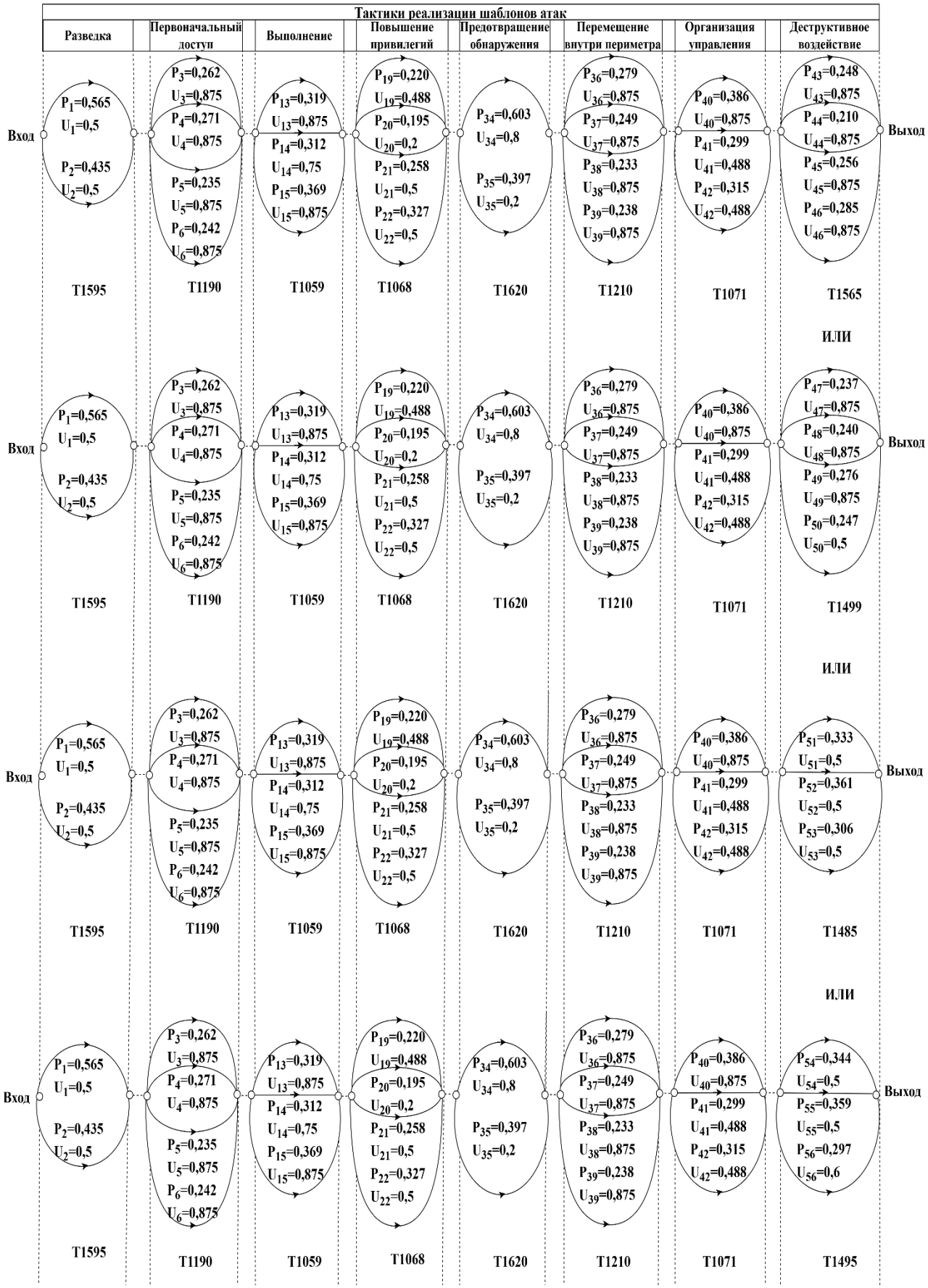

Рисунок 26. Графовая модель вероятных сценариев реализации шаблона кибератаки CAPEC-42 (часть 15)

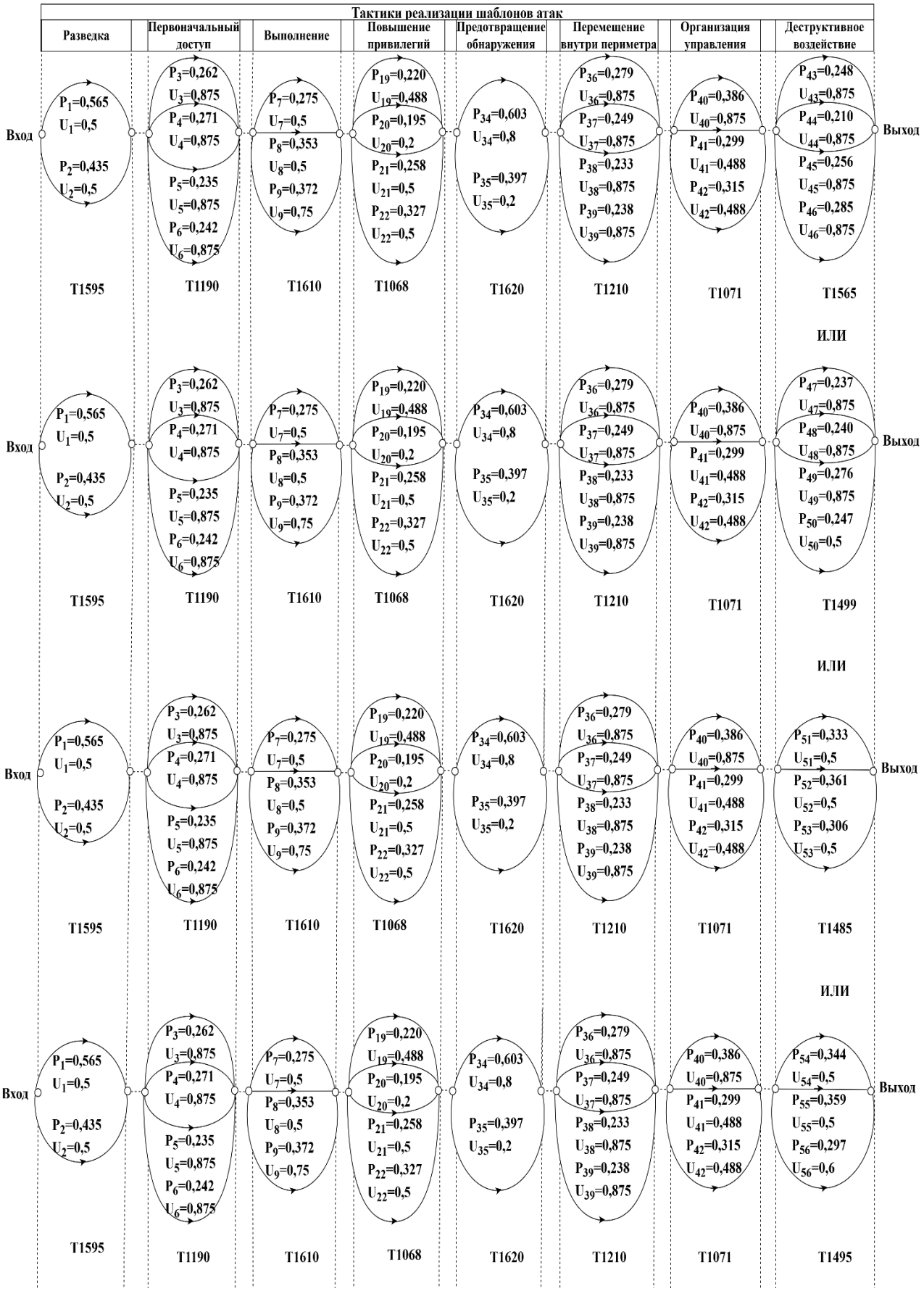

Рисунок 27. Графовая модель вероятных сценариев реализации шаблона кибератаки CAPEC-42 (часть 16)

Проведенный анализа сценариев атак CAPEC-71 выполняется на основе данных, представленных в таблице 31, в которой указаны расчёты вероятностей реализации единичных атак и ущерба.

Таблица 31 - Соответствие параметров вероятных сценариев реализации шаблона кибератаки CAPEC-71

Шаблон атаки на защищаемую систему	Техники эксплуатации уязвимостей атакуемой системы	Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Критичности эксплуатируемых уязвимостей атакуемой системы	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб эксплуатации уязвимостей атакуемой системы
CAPEC-71	T1133	CVE-2025-1767	0.5626	0.302	0.75
		CVE-2025-27493	0.6982	0.375	0.875
		CVE-2023-23840	0.6007	0.323	0.875
	ИЛИ				
	T1566	CVE-2024-33510	0.5296	0.320	0.2
		CVE-2022-26137	0.7043	0.425	0.488
		CVE-2022-26136	0.4228	0.255	0.2
	ИЛИ				
	T1190	CVE-2024-12962	0.5973	0.335	0.488
		CVE-2024-12967	0.573	0.321	0.488
		CVE-2024-12968	0.6134	0.344	0.488
	T1569	CVE-2025-21375	0.5988	0.340	0.875
		CVE-2023-40037	0.5376	0.305	0.5
		CVE-2023-33225	0.6251	0.355	0.875
	ИЛИ				
	T1204	CVE-2025-1080	0.6362	0.353	0.8
		CVE-2023-31169	0.4867	0.270	0.5
		CVE-2024-30103	0.6814	0.378	0.875
	ИЛИ				
	T1059	CVE-2024-10914	0.7916	0.342	0.875
		CVE-2024-10915	0.8763	0.379	0.875
		CVE-2024-50572	0.644	0.279	0.875
	T1548	CVE-2025-24073	0.8032	0.357	0.875
		CVE-2025-29811	0.8032	0.357	0.875
		CVE-2025-26647	0.6424	0.286	0.875
	ИЛИ				
	T1546	CVE-2024-54158	0.346	0.224	0.5
		CVE-2024-20278	0.6011	0.390	0.2
		CVE-2024-47565	0.5954	0.386	0.2
	ИЛИ				
	T1543	CVE-2024-12350	0.69	0.310	0.875
		CVE-2025-24446	0.7328	0.329	0.875
		CVE-2025-27489	0.8032	0.361	0.875
	T1562	CVE-2024-50340	0.7146	0.414	0.488
		CVE-2024-11124	0.5676	0.329	0.875
		CVE-2024-11234	0.4433	0.257	0.36

Продолжение таблицы 31

Шаблон атаки на защищаемую систему	Техники эксплуатации уязвимостей атакуемой системы	Уязвимости атакуемой системы, вероятно эксплуатируемые заданными техниками	Критичности эксплуатируемых уязвимостей атакуемой системы	Вероятности успешной эксплуатации уязвимостей атакуемой системы	Ущерб эксплуатации уязвимостей атакуемой системы
CAPEC-71	T1574	CVE-2025-24074	0.8096	0.333	0.875
		CVE-2025-24060	0.8096	0.333	0.875
		CVE-2025-24062	0.8096	0.333	0.875
	ИЛИ				
	T1620	CVE-2025-31477	0.8328	0.473	0.875
		CVE-2025-1736	0.4089	0.233	0.2
		CVE-2023-23843	0.5174	0.294	0.875
	T1552	CVE-2025-24058	0.8032	0.368	0.875
		CVE-2025-27110	0.6737	0.309	0.5
		CVE-2025-29822	0.7052	0.323	0.875
	T1005	CVE-2025-29821	0.6072	0.381	0.5
		CVE-2025-24514	0.585	0.367	0.875
		CVE-2025-20227	0.4023	0.252	0.2
	T1071	CVE-2024-12966	0.6134	0.360	0.488
		CVE-2024-12965	0.573	0.336	0.488
		CVE-2023-23844	0.5177	0.304	0.875
	T1499	CVE-2024-56717	0.4634	0.253	0.5
		CVE-2025-20146	0.6843	0.374	0.5
		CVE-2025-20142	0.6822	0.373	0.5

Граф, представленный на рисунках 28-41 демонстрирует взаимосвязи между разными техниками эксплуатации уязвимостей и уровнем их критичности, ориентируясь на CAPEC-71, который служит удобным средством выявления опасных путей вторжения и оценки эффективности существующих защитных мер.

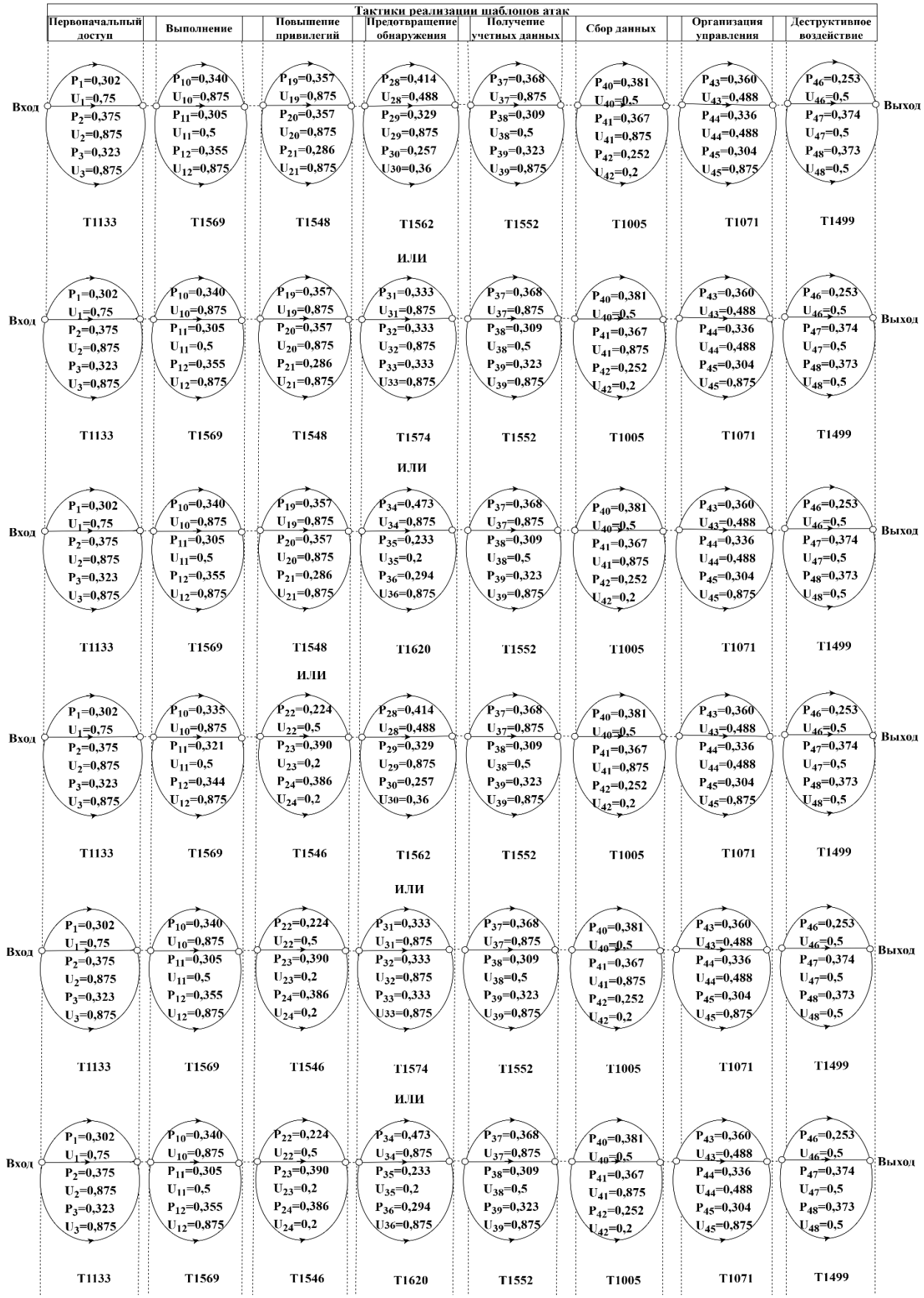

Рисунок 28. Графовая модель вероятных сценариев реализации шаблона кибератаки CAPEC-71 (часть 1)

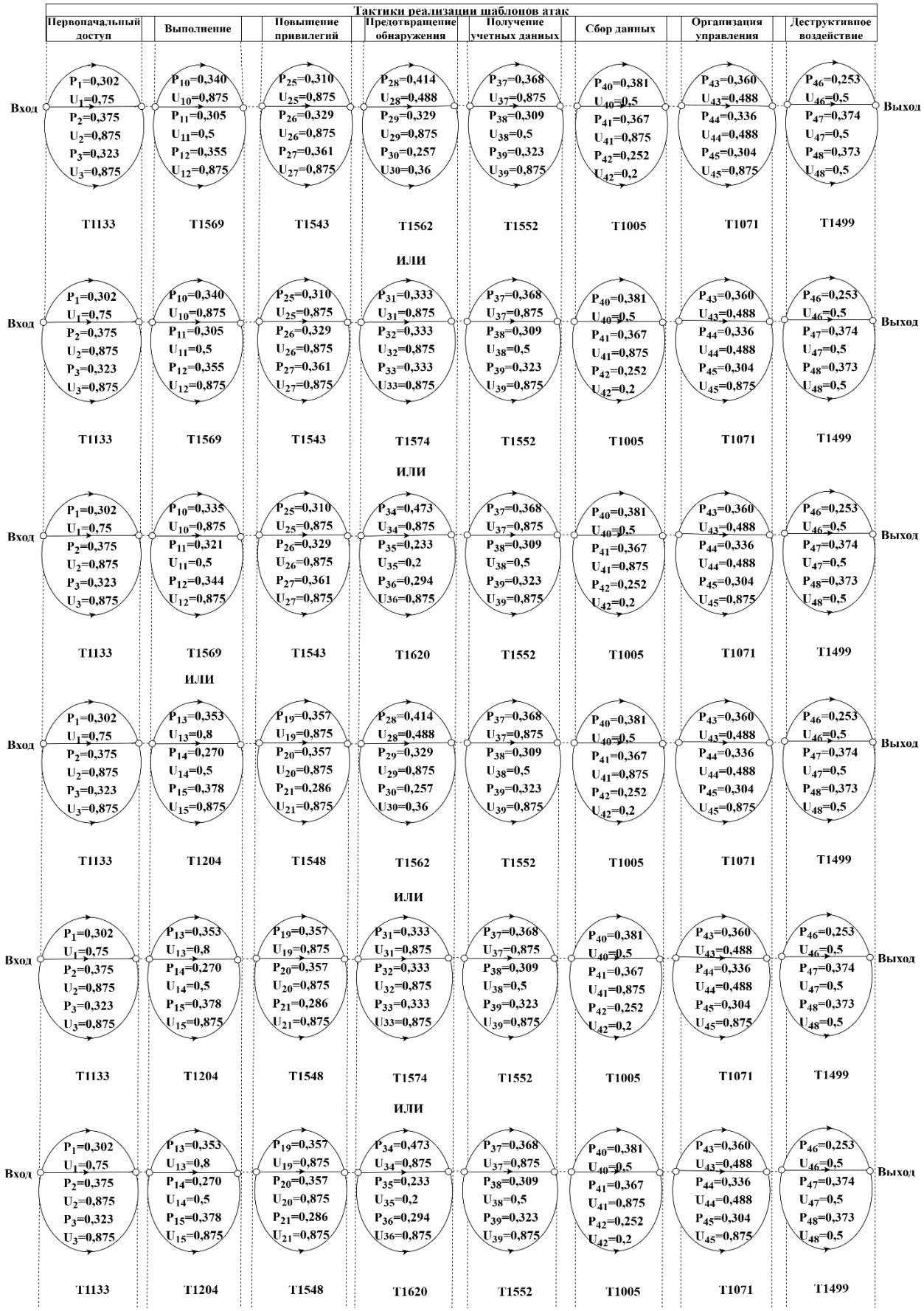

Рисунок 29. Графовая модель вероятных сценариев реализации шаблона кибератаки CAPEC-71 (часть 2)

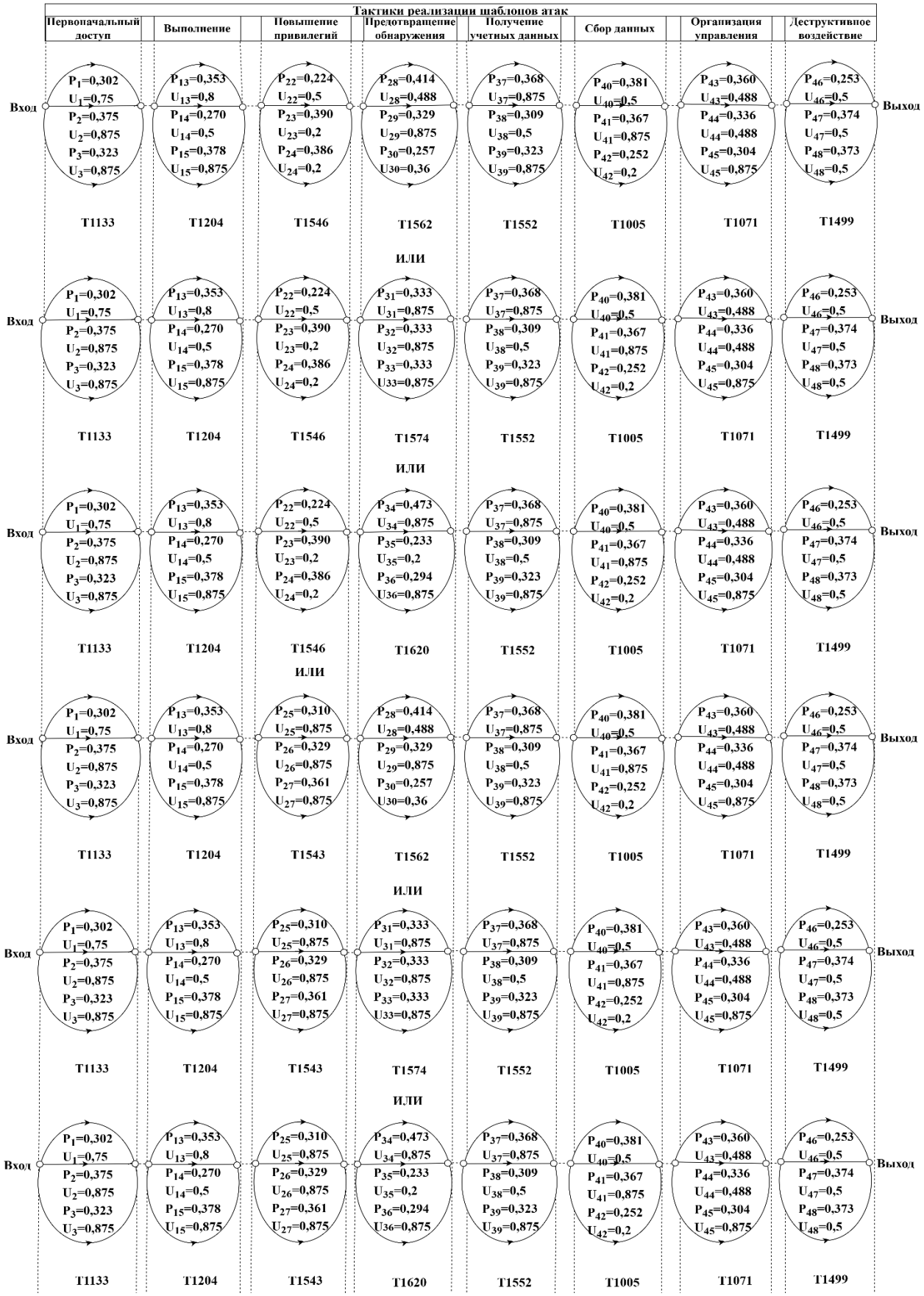

Рисунок 30. Графовая модель вероятных сценариев реализации шаблона кибератаки CAPEC-71 (часть 3)

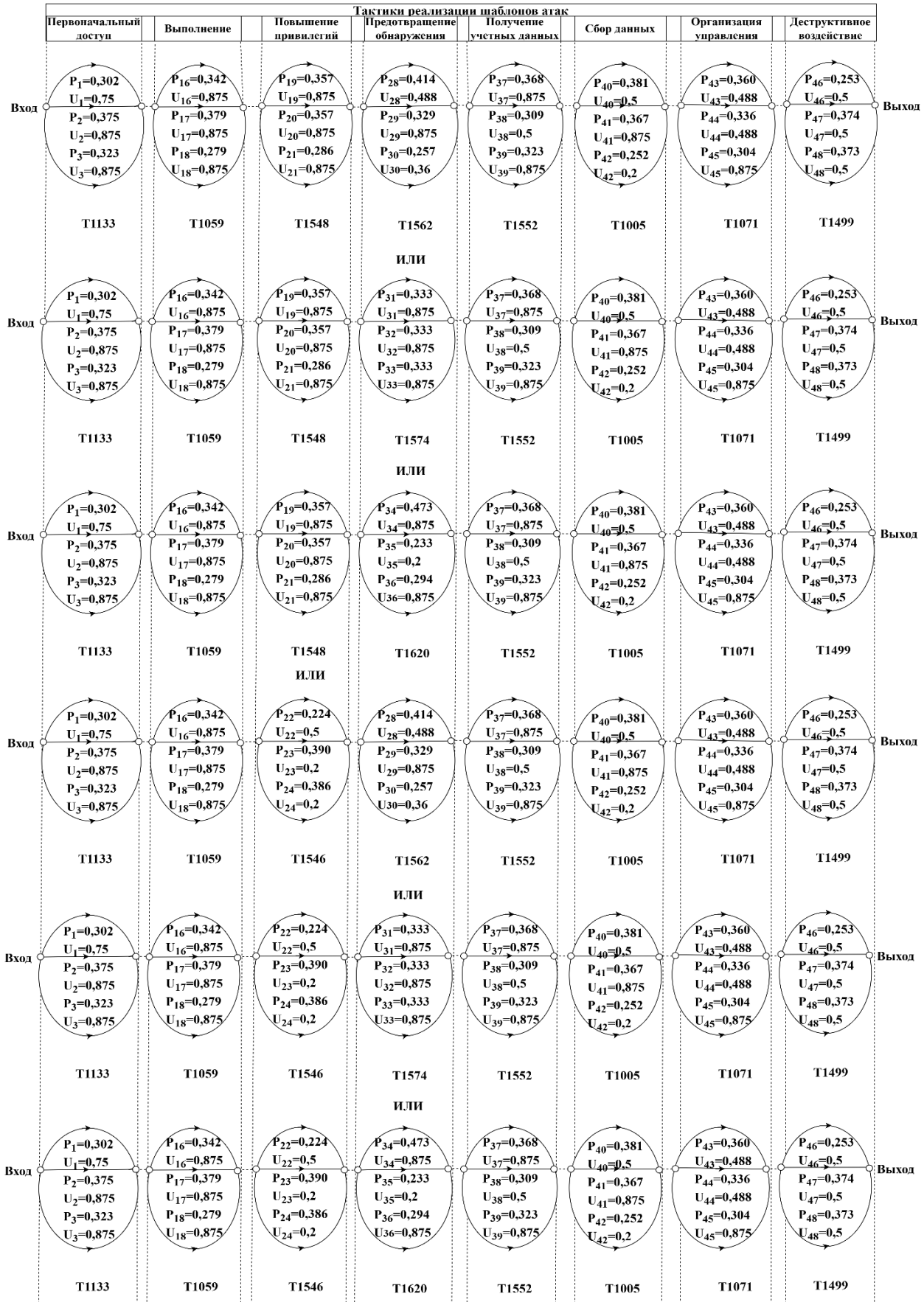

Рисунок 31. Графовая модель вероятных сценариев реализации шаблона кибератаки CAPEC-71 (часть 4)

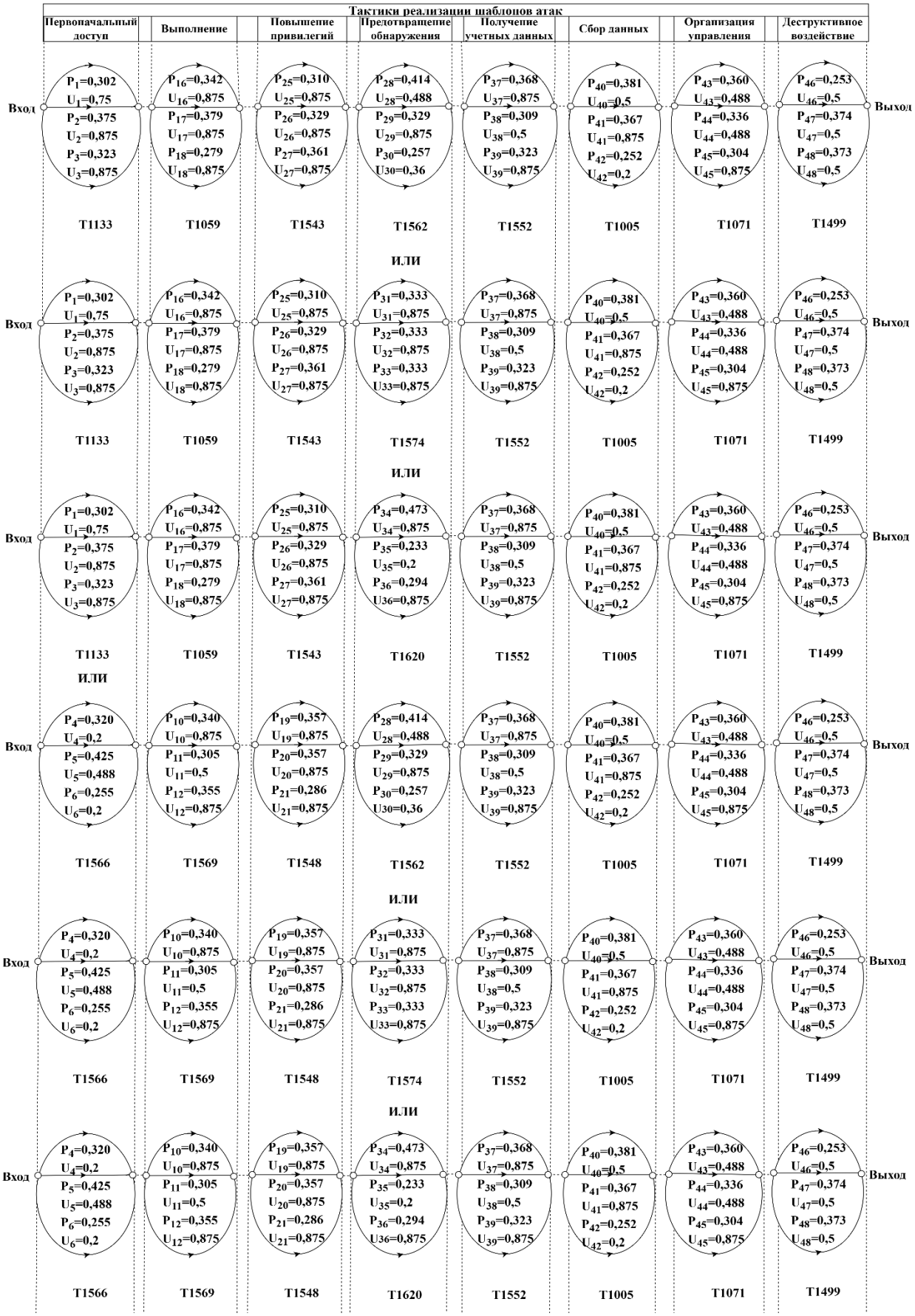

Рисунок 32. Графовая модель вероятных сценариев реализации шаблона кибератаки CAPEC-71 (часть 5)

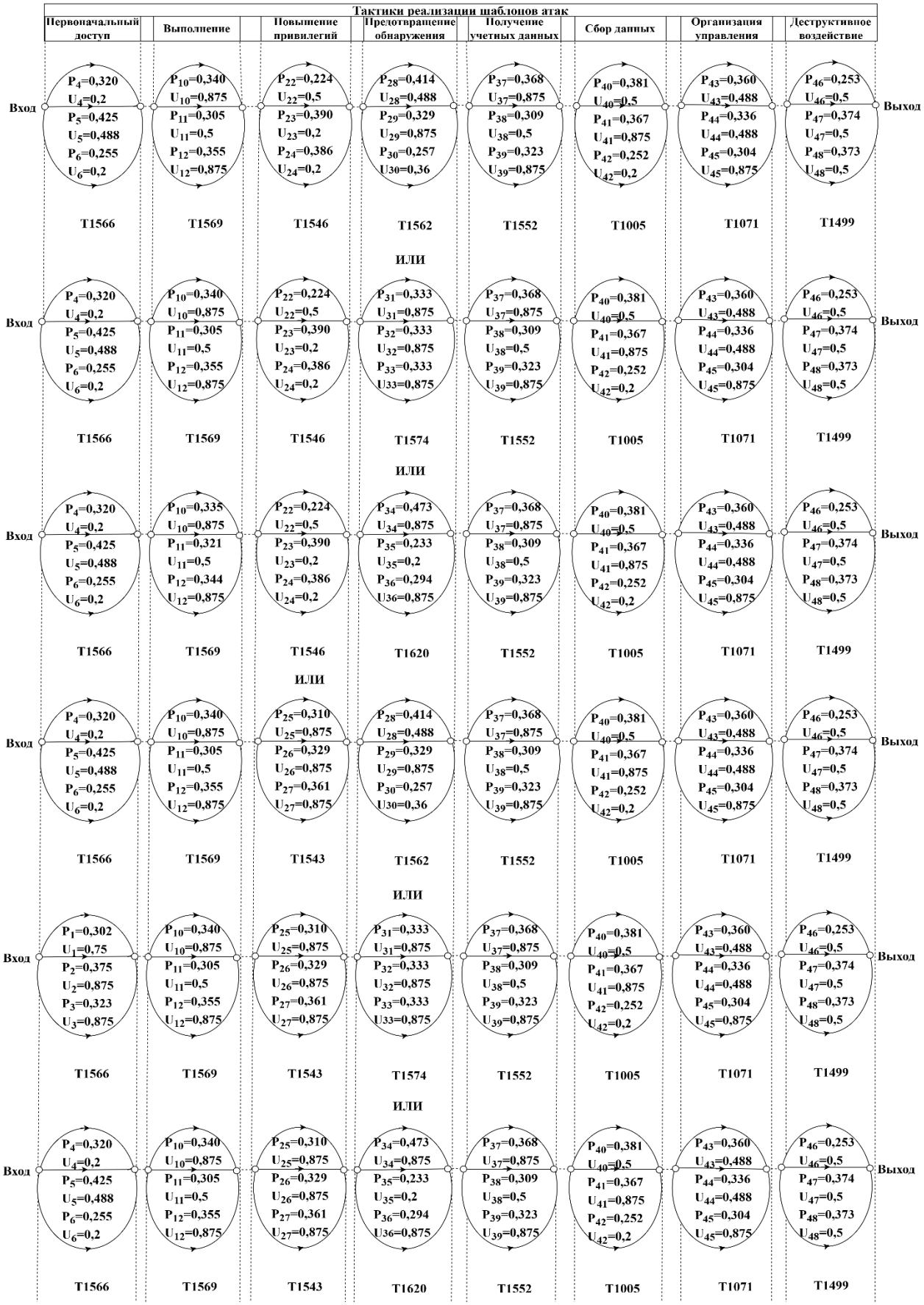

Рисунок 33. Графовая модель вероятных сценариев реализации шаблона кибератаки CAPEC-71 (часть 6)

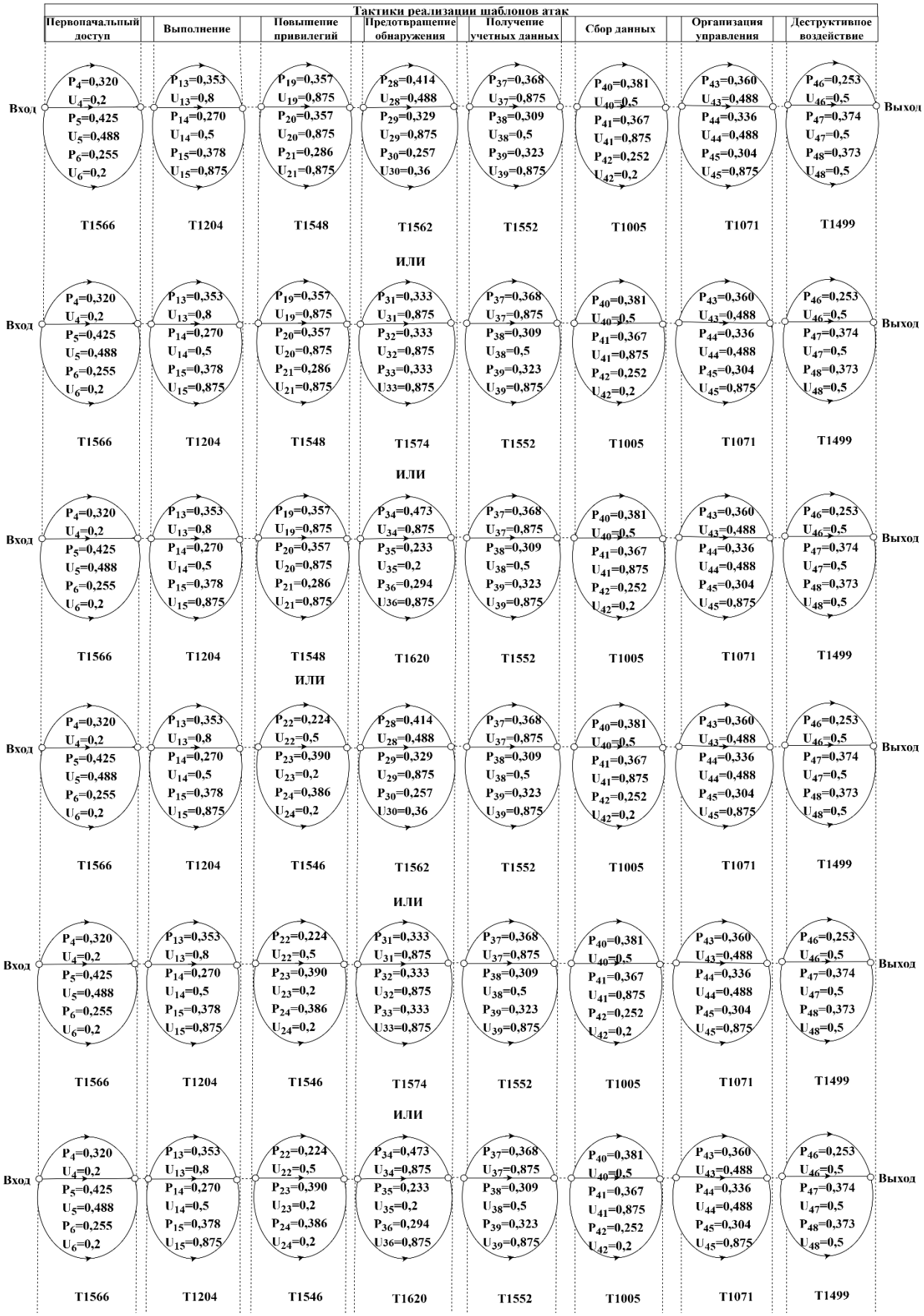

Рисунок 34. Графовая модель вероятных сценариев реализации шаблона кибератаки CAPEC-71 (часть 7)

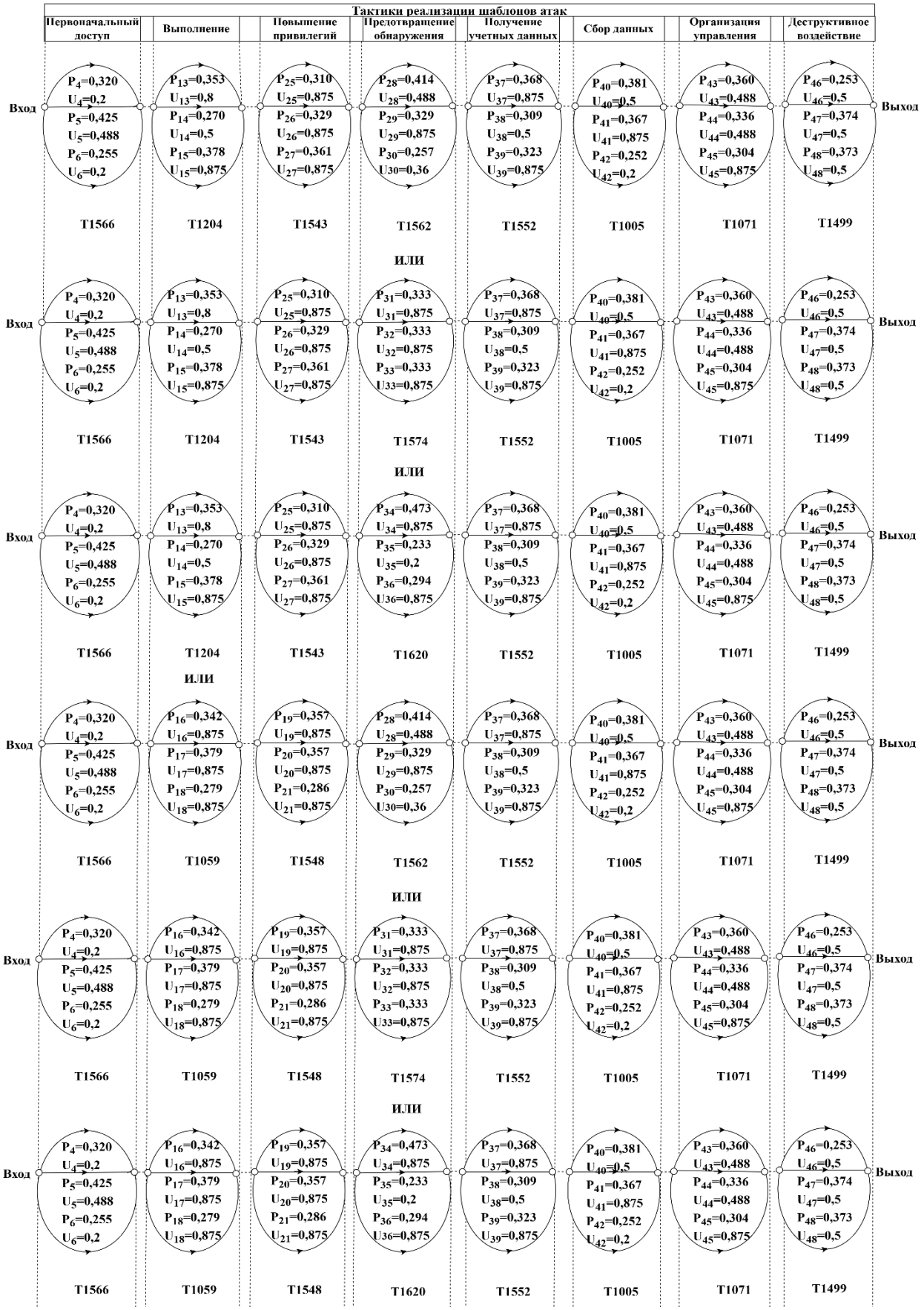

Рисунок 35. Графовая модель вероятных сценариев реализации шаблона кибератаки CAPEC-71 (часть 8)

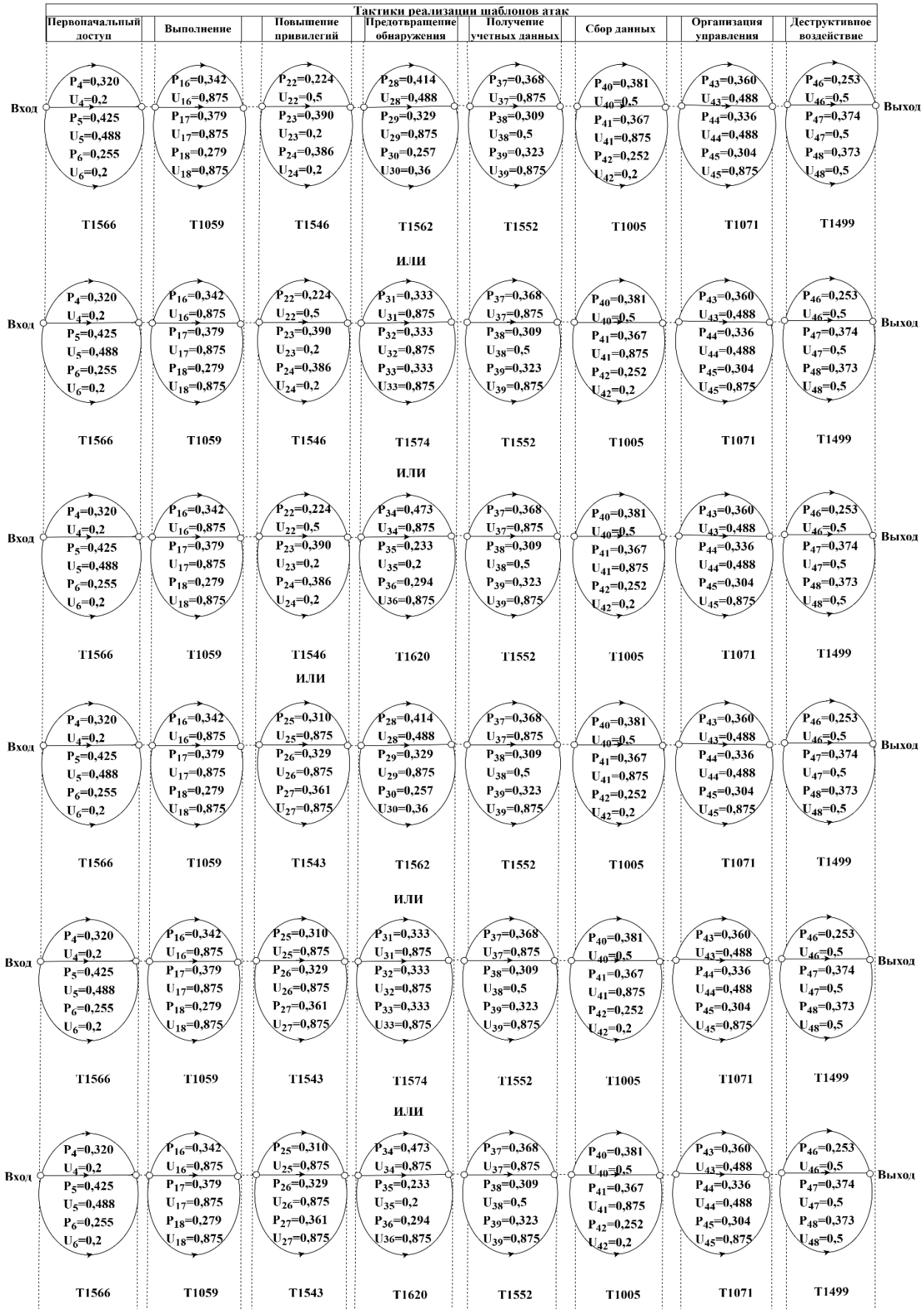

Рисунок 36. Графовая модель вероятных сценариев реализации шаблона кибератаки CAPEC-71 (часть 9)

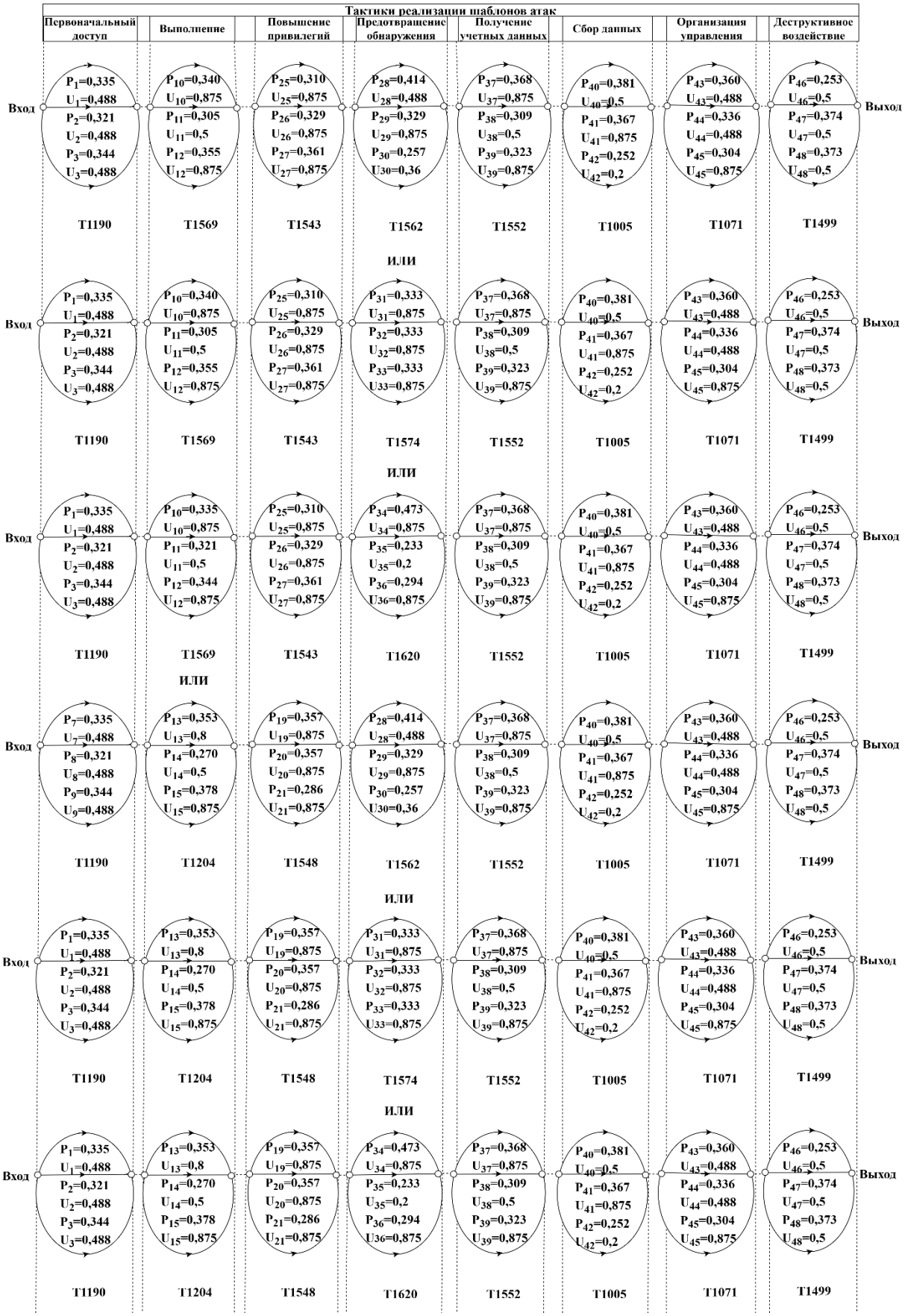

Рисунок 37. Графовая модель вероятных сценариев реализации шаблона кибератаки CAPEC-71 (часть 10)

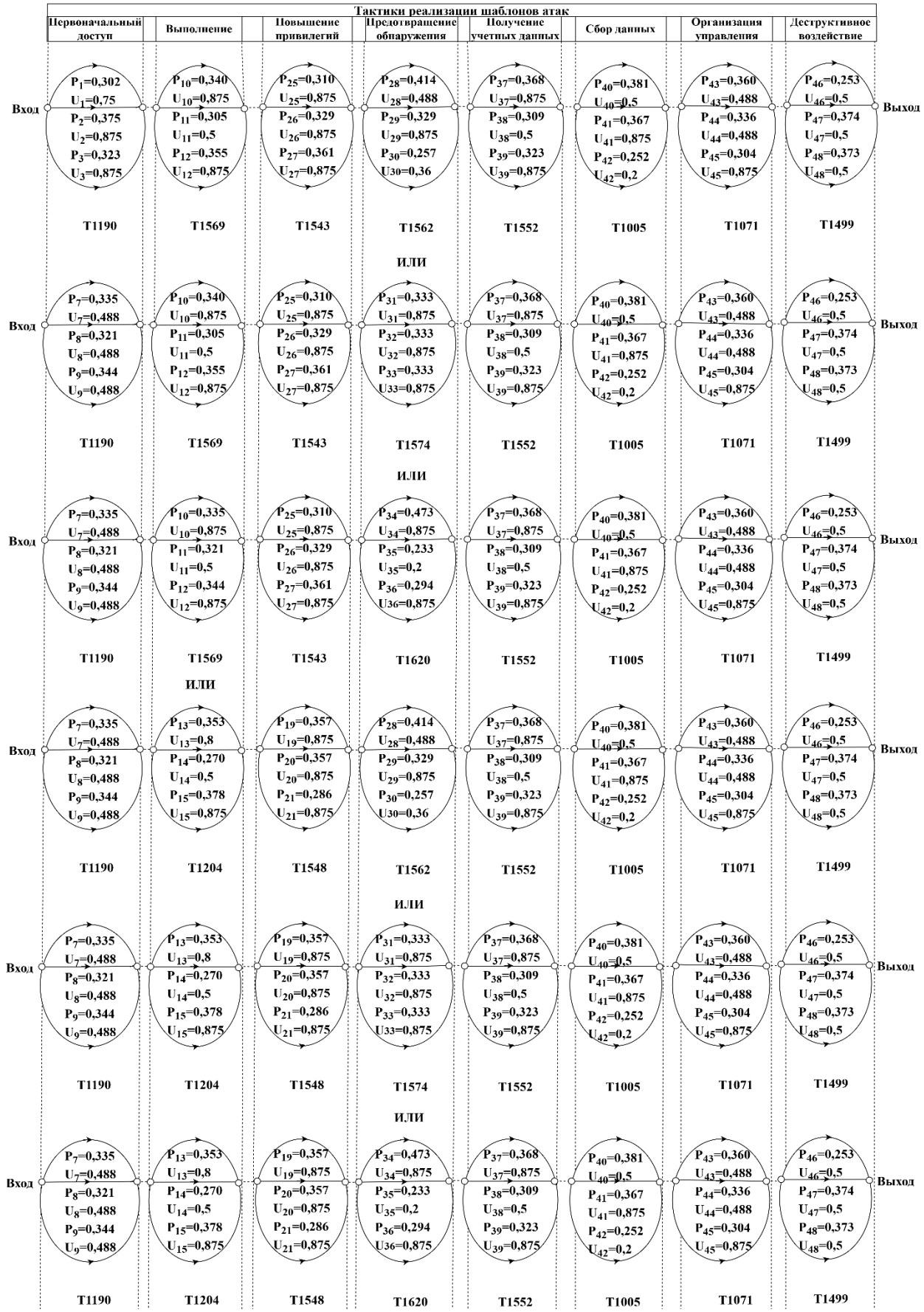

Рисунок 38. Графовая модель вероятных сценариев реализации шаблона кибератаки CAPEC-71 (часть 11)

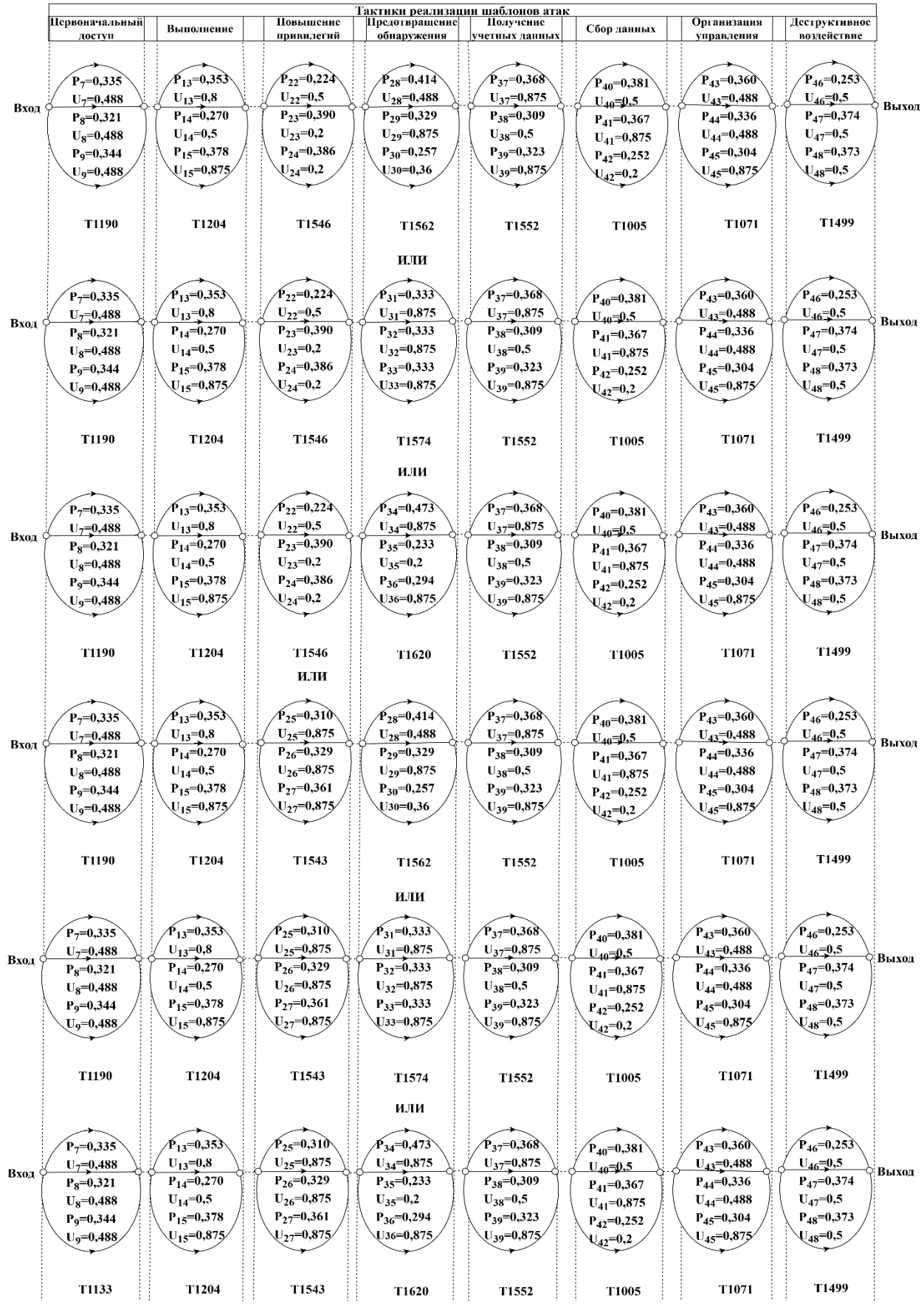

Рисунок 39. Графовая модель вероятных сценариев реализации шаблона кибератаки CAPEC-71 (часть 12)

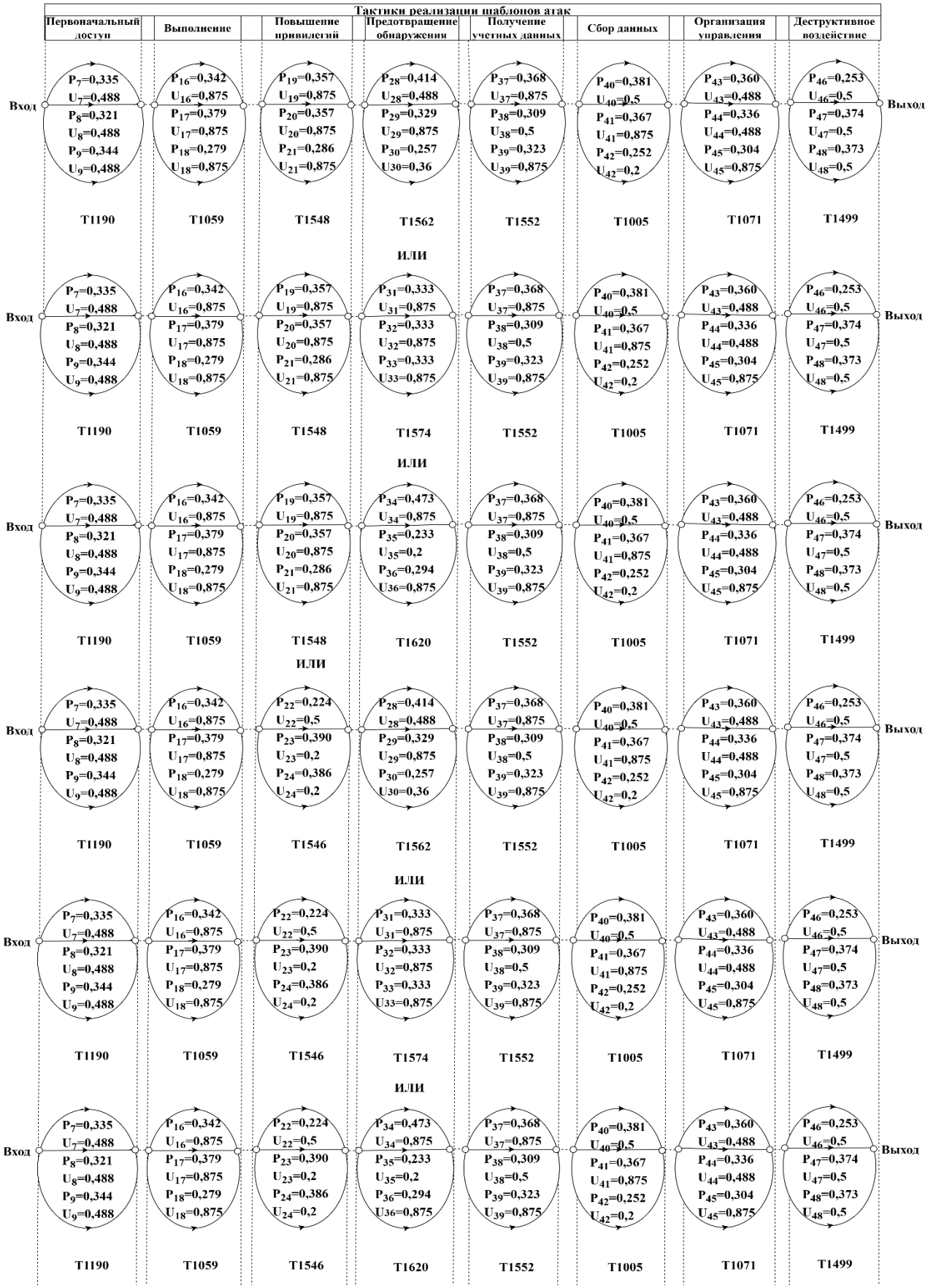

Рисунок 40. Графовая модель вероятных сценариев реализации шаблона кибератаки CAPEC-71 (часть 13)

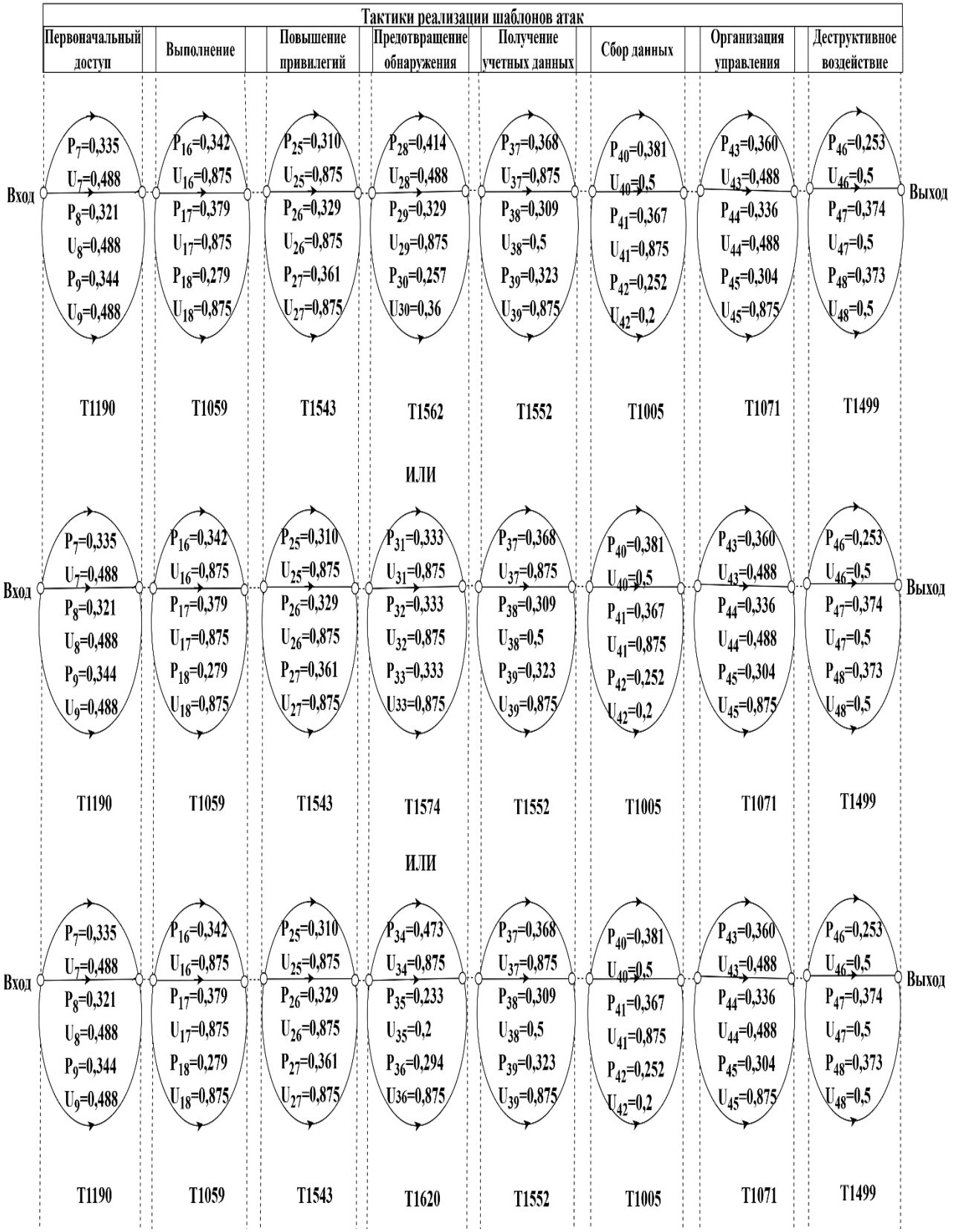

Рисунок 41. Графовая модель вероятных сценариев реализации шаблона кибератаки CAPEC-71 (часть 14)

Разработанные сценарии атак обладают высокой практической ценностью. Они не только демонстрируют, какими методами злоумышленники могут воспользоваться выявленными уязвимостями, но и дают возможность установить приоритеты среди этих уязвимостей, исходя из их опасности и важности оперативного устранения. Наиболее опасные уязвимости - те, которые характеризуются повышенной вероятностью эксплуатации и способны нанести значительный ущерб информационной инфраструктуре, занимают верхние строчки в списке приоритетов. Оценка осуществляется также с учётом интересов самих злоумышленников, ведь именно такие уязвимости зачастую применяются ими для достижения своих целей.

3.3 Расчет и анализ рисков успешной реализации сценариев атак

В данной главе представлена методика количественного анализа рисков, связанных с успешной реализацией сценариев кибератак. Основы подхода составляет анализ вероятностей успешного выполнения атак и оценки возможного ущерба, полученные на основе моделирования различных сценариев.

Особое внимание уделяется выбору оптимального пути среди всех возможных вариантов развития атаки: наиболее вероятный путь характеризуется наибольшим риском и ущербом, наименее вероятный путь - наименьшим показателем. Такой подход позволяет точно оценить диапазон рисков и определить приоритеты для усиления защиты.

Анализ рисков объединяет два аспекта: вероятностную оценку успешности атакующих действий и потенциальный ущерб. Получаемые результаты позволяют не только ранжировать сценарии по уровню угрозы, но и принимать обоснованные решения по распределению ресурсов для повышения уровня защиты. Наибольшее внимание уделяется сценариям с высокой вероятностью реализации атаки и значительным ущербом.

Еще одним важным компонентом методики является графовая модель, позволяющая наглядно представить все возможные маршруты атак - от начальной точки проникновения до конечного результата.

После определения всех необходимых параметров для каждой составляющей модели, производится вычисление общего риска, соотносимого с реализацией выбранного сценария кибератаки. Этот риск определяется как объединенное произведение вероятностей успешной эксплуатации всех задействованных уязвимостей, умноженное на суммарный потенциальный ущерб, который система понесет в случае успешного осуществления данного сценария [86], который вычисляется по формуле (5):

$$\text{Risk} = \prod_{i}^{k} \text{p}_i \times \sum_{j}^{k} \text{U}_j. \quad (5)$$

где: p_i - вероятность эксплуатации j-ой уязвимости посредством реализации техники Ti;

U_j - ущерб, наносимый атакуемой системе в результате эксплуатации уязвимости $CVEj$ в ходе реализации техники Ti;

k- количество используемых техник.

Для оценки рисков, связанных с реализацией сценариев атаки CAPEC-465, был осуществлён анализ нескольких возможных путей проникновения. В результате был выбран сценарий с наиболее вероятным путем проведения атаки. Вероятности успешной эксплуатации уязвимостей на каждом шаге данного сценария составили 0,562; 0,547; 1; 0,547 и 1 соответственно. Ущерб для этих шагов был определен как 0,75; 0,75; 0,75; 0,2 и 0,875.

Подставляя эти значения в формулу (5), получаем наибольшее значение риска:

$$\text{Risk} = (0{,}562 * 0{,}547 * 1 * 0{,}547 * 1) * (0{,}75 + 0{,}75 + 0{,}75 + 0{,}2 + 0{,}875)$$
$$= 0{,}16586 * 3{,}325 = 0{,}5587904.$$

Рисунок 42 демонстрирует графовую модель наиболее вероятного сценария атаки, соответствующему рассматриваемому шаблону CAPEC-465.

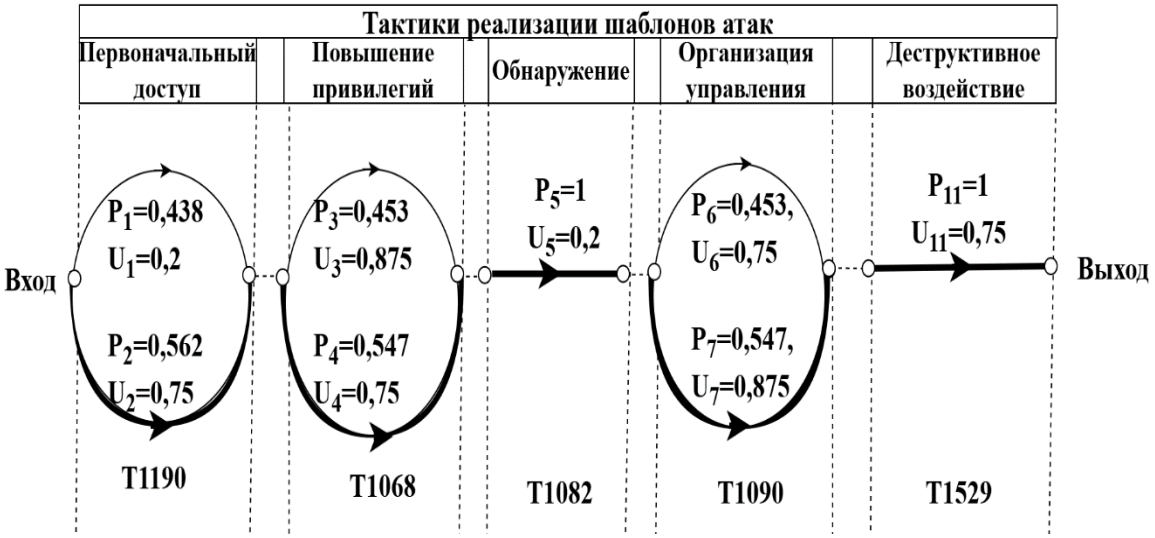

Рисунок 42. Графовая модель наиболее вероятного сценария реализации шаблона кибератаки CAPEC-465

Наименее вероятный сценарий изображен на рисунке 43.

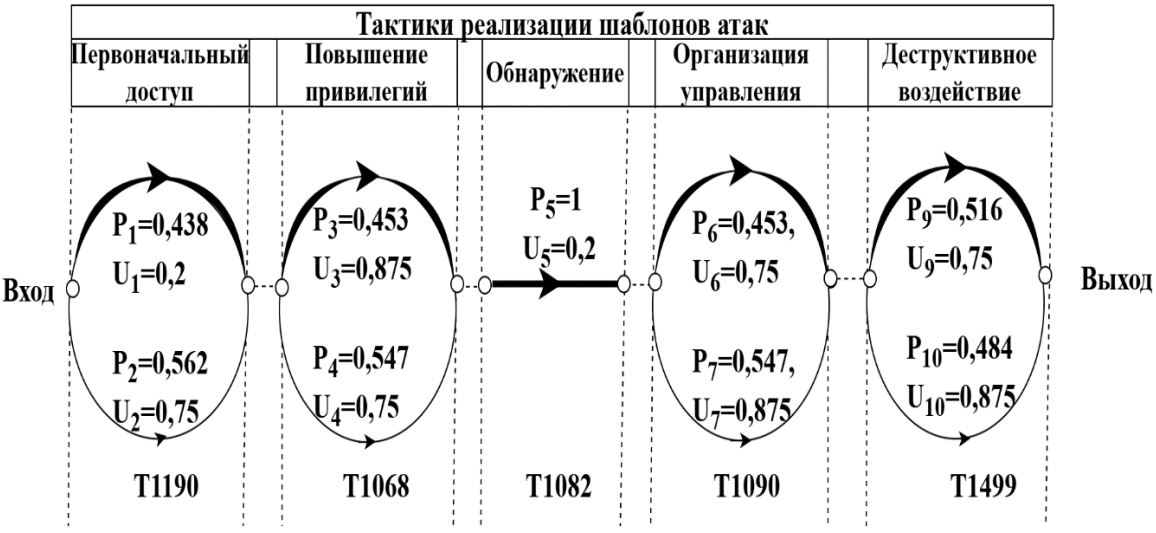

Рисунок 43. Графовая модель пути с наименее вероятным сценарием реализации шаблона кибератаки CAPEC-465

Для этого сценария вероятности успешной эксплуатации уязвимостей составили 0,438; 0,453; 1; 0,453; 0,516 соответственно, а ущерб от каждого этапа был определен как 0,2; 0,875; 0,2; 0,75; 0,75. Подставляя эти значения в формулу (5), получаем:

$$\text{Risk} = (0{,}438 * 0{,}453 * 1 * 0{,}453 * 0{,}516) * (0{,}2 + 0{,}875 + 0{,}2 + 0{,}75 + 0{,}75) = 0{,}04637 * 2{,}225 = 0{,}1031659.$$

Данный путь характеризуется самой низкой оценкой уровня опасности среди всех рассматриваемых версий.

При определении рисков реализации сценария атаки CAPEC-44 были изучены разные способы возможного вторжения злоумышленника. После подробного разбора различных вариантов был выбран сценарий, у которого выявлен наибольший риск Вычисленные вероятности успеха на отдельных стадиях избранного сценария составили следующие значения: 0,362; 1; 0,396; 0,551; 0,517 и 0,559. Ущерб, наносимый каждой фазой атаки, показал следующие значения: 0,875; 0,875; 0,875; 0,875; 0,2 и 0,875.

Подставляя эти значения в формулу (5), получаем наибольшее значение риска:

$$\text{Risk} = (0{,}362 * 1 * 0{,}396 * 0{,}551 * 0{,}517 * 0{,}559) * (0{,}875 + 0{,}875 + 0{,}875 + 0{,}875 + 0{,}2 + 0{,}875) = 0{,}02283 * 4{,}575 = 0{,}1044356.$$

Рисунок 44 демонстрирует графовую модель наиболее вероятного сценария атаки, соответствующему рассматриваемому шаблону CAPEC-44.

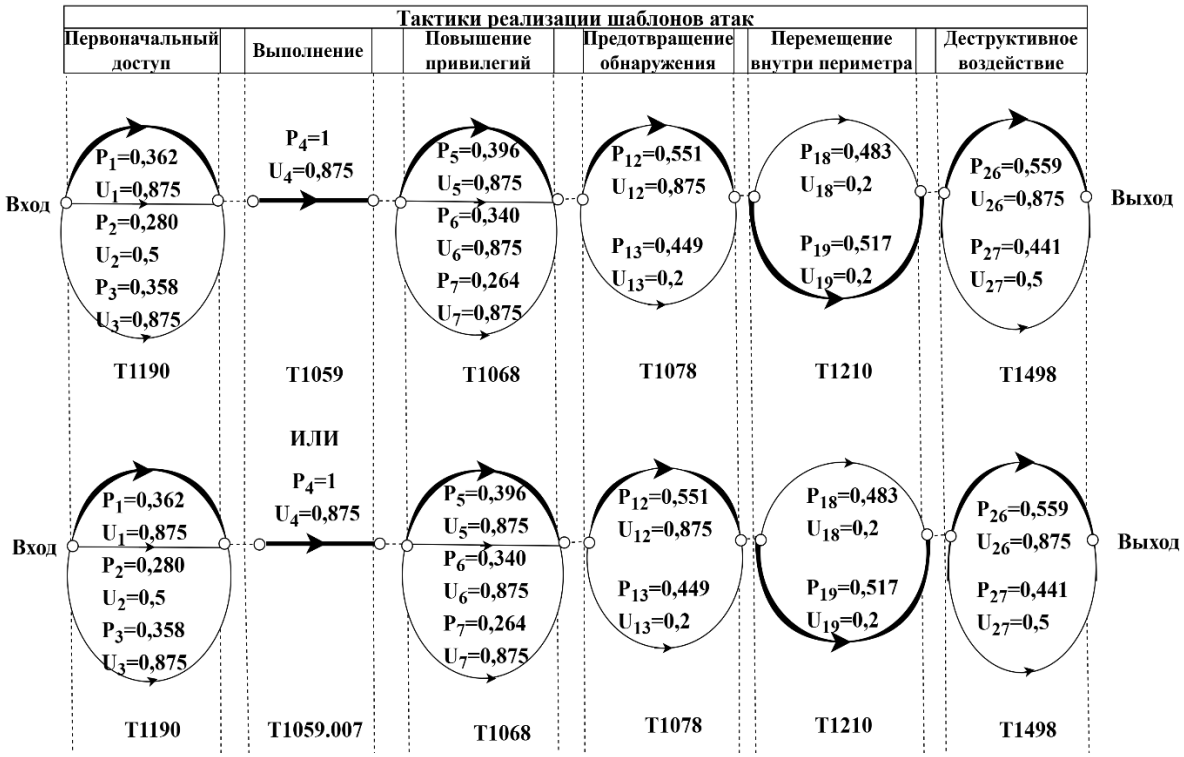

Рисунок 44. Графовая модель наиболее вероятного сценария реализации шаблона кибератаки CAPEC-44

Наименее вероятный сценарий изображен на рисунке 45.

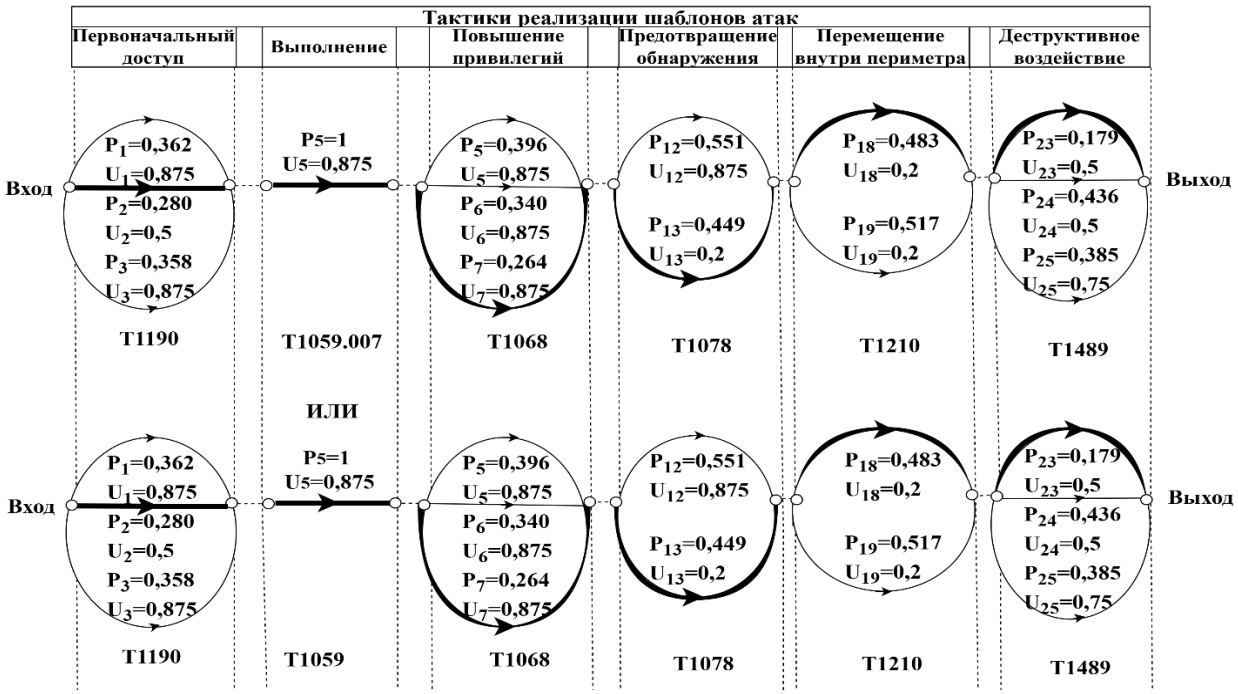

Рисунок 45. Графовая модель пути с наименее вероятным сценарием реализации шаблона кибератаки CAPEC-44

Для этого сценария вероятности успешной эксплуатации уязвимостей составили 0,280; 1; 0,264; 0,449; 0,483; 0,179 соответственно, а ущерб от каждого этапа был определен как 0,5; 0,875; 0,875; 0,2; 0,2; 0,5. Подставляя эти значения в формулу (5), получаем:

$$\text{Risk} = (0{,}280 * 1 * 0{,}264 * 0{,}449 * 0{,}483 * 0{,}179) * (0{,}5 + 0{,}875 + 0{,}875 + 0{,}2 + 0{,}2 + 0{,}5) = 0{,}00286 * 3{,}15 = 0{,}00903.$$

Этот вариант пути имеет наименьшую оценку риска среди всех возможных путей. Оценка угрозы минимальна, что делает его наиболее безопасным выбором.

Проведён детальный разбор возможных путей проведения атак CAPEC-42. Среди множества изучаемых способов был определён один путь атаки, характеризующийся наибольшей степенью опасности. Итоги исследования показали, что шансы удачно воспользоваться найденными уязвимостями составляют: 0,565; 0,271; 0,473; 0,327; 0,603; 0,279; 0,386 и 0,361. Величина возможного ущерба на различных этапах составила: 0,5; 0,875; 0,875; 0,5; 0,8; 0,875; 0,875 и 0,5.

Подставляя эти значения в формулу (5), получаем наибольшее значение риска:

$$\text{Risk} = (0{,}565 * 0{,}271 * 0{,}473 * 0{,}327 * 0{,}603 * 0{,}279 * 0{,}386 * 0{,}361) * (0{,}5 + 0{,}875 + 0{,}875 + 0{,}5 + 0{,}8 + 0{,}875 + 0{,}875 + 0{,}5) = 0{,}00055 * 5{,}8 = 0{,}00319.$$

Рисунок 46 демонстрирует графовую модель наиболее вероятного сценария атаки, соответствующему рассматриваемому шаблону CAPEC-42.

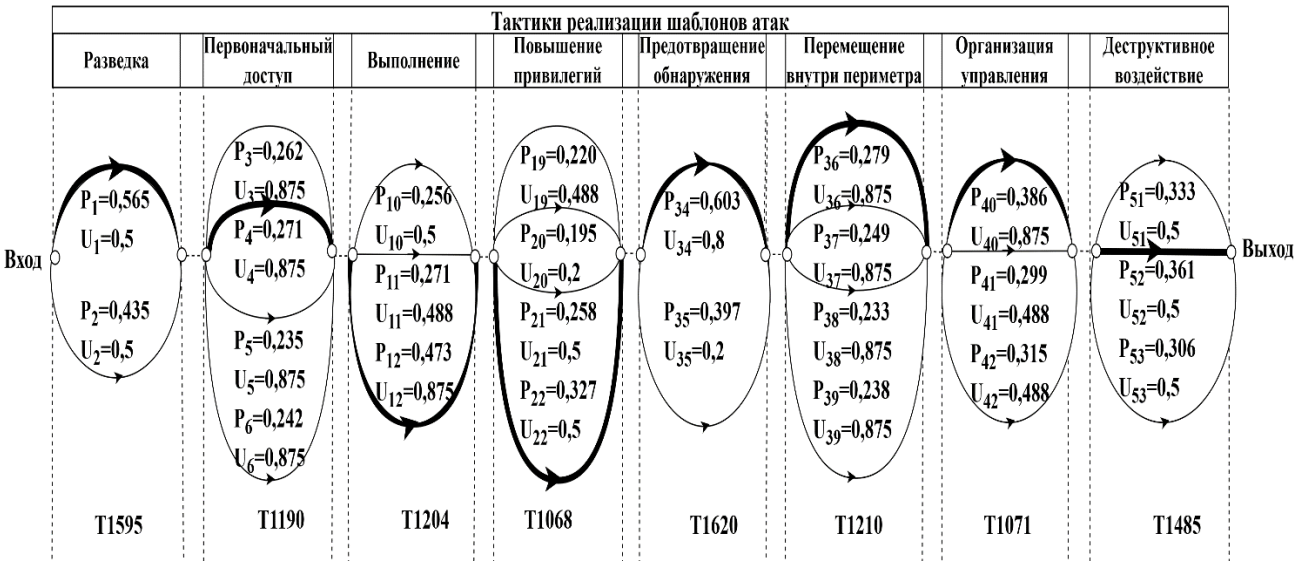

Рисунок 46. Графовая модель наиболее вероятного сценария реализации шаблона кибератаки CAPEC-42

Наименее вероятный сценарий изображен на рисунке 47.

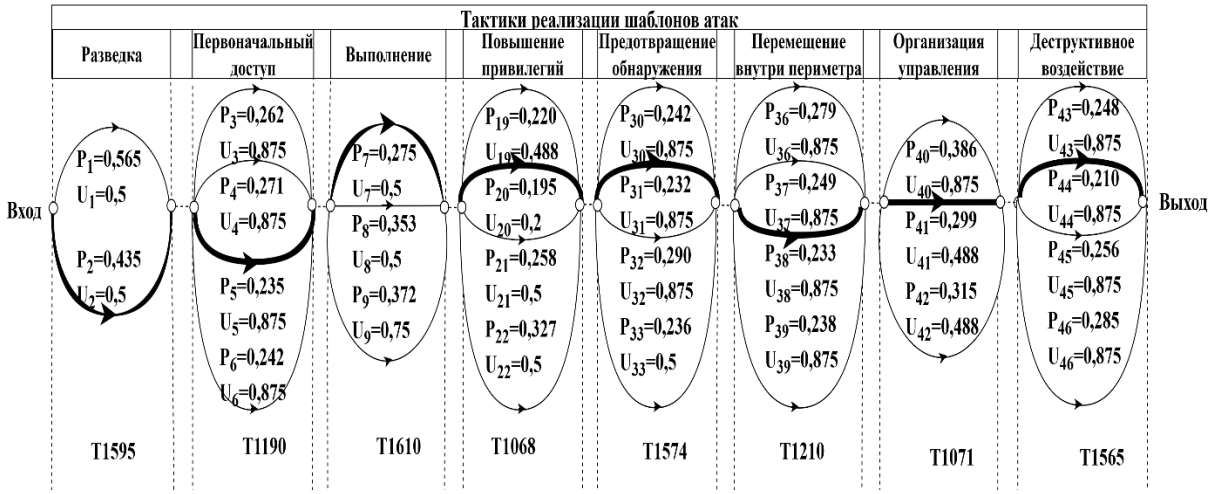

Рисунок 47. Графовая модель пути с наименее вероятным сценарием реализации шаблона кибератаки CAPEC-42

Для этого сценария вероятности успешной эксплуатации уязвимостей составили 0,435; 0,235; 0,275; 0,195; 0,232; 0,233; 0,299; 0,210 соответственно, а ущерб от каждого этапа был определен как 0,5; 0,875; 0,5; 0,2; 0,875; 0,875; 0,488; 0,875. Подставляя эти значения в формулу (5), получаем:

$$\text{Risk} = (0{,}435 * 0{,}235 * 0{,}275 * 0{,}195 * 0{,}232 * 0{,}233 * 0{,}299 * 0{,}210) * (0{,}5 + 0{,}875 + 0{,}5 + 0{,}2 + 0{,}875 + 0{,}875 + 0{,}488 + 0{,}875) = 0{,}00055 * 5{,}188 = 0{,}0000965.$$

Было выявлено, что этот маршрут имеет наименьшую оценку риска среди предложенных вариантов. Уровень возможной опасности незначителен, обеспечивая оптимальную безопасность.

Разбор проводился с целью обнаружения уязвимых мест системы безопасности и установления оптимальных способов защиты от вредоносных действий CAPEC-71. Были исследованы возможные сценарии всех возможных путей, среди которых выявлен вариант, имеющий наибольшую вероятность реализации. Расчётная оценка успешности реализации этапов составила: 0,425; 0,379; 0,361; 0,473; 0,368; 0,381; 0,360 и 0,374. Показатели степени ущерба, обусловленного каждым этапом нападения, оказались равны следующим величинам: 0,488; 0,875; 0,875; 0,875; 0,875; 0,5; 0,488 и 0,5.

Подставляя эти значения в формулу (5), получаем наибольшее значение риска:

$$\text{Risk} = (0{,}425 * 0{,}379 * 0{,}361 * 0{,}473 * 0{,}368 * 0{,}381 * 0{,}360 * 0{,}374) * (0{,}488 + 0{,}875 + 0{,}875 + 0{,}875 + 0{,}875 + 0{,}5 + 0{,}488 + 0{,}5) = 0{,}00055 * 5{,}776 = 0{,}0029989.$$

Рисунок 48 демонстрирует графовую модель наиболее вероятного сценария атаки, соответствующему рассматриваемому шаблону CAPEC-71.

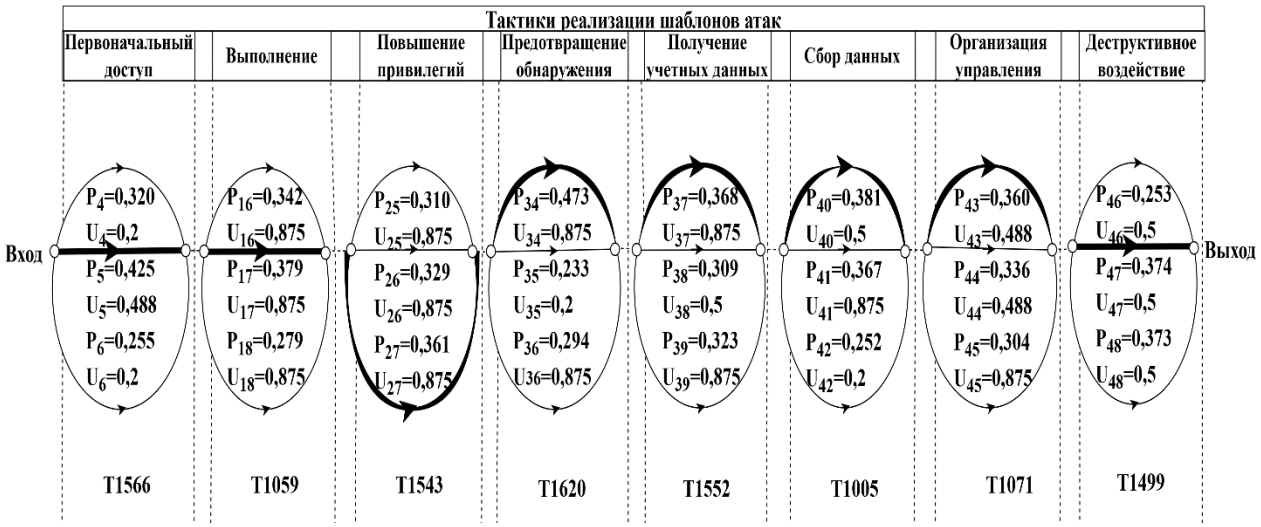

Рисунок 48. Графовая модель наиболее вероятного сценария реализации шаблона кибератаки CAPEC-71

Наименее вероятный сценарий изображен на рисунке 49.

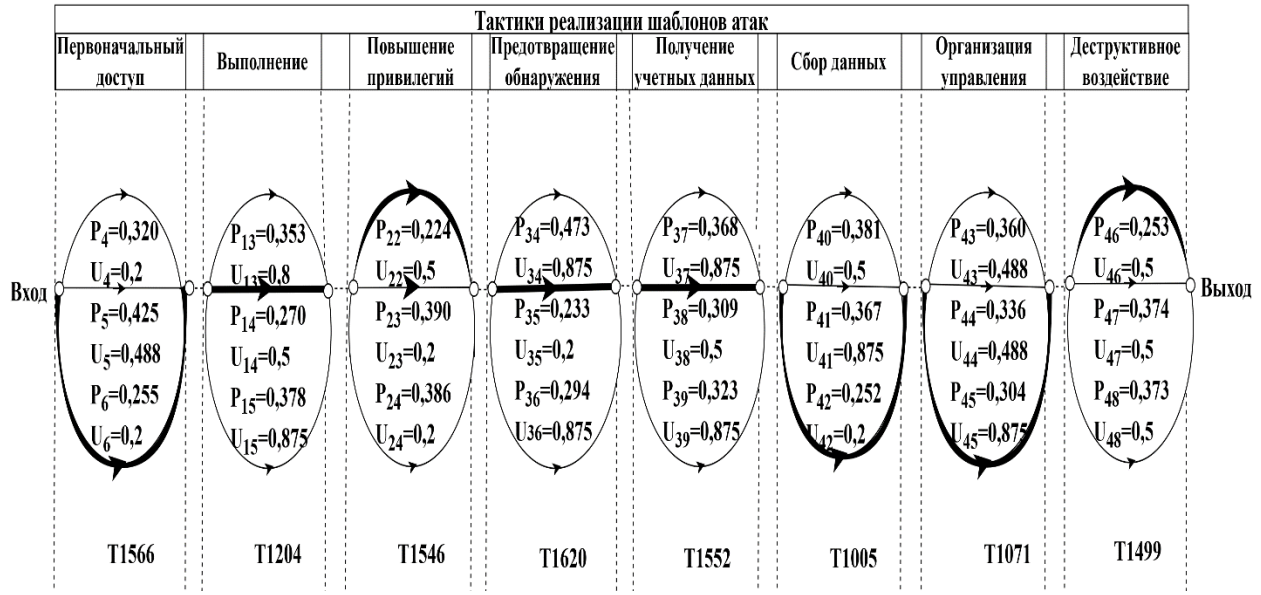

Рисунок 49. Графовая модель пути с наименее вероятным сценарием реализации шаблона кибератаки CAPEC-71

Для этого сценария вероятности успешной эксплуатации уязвимостей составили 0,255; 0,270; 0,224; 0,233; 0,309; 0,252; 0,304; 0,253 соответственно, а ущерб от каждого этапа был определен как 0,2; 0,5; 0,5; 0,2; 0,5; 0,2; 0,875; 0,5. Подставляя эти значения в формулу (5), получаем:

$$\text{Risk} = (0{,}255 * 0{,}270 * 0{,}244 * 0{,}233 * 0{,}309 * 0{,}252 * 0{,}304 * 0{,}253)$$
$$* (0{,}2 + 0{,}5 + 0{,}5 + 0{,}2 + 0{,}5 + 0{,}2 + 0{,}875 + 0{,}5)$$
$$= 0{,}00055 * 3{,}475 = 0{,}0000814.$$

Рассматриваемый маршрут выделяется наименьшим уровнем опасности по сравнению с иными вариантами.

Подводя итоги расчета рисков успешного осуществления различных сценариев кибератак становится ясно, насколько важен этот этап для построения действенной системы защиты информационных ресурсов. Оценка рисков, учитывающая вероятность возникновения неблагоприятных событий, даёт возможность выявить критические точки потенциального проникновения злоумышленников.

Полученная информация позволяет сформировать четкий перечень первоочередных мер по устранению слабых мест и усилению механизмов защиты. Это способствует повышению общей защищенности инфраструктуры и минимизации возможных последствий от внешних воздействий.

4 Разработка организационных мер по снижению рисков реализации выявленных сценариев атак

4.1 Меры реагирования и ликвидации последствий реализации сценариев атак

Современные информационные технологии предоставляют организациям значительные преимущества, но вместе с ними возникают и серьезные угрозы безопасности. Типовые политики и технические средства защиты редко предоставляют полную гарантию безопасности информации, ведь невозможно предусмотреть абсолютно все возможные виды атак и уязвимости. Даже при применении комплексных мер защиты нередко остаются незамеченными уязвимые места, эксплуатация которых способна привести к серьезным последствиям – потере конфиденциальных данных, нарушению непрерывности бизнеса и репутационным ущербам.

Для минимизации рисков рекомендуется применять ряд важных организационно-технических мер:

1) Комплексный анализ угроз и регулярная оценка рисков

Организации необходимо регулярно анализировать состояние своей информационно-технологической среды и оценивать возникающие опасности. Такой подход включает выявление новых типов угроз, периодическое проведение тестирования на проникновение («penetration testing») и использование технологий мониторинга безопасности, таких как системы предотвращения вторжений (IDS/IPS), системы обнаружения вредоносных программ (AV) и др. Этот процесс помогает заранее подготовиться к возможной атаке и повысить уровень готовности к быстрому реагированию.

2) Постоянное обучение и повышение квалификации сотрудников

Большое значение имеет формирование культуры информационной безопасности среди работников организации. Проведение регулярных тренингов и образовательных программ способствует увеличению осведомлённости сотрудников относительно вероятных угроз и методов борьбы с ними. Важно обеспечить доступ ко всей необходимой документации и процедурам реагирования на инциденты информационной безопасности [87-88].

3) Активное применение многоуровневой модели защиты

Защита должна осуществляться на нескольких уровнях одновременно, включая физические ограничения допуска к оборудованию, контроль авторизованного доступа пользователей, шифрование каналов передачи данных и соблюдение принципов минимальной привилегии («least privilege»). Такая стратегия существенно усложняет возможность успешного выполнения даже хорошо подготовленной атаки.

4) Периодическая проверка соответствия требованиям законодательства и международных стандартов

Качественная защита требует соблюдения обязательных требований нормативных актов государства и отраслевых стандартов. Например, в соответствии с Федеральным законом №152-ФЗ «О персональных данных», организации обязаны защищать персональные данные пользователей. Международные стандарты серии ISO/IEC 27000 определяют требования к системе менеджмента информационной безопасности и предлагают методики для её эффективной реализации [89].

5) Организация внутреннего взаимодействия между подразделениями

Важность координации различных подразделений внутри организации трудно переоценить. Координация усилий специалистов отдела информационной безопасности, IT-отдела, службы внутренней безопасности и иных участников процесса обеспечивает своевременное принятие эффективных мер по предотвращению и устранению последствий нарушений информационной безопасности.

Таблица 32 демонстрирует поэтапную реализацию модели MITRE ATT&CK, подробно иллюстрируя процесс зарегистрированных инцидентов, предлагаемых мер реагирования и процедур ликвидации последствий на каждом этапе кибератаки.

Таблица 32 – Организационный регламент противодействия шаблона атаки CAPEC-465

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
1	2	3	4
Первоначальный Доступ	Несанкционированный доступ к прокси-серверу или связанному публичному приложению (T1190) был осуществлён через эксплуатацию уязвимостей CVE-2024-9870 и CVE-2019-1841, что зафиксировано аномальными запросами и попытками аутентификации, указывающими на использование известной уязвимости.	1.Немедленно заблокировали подозрительные IP-адреса, с которых исходили попытки несанкционированного доступа, на уровне межсетевого экрана. 2.Временно ограничили или отключили доступ к уязвимому общедоступному приложению/прокси-серверу извне.	1.Применили все доступные патчи и обновления для устранения уязвимости на всех общедоступных приложениях и прокси-серверах. 2. Пересмотрели и ужесточили правила межсетевого экрана для публично доступных сервисов, внедряя принцип наименьших привилегий.
Повышение привилегий	Злоумышленник успешно повысил свои привилегии на скомпрометированной системе (T1068), используя уязвимости CVE-2024-0387 и CVE-2025-0237, что было обнаружено по действиям, выполненным от имени непривилегированной учетной записи, но требовавшим повышенных прав.	1.Немедленно отключили или заблокировали скомпрометированные учетные записи с повышенными привилегиями. 2.Изолировали системы, на которых произошло повышение привилегий, для предотвращения дальнейшей компрометации.	1.Применили патчи для устранения уязвимости на всех серверах и рабочих станциях. 2.Пересмотрели и внедрили модель наименьших привилегий для всех системных учетных записей и приложений.
Обнаружение	Злоумышленник провел несанкционированное сканирование системы или сбор информации через прокси-сервер (T1082), используя уязвимость CVE-2024-9870, что выражалось в подозрительных запросах к системным файлам, конфигурационным данным и сетевым ресурсам, фиксируемых непосредственно на прокси-сервере или проходящих через него и указывающих на исследование системы.	1.Идентифицировали и немедленно заблокировали источники сканирования или запросов на сбор информации. 2.Проанализировали сетевой трафик, проходящий через прокси-сервер, на предмет аномального поведения или запросов к чувствительным ресурсам.	1.Применили патчи для устранения уязвимости. 2.Усилили сегментацию сети, чтобы ограничить доступ к критическим системам даже в случае компрометации прокси-сервера. 3.Внедрили или обновили системы мониторинга сети и хостов для обнаружения подозрительных операций по изучению системы.

Продолжение таблицы 32

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
1	2	3	4
Организация управления	Злоумышленник установил канал управления и контроля (C2) через скомпрометированный прокси-сервер (T1090), используя уязвимости CVE-2024-9870, CVE-2025-25061 для маскировки связи, что привело к выявлению аномального исходящего трафика с прокси-сервера к неизвестным внешним адресам, соответствующего характерным признакам C2-коммуникаций.	1.Идентифицировали и заблокировали IP-адреса и домены, используемые для C2-связи на уровне межсетевого экрана. 2.Изолировали прокси-сервер, используемый в качестве прокси C2, чтобы прервать канал управления. 3.Провели немедленный анализ исходящего трафика с прокси-сервера на наличие аномалий и индикаторов компрометации.	1.Применили патчи для устранения уязвимости. 2.Настроили прозрачные прокси-серверы на использование только на использование только фактического IP-адреса сетевого уровня для маршрутизации запросов, отключив маршрутизацию на основе информации об адресе в заголовке HTTP-хоста. 3.Внедрили или обновили правила IDS/IPS для обнаружения известных паттернов C2-связи и аномалий в поведении прокси-сервера.
Деструктивное воздействие	Злоумышленник использовал уязвимсоть CVE-2019-1841 в Cisco DNA Center, сопряженную с ненадлежащей проверкой пользовательских данных, что дало возможность отправлять произвольные HTTP-запросы к внутренним службам без дополнительной аутентификации. Это обусловило вероятность обхода систем защиты и получение несанкционированного доступа к критически важным сервисам. В результате была инициирована техника (T1529) что спровоцировало неожиданное завершение работы ключевых компонентов инфраструктуры.	1. Немедленно изолировали затронутые системы Cisco DNA Center и управляемые коммутаторы от главной сети для предотвращения дальнейших несанкционированных операций и распространения атаки. 2. Отключили или перевели в безопасный режим сенсорные панели ViewJet, дабы ограничить воздействие на целостность информации. 3. Провели детальный анализ журналов и сетевого трафика для выявления источника атаки и точных команд, повлекших сбои и нарушения целостности. 4. Активировали мониторинг и систему обнаружения вторжений для оперативного выявления повторных попыток эксплуатации уязвимостей.	1. Установили все нужные исправления и обновления для Cisco DNA Center (версия 1.2.5 и выше) и контролируемых коммутаторов серий EDS-4000/G4000, убирающие уязвимости. 2. Обновили микропрограммное обеспечение сенсорных панелей ViewJet C-more Series и GC-A2 Series. 3. Укрепили методы контроля доступа, включая применение многофакторной аутентификации и улучшение правил фильтрации сетевого трафика. 4. Осуществили повторное тестирование на проникновение и оценку безопасности для проверки результативности примененных мер и выявления потенциальных новых уязвимостей.

Продолжение таблицы 32

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
1	2	3	4
	Также был зарегистрирован инцидент с техникой T1499, касающийся эксплуатации уязвимости CVE-2024-0387, позволяющей удалённому злоумышленнику обходить контроль доступа на управляемых коммутаторах и отправлять запросы от имени устройства. Вдобавок, уязвимость CVE-2025-25061 в микропрограммном обеспечении сенсорных панелей ViewJet (T1485) дала возможность нарушителю воздействовать на целостность данных		

Разработанный комплекс организационных мер направлен на повышение устойчивости информационной системы. Применение предложенных методов позволяет значительно уменьшить риски появления серьёзных инцидентов и снизить возможное негативное влияние взломов и несанкционированных действий на информационную инфраструктуру предприятия. Эти меры являются частью комплексного подхода к обеспечению безопасной и стабильной работы организаций в условиях современной цифровой экономики.

ЗАКЛЮЧЕНИЕ

В процессе проведения исследования была достигнута поставленная цель − повышение защищенности автоматизированных информационных систем от атак класса «Злоупотребление механизмами обработки данных». Это стало возможным благодаря следующим результатам исследования:

- изучена структурированная база данных кибератак класса «Злоупотребление механизмами обработки данных» на АИС, аккумулирующая статистические и экспертные метрики, извлечённые из открытых интернет-источников;

- представлено векторное представление пар «атака – уязвимость» на основе анализа стандартов CAPEC, CWE и CVE, отражающее динамику развития атак злоумышленника в ходе взаимодействия с АИС;

- проведена методика оценки рисков нарушения информационной безопасности АИС в результате реализации кибератак класса «Злоупотребление механизмами обработки данных», с учётом специфики используемых злоумышленников сценариев;

- сформирован комплекс регламентов реагирования и ликвидации последствий в отношении кибератак класса «Злоупотребление механизмами обработки данных» на уязвимости АИС.

Полученные оценки рисков успешной реализации рассматриваемого множества атак открывают перспективу их регулирования в целях повышения защищенности атакуемых объектов.

В этой связи, для достижения поставленной в работе цели предлагаются следующие организационные меры защиты атакуемых объектов:

− оперативное обнаружение и блокировка подозрительной активности;

− ограничение доступности уязвимых компонентов;

− быстрая нейтрализация скомпрометированных учётных записей;

− изоляция подвергшихся атаке систем;

− постоянный мониторинг и анализ сетевого трафика;

− регулярное обновление программного обеспечения;

− повторная проверка состояния безопасности;

− создание и внедрение подробных инструкций для сотрудников.

Внедрение предложенных мер, связанных с кибератаками класса «Злоупотребление механизмами обработки данных», способствует значительному снижению вероятности успешной эксплуатации уязвимостей в автоматизированных информационных системах. Представленные методы анализа и управления рисками создают прочную основу для формирования комплексной стратегии защиты, адаптированной к специфике подобных угроз.

Собранные материалы, изложенные в работе, могут стать важным инструментом для организаций, стремящихся повысить уровень своей информационной безопасности и провести более глубокий аудит существующих процессов. Это позволит не только обнаружить потенциальные уязвимости, но и своевременно внедрить эффективные меры по их противодействию.

Таким образом, применение представленных в исследовании рекомендаций станет значительным шагом в повышении уровня безопасности автоматизированных информационных систем, что крайне актуально в условиях современного роста числа и сложности кибератак.

СПИСОК ЛИТЕРАТУРЫ

1 Эпидемии в телекоммуникационных сетях / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2017. – 284 с. (Серия «Теория сетевых войн»; вып. 1). – Текст: непосредственный.

2 Атакуемые взвешенные сети / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2017. – 284 с. (Серия «Теория сетевых войн»; вып. 2). – Текст: непосредственный.

3 Социальные сети и деструктивный контент / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2017. – 284 с. (Серия «Теория сетевых войн»; вып. 3). – Текст: непосредственный.

4 Социальные сети и риск-мониторинг / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2019. – 284 с. (Серия «Теория сетевых войн»; вып. 4). – Текст: непосредственный.

5 Социальные сети и психологическая безопасность / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2020. – 284 с. (Серия «Теория сетевых войн»; вып. 5). – Текст: непосредственный.

6 Сетео-информационная эпидемиология / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2021. – 284 с. (Серия «Теория сетевых войн»; вып. 6). – Текст: непосредственный.

7 Картография защищаемого киберпространства / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2022. – 372 с. (Серия «Теория сетевых войн»; вып. 7). – Текст: непосредственный.

8 Организационно-правовая защита сетей / Остапенко [и др.]; [под ред. чл. – корр. РАН Д.А. Новикова]. – М: Горячая линия – Телеком, 2023. – 228 с. (Серия «Теория сетевых войн»; вып. 8). – Текст: непосредственный.

9 CAPEC. – Электрон. дан. – Режим доступа: https://capec.mitre.org/. – Текст: электронный.

10 MITRE ATT&CK. – Электрон. дан. – Режим доступа: https://attack.mitre.org/matrices/enterprise/. – Текст: электронный.

11 MITRE ATT&CK (Positive Technologies). – Электрон. дан. – Режим доступа: https://mitre.ptsecurity.com/ru-RU. – Текст: электронный.

12 CWE - Common Weakness Enumeration. – Электрон. дан. – Режим доступа: https://cwe.mitre.org/index.html. – Текст: электронный.

13 Банк данных угроз безопасности информации ФСТЭК России https://bdu.fstec.ru/threat.– Текст: электронный.

14 NIST NVD. – Электрон. дан. – Режим доступа: https://nvd.nist.gov/. – Текст: электронный.

15 Exploit Prediction Scoring System (EPSS). – Электрон. дан. – Режим доступа: https://www.first.org/epss/. – Текст: электронный.

16 Общая система оценки уязвимостей (CVSS). – Электрон. дан. – Режим доступа: https://www.first.org/cvss/specificationdocument. – Текст: электронный.

17 Common Vulnerability Scoring System v3.1. – Электрон. дан. – Режим доступа: https://www.first.org/cvss/v3.1/. – Текст: электронный.

18 Common Vulnerability Scoring System v4.0. – Электрон. дан. – Режим доступа: https://www.first.org/cvss/v4.0/. – Текст: электронный.

19 OWASP Risk Rating. – Электрон. дан. – Режим доступа: https://owasp-risk-rating.com/. – Текст: электронный.

20 SSVC Calculator. – Электрон. дан. – Режим доступа: https://www.cisa.gov/ssvc-calculator. – Текст: электронный.

21 The Vulnerability Impact Scoring System (VISS). – Электрон. дан. – Режим доступа: https://viss.zoom.com/specifications#2-metrics. – Текст: электронный.

22 VISS калькулятор. – Электрон. дан. – Режим доступа: https://viss.zoom.com/calculator/0.07#VISS:0.07:PLI:NA/ICI:N/III:N/IAI:N/ITN:NA/STN:NA/DTN:NA/TIM:N/DCI:N/DII:N/DAI:N/DCL:N/UCI:NA – Текст: электронный.

23 Калькулятор BVSS. – Электрон. дан. – Режим доступа: https://www.halborn.com/bvss. – Текст: электронный.

24 Healthcare Vulnerability Scoring System (HVSS). – Электрон. дан. – Режим доступа: https://hvss.online/. – Текст: электронный.

25 HVSS v1.0 Documentation). – Электрон. дан. – Режим доступа: https://hvss.online/doc/v1.0/HVSS_v1.0_Documentation.pdf. – Текст: электронный.

26 How Red Hat uses CVSSv3 to Assist in Rating Flaws.– Электрон. дан. – Режим доступа: https://www.redhat.com/en/blog/how-red-hatuses-cvssv3-assist-rating-flaws. – Текст: электронный.

27 Остапенко Г.А. Совершенствование организационно-правового обеспечения информационной безопасности предприятия: формирование риск-ландшафта сетевых атак / Г.А. Остапенко, Д.В. Щербакова, Т.Ю. Мирошниченко, А.А. Остапенко, А.Ю. Пекло // Информация и безопасность. 2023. - Т. 26. Вып. 2. - С. 203-210. – Текст: непосредственный.

28 Остапенко Г.А. Организационно-правовая защита от сетевых атак: методики формирования частных политик, регламентов и инструкций обеспечения безопасности организации (часть I) / Г.А. Остапенко, Д.В. Щербакова, Т.Ю. Мирошниченко, А.А. Остапенко, А.С. Кривошеин // Информация и безопасность. 2023. - Т. 26. Вып. 3. - С. 329-340. – Текст: непосредственный.

29 Остапенко Г.А. Организационно-правовая защита от сетевых атак: методики формирования частных политик, регламентов и инструкций обеспечения безопасности организации (часть II) / Г.А. Остапенко, Д.В. Щербакова, Т.Ю. Мирошниченко, А.А. Остапенко, А.Г. Краснобородкин // Информация и безопасность. 2023. - Т. 26. Вып. 3. - С. 329-340. – Текст: непосредственный.

30 Остапенко Г.А. Организационно-правовая защита от сетевых атак: методики формирования частных политик, регламентов и инструкций обеспечения безопасности организации (часть III) / Г.А. Остапенко, Д.В. Щербакова, Т.Ю. Мирошниченко, А.А. Остапенко, А.Г. Краснобородкин // Информация и безопасность. 2023. - Т. 26. Вып. 3. - С. 341-358. – Текст: непосредственный.

31 Остапенко А.Г. Проектная деятельность: научно-методическое развитие в направлении внедрения средств искусственного интеллекта для обеспечения организационно-правовой защиты корпоративных сетей / А.Г. Остапенко, Д.В. Щербакова, А.А. Остапенко, Д.А. Нархов // Информация и безопасность. 2023. - Т. 26. Вып. 3. - С. 447-454. – Текст: непосредственный.

32 Остапенко Г.А. Нейросетевые задачи и компетенции проектной деятельности по созданию защищённых автоматизированных информационных систем / Г.А. Остапенко, А.П. Васильченко // Информация и безопасность. 2023. - Т. 26. Вып. 4. - С. 579-586. – Текст: непосредственный.

33 Остапенко Г.А. Методики регламентации обеспечения информационной безопасности атакуемых автоматизированных систем / Г.А. Остапенко, А.П. Васильченко // Информация и безопасность.2023. - Т.26.Вып. 4.- С.597-602. – Текст: непосредственный.

34 Пекло А.Ю. Атаки типа "сетевая разведка": риск-ландшафт и частная политика информационной безопасности предприятия / А.Ю. Пекло, Г.А. Остапенко, Д.В. Щербакова, А.А. Остапенко // Информация и безопасность. 2023. Т. 26. Вып. 2. С. 235-246.

35 Остапенко А.Г. Направление совершенствования нормативно-правового обеспечения объектов информатизации на основе риск-анализа их кибербезопасности/ А.Г. Остапенко, Д.В. Щербакова, Д.А. Нархов, Ю.В. Макаров, А.С. Кривошеин // Информация и безопасность.2022. - Т.25.Вып. 4. - С.593-598. – Текст: непосредственный.

36 Остапенко Г.А. Формализация знаний и данных кибератак и уязвимостей / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Д.С. Покудин [и другие] // Информация и безопасность. 2024. - Т. 27. Вып. 2. - С. 231-238. – Текст: непосредственный.

37 Остапенко Г.А. Модуль нейросетевой регламентации мер противодействия кибератакам/ Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, А.А. Ноздрюхин [и другие] // Информация и безопасность. 2024. - Т. 27. Вып. 2. - С. 239-246. – Текст: непосредственный. – Текст: непосредственный.

38 Остапенко Г.А. Модернизация методического обеспечения автоматизированного сервиса агрегации данных и риск-анализа уязвимостей/ Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Н.Н. Корвяков [и другие] // Информация и безопасность. 2024. - Т. 27. Вып. 2. - С. 219-230. – Текст: непосредственный.

39 Остапенко Г.А. Автоматизированный банк знаний и калькулятор рисков реализации кибератак и уязвимостей (часть I) / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Д.С. Нестеров, А.С. Дубов, В.А. Старцев // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 7-30. – Текст: непосредственный.

40 Хромых С.А. Сетевые атаки на уровне приложений: риск-ландшафт и частная политика информационной безопасности предприятия / С.А. Хромых, Г.А. Остапенко, Д.В. Щербакова, А.А. Остапенко // Информация и безопасность. 2023. Т. 26. Вып. 2. С. 261-276. – Текст: непосредственный.

41 Остапенко Г.А. Автоматизированный банк знаний и калькулятор рисков реализации кибератак и уязвимостей (часть II) / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Д.С. Нестеров, А.С. Дубов, В.А. Старцев // Информация и безопасность. 2024. Т. 27. Вып. 1. С. 31-54. – Текст: непосредственный.

42 Остапенко Г.А. Нейросетевой сервис регламентации мер противодействия кибератакам (часть I) / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, А.А. Ноздрюхин, А.Г. Остапенко, И.Л. Батаронов, А.С. Кривошеин // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 319-336. – Текст: непосредственный.

43 Остапенко Г.А. Нейросетевой сервис регламентации мер противодействия кибератакам (часть II) / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, А.А. Ноздрюхин, А.Г. Остапенко, И.Л. Батаронов, Д.С. Печкин // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 337-378. – Текст: непосредственный.

44 Остапенко Г.А. Использование средств искусственного интеллекта в ходе исследовательского и учебного процессов при подготовке специалистов по защите информации / Г.А. Остапенко, А.О. Калашников, А.Г. Остапенко, Е.А. Москалева, Д.О. Карпеев, О.В. Поздышева, Ю.В. Макаров // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 389-400. – Текст: непосредственный.

45 Остапенко А.А. Методики и алгоритмы риск-анализа успешности реализации массированных кибератак / А.А. Остапенко // Информация и безопасность. 2024. Т. 27. Вып. 3. С. 401-420. – Текст: непосредственный.

46 Остапенко А.Г. Картографирование киберпространства и защита информации / А.Г. Остапенко, А.Л. Сердечный, С.Д. Трубицын, Д.А. Нархов, В.Ю. Остапенко // Информация и безопасность. 2022. Т. 25. Вып. 1. С. 89-106. – Текст: непосредственный.

47 Остапенко А.Г. Картографирование киберпространства и обеспечение информационной безопасности / А.Г. Остапенко, А.Л. Сердечный, С.Д. Трубицын, Д.А. Нархов, В.Ю. Остапенко // Информация и безопасность. 2022. Т. 25. Вып. 1. С. 115-128. – Текст: непосредственный.

48 Остапенко Г.А. Матричная формализация целеполагания и результативности проектной деятельности в сфере защиты информации и обеспечения информационной безопасности / Г.А. Остапенко, В.И. Белоножкин, Н.И. Баранников, А.А. Остапенко, А.Г. Краснобородкин, Т.Ю. Мирошниченко // Информация и безопасность. 2022. Т. 25. Вып. 4. С. 475-484. – Текст: непосредственный.

49 Смирнов В.В. Кибератаки вида "анализ целевого объекта": риск-ландшафт векторов атак и уязвимостей телекоммуникационных сетей / В.В. Смирнов, А.П. Васильченко, А.А. Остапенко, А.В. Гречишкин, С.С. Куликов, Д.Н. Рахманин // Информация и безопасность. 2024. Т. 27. Вып. 2. С. 273-284. – Текст: непосредственный.

50 Жидков Э.И. Кибератаки вида "социальная инженерия": риск-ландшафт векторов атак и уязвимостей телекоммуникационных сетей / Э.И. Жидков, А.П. Васильченко, А.А. Остапенко, А.С. Кольцов, Е.А. Шварцкопф, А.С. Щеголеватых // Информация и безопасность. 2024. Т. 27. № 2. С. 285-298. – Текст: непосредственный.

51 Компания Wallarm опубликовала отчёт API ThreatStats 2025. – Электрон. дан. – Режим доступа: https://www.itsec.ru/news/kompaniya-wallarm-opublikovala-otchiot-api-threatstats-2025/bvss. – Текст: электронный.

52 Количество DDoS-атак на API выросло вдвое: главными целями стали ритейл и банки. – Электрон. дан. – Режим доступа:

https://infobezopasnost.ru/blog/news/kolichestvo-ddos-atak-na-api-vyroslo-vdvoe-glavnymi-tselyami-stali-ritejl-i-banki/. – Текст: электронный.

53 В IV квартале 2024 г. DDoS-атак на API стало вдвое больше, 70% пришлось на ритейл и банки. – Электрон. дан. – Режим доступа: https://safe.cnews.ru/news/line/2025-03-03_v_iv_kvartale_2024_gddos-atak. – Текст: электронный.

54 Eugene Spafford, Robert Morris Jr., Daniel Geer, "Reflexive Security in Computer Systems," Proceedings of the IEEE Symposium on Research in Security and Privacy, May 1988. – Текст: непосредственный.

55 Richard A. Kemmerer, "A Logic-Based Model for Reasoning About Malicious Software," ACM Transactions on Information and System Security, Vol. 2, No. 3, August 1999. – Текст: непосредственный.

56 Rolf Oppliger, "Security in Distributed and Networking Environments", Artech House Publishers, 2004. – Текст: непосредственный.

57 Adrian Pastor, Violent Python: A Cookbook for Hackers, Forensic Analysts, Penetration Testers and Security Engineers, Elsevier Science, 2013. – Текст: непосредственный.

58 Michalis Polychronakis, Practical Malware Analysis: Building Better Detection Tools, No Starch Press, 2012. – Текст: непосредственный.

59 Новая тактика кибератак: злоупотребление Microsoft Graph API. – Электрон. дан. – Режим доступа: https://securitymedia.org/news/novaya-taktika-kiberatak-zloupotreblenie-microsoft-graph-api.html.– Текст: электронный.

60 ГОСТ Р ИСО/МЭК 15408-2-2013. – Электрон. дан. – Режим доступа: https://docs.cntd.ru/document/1200105710. – Текст: электронный.

61 ГОСТ Р ИСО/МЭК 27001-2021. – Электрон. дан. – Режим доступа: https://docs.cntd.ru/document/1200181890. – Текст: электронный.

62 ГОСТ Р 59710-2022. – Электрон. дан. – Режим доступа: https://docs.cntd.ru/document/1200194356. – Текст: электронный.

63 ГОСТ Р 59711-2022. – Электрон. дан. – Режим доступа: https://docs.cntd.ru/document/1200194357. – Текст: электронный.

64 ГОСТ Р 59547-2021. – Электрон. дан. – Режим доступа: https://docs.cntd.ru/document/1200180385. – Текст: электронный.

65 ИСО/МЭК 13335-1:2006. Информационная технология - Методы обеспечения безопасности - Управление безопасностью информационных и телекоммуникационных технологий - Часть 1 - Концепция и модели управления безопасностью информационных и телекоммуникационных технологий. URL: https://docs.cntd.ru/document/1200048398. – Текст: электронный.

66 Перечисление и классификация распространённых моделей атак. – Электрон. дан. – Режим доступа: https://en.m.wikipedia.org/wiki/Common_Attack_Pattern_Enumeration_and_Classification. – Текст: электронный.

67 Иерархия CAPEC. – Электрон. дан. – Режим доступа: https://www.ibm.com/think/x-force/capec-making-heads-or-tails-of-attack-patterns#Familiar+Standards. – Текст: электронный.

68 Что такое база MITRE ATT&CK и для чего она нужна?– Электрон. дан. – Режим доступа: https://www.securitylab.ru/analytics/537350.php. – Текст: электронный.

69 Национальная база данных об Уязвимостях. – Электрон. дан. – Режим доступа: https://en.wikipedia.org/wiki/National_Vulnerability_Database. – Текст: электронный.

70 Common Vulnerability Scoring System. – Электрон. дан. – Режим доступа: https://ru.wikipedia.org/wiki/Common_Vulnerability_Scoring_System. – Текст: электронный.

71 CVSS (Common Vulnerability Scoring System). – Электрон. дан. – Режим доступа: https://encyclopedia.kaspersky.ru/glossary/cvss-common-vulnerability-scoring-system/. – Текст: электронный.

72 Как ранжировать уязвимости по уровню опасности – Электрон. дан. – Режим доступа: https://www.anti-malware.ru/practice/methods/How-to-rank-vulnerabilities-by-severity-level. – Текст: электронный.

73 CVSS 4.0 - обновленная система оценки уязвимостей. – Электрон. дан. – Режим доступа: https://www.securitylab.ru/blog/company/Rubikon/353450.php. – Текст: электронный.

74 CVSS 4.0: как новая система классификации уязвимостей влияет на управление ими. – Электрон. дан. – Режим доступа: https://www.anti-malware.ru/analytics/Technology_Analysis/CVSS-4-0#part2. – Текст: электронный.

75 Как приоритизировать выявленные уязвимости. – Электрон. дан. – Режим доступа: https://www.anti-malware.ru/practice/methods/Vulnerability-Prioritization-Technology?ysclid=mcknxjq5up934535461#part3. – Текст: электронный.

76 Остапенко А.А. Оценка критичности уязвимостей с использованием данных множества риск-калькуляторов / А.А. Остапенко, В.П. Шелякин, Е.С. Короткова, А.С. Кривошеин, Д.А. Мальцева, П.А. Меркулов, Н.Д. Никитин, М.О. Титаренко // Информация и безопасность. 2024. Т. 27. Вып. 4. С. 521-542. – Текст: непосредственный.

77 Все о прозрачных прокси: настройка, фильтрация и повышение производительности сети. – Электрон. дан. – Режим до-ступа: https://capmonster.cloud/ru/blog/bypass-captcha/all-about-transparent-proxies-configuration-filtering-and-network-performance-optimization. – Текст: электронный.

78 До 42% российских IP-адресов, блокируемых из-за DDoS, — в основном прокси. – Электрон. дан. – Режим доступа: https://www.anti-malware.ru/news/2024-02-14-114534/42801. – Текст: электронный.

79 Атаки на переполнение буфера. – Электрон. дан. – Режим доступа: https://www.baeldung.com/cs/buffer-overflow. – Текст: электронный.

80 Бинарные уязвимости и способы борьбы с ними. – Электрон. дан. – Режим доступа: https://habr.com/ru/articles/830680/. – Текст: электронный.

81 MIME. – Электрон. дан. – Режим доступа: https://ru.wikipedia.org/wiki/MIME. – Текст: электронный.

82 Самые крупные хакерские атаки в России с 2021 по 2025 год. – Электрон. дан. – Режим доступа: https://www.computerra.ru/309334/samye-krupnye-hakerskie-ataki-v-rossii-s-2021-po-2025-god/. – Текст: электронный.

83 Как скрыть вредоносное ПО в Unicode. – Электрон. дан. – Режим доступа: https://www.secureworks.com/blog/how-to-hide-malware-in-unicode. – Текст: электронный.

84 Остапенко Г.А. Модернизация методического обеспечения автоматизированного сервиса агрегации данных и риск-анализа уязвимостей / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Н.Н. Корвяков, Д.С. Покудин, А.А. Ноздрюхин // Информация и безопасность. 2024. Т. 27. Вып. 2. С. 219-230. – Текст: непосредственный.

85 Модель угроз и модель нарушителя физической безопасности. – Электрон. дан. – Режим доступа: https://dvboyarkin.ru/wp-content/uploads/2020/03/Model-ugroz-i-model-narushitelya.pdf. – Текст: электронный.

86 Остапенко Г.А. Формализация знаний и данных кибератак и уязвимостей / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Д.С. Покудин, Н.Н. Корвяков, А.А. Ноздрюхин // Информация и безопасность. 2024. Т. 27. Вып. 2. С. 231-238. – Текст: непосредственный.

87 ISO/IEC 27001:2013 Информационные технологии. Методы обеспечения защиты. Системы менеджмента информационной безопасности. Требования. – Электрон. дан. – Режим доступа https://certgroup.org/wp-content/uploads/2023/06/iso-mek-27001-2013rus.pdf. – Текст: электронный.

88 Федеральный закон от 27 июля 2006 г. N 149-ФЗ «Об информации, информационных технологиях и о защите информации» (с изменениями и дополнениями). – Электрон. дан. – Режим доступа: https://base.garant.ru/12148555/. – Текст: электронный.

89 Федеральный закон от 27 июля 2006 г. N 152-ФЗ «О персональных данных». – Электрон. дан. – Режим доступа: https://base.garant.ru/12148567/. – Текст: электронный.

ПРИЛОЖЕНИЕ А

Таблица А1 – Паспорт уязвимости CVE-2019-1841

Идентификатор уязвимости	CVE-2019-1841 Уязвимость компонента Software Image Management службы управления идентификацией системы управления сетью Cisco Digital Network Architecture Center (DNA) Center связана с недостаточной проверкой введенных пользователем данных. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, получить доступ к внутренним службам путем отправки произвольных HTTP-запросов
Идентификатор типа ошибки	CWE-441
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:S/C:C/I:C/A:N
	CVSS 3.0: AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 8,5)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А2 – Паспорт уязвимости CVE-2025-25061

Идентификатор уязвимости	CVE-2025-25061 Уязвимость микропрограммного обеспечения сенсорных панелей ViewJet C-more Series и GC-A2 Series связана с возможностью обхода механизмов контроля доступа. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, оказать воздействие на целостность защищаемой информации
Идентификатор типа ошибки	CWE-441
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:N/C:N/I:P/A:N
	CVSS 3.0: AV:N/AC:L/PR:N/UI:N/S:C/C:N/I:L/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Данные уточняются
Участие в инцидентах	Нет

Таблица А3 – Паспорт уязвимости CVE-2024-0387

Идентификатор уязвимости	CVE-2024-0387 Уязвимость веб-службы микропрограммного обеспечения управляемых коммутаторов серий EDS-4000/G4000 связана с возможностью обхода механизмов контроля доступа. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, отправлять запросы к уязвимому устройству и от его имени другим устройствам сети
Идентификатор типа ошибки	CWE-441
Базовый вектор	CVSS 2.0: AV:A/AC:L/Au:S/C:C/I:C/A:C
	CVSS 3.0: AV:A/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,7)
	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А4 – Паспорт уязвимости CVE-2025-0237

Идентификатор уязвимости	CVE-2025-0237 Уязвимость интерфейса WebChannel API браузеров Mozilla Firefox, Firefox ESR и почтовых клиентов Thunderbird, Thunderbird ESR связана с недостатками процедуры авторизации. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, повысить свои привилегии
Идентификатор типа ошибки	CWE-441
Базовый вектор	CVSS 2.0: AV:N/AC:H/Au:N/C:C/I:C/A:N
	CVSS 3.0: AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:H/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,1)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А5 – Паспорт уязвимости CVE-2025-24153

Идентификатор уязвимости	CVE-2025-24153 Уязвимость реализации протокола SMB операционной системы Mac OS связана с копированием буфера без проверки размера входных данных. Эксплуатация уязвимости может позволить нарушителю повысить свои привилегии и выполнить произвольный код
Идентификатор типа ошибки	CWE-120
Базовый вектор	CVSS 2.0: AV:L/AC:L/Au:S/C:C/I:C/A:C
	CVSS 3.0: AV:L/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,8)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6,7)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А6 – Паспорт уязвимости CVE-2025-25510

Идентификатор уязвимости	CVE-2025-25510 Уязвимость функции get_parentControl_list_Info() микропрограммного обеспечения маршрутизаторов Tenda AC8 связана с выходом операции за границы буфера в памяти при обработке параметра urls. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-120
Базовый вектор	CVSS 2.0: AV:L/AC:L/Au:S/C:N/I:N/A:C
	CVSS 3.0: AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,6)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А7 – Паспорт уязвимости CVE-2025-25505

Идентификатор уязвимости	CVE-2025-25505 Уязвимость функции sub_452A4() микропрограммного обеспечения маршрутизаторов Tenda AC6 связана с выходом операции за границы буфера в памяти при обработке параметра callback. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-120
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:N/C:P/I:P/A:N
	CVSS 3.0: AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,4)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Данные уточняются
Участие в инцидентах	Нет

Таблица А8 – Паспорт уязвимости CVE-2025-25472

Идентификатор уязвимости	CVE-2025-25472 Уязвимость библиотеки для работы с форматом DICOM DCMTK связана с выходом операции за границы буфера в памяти. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-120
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:N/C:N/I:P/A:N
	CVSS 3.0: AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А9 – Паспорт уязвимости CVE-2025-25662

Идентификатор уязвимости	CVE-2025-25662 Уязвимость функции SafeSetMacFilter микропрограммного обеспечения беспроводной Wi-Fi точки доступа Tenda O4 V3.0, позволяющая нарушителю оказать влияние на конфиденциальность, целостность и доступность защищаемой информации
Идентификатор типа ошибки	CWE-120
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:N/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 2.0 составляет 10)
	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8)
Статус уязвимости	Потенциальная уязвимость
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А10 – Паспорт уязвимости CVE-2025-22907

Идентификатор уязвимости	CVE-2025-22907 Уязвимость функции formWlSiteSurvey микропрограммного обеспечения маршрутизаторов EDIMAX RE11S связана с копированием буфера без проверки размера входных данных при обработке параметра selSSID. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, выполнить произвольный код или вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-120
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:N/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 2.0 составляет 10)
	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А11 – Паспорт уязвимости CVE-2025-22916

Идентификатор уязвимости	CVE-2025-22916 Уязвимость функции formPPPoESetup микропрограммного обеспечения маршрутизаторов EDIMAX RE11S, позволяющая нарушителю выполнить произвольный код или вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-120
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:N/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 2.0 составляет 10)
	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А12 – Паспорт уязвимости CVE-2025-22904

Идентификатор уязвимости	CVE-2025-22904 Уязвимость функции setWAN микропрограммного обеспечения маршрутизаторов EDIMAX RE11S связана с копированием буфера без проверки размера входных данных при обработке параметра pppUserName. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, выполнить произвольный код или вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-120
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:N/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 2.0 составляет 10)
	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А13 – Паспорт уязвимости CVE-2025-25900

Идентификатор уязвимости	CVE-2025-25900 Уязвимость функции netfs_pgpriv2_write_to_the_cache ядра операционной системы Linux связана с неправильной проверкой вводимых данных. Эксплуатация уязвимости может позволить нарушителю вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-120
Базовый вектор	CVSS 2.0: AV:L/AC:L/Au:S/C:N/I:N/A:C
	CVSS 3.0: AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,6)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А14 – Паспорт уязвимости CVE-2025-0566

Идентификатор уязвимости	CVE-2025-0566 Уязвимость функции formSetDevNetName() (goform/SetDevNetNam) микропрограммного обеспечения маршрутизаторов Tenda A15 связана с выходом операции за границы буфера в памяти при обработке параметра mac. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, выполнить произвольный код или вызвать отказ в обслуживании путем отправки специально сформированного HTTP-запроса
Идентификатор типа ошибки	CWE-119
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:S/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 9)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 8,8)
Статус уязвимости	Потенциальная уязвимость
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Данные уточняются
Участие в инцидентах	Нет

Таблица А15 – Паспорт уязвимости CVE-2025-0848

Идентификатор уязвимости	CVE-2025-0848 Уязвимость функции SetCmdlineRun (/goform/SetCmdlineRun) микропрограммного обеспечения маршрутизаторов Tenda A18 связана с переполнением буфера в стеке. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, вызвать отказ в обслуживании путем отправки специально созданного POST-запроса с параметром wpapsk_crypto5g
Идентификатор типа ошибки	CWE-119
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:S/C:N/I:N/A:C
	CVSS 3.0: AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,8)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6,5)
Статус уязвимости	Потенциальная уязвимость
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Данные уточняются
Участие в инцидентах	Нет

Таблица А16 – Паспорт уязвимости CVE-2025-24151

Идентификатор уязвимости	CVE-2025-24151 Уязвимость реализации протокола SMB операционных систем macOS связана с выходом операции за границы буфера в памяти. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-119
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:N/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 2.0 составляет 10)
	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А17 – Паспорт уязвимости CVE-2025-24126

Идентификатор уязвимости	CVE-2025-24126 Уязвимость реализации технологии AirPlay операционных систем macOS, iOS, iPadOS, watchOS, tvOS, visionOS связана с выходом операции за границы буфера в памяти. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, вызвать отказ в обслуживании или выполнить произвольный код
Идентификатор типа ошибки	CWE-119
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:N/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 2.0 составляет 10)
	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А18 – Паспорт уязвимости CVE-2025-0753

Идентификатор уязвимости	CVE-2025-0753 Уязвимость функции AP4_StdcFileByteStream::ReadPartial() библиотеки чтения и записи файлов ISO-MP4 Bento4 связана с выходом операции за границы буфера в памяти. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, оказать воздействие на конфиденциальность, целостность и доступность защищаемой информации
Идентификатор типа ошибки	CWE-119
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:N/C:P/I:P/A:P
	CVSS 3.0: AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:L
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,5)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6,3)
Статус уязвимости	Потенциальная уязвимость
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Данные уточняются
Участие в инцидентах	Нет

Таблица А19 – Паспорт уязвимости CVE-2025-1539

Идентификатор уязвимости	CVE-2025-1539 Уязвимость функции replace_special_char() микропрограммного обеспечения усилителя беспроводного сигнала D-Link DAP-1320 связана с выходом операции за границы буфера в памяти. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-119
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:S/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 9)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 8,8)
Статус уязвимости	Потенциальная уязвимость
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Данные уточняются
Участие в инцидентах	Нет

Таблица А20 – Паспорт уязвимости CVE-2025-1538

Идентификатор уязвимости	CVE-2025-1538 Уязвимость функции set_ws_action() микропрограммного обеспечения усилителя беспроводного сигнала D-Link DAP-1320 связана с выходом операции за границы буфера в памяти. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-119
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:S/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 9)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 8,8)
Статус уязвимости	Потенциальная уязвимость
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Данные уточняются
Участие в инцидентах	Нет

Таблица А21 – Паспорт уязвимости CVE-2025-0285

Идентификатор уязвимости	CVE-2025-0285 Уязвимость драйвера BioNTdrv.sys программного обеспечения для работы с разделами жестких дисков Paragon Partition Manager связана с выходом операции за границы буфера в памяти. Эксплуатация уязвимости может позволить нарушителю повысить свои привилегии
Идентификатор типа ошибки	CWE-119
Базовый вектор	CVSS 2.0: AV:L/AC:L/Au:S/C:C/I:C/A:C
	CVSS 3.0: AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,8)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А22– Паспорт уязвимости CVE-2025-0927

Идентификатор уязвимости	CVE-2025-0927 Уязвимость драйвера файловой системы HFS ядра операционной системы Linux связана с выходом операции за границы буфера в памяти. Эксплуатация уязвимости может позволить нарушителю выполнить произвольный код путем монтирования специально сформированного образа файловой системы
Идентификатор типа ошибки	CWE-119
Базовый вектор	CVSS 2.0: AV:L/AC:L/Au:S/C:C/I:C/A:C
	CVSS 3.0: AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,8)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А23 – Паспорт уязвимости CVE-2025-1215

Идентификатор уязвимости	CVE-2025-1215 Уязвимость текстового редактора vim связана с манипулированием аргументом —log, приводящее к повреждению памяти. Эксплуатация уязвимости может позволить нарушителю вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-119
Базовый вектор	CVSS 2.0: AV:L/AC:L/Au:S/C:N/I:N/A:P
	CVSS 3.0: AV:L/AC:L/PR:L/UI:R/S:U/C:N/I:N/A:L
Уровень опасности уязвимости	Низкий уровень опасности (базовая оценка CVSS 2.0 составляет 1,7)
	Низкий уровень опасности (базовая оценка CVSS 3.0 составляет 2,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А24 – Паспорт уязвимости CVE-2025-1814

Идентификатор уязвимости	CVE-2025-1814 Уязвимость микропрограммного обеспечения маршрутизаторов Tenda AC6 связана с выходом операции за границы буфера в памяти при обработке параметра wpapsk_crypto. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, выполнить произвольный код или вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-119
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:S/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 9)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 8,8)
Статус уязвимости	Потенциальная уязвимость
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Данные уточняются
Участие в инцидентах	Нет

Таблица А25 – Паспорт уязвимости CVE-2023-28936

Идентификатор уязвимости	CVE-2023-28936 Уязвимость программного обеспечения видеоконференцсвязи Apache OpenMeetings связана с недостаточным сравнением. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибки	CWE-697
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:N/C:P/I:N/A:N
	CVSS 3.0: AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А26 – Паспорт уязвимости CVE-2023-49994

Идентификатор уязвимости	CVE-2023-49994 Уязвимость функции PeaksToHarmspect() программного синтезатора речи Espeak связана с ошибками в сравнении. Эксплуатация уязвимости может позволить нарушителю вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-697
Базовый вектор	CVSS 2.0: AV:L/AC:L/Au:N/C:N/I:N/A:C
	CVSS 3.0: AV:L/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,9)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А27 – Паспорт уязвимости CVE-2023-45133

Идентификатор уязвимости	CVE-2023-45133 Уязвимость функциии path.evaluate() или path.evaluateTruthy() компилятора для написания JavaScript кода Babel связана с неправильным сравнением. Эксплуатация уязвимости может позволить нарушителю выполнить произвольный код
Идентификатор типа ошибки	CWE-697
Базовый вектор	CVSS 2.0: AV:L/AC:L/Au:N/C:C/I:C/A:C
	CVSS 3.0: AV:L/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,8)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 8,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А28 – Паспорт уязвимости CVE-2024-23903

Идентификатор уязвимости	CVE-2024-23903 Уязвимость плагина Jenkins GitLab Branch Source Plugin связана с недостатками процедуры авторизации. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить несанкционированный доступ к конфиденциальной информации
Идентификатор типа ошибки	CWE-697
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:N/C:P/I:N/A:N
	CVSS 3.0: AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А29 – Паспорт уязвимости CVE-2024-41958

Идентификатор уязвимости	CVE-2024-41958 Уязвимость функции механизма двухфакторной аутентификации (2FA) средства развертывания и управления почтовым сервером, основанного на контейнерной технологии Docker, mailcow:dockerized связана с непринятием мер по защите структуры веб-страницы. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, обойти защиту 2FA и получить несанкционированный доступ
Идентификатор типа ошибки	CWE-697
Базовый вектор	CVSS 2.0: AV:N/AC:H/Au:S/C:C/I:P/A:N
	CVSS 3.0: AV:N/AC:H/PR:H/UI:N/S:C/C:H/I:L/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5,6)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6,6)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А30 – Паспорт уязвимости CVE-2025-3346

Идентификатор уязвимости	CVE-2025-3346 Уязвимость функции formSetPPTPServer() микропрограммного обеспечения маршрутизаторов Tenda AC7 связана с выходом операции за границы буфера в памяти при обработке параметров pptp_server_start_ip и pptp_server_end_ip. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, выполнить произвольный код или вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-120
	CWE-119
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:S/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 9)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 8,8)
Статус уязвимости	Потенциальная уязвимость
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Данные уточняются
Участие в инцидентах	Нет

Таблица А31 – Паспорт уязвимости CVE-2025-25456

Идентификатор уязвимости	CVE-2025-25456 Уязвимость функции AdvSetMacMtuWan микропрограммного обеспечения маршрутизаторов Tenda AC10 связана с копированием буфера без проверки размера входных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, выполнить произвольный код путем отправки специально сформированного GET-запроса
Идентификатор типа ошибки	CWE-120
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:N/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 2.0 составляет 10)
	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8)
Статус уязвимости	Потенциальная уязвимость
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Данные уточняются
Участие в инцидентах	Нет

Таблица А32– Паспорт уязвимости CVE-CVE-2025-20115

Идентификатор уязвимости	CVE-2025-20115 Уязвимость реализации протокола маршрутизации BGP операционных систем Cisco IOS XR связана с выходом операции за границы буфера в памяти. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, вызвать отказ в обслуживании путем отправки специально сформированного BGP-запроса
Идентификатор типа ошибки	CWE-120
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:N/C:N/I:N/A:C
	CVSS 3.0: AV:N/AC:L/PR:N/UI:N/S:C/C:N/I:N/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,8)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 8,6)
Статус уязвимости	Потенциальная уязвимость
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А33 – Паспорт уязвимости CVE-2025-27834

Идентификатор уязвимости	CVE-2025-27834 Уязвимость функции Type 4 файла pdf/pdf_func.c набора программного обеспечения для обработки, преобразования и генерации документов Ghostscript связана с копированием буфера без проверки размера входных данных. Эксплуатация уязвимости может позволить нарушителю выполнить произвольный код с помощью специально созданного PDF-файла
Идентификатор типа ошибки	CWE-120
Базовый вектор	CVSS 2.0: AV:L/AC:L/Au:N/C:C/I:C/A:C
	CVSS 3.0: AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,2)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А34 – Паспорт уязвимости CVE-2025-27830

Идентификатор уязвимости	CVE-2025-27830 Уязвимость файлов base/write_t1.c и psi/zfapi.c компонента DollarBlend набора программного обеспечения для обработки, преобразования и генерации документов Ghostscript связана с копированием буфера без проверки размера входных данных. Эксплуатация уязвимости может позволить нарушителю выполнить произвольный код
Идентификатор типа ошибки	CWE-120
Базовый вектор	CVSS 2.0: AV:L/AC:L/Au:N/C:C/I:C/A:C
	CVSS 3.0: AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,2)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А35 – Паспорт уязвимости CVE-2025-25898

Идентификатор уязвимости	CVE-2025-25898 Уязвимость микропрограммного обеспечения маршрутизаторов TP-Link TL-WR841ND связана с выходом операции за границы буфера в памяти при обработке параметра pskSecret на странице userRpm/WlanSecurityRpm.htm. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, вызвать отказ в обслуживании путем отправки специально созданных пакетов
Идентификатор типа ошибки	CWE-120
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:N/C:N/I:N/A:C
	CVSS 3.0: AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,8)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,5)
Статус уязвимости	Потенциальная уязвимость
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Данные уточняются
Участие в инцидентах	Нет

Таблица А36 – Паспорт уязвимости CVE-2025-1365

Идентификатор уязвимости	CVE-2025-1365 Уязвимость функции process_symtab() компонента eu-readelf утилиты для модификации и анализа бинарных файлов ELF Elfutils связана с копированием буфера без проверки размера входных данных. Эксплуатация уязвимости может позволить нарушителю вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-120
	CWE-119
Базовый вектор	CVSS 2.0: AV:L/AC:L/Au:S/C:P/I:P/A:P
	CVSS 3.0: AV:L/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:L
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,3)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А37 – Паспорт уязвимости CVE-2025-28398

Идентификатор уязвимости	CVE-2025-28398 Уязвимость функции ipsec_net_asp микропрограммного обеспечения сетевого устройства D-Link DI-8100 связана с копированием буфера без проверки размера входных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, выполнить произвольный код путем отправки специально сформированного запроса
Идентификатор типа ошибки	CWE-120
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:N/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 2.0 составляет 10)
	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8)
Статус уязвимости	Потенциальная уязвимость
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Данные уточняются
Участие в инцидентах	Нет

Таблица А38 – Паспорт уязвимости CVE-2025-25663

Идентификатор уязвимости	CVE-2025-25663 Уязвимость функции SUB_0046AC38 микропрограммного обеспечения маршрутизаторов Tenda AC8V4 связана с копированием буфера без проверки размера входных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, оказать влияние на конфиденциальность, целостность и доступность защищаемой информации
Идентификатор типа ошибки	CWE-120
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:N/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 2.0 составляет 10)
	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8)
Статус уязвимости	Потенциальная уязвимость
Наличие эксплойта	Данные уточняются
Способ устранения	Данные уточняются
Участие в инцидентах	Нет

Таблица А39 – Паспорт уязвимости CVE-2025-23397

Идентификатор уязвимости	CVE-2025-23397 Уязвимость системы управления жизненным циклом продукции Teamcenter Visualization и программной среды имитационного моделирования систем и процессов Siemens Tecnomatix Plant Simulation связана с выходом операции за границы буфера в памяти. Эксплуатация уязвимости может позволить нарушителю выполнить произвольный код
Идентификатор типа ошибки	CWE-119
Базовый вектор	CVSS 2.0: AV:L/AC:L/Au:N/C:C/I:C/A:C
	CVSS 3.0: AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,2)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А40 – Паспорт уязвимости CVE-2025-23398

Идентификатор уязвимости	CVE-2025-23398 Уязвимость системы управления жизненным циклом продукции Teamcenter Visualization и программной среды имитационного моделирования систем и процессов Siemens Tecnomatix Plant Simulation связана с выходом операции за границы буфера в памяти. Эксплуатация уязвимости может позволить нарушителю выполнить произвольный код
Идентификатор типа ошибки	CWE-119
Базовый вектор	CVSS 2.0: AV:L/AC:L/Au:N/C:C/I:C/A:C
	CVSS 3.0: AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,2)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А41 – Паспорт уязвимости CVE-2025-23400

Идентификатор уязвимости	CVE-2025-23400 Уязвимость системы управления жизненным циклом продукции Teamcenter Visualization и программной среды имитационного моделирования систем и процессов Siemens Tecnomatix Plant Simulation связана с выходом операции за границы буфера в памяти. Эксплуатация уязвимости может позволить нарушителю выполнить произвольный код
Идентификатор типа ошибки	CWE-119
Базовый вектор	CVSS 2.0: AV:L/AC:L/Au:N/C:C/I:C/A:C
	CVSS 3.0: AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,2)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А42 – Паспорт уязвимости CVE-2025-2619

Идентификатор уязвимости	CVE-2025-2619 Уязвимость функции check_dws_cookie() микропрограммного обеспечения беспроводных повторителей D-Link DAP-1620 связана с выходом операции за границы буфера в памяти. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, выполнить произвольный код или вызвать отказ в обслуживании путем отправки специально сформированных HTTP-запросов
Идентификатор типа ошибки	CWE-119
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:N/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 2.0 составляет 10)
	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8)
Статус уязвимости	Потенциальная уязвимость
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Данные уточняются
Участие в инцидентах	Нет

Таблица А43 – Паспорт уязвимости CVE-2025-2620

Идентификатор уязвимости	CVE-2025-2620 Уязвимость функции mod_graph_auth_uri_handler() микропрограммного обеспечения беспроводных повторителей D-Link DAP-1620 связана с выходом операции за границы буфера в памяти. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, выполнить произвольный код или вызвать отказ в обслуживании путем отправки специально сформированных HTTP-запросов
Идентификатор типа ошибки	CWE-119
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:N/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 2.0 составляет 10)
	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8)
Статус уязвимости	Потенциальная уязвимость
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Данные уточняются
Участие в инцидентах	Нет

Таблица А44 – Паспорт уязвимости CVE-2025-2618

Идентификатор уязвимости	CVE-2025-2618 Уязвимость функции set_ws_action() микропрограммного обеспечения беспроводных повторителей D-Link DAP-1620 связана с выходом операции за границы буфера в памяти. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, оказать воздействие на конфиденциальность, целостность и доступность защищаемой информации путем отправки специально сформированных HTTP-запросов
Идентификатор типа ошибки	CWE-119
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:N/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 2.0 составляет 10)
	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8)
Статус уязвимости	Потенциальная уязвимость
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Данные уточняются
Участие в инцидентах	Нет

Таблица А45 – Паспорт уязвимости CVE-2025-2621

Идентификатор уязвимости	CVE-2025-2621 Уязвимость функции check_dws_cooki() микропрограммного обеспечения беспроводных повторителей D-Link DAP-1620 связана с выходом операции за границы буфера в памяти при обработке параметра uid. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, оказать воздействие на конфиденциальность, целостность и доступность защищаемой информации путем отправки специально сформированных HTTP-запросов
Идентификатор типа ошибки	CWE-119
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:N/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 2.0 составляет 10)
	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8)
Статус уязвимости	Потенциальная уязвимость
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Данные уточняются
Участие в инцидентах	Нет

Таблица А46 – Паспорт уязвимости CVE-2025-3538

Идентификатор уязвимости	CVE-2025-3538 Уязвимость функции auth_asp микропрограммного обеспечения маршрутизаторов D-link DI-8100 связана с переполнением буфера в стеке. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, выполнить произвольный код путем отправки специально сформированного GET-запроса
Идентификатор типа ошибки	CWE-119
Базовый вектор	CVSS 2.0: AV:A/AC:L/Au:N/C:C/I:C/A:C
	CVSS 3.0: AV:A/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 8,3)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 8,8)
Статус уязвимости	Потенциальная уязвимость
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Данные уточняются
Участие в инцидентах	Нет

Таблица А47 – Паспорт уязвимости CVE-2025-3161

Идентификатор уязвимости	CVE-2025-3161 Уязвимость функции ShutdownSetAdd() микропрограммного обеспечения маршрутизаторов Tenda AC10 связана с выходом операции за границы буфера в памяти при обработке длины параметра time. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, выполнить произвольный код или вызвать отказ в обслуживании путем отправки специально созданных запросов
Идентификатор типа ошибки	CWE-119
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:S/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 9)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 8,8)
Статус уязвимости	Потенциальная уязвимость
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Данные уточняются
Участие в инцидентах	Нет

Таблица А48 – Паспорт уязвимости CVE-2024-23828

Идентификатор уязвимости	CVE-2024-23828 Уязвимость конфигурационного файла app.ini пользовательского интерфейса Nginx UI сервера nginx связана с непринятием мер по нейтрализации специальных элементов при обработке параметров test_config_cmd и start_cmd. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, выполнить произвольный код
Идентификатор типа ошибки	CWE-74
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:S/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 9)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 8,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А49 – Паспорт уязвимости CVE-2024-22319

Идентификатор уязвимости	CVE-2024-22319 Уязвимость системы управления бизнес-правилами в корпоративной среде IBM Operational Decision Manager существует из-за непринятия мер по нейтрализации специальных элементов, используемых в команде операционной системы. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, выполнить произвольный код путем внедрения JNDI при передаче непроверенного аргумента определенному API
Идентификатор типа ошибки	CWE-74
Базовый вектор	CVSS 2.0: AV:N/AC:H/Au:N/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,6)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 8,1)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А50 – Паспорт уязвимости CVE-2024-1619

Идентификатор уязвимости	CVE-2024-1619 Уязвимость антивирусного программного обеспечения Kaspersky Security для Linux Mail Server 8 существует из-за непринятия мер по нейтрализации специальных элементов. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, выполнить несанкционированные действия при переходе администратором по вредоносной ссылке
Идентификатор типа ошибки	CWE-74
Базовый вектор	CVSS 2.0: AV:N/AC:H/Au:S/C:C/I:N/A:N
	CVSS 3.0: AV:N/AC:H/PR:L/UI:R/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,9)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 4,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А51 – Паспорт уязвимости CVE-2024-21900

Идентификатор уязвимости	CVE-2024-21900 Уязвимость операционных систем QTS, QuTS Hero, QuTScloud и myQNAPcloud, существующая из-за непринятия мер по нейтрализации специальных элементов, позволяющая нарушителю выполнить произвольные команды
Идентификатор типа ошибки	CWE-74
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:S/C:N/I:P/A:N
	CVSS 3.0: AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 4,3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А52 – Паспорт уязвимости CVE-2024-39483

Идентификатор уязвимости	CVE-2024-39483 Уязвимость ядра операционной системы Linux связана с недостаточной нейтрализацией специальных элементов в запросе. Эксплуатация уязвимости может позволить нарушителю вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-74
Базовый вектор	CVSS 2.0: AV:L/AC:L/Au:S/C:N/I:N/A:C
	CVSS 3.0: AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,6)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А53 – Паспорт уязвимости CVE-2024-21687

Идентификатор уязвимости	CVE-2024-21687 Уязвимость системы непрерывной интеграции Atlassian Bamboo связана с неверной нейтрализация особых элементов в выходных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить доступ к локальным файлам сервера с возможностью их выполнения
Идентификатор типа ошибки	CWE-74
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:S/C:C/I:C/A:N
	CVSS 3.0: AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 8,1)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 8,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А54 – Паспорт уязвимости CVE-2024-38366

Идентификатор уязвимости	CVE-2024-38366 Уязвимость менеджера зависимостей для проектов Swift и Objective-C CocoaPods существует из-за непринятия мер по нейтрализации специальных элементов. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, выполнить произвольный код
Идентификатор типа ошибки	CWE-74
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:N/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 2.0 составляет 10)
	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 10)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А55 – Паспорт уязвимости CVE-2024-20429

Идентификатор уязвимости	CVE-2024-20429 Уязвимость веб-интерфейса управления операционной системы Cisco AsyncOS системы обеспечения безопасности электронной почты Cisco Secure Email Gateway, связанная с неверной нейтрализацией особых элементов в выходных данных, используемых входящим компонентом. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, выполнить произвольные системные команды путём отправки специально сформированных HTTP-запросов
Идентификатор типа ошибки	CWE-74
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:M/C:C/I:C/A:N
	CVSS 3.0: AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,7)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 6,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А56 – Паспорт уязвимости CVE-2025-0528

Идентификатор уязвимости	CVE-2025-0528 Уязвимость демона telnetd микропрограммного обеспечения маршрутизаторов Tenda AC8, AC10 и AC18 связана с непринятием мер по очистке данных на управляющем уровне. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, выполнить произвольные команды
Идентификатор типа ошибки	CWE-74
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:S/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 9)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,2)
Статус уязвимости	Потенциальная уязвимость
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Данные уточняются
Участие в инцидентах	Нет

Таблица А57 – Паспорт уязвимости CVE-2024-53263

Идентификатор уязвимости	CVE-2024-53263 Уязвимость расширение Git для управления версиями больших файлов Git LFS связана с неверной нейтрализацией особых элементов в выходных данных, используемых входящим компонентом. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, получить несанкционированный доступ к учетным данным пользователя
Идентификатор типа ошибки	CWE-74
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:N/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 2.0 составляет 10)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 8,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А58 – Паспорт уязвимости CVE-2024-39784

Идентификатор уязвимости	CVE-2024-39784 Уязвимость функции add_dir() сценария nas.cgi микропрограммного обеспечения маршрутизаторов Wavlink AC3000 (WL-WN533A8) связана с непринятия мер по нейтрализации специальных элементов. Эксплуатация уязвимости позволяет нарушителю, действующему удаленно, выполнить произвольные команды путем отправки специально сформированных HTTP-запросов
Идентификатор типа ошибки	CWE-74
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:S/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 9)
	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,1)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Данные уточняются
Участие в инцидентах	Нет

Таблица А59– Паспорт уязвимости CVE-2024-39785

Идентификатор уязвимости	CVE-2024-39785 Уязвимость функции add_dir() сценария nas.cgi микропрограммного обеспечения маршрутизаторов Wavlink AC3000 (WL-WN533A8) связана с непринятия мер по нейтрализации специальных элементов. Эксплуатация уязвимости позволяет нарушителю, действующему удаленно, выполнить произвольные команды путем отправки специально сформированных HTTP-запросов
Идентификатор типа ошибки	CWE-74
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:S/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 9)
	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,1)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Данные уточняются
Участие в инцидентах	Нет

Таблица А60 – Паспорт уязвимости CVE-2025-1192

Идентификатор уязвимости	CVE-2025-1192 Уязвимость сценария select-menu.php веб-системы для онлайн-бронирования Multi Restaurant Table Reservation System связана с непринятием мер по защите структуры запроса SQL при обработке параметра table. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, выполнить произвольный код
Идентификатор типа ошибки	CWE-74
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:S/C:P/I:P/A:P
	CVSS 3.0: AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:L
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,5)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6,3)
Статус уязвимости	Потенциальная уязвимость
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Данные уточняются
Участие в инцидентах	Нет

Таблица А61 – Паспорт уязвимости CVE-2025-3249

Идентификатор уязвимости	CVE-2025-3249 Уязвимость функции apcli_cancel_wps() (/usr/lib/lua/luci/controller/mtkwifi.lua) микропрограммного обеспечения маршрутизаторов TOTOLINK A6000R связана с непринятием мер по нейтрализации специальных элементов, используемых в команде операционной системы. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, выполнить произвольные команды или вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-74
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:S/C:P/I:P/A:P
	CVSS 3.0: AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:L
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,5)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6,3)
Статус уязвимости	Потенциальная уязвимость
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Данные уточняются
Участие в инцидентах	Нет

Таблица А62 – Паспорт уязвимости CVE-2025-21350

Идентификатор уязвимости	CVE-2025-21350 Уязвимость реализации протокола Kerberos операционных систем Windows связана с недостаточной проверкой входных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-20
Базовый вектор	CVSS 2.0: AV:N/AC:H/Au:N/C:N/I:N/A:C
	CVSS 3.0: AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5,4)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,9)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А63 – Паспорт уязвимости CVE-2025-24319

Идентификатор уязвимости	CVE-2025-24319 Уязвимость прикладного программного интерфейса инструмента управления BIG-IP Next Central Manager связана с недостаточной проверкой входных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-20
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:S/C:N/I:N/A:C
	CVSS 3.0: AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,8)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А64 – Паспорт уязвимости CVE-2025-20183

Идентификатор уязвимости	CVE-2025-20183 Уязвимость функции Range Request Forward операционной системы Cisco AsyncOS интернет-шлюзов Cisco Secure Web Appliance связана с недостаточной проверкой входных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, обойти ограничения безопасности и записывать произвольные файлы
Идентификатор типа ошибки	CWE-20
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:N/C:N/I:P/A:N
	CVSS 3.0: AV:N/AC:L/PR:N/UI:N/S:C/C:N/I:L/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А65 – Паспорт уязвимости CVE-2025-23380

Идентификатор уязвимости	CVE-2025-23380 Уязвимость функции apcli_cancel_wps() (/usr/lib/lua/luci/controller/mtkwifi.lua) микропрограммного обеспечения маршрутизаторов TOTOLINK A6000R связана с непринятием мер по нейтрализации специальных элементов, используемых в команде операционной системы. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, выполнить произвольные команды или вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-20
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:S/C:P/I:P/A:P
	CVSS 3.0: AV:L/AC:H/PR:H/UI:R/S:U/C:H/I:L/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,5)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 4,6)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А66 – Паспорт уязвимости CVE-2025-20184

Идентификатор уязвимости	CVE-2025-20184 Уязвимость веб-интерфейса управления операционной системы Cisco AsyncOS связана с недостаточной проверкой входных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, повысить свои привилегии и выполнить произвольные команды
Идентификатор типа ошибки	CWE-20
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:S/C:C/I:C/A:N
	CVSS 3.0: AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 8,5)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А67 – Паспорт уязвимости CVE-2025-0514

Идентификатор уязвимости	CVE-2025-0514 Уязвимость пакета офисных программ LibreOffice связана с ошибками при обработке гиперссылок в документе. Эксплуатация уязвимости может позволить нарушителю выполнить произвольный код при условии открытия пользователем специально сформированной гиперссылки
Идентификатор типа ошибки	CWE-20
Базовый вектор	CVSS 2.0: AV:L/AC:H/Au:N/C:C/I:P/A:C
	CVSS 3.0: AV:L/AC:H/PR:N/UI:R/S:C/C:H/I:L/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5,9)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,6)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А68 – Паспорт уязвимости CVE-2025-21194

Идентификатор уязвимости	CVE-2025-21194 Уязвимость микропрограммного обеспечения сенсорных дисплеев Microsoft Surface связана с недостаточной проверкой входных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, выполнить обход функций безопасности
Идентификатор типа ошибки	CWE-20
Базовый вектор	CVSS 2.0: AV:A/AC:H/Au:N/C:C/I:C/A:C
	CVSS 3.0: AV:A/AC:H/PR:N/UI:R/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,8)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,1)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А69 – Паспорт уязвимости CVE-2025-24970

Идентификатор уязвимости	CVE-2025-24970 Уязвимость сетевого программного средства Netty связана с недостаточной проверкой введенных пользователем данных в SslHandler при использовании собственного SSLEngine. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-20
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:N/C:N/I:N/A:C
	CVSS 3.0: AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,8)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А70 – Паспорт уязвимости CVE-2025-21873

Идентификатор уязвимости	CVE-2025-21873 Уязвимость функции ufshcd_rpm_put_sync() (drivers/ufs/core/ufs_bsg.c) ядра операционной системы Linux связана с недостаточной проверкой входных данных.. Эксплуатация уязвимости может позволить нарушителю вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-20
Базовый вектор	CVSS 2.0: AV:L/AC:L/Au:S/C:N/I:N/A:C
	CVSS 3.0: AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5,5)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 4,6)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А71 – Паспорт уязвимости CVE-2025-21916

Идентификатор уязвимости	CVE-2025-21916 Уязвимость функции usb_find_common_endpoints() драйвера USB (drivers/usb/atm/cxacru.c) ядра операционных систем Linux связана с недостаточной проверкой входных данных при обработке конечных точек. Эксплуатация уязвимости может позволить нарушителю вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-20
Базовый вектор	CVSS 2.0: AV:L/AC:L/Au:S/C:N/I:N/A:C
	CVSS 3.0: AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,6)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А72 – Паспорт уязвимости CVE-2025-21235

Идентификатор уязвимости	CVE-2025-21235 Уязвимость службы PrintWorkflowUserSvc операционных систем Windows связана с недостаточной проверкой входных данных. Эксплуатация уязвимости может позволить нарушителю повысить свои привилегии
Идентификатор типа ошибки	CWE-20
Базовый вектор	CVSS 2.0: AV:L/AC:L/Au:S/C:C/I:C/A:C
	CVSS 3.0: AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,8)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А73 – Паспорт уязвимости CVE-2025-21230

Идентификатор уязвимости	CVE-2025-21230 Уязвимость службы очереди сообщений Microsoft Message Queuing (MSMQ) операционных систем Windows связана с неконтролируемым потреблением ресурсов в результате некорректной проверки входных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-20
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:S/C:P/I:P/A:P
	CVSS 3.0: AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:L
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,8)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А74 – Паспорт уязвимости CVE-2025-21234

Идентификатор уязвимости	CVE-2025-21234 Уязвимость службы PrintWorkflowUserSvc операционных систем Windows связана с недостаточной проверкой входных данных. Эксплуатация уязвимости может позволить нарушителю повысить свои привилегии
Идентификатор типа ошибки	CWE-20
Базовый вектор	CVSS 2.0: AV:L/AC:L/Au:S/C:C/I:C/A:C
	CVSS 3.0: AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,8)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А75 – Паспорт уязвимости CVE-2025-21280

Идентификатор уязвимости	CVE-2025-21280 Уязвимость модуля Virtual Trusted Platform Module операционных систем Microsoft Windows связана с недостаточной проверкой входных данных. Эксплуатация уязвимости может позволить нарушителю вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-20
Базовый вектор	CVSS 2.0: AV:L/AC:L/Au:S/C:N/I:N/A:C
	CVSS 3.0: AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,6)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А76 – Паспорт уязвимости CVE-2025-21370

Идентификатор уязвимости	CVE-2025-21370 Уязвимость доверенной среды выполнения Virtualization-Based Security (VBS) Enclave операционных систем Microsoft Windows связана с недостаточной проверкой вводимых данных. Эксплуатация уязвимости может позволить нарушителю повысить свои привилегии
Идентификатор типа ошибки	CWE-20
Базовый вектор	CVSS 2.0: AV:L/AC:L/Au:S/C:C/I:C/A:C
	CVSS 3.0: AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,8)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А77 – Паспорт уязвимости CVE-2025-24124

Идентификатор уязвимости	CVE-2025-24124 Уязвимость компонента CoreMedia операционных систем macOS, iOS, iPadOS, watchOS, tvOS, visionOS связана с некорректной зачисткой или освобождением ресурсов. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-20
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:N/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 2.0 составляет 10)
	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А78 – Паспорт уязвимости CVE-2025-21677

Идентификатор уязвимости	CVE-2025-21677 Уязвимость функции pfcp_newlink() операционных систем Linux связана с некорректным отображением списка сетевых устройств в результате недостаточной проверки входных данных. Эксплуатация уязвимости может позволить нарушителю вызвать отказ в обслуживании.
Идентификатор типа ошибки	CWE-20
Базовый вектор	CVSS 2.0: AV:L/AC:L/Au:S/C:N/I:N/A:C
	CVSS 3.0: AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,6)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А79 – Паспорт уязвимости CVE-2025-21678

Идентификатор уязвимости	CVE-2025-21678 Уязвимость функции pfcp_newlink() операционных систем Linux связана с некорректным отображением списка сетевых устройств в результате недостаточной проверки входных данных. Эксплуатация уязвимости может позволить нарушителю вызвать отказ в обслуживании.
Идентификатор типа ошибки	CWE-20
Базовый вектор	CVSS 2.0: AV:L/AC:L/Au:S/C:N/I:N/A:C
	CVSS 3.0: AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,6)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А80 – Паспорт уязвимости CVE-2025-21284

Идентификатор уязвимости	CVE-2025-21284 Уязвимость модуля Windows Virtual Trusted Platform операционных систем Windows существует из-за недостаточной проверки входных данных. Эксплуатация уязвимости может позволить нарушителю вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-20
Базовый вектор	CVSS 2.0: AV:L/AC:L/Au:S/C:N/I:N/A:C
	CVSS 3.0: AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,6)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А81 – Паспорт уязвимости CVE-2025-21686

Идентификатор уязвимости	CVE-2025-21686 Уязвимость функции io_clone_buffers() модуля io_uring/rsrc.c интерфейса асинхронного ввода/вывода ядра операционной системы Linux связана с неправильной проверкой вводимых данных. Эксплуатация уязвимости может позволить нарушителю вызвать отказ в обслуживании.
Идентификатор типа ошибки	CWE-20
Базовый вектор	CVSS 2.0: AV:L/AC:L/Au:S/C:N/I:N/A:C
	CVSS 3.0: AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,6)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А82 – Паспорт уязвимости CVE-2025-0938

Идентификатор уязвимости	CVE-2025-0938 Уязвимость функций urllib.parse.urlsplit() и urlparse() интерпретатора языка программирования Python связана с неправильной проверкой входных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, повысить свои привилегии
Идентификатор типа ошибки	CWE-20
Базовый вектор	CVSS 2.0: AV:N/AC:H/Au:N/C:N/I:C/A:N
	CVSS 3.0: AV:N/AC:H/PR:N/UI:N/S:C/C:N/I:H/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5,4)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А83 – Паспорт уязвимости CVE-2024-10914

Идентификатор уязвимости	CVE-2024-10914 Уязвимость функции cgi_user_add CGI-скрипта /cgi-bin/account_mgr.cgi?cmd=cgi_user_add микропрограммного обеспечения устройств D-Link DNS-320, DNS-320LW, DNS-325 и DNS-340L связана с непринятием мер по нейтрализации специальных элементов, используемых в команде операционной системы. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, выполнять произвольные команды путём отправки специально сформированного HTTP GET-запроса
Идентификатор типа ошибки	CWE-74
Базовый вектор	CVSS 2.0: AV:N/AC:H/Au:N/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,6)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 8,1)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Да

Таблица А84 – Паспорт уязвимости CVE-2024-10915

Идентификатор уязвимости	CVE-2024-10915 Уязвимость функции cgi_user_add файла /cgi-bin/account_mgr.cgi?cmd=cgi_user_add микропрограммного обеспечения маршрутизаторов D-Link DNS-320, DNS-320LW, DNS-325 и DNS-340L связана с непринятием мер по нейтрализации специальных элементов. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, выполнить произвольный код
Идентификатор типа ошибки	CWE-74
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:N/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 2.0 составляет 10)
	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8)
Статус уязвимости	Потенциальная уязвимость
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Данные уточняются
Участие в инцидентах	Нет

Таблица А85– Паспорт уязвимости CVE-2024-33510

Идентификатор уязвимости	CVE-2024-33510 Уязвимость операционной системы FortiOS, прокси-сервера для защиты от интернет-атак FortiProxy и масштабируемой облачной системы безопасности FortiSASE связана с некорректно реализованной проверкой безопасности для стандартных элементов. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, проводить фишинговые атаки с помощью специально созданного запроса
Идентификатор типа ошибки	CWE-74
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:N/C:N/I:P/A:N
	CVSS 3.0: AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:L/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 4,3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А86 – Паспорт уязвимости CVE-2024-50572

Идентификатор уязвимости	CVE-2024-50572 Уязвимость микропрограммного обеспечения промышленных маршрутизаторов семейства SCALANCE M-800 (включая S615, MUM-800 и RM1224) связана с недостаточной проверкой входных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, внедрить код в корневую папку, повысив при этом свои привилегии
Идентификатор типа ошибки	CWE-74
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:S/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 9)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,2)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А87 – Паспорт уязвимости CVE-2024-11124

Идентификатор уязвимости	CVE-2024-11124 Уязвимость компонента /src/UIOMatic/wwwroot/backoffice/resources/uioMaticObject.r программного средства для автоматической генерации интегрированного пользовательского интерфейса в Umbraco UI-O-Matic связана с непринятием мер по защите структуры запроса SQL. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, выполнить произвольный SQL-код с помощью специально созданного GET-запроса с filepath '*/uiomatic/object/GetById?typeAlias=cities&id=10'
Идентификатор типа ошибки	CWE-74
Базовый вектор	CVSS 2.0: AV:L/AC:L/Au:S/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 9)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,2)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Данные уточняются
Участие в инцидентах	Нет

Таблица А88– Паспорт уязвимости CVE-2024-11234

Идентификатор уязвимости	CVE-2024-11234 Уязвимость конфигурации request_fulluri интерпретатора языка программирования PHP связана с непринятием мер по нейтрализации CRLF-последовательностей в результате использования значения true. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, отправить скрытый HTTP-запрос (атака типа HTTP Request Smuggling)
Идентификатор типа ошибки	CWE-74
Базовый вектор	CVSS 2.0: AV:N/AC:H/Au:N/C:P/I:P/A:N
	CVSS 3.0: AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 4,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А89– Паспорт уязвимости CVE-2024-12962

Идентификатор уязвимости	CVE-2024-12962 Уязвимость сценария _all_edits.php (/_parse/_all_edits.php) системы подбора персонала Job Recruitment связана с непринятием мер по нейтрализации специальных элементов при обработке параметра skillset. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить несанкционированный доступ к защищаемой информации и выполнить произвольный код путем отправки специально сформированного запроса
Идентификатор типа ошибки	CWE-74
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:N/C:P/I:P/A:P
	CVSS 3.0: AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,5)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,3)
Статус уязвимости	Потенциальная уязвимость
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Данные уточняются
Участие в инцидентах	Нет

Таблица А90– Паспорт уязвимости CVE-2024-12967

Идентификатор уязвимости	CVE-2024-12967 Уязвимость функции fln_update() сценария _all_edits.php (/_parse/_all_edits.php) системы подбора персонала Job Recruitment связана с непринятием мер по нейтрализации специальных элементов при обработке параметров fname и lname. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить несанкционированный доступ к защищаемой информации и выполнить произвольный код путем отправки специально сформированного запроса
Идентификатор типа ошибки	CWE-74
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:N/C:P/I:P/A:P
	CVSS 3.0: AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,5)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,3)
Статус уязвимости	Потенциальная уязвимость
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Данные уточняются
Участие в инцидентах	Нет

Таблица А91– Паспорт уязвимости CVE-2024-12968

Идентификатор уязвимости	CVE-2024-12968 Уязвимость функции edit_jobpost() сценария _all_edits.php (/_parse/_all_edits.php) системы подбора персонала Job Recruitment связана с непринятием мер по нейтрализации специальных элементов при обработке параметра jobtype. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить несанкционированный доступ к защищаемой информации и выполнить произвольный код путем отправки специально сформированного запроса
Идентификатор типа ошибки	CWE-74
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:N/C:P/I:P/A:P
	CVSS 3.0: AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,5)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,3)
Статус уязвимости	Потенциальная уязвимость
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Данные уточняются
Участие в инцидентах	Нет

Таблица А92– Паспорт уязвимости CVE-2024-12966

Идентификатор уязвимости	CVE-2024-12966 Уязвимость интерфейса командной строки (CLI) пакета Skupper программного средства управления и интеграции микросервисов в облачных и гибридных средах Red Hat Service Interconnect связана с обходом аутентификации в результате использования режима по умолчанию. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить несанкционированный доступ к защищаемой информации или вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-74
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:S/C:P/I:N/A:C
	CVSS 3.0: AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,5)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,1)
Статус уязвимости	Потенциальная уязвимость
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Данные уточняются
Участие в инцидентах	Нет

Таблица А93– Паспорт уязвимости CVE-2024-12965

Идентификатор уязвимости	CVE-2024-12965 Уязвимость сценария update_ex_detail.php системы управления портфелем Portfolio Management System связана с непринятием мер по нейтрализации специальных элементов при обработке параметра q. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить несанкционированный доступ на чтение, изменение и удаление данных и выполнить произвольный код путем отправки специально сформированного запроса
Идентификатор типа ошибки	CWE-74
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:N/C:P/I:P/A:P
	CVSS 3.0: AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,5)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,3)
Статус уязвимости	Потенциальная уязвимость
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Данные уточняются
Участие в инцидентах	Нет

Таблица А94– Паспорт уязвимости CVE-2024-12350

Идентификатор уязвимости	CVE-2024-12350 Уязвимость компонента Template Handler файла \src\main\java\com\cms\controller\admin\TemplateController.java системы управления контентом Jfinal CMS связана с неверным управлением генерацией кода. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, выполнить произвольный код
Идентификатор типа ошибки	CWE-74
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:S/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 9)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 8,8)
Статус уязвимости	Потенциальная уязвимость
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Данные уточняются
Участие в инцидентах	Нет

Таблица А95– Паспорт уязвимости CVE-2024-56717

Идентификатор уязвимости	CVE-2024-56717 Уязвимость функции ocelot_ifh_set_basic() компонента ocelot.c ядра операционной системы Linux связана с недостаточной нейтрализацией специальных элементов в запросе. Эксплуатация уязвимости может позволить нарушителю вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-74
Базовый вектор	CVSS 2.0: AV:L/AC:L/Au:S/C:N/I:N/A:C
	CVSS 3.0: AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,6)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А96– Паспорт уязвимости CVE-2025-31477

Идентификатор уязвимости	CVE-2025-31477 Уязвимость плагина shell фреймворка создания кроссплатформенных десктопных приложений Tauri связана с недостаточной проверкой входных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, обойти ограничения безопасности и выполнить произвольный код
Идентификатор типа ошибки	CWE-20
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:N/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 2.0 составляет 10)
	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А97– Паспорт уязвимости CVE-2025-24446

Идентификатор уязвимости	CVE-2025-24446 Уязвимость программной платформы ColdFusion связана с недостаточной проверкой входных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибки	CWE-20
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:S/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 9)
	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,1)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А98– Паспорт уязвимости CVE-2025-24073

Идентификатор уязвимости	CVE-2025-24073 Уязвимость библиотеки Microsoft DWM Core Library операционных систем Windows связана с недостаточной проверкой вводимых данных. Эксплуатация уязвимости может позволить нарушителю повысить свои привилегии
Идентификатор типа ошибки	CWE-20
Базовый вектор	CVSS 2.0: AV:L/AC:L/Au:S/C:C/I:C/A:C
	CVSS 3.0: AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,8)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А99– Паспорт уязвимости CVE-2025-29811

Идентификатор уязвимости	CVE-2025-29811 Уязвимость драйвера Windows Mobile Broadband Driver операционных систем Microsoft Windows связана с выходом операции за границы буфера в памяти в результате недостаточной проверки входных данных. Эксплуатация уязвимости может позволить нарушителю повысить свои привилегии
Идентификатор типа ошибки	CWE-20
Базовый вектор	CVSS 2.0: AV:L/AC:L/Au:S/C:C/I:C/A:C
	CVSS 3.0: AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,8)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А100– Паспорт уязвимости CVE-2025-26647

Идентификатор уязвимости	CVE-2025-26647 Уязвимость реализации сетевого протокола аутентификации Kerberos операционных систем Windows связана с недостаточной проверкой входных данных. Эксплуатация уязвимости позволяет нарушителю, действующему удаленно, повысить свои привилегии
Идентификатор типа ошибки	CWE-20
Базовый вектор	CVSS 2.0: AV:N/AC:H/Au:N/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,6)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 8,1)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А101– Паспорт уязвимости CVE-2025-27489

Идентификатор уязвимости	CVE-2025-27489 Уязвимость гиперконвергентной инфраструктуры Microsoft Azure Stack (HCI) связана с недостаточной проверкой входных данных. Эксплуатация уязвимости может позволить нарушителю повысить свои привилегии
Идентификатор типа ошибки	CWE-20
Базовый вектор	CVSS 2.0: AV:L/AC:L/Au:S/C:C/I:C/A:C
	CVSS 3.0: AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,8)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А102– Паспорт уязвимости CVE-2025-24058

Идентификатор уязвимости	CVE-2025-24058 Уязвимость библиотеки Microsoft DWM Core Library операционной системы Windows связана с недостаточной проверкой входных данных. Эксплуатация уязвимости может позволить нарушителю повысить свои привилегии
Идентификатор типа ошибки	CWE-20
Базовый вектор	CVSS 2.0: AV:L/AC:L/Au:S/C:C/I:C/A:C
	CVSS 3.0: AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,8)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А103– Паспорт уязвимости CVE-2025-24074

Идентификатор уязвимости	CVE-2025-24074 Уязвимость библиотеки Microsoft DWM Core Library операционной системы Windows связана с недостаточной проверкой входных данных. Эксплуатация уязвимости может позволить нарушителю повысить свои привилегии
Идентификатор типа ошибки	CWE-20
Базовый вектор	CVSS 2.0: AV:L/AC:L/Au:S/C:C/I:C/A:C
	CVSS 3.0: AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,8)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А104– Паспорт уязвимости CVE-2025-24060

Идентификатор уязвимости	CVE-2025-24060 Уязвимость библиотеки Microsoft DWM Core Library операционных систем Windows связана с недостаточной проверкой входных данных. Эксплуатация уязвимости может позволить нарушителю повысить свои привилегии
Идентификатор типа ошибки	CWE-20
Базовый вектор	CVSS 2.0: AV:L/AC:L/Au:S/C:C/I:C/A:C
	CVSS 3.0: AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,8)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А105– Паспорт уязвимости CVE-2025-24062

Идентификатор уязвимости	CVE-2025-24062 Уязвимость библиотеки Microsoft DWM Core Library операционных систем Windows связана с недостаточной проверкой входных данных. Эксплуатация уязвимости может позволить нарушителю повысить свои привилегии
Идентификатор типа ошибки	CWE-20
Базовый вектор	CVSS 2.0: AV:L/AC:L/Au:S/C:C/I:C/A:C
	CVSS 3.0: AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,8)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А106– Паспорт уязвимости CVE-2025-29821

Идентификатор уязвимости	CVE-2025-29821 Уязвимость программного средства для управления малым и средним бизнесом Microsoft Dynamics 365 Business Central связана с недостаточной проверкой входных данных. Эксплуатация уязвимости может позволить нарушителю получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибки	CWE-20
Базовый вектор	CVSS 2.0: AV:L/AC:L/Au:S/C:C/I:N/A:N
	CVSS 3.0: AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,6)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 5,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А107– Паспорт уязвимости CVE-2025-1767

Идентификатор уязвимости	CVE-2025-1767 Уязвимость функции gitRepo программного средства управления кластерами виртуальных машин Kubernetes связана с недостаточной проверкой входных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, оказать влияние на конфиденциальность и целостность защищаемой информации
Идентификатор типа ошибки	CWE-20
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:S/C:C/I:C/A:N
	CVSS 3.0: AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 8,5)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А108– Паспорт уязвимости CVE-2025-1736

Идентификатор уязвимости	CVE-2025-1736 Уязвимость функции check_has_header() интерпретатора языка программирования PHP связана с недостаточной проверкой входных данных при обработке заголовков HTTP-запросов. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-20
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:N/C:N/I:N/A:P
	CVSS 3.0: AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:L
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 4,3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А109– Паспорт уязвимости CVE-2025-27493

Идентификатор уязвимости	CVE-2025-27493 Уязвимость интерфейса командной строки telnet интегрированных контроллеров IP-доступа SiPass связана с недостаточной проверкой входных данных. Эксплуатация уязвимости может позволить нарушителю выполнить произвольные команды и получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибки	CWE-20
Базовый вектор	CVSS 2.0: AV:L/AC:L/Au:S/C:C/I:C/A:C
	CVSS 3.0: AV:L/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,8)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 8,2)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А110– Паспорт уязвимости CVE-2025-24514

Идентификатор уязвимости	CVE-2025-24514 Уязвимость контроллера входящего трафика в кластере Kubernetes ingress-nginx связана с недостаточной проверкой входных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, выполнить произвольный код
Идентификатор типа ошибки	CWE-20
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:S/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 9)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 8,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А111– Паспорт уязвимости CVE-2025-20227

Идентификатор уязвимости	CVE-2025-20227 Уязвимость панели инструментов Splunk Dashboard Studio веб-интерфейса Splunk Web платформы для операционного анализа Splunk Enterprise связана с недостаточной проверкой входных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, раскрыть защищаемую информацию посредством обхода модального диалогового окна предупреждения о внешнем содержимом
Идентификатор типа ошибки	CWE-20
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:S/C:P/I:N/A:N
	CVSS 3.0: AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 4,3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А112– Паспорт уязвимости CVE-2025-20146

Идентификатор уязвимости	CVE-2025-20146 Уязвимость операционной системы Cisco IOS XR маршрутизаторов Cisco ASR 9000 связана с недостаточной проверкой входных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-20
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:N/C:N/I:N/A:C
	CVSS 3.0: AV:N/AC:L/PR:N/UI:N/S:C/C:N/I:N/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,8)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 8,6)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А113– Паспорт уязвимости CVE-2025-20142

Идентификатор уязвимости	CVE-2025-20142 Уязвимость операционной системы Cisco IOS XR маршрутизаторов Cisco ASR 9000 связана с недостаточной проверкой входных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-20
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:N/C:N/I:N/A:C
	CVSS 3.0: AV:N/AC:L/PR:N/UI:N/S:C/C:N/I:N/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,8)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 8,6)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А114– Паспорт уязвимости CVE-2025-1080

Идентификатор уязвимости	CVE-2025-1080 Уязвимость схемы vnd.libreoffice.command пакета офисных программ LibreOffice связана с недостаточной проверкой входных данных. Эксплуатация уязвимости может позволить нарушителю получить несанкционированный доступ к защищаемой информации или вызвать отказ в обслуживании
Идентификатор типа ошибки	CWE-20
Базовый вектор	CVSS 2.0: AV:L/AC:H/Au:N/C:C/I:P/A:C
	CVSS 3.0: AV:L/AC:H/PR:N/UI:R/S:C/C:H/I:L/A:H
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5,9)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,6)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А115– Паспорт уязвимости CVE-2025-21375

Идентификатор уязвимости	CVE-2025-21375 Уязвимость функции formSetPPTPServer микропрограммного обеспечения маршрутизаторов Tenda AC18 связана с переполнением буфера на стеке при обработке параметра startIP. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, оказать воздействие на конфиденциальность, целостность и доступность защищаемой информации
Идентификатор типа ошибки	CWE-20
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:N/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Критический уровень опасности (базовая оценка CVSS 2.0 составляет 10)
	Критический уровень опасности (базовая оценка CVSS 3.0 составляет 9,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Данные уточняются
Участие в инцидентах	Нет

Таблица А116– Паспорт уязвимости CVE-2023-31169

Идентификатор уязвимости	CVE-2023-31169 Уязвимость средства управления устройствами энергосистемы AcSELerator QuickSet SEL-5030 связана с неправильной обработкой данных на основе стандарта кодирования Unicode. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, выполнить произвольный код
Идентификатор типа ошибки	CWE-176
Базовый вектор	CVSS 2.0: AV:N/AC:H/Au:S/C:N/I:C/A:N
	CVSS 3.0: AV:N/AC:H/PR:L/UI:R/S:U/C:N/I:H/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4,9)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 4,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А117– Паспорт уязвимости CVE-2024-54158

Идентификатор уязвимости	CVE-2024-54158 Уязвимость программного средства управления проектами и задачами JetBrains YouTrack связана с неправильным кодированием данных стандарта Punycode. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, проводить спуфинг-атаки
Идентификатор типа ошибки	CWE-173
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:S/C:N/I:P/A:N
	CVSS 3.0: AV:N/AC:L/PR:L/UI:R/S:U/C:N/I:L/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4)
	Низкий уровень опасности (базовая оценка CVSS 3.0 составляет 3,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А118– Паспорт уязвимости CVE-2025-27110

Идентификатор уязвимости	CVE-2025-27110 Уязвимость библиотеки Libmodsecurity3 межсетевого экрана для защиты веб-приложений ModSecurity связана с некорректной обработкой HTML-сущностей в ходе декодирования. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, обойти существующие ограничения безопасности путем отправки HTML-сущностей, содержащих ведущие нули
Идентификатор типа ошибки	CWE-172
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:N/C:N/I:C/A:N
	CVSS 3.0: AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,8)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А119– Паспорт уязвимости CVE-2022-26137

Идентификатор уязвимости	CVE-2022-26137 Уязвимость компонента Servlet Filter программных продуктов обработки данных Atlassian Jira, Jira Service Management, Confluence, Bitbucket, Bamboo, Crowd, Fisheye и Crucible связана с неправильным порядком поведения. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, обойти процедуру аутентификации и проводить межсайтовый скриптинг
Идентификатор типа ошибки	CWE-180
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:N/C:P/I:P/A:P
	CVSS 3.0: AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,5)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А120– Паспорт уязвимости CVE-2022-26136

Идентификатор уязвимости	CVE-2022-26136 Уязвимость программных продуктов обработки данных Atlassian Jira, Jira Service Management, Confluence, Bitbucket, Bamboo, Crowd, Fisheye и Crucible связана с неправильным порядком поведения. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, обойти процедуру аутентификации и проводить межсайтовый скриптинг
Идентификатор типа ошибки	CWE-180
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:N/C:N/I:P/A:N
	CVSS 3.0: AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 5)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 5,3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А121– Паспорт уязвимости CVE-2024-20278

Идентификатор уязвимости	CVE-2024-20278 Уязвимость реализации протокола NETCONF операционных систем Cisco IOS XE связана с использованием неполного чёрного списка при обработке входных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, повысить свои привилегии до уровня root
Идентификатор типа ошибки	CWE-184
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:S/C:C/I:C/A:N
	CVSS 3.0: AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:N
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 8,5)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А122– Паспорт уязвимости CVE-2024-30103

Идентификатор уязвимости	CVE-2024-30103 Уязвимость почтового клиента Microsoft Outlook для операционных систем Windows связана с использованием неполного чёрного списка при обработке входных данных. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, выполнить произвольный код путём создания специально сформированных DLL-файлов
Идентификатор типа ошибки	CWE-184
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:S/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 9)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 8,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует в открытом доступе
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А123– Паспорт уязвимости CVE-2025-29822

Идентификатор уязвимости	CVE-2025-29822 Уязвимость пакетов программ Microsoft Office и 365 Apps for Enterprise связана с использованием неполного чёрного списка. Эксплуатация уязвимости может позволить нарушителю обойти ограничения безопасности
Идентификатор типа ошибки	CWE-184
Базовый вектор	CVSS 2.0: AV:L/AC:L/Au:N/C:C/I:C/A:C
	CVSS 3.0: AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 7,2)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,8)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А124– Паспорт уязвимости CVE-2024-47565

Идентификатор уязвимости	CVE-2024-47565 Уязвимость программного обеспечения для обеспечения безопасности Siemens SINEC Security Monitor связана с неправильной проверкой соответствия введенных пользователем данных списку допустимых значений. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, нарушить целостность конфигурации уязвимого приложения
Идентификатор типа ошибки	CWE-183
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:S/C:N/I:P/A:N
	CVSS 3.0: AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 4)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 4,3)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А125– Паспорт уязвимости CVE-2023-23844

Идентификатор уязвимости	CVE-2023-23844 Уязвимость класса BlacklistedFilesChecker программного обеспечения сетевого мониторинга SolarWinds Orion Platform связана с недостаточным сравнением. Эксплуатация уязвимости позволяет нарушителю, действующему удаленно, выполнить произвольный код в контексте SYSTEM.
Идентификатор типа ошибки	CWE-697
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:M/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 8,3)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,2)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А126– Паспорт уязвимости CVE-2023-23843

Идентификатор уязвимости	CVE-2023-23843 Уязвимость метода UpdateActionsProperties программного обеспечения сетевого мониторинга SolarWinds Orion Platform связана с недостаточным сравнением. Эксплуатация уязвимости позволяет нарушителю, действующему удаленно, выполнить произвольный код в контексте NETWORK SERVICE.
Идентификатор типа ошибки	CWE-697
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:M/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 8,3)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,2)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А127– Паспорт уязвимости CVE-2023-40037

Идентификатор уязвимости	CVE-2023-40037 Уязвимость платформы обработки данных Apache NiFi связана с недостаточным сравнением. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, получить несанкционированный доступ к защищаемой информации
Идентификатор типа ошибки	CWE-697
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:S/C:N/I:C/A:N
	CVSS 3.0: AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:N
Уровень опасности уязвимости	Средний уровень опасности (базовая оценка CVSS 2.0 составляет 6,8)
	Средний уровень опасности (базовая оценка CVSS 3.0 составляет 6,5)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А128– Паспорт уязвимости CVE-2023-23840

Идентификатор уязвимости	CVE-2023-23840 Уязвимость метода UpdateAction программного обеспечения сетевого мониторинга SolarWinds Orion Platform связана с некорректным сравнением строк. Эксплуатация уязвимости может позволить нарушителю, действующему удалённо, выполнить произвольный код с привилегиями сетевой службы (NETWORK SERVICE)
Идентификатор типа ошибки	CWE-697
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:M/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 8,3)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,2)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

Таблица А129– Паспорт уязвимости CVE-2023-33225

Идентификатор уязвимости	CVE-2023-33225 Уязвимость программного обеспечения сетевого мониторинга и управления ИТ-инфраструктурой SolarWinds Platform связана с недостаточным сравнением. Эксплуатация уязвимости позволяет нарушителю, действующему удаленно, выполнить произвольные команды с привилегиями SYSTEM
Идентификатор типа ошибки	CWE-697
Базовый вектор	CVSS 2.0: AV:N/AC:L/Au:M/C:C/I:C/A:C
	CVSS 3.0: AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H
Уровень опасности уязвимости	Высокий уровень опасности (базовая оценка CVSS 2.0 составляет 8,3)
	Высокий уровень опасности (базовая оценка CVSS 3.0 составляет 7,2)
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Данные уточняются
Способ устранения	Обновление программного обеспечения
Участие в инцидентах	Нет

ПРИЛОЖЕНИЕ Б

Таблица Б1 – Организационный регламент противодействия шаблона атаки CAPEC-44

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
1	2	3	4
Первоначальный Доступ	Злоумышленник предпринял попытки получения доступа (T1190) через эксплуатацию уязвимостей в микропрограммном обеспечении маршрутизаторов Tenda моделей AC6, A18 и A15 (CVE-2025-1814, CVE-2025-0848, CVE-2025-0566). Уязвимости связаны с выходом за границы буфера и переполнением стека при обработке определенных параметров, что позволило удалённому злоумышленнику выполнить произвольный код либо вызвать отказ в обслуживании.	1. Немедленно заблокировали IP-адреса и сетевые сеансы, с которых исходили подозрительные запросы, на уровне брандмауэра и системы предупреждения вторжений. 2. Временно ограничили или отключили доступ к уязвимым маршрутизатором из внешних сетей для предотвращения дальнейшего использования. 3. Осуществили детальный анализ логов маршрутизаторов и сетевого трафика для выявления масштабов атаки и определения возможных последствий эксплуатации уязвимостей.	1. Произвели установку официальных патчей и микропрограммного обеспечения на всех затронутых моделей маршрутизаторов для устранения обнаруженных уязвимостей. 2. Усилили меры контроля доступа к сетевому оборудованию, в том числе посредством внедрения многофакторной аутентификации и ограничения доступа по IP-адресам. 3. Пересмотрели и обновили правила фильтрации трафика, чтобы пресечь попытки эксплуатации подобных уязвимостей в будущем.
Выполнение	Злоумышленник предпринял атаку, задействовав недостатки в разных компонентах системы, касающихся исполнения команд и скриптов (T1059), в том числе интерпретаторы командной строки и JavaScript (T1059.007), и также недостатки в клиентском программном обеспечении (T1203). В частности, были выявлены попытки применения эксплуатирующих уязвимостей: CVE-2025-24153, CVE-2023-45133, CVE-2025-0753,	1. Немедленно изолировали затронутые системы и клиентские устройства для предотвращения дальнейшего выполнения вредоносных команд и распространения атаки. 2. Блокировали источники атак на уровне брандмауэра и системы обнаружения вторжений, ограничив доступ к уязвимым сервисам и устройствам. 3. Произвели анализ логов и трассировки	1. Установили все доступные обновления и патчи для операционных систем, интерпретаторов команд и клиентского ПО, устранив обнаруженные уязвимости. 2. Усилили меры контроля доступа, включая внедрение многофакторной аутентификации и ограничение прав пользователей на выполнение важных команд и скриптов. 3. Обновили политики безопасности и правила фильтрации трафика, чтобы блокировать попытки эксплуатации аналогичных уязвимостей в дальнейшем.

Продолжение таблицы Б1

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
1	2	3	4
	CVE-2025-1539 и CVE-2025-1538 где. наблюдалась необычная активность в форме специально составленных запросов и команд, нацеленных на эксплуатацию уязвимостей.	выполнения команд для выявления характера и объема выполненных злоумышленником действий.	
Повышение привилегий	Злоумышленник осуществил повышение привилегий (T1068) на устройствах маршрутизаторов EDIMAX RE11S, эксплуатируя несколько уязвимостей микропрограммного обеспечения, включая CVE-2025-22907, CVE-2025-22916 и CVE-2025-22904. Эти уязвимости связаны с некорректной обработкой входящих данных при копировании буфера в функциях formWlSiteSurvey, formPPPoESetup и setWAN, что дало возможность удалённому нарушителю исполнить произвольный код или вызвать отказ в обслуживании.	1. Немедленно изолировали затронутые маршрутизаторы, чтобы предотвратить дальнейшее выполнение вредоносного кода и распространение атаки. 2. Заблокировали IP-адреса и сессии, с которых предпринимались попытки эксплуатации уязвимостей, на уровне межсетевого экрана и системы обнаружения вторжений. 3. Провели подробный анализ журналов событий и системных логов для выявления характера и объёма действий злоумышленника.	1. Произвели установку официальных обновлений и патчей микропрограммного обеспечения на всех затронутых маршрутизаторах для устранения уязвимостей. 2. Усилили контроль доступа к сетевому оборудованию, внедрив многофакторную аутентификацию и ограничив полномочия пользователей на выполнение критичных операций. 3. Обновили правила фильтрации трафика для блокировки подобных атак в дальнейшем.
Предотвращение обнаружения	Злоумышленник применил методы сокрытия следов (T1574, T1211 и T1078) и эксплуатации уязвимостей в различных компонентах инфраструктуры для скрытия своих действий и получения несанкционированного доступа к важным ресурсам. В ходе атаки были использованы уязвимости, включая CVE-2025-1215, CVE-2023-28936, CVE-2025-0285, CVE-2025-0927 CVE-2024-23903 и CVE-2024-41958, затрагивающие процедуры	1. Немедленно изолировали скомпрометированные системы и сервисы от базовой инфраструктуры для предотвращения дальнейшего распространения атак и сокрытия действий злоумышленника. 2. Заблокировали подозрительные IP-адреса и аккаунты, участвующие в атаках, на уровне брандмауэра и систем контроля доступа.	1. Установили патчи и обновления для уязвимых элементов — текстового редактора, видеоконференцсвязи, драйверов и программного обеспечения. 2. Усилили процессы аутентификации и контроля доступа, включая пересмотр и усиление механизмов двухфакторной аутентификации, а также внедрение дополнительных инструментов мониторинга и обнаружения подозрительной активности.

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
1	2	3	4
	авторизации и механизм двухфакторной аутентификации в Jenkins и mailcow соответственно. Эксплуатация данных уязвимостей сопровождалась попытками обхода систем защиты и маскировкой вредоносной активности.	3. Провели тщательный анализ системных журналов, дампов памяти и сетевого трафика для выявления всех следов активности злоумышленника и определения масштаба причиненного ущерба.	3. Обновили политики безопасности и правила фильтрации трафика для предотвращения повторных попыток использования подобных уязвимостей.
Перемещение внутри периметра	Злоумышленник произвел перемещение внутри периметра (T1210), применяя уязвимости в микропрограммном обеспечении маршрутизаторов Tenda моделей AC8 и AC6, а именно CVE-2025-25510 и CVE-2025-25505. Обе уязвимости сопряжены с выходом за пределы буфера при обработке параметров urls и callback, что дало возможность удаленному нарушителю инициировать отказ в обслуживании и расширить контроль над сетевыми устройствами.	1. Немедленно изолировали затронутые маршрутизаторы от прочей инфраструктуры для предотвращения дальнейшего распространения вредоносной активности. 2. Заблокировали IP-адреса и сессии, с которых поступали подозрительные запросы, на уровне брандмауэра и системы обнаружения вторжений. 3. Осуществили тщательный анализ системных журналов и сетевого трафика для выявления точек входа и путей перемещения злоумышленника внутри сети.	1. Установили все необходимые патчи и обновления микропрограммного обеспечения на маршрутизаторе Tenda для устранения обнаруженных уязвимостей. 2. Усилили контроль доступа к сетевому оборудованию, внедрив многофакторную аутентификацию и ограничив полномочия пользователей на конфигурацию устройств. 3. Обновили политики сетевой безопасности и правила фильтрации трафика, чтобы исключить повторные попытки эксплуатации подобных уязвимостей
Деструктивное воздействие	Злоумышленник совершил вредоносное воздействие (T1499, T1489 и T1498) важных элементов инфраструктуры, применяя уязвимости CVE-2025-24131, CVE-2025-25472, CVE-2025-25900, CVE-2025-24151, CVE-2025-24126, CVE-2025-25662 и CVE-2023-49994, касающиеся переполнения буфера и ошибок обработки информации в разных системах и приложениях. Использование этих.	1. Немедленно изолировали затронутые системы и устройства от основной сети для предотвращения дальнейшего распространения сбоев и минимизации воздействия на пользователей. 2. Отключили или ограничили функционирование уязвимых сервисов, чтобы предотвратить следующие попытки эксплуатации.	1. Установили все нужные патчи и обновления программного обеспечения, исправив обнаруженные уязвимости во всех затронутых компонентах. 2. Усилили защиту инфраструктуры, внедрив дополнительные меры безопасности, включая многофакторную аутентификацию, ужесточённый контроль доступа и обновлённые правила фильтрации трафика. 3. Осуществили повторное тестирование на

Продолжение таблицы Б1

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
1	2	3	4
	уязвимостей вызвало отказы в обслуживании, нарушая доступность сервисов и уменьшая качество функционирования инфраструктуры	3. Произвели детальный анализ системных журналов, дампов памяти и сетевого трафика для выявления источников атак и оценки масштаба инцидента.	проникновение и аудит безопасности для оценки действенности принятых мер и выявления потенциальных слабых мест в системе защиты.

Таблица Б2 – Организационный регламент противодействия шаблона атаки CAPEC-42

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
1	2	3	4
Разведка	Злоумышленник осуществил активное сканирование (T1595) информационной инфраструктуры для выявления слабых мест для последующей эксплуатации. В ходе атаки были зарегистрированы попытки эксплуатации уязвимостей CVE-2025-24124 и CVE-2025-0938, позволяющие удаленному нарушителю повысить свои привилегии за счет неправильной проверки входных данных.	1. Немедленно заблокировали IP-адреса и сетевые сеансы, с которых производилось сканирование, на уровне брандмауэра и системы обнаружения вторжений. 2. Усилили наблюдение за сетевым трафиком и журналами систем для оперативного обнаружения повторных попыток сканирования. 3. Осуществили анализ журналов безопасности и системных логов для оценки масштабов и направленности атаки.	1. Установили всевозможные обновления и патчи для устранения уязвимости в компоненте CoreMedia и устранили неполадки в программном обеспечении, применяющем функции urllib.parse. 2. Укрепили контроль доступа и полномочия пользователей, сведя к минимуму шансы повышения привилегий через уязвимые функции. 3. Обновили правила фильтрации трафика и политики безопасности для предотвращения атак в дальнейшем.
Первоначальный доступ	Злоумышленник осуществил доступ (T1190) к сети, применяя ряд уязвимостей в общедоступных приложениях сетевого оборудования. В частности, были зафиксированы попытки использования уязвимостей	1. Немедленно изолировали уязвимые устройства и сервисы от основной сети для предотвращения дальнейшего распространения атаки и ограничения доступа злоумышленника. 2. Заблокировали IP-адреса и сессии, с	1. Установили патчи и обновления микропрограммного обеспечения маршрутизаторов и серверных приложений. 2. Усилили меры контроля доступа и аутентификации, включая внедрение многофакторной аутентификации и

Продолжение таблицы Б2

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
1	2	3	4
	CVE-2025-3538, CVE-2025-3161, CVE-2024-23828 и CVE-2024-22319 в системе управления правилами IBM Operational Decision Manager, которые позволяют удалённое выполнение произвольного кода.	которых происходили попытки эксплуатации, на уровне брандмауэра и системы обнаружения вторжений. 3. Провели подробный анализ журналов событий и сетевого трафика для выявления объёма и характера вредоносной активности.	ограничение полномочий пользователей. 3. Обновили правила фильтрации трафика и политики защиты для предотвращения повторных попыток эксплуатации аналогичных уязвимостей.
Выполнение	Злоумышленник осуществил попытки произвольного кода через эксплуатацию уязвимостей (CVE-2025-21677, CVE-2025-21678, CVE-2025-20184, CVE-2024-1619, CVE-2025-1365, CVE-2025-25663, CVE-2025-3346, CVE-2024-21687, CVE-2024-38366, CVE-2025-23397, CVE-2025-23398, CVE-2025-23400) для запуска контейнера (T1610), выполнения команд с участием пользователя (T1204), использования интерпретаторов командной строки и сценариев (T1059) и эксплуатации уязвимостей клиентского ПО (T1203). Инцидент повлек нарушение стабильности работы ИТ-инфраструктуры и временную потерю услуг для конечных пользователей.	1. Изолировали затронутые серверы и устройства. 2. Осуществили детальный анализ лог-файлов, журналов событий и перехваченных пакетов для установления точной последовательности действий злоумышленника. 3. Осуществили переустановку паролей для всех учетных записей, имеющие административные полномочия.	1. Установили все доступные патчи безопасности и обновления ПО. 2. Усилили правила доступа, внедрили обязательные механизмы двухфакторной аутентификации и ограничили права на запуск программ. 3. Провели дополнительное тестирование на предмет скрытых угроз и проверки устойчивости системы. 4. Пересмотрели настройки брандмауэров и IPS (Intrusion Prevention System), фильтров и сигнатурных алгоритмов обнаружения аномалий.
Повышение привилегий	Злоумышленник применил уязвимости CVE-2025-1365, CVE-2024-21900, CVE-2024-39483 и CVE-2024-20429 для повышения привилегий в системе (T1068), что позволило нарушителю выполнить произвольные команды и вызвать	1. Немедленно изолировали все затронутые системы информационной инфраструктуры, чтобы предотвратить последующие атаки и ограничить распространение	1. Установили все доступные патчи безопасности и обновления ПО. 2. Ввели дополнительные меры защиты на всех серверах инфраструктуры, включая двухфакторную аутентификацию, усиленный контроль доступа и правила фильтрации трафика.

Продолжение таблицы Б2

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
1	2	3	4
	дополнительные отказы в работе сервисов. Это привело к отключению важных систем и нарушению обслуживания пользователей.	вредоносного воздействия. 2. Отключили либо изолировали затронутые серверы из сети для предотвращения дальнейшего распространения негативных последствий атаки и минимизации ущерба. 3. Провели детальный анализ системных журналов и дампов памяти на затронутых серверах для определения точных действий злоумышленника и выявления использованных уязвимостей.	3. Осуществили повторное тестирование на проникновение для оценки эффективности принятых мер и выявления возможных слабых мест в системе защиты.
Предотвращение обнаружения	Злоумышленник предпринял комплексную атаку, применяя следующие уязвимости (CVE-2025-21230, CVE-2025-21280, CVE-2025-21284, CVE-2025-21194, CVE-2025-21235, CVE-2025-21234, CVE-2025-21686, CVE-2025-27834, CVE-2025-27830, CVE-2025-25898, CVE-2025-28398, CVE-2025-0514, CVE-2025-20183), дающие возможность ослаблять защитные механизмы (T1562), обходить механизмы контроля привилегий (T1548), перехватывать поток исполнения (T1574) и загружать отражённый код (T1620). Атака привела к снижению производительности и отказу отдельных сервисов.	1. Изолировали серверы и рабочие станции. 2. Фиксация и сбор свидетельства происшествия — снимки оперативной памяти, журналы событий, файловые отпечатки, а также сетевые пакеты для последующего анализа.	1. Установили патчи и обновления ПО. 2. Осуществили мониторинг изменений поведения системы, установили инструменты IDS/IPS, внедрили решения для отслеживания подозрительных действий. 3. Провели тесты на проникновение и безопасность..

Продолжение таблицы Б2

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
1	2	3	4
Перемещение внутри периметра	Злоумышленник применил уязвимости (CVE-2025-2619, CVE-2025-2620, CVE-2025-2618, CVE-2025-2621) в удалённых сервисах беспроводных ретрансляторов D-Link DAP-1620 (T1210), позволившие ему передвигаться внутри периметра сети и вызывать отказ в обслуживании или исполнять произвольный код.	1. Отключили зараженные беспроводные повторители. 2. Начали фиксировать всю доступную информацию, включая логи, дампы памяти и трафик, необходимые для проведения анализа. 3. Остановили все автоматические процессы обновления прошивки и внесли ограничения на сетевое взаимодействие между устройствами, чтобы исключить угрозу переноса инфекции. 4. Выявили состояние смежных сетей и зон, где используются аналогичные устройства.	1. Установили официальные обновления и патчи. 2. Произвели полную перезагрузку устройств в первоначальное состояние, предварительно произведя очистку всех модулей и флеш-памяти. 3. Активировали инструменты постоянного наблюдения за активностью и состоянием приборов, запустили ежедневные проверки целостности прошивок и аппаратных компонентов. 4. Обновили принципы сегментирования сети, ввели программно-аппаратные барьеры между зонами ответственности и разные уровни доступа для различных типов оборудования.
Организация управления	Злоумышленник применил уязвимости (CVE-2025-0528, CVE-2025-1192, CVE-2025-3249) в протоколах прикладного уровня (T1071), дающих возможность исполнить произвольные команды или спровоцировать отказ в обслуживании на устройствах Tenda AC8, AC10, AC18 и TOTOLINK A6000R. Этот инцидент привел к риску раскрытия информации.	1. Отключили маршрутизаторы и веб-серверы, подвергшиеся атаке, оперативно отсоединили от сети, что гарантировало прекращение последующих нарушений и сохранение данных. 2. Произвели сбор информации: лог-файлов, журналов событий, содержимых памяти пострадавших устройств.	1. Установили обновление и патчи. 2. Сменили прошивку маршрутизаторов, которые были сброшены до заводских установок и заново сконфигурировали с применением самой свежей версии прошивки.
Деструктивное воздействие	Злоумышленник применил уязвимости (CVE-2024-53263, CVE-2025-21370, CVE-2024-39784, CVE-2024-39785, CVE-2025-3328, CVE-2025-3346, CVE-2025-25456, CVE-2025-20115, CVE-2025-21350, CVE-2025-24319,	1. Ограничили доступ пользователей и устройств к информационной инфраструктуре. 2. Обнаружили признаки атаки посредством анализа.	1. Восстановили работоспособность систем и сервисов. 2. Проверили сохранность резервных копий. 3. Пересмотрели и укрепили политику информационной безопасности.

Продолжение таблицы Б2

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
1	2	3	4
	CVE-2025-24970, CVE-2025-21873 и CVE-2025-21916. Данные уязвимости связаны с недостаточной нейтрализацией элементов в выходных данных разных микропрограммных обеспечений и способны позволить нарушителю получить несанкционированный доступ к учетным данным пользователя, выполнять произвольные команды и вызывать отказ в обслуживании (T1565, T1499, T1485 и T1495).	журналов событий и сетевого трафика. 3. Отключили на время сервисы и приложения, использующие уязвимые компоненты	

Таблица Б3 – Организационный регламент противодействия шаблона атаки CAPEC-71

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
1	2	3	4
Первоначальный доступ	Злоумышленник получил доступ к внешним сервисам удалённого доступа (T1133), фишингу (T1566) и общедоступным приложениям (T1190). Были обнаружены попытки использования уязвимостей CVE-2025-1767, CVE-2025-27493, CVE-2023-23840, CVE-2024-33510, CVE-2022-26137,CVE-2022-26136, CVE-2024-12962, CVE-2024-12967 и CVE-2024-12968, что дало возможность получить несанкционированный доступ и выполнить произвольный код.	1. Немедленно заблокировали внешние подключения службам и приложениям. 2. Изучили журнал событий. 3. Установили последние исправления и обновления для уязвимого ПО и платформ.	1. Возобновили работоспособность программного обеспечения и базы данных из резервных копий. 2. Провели тестирование работы систем и обеспечили устойчивость к новым попыткам атак. 3. Провели анализ архитектуры приложений и устранение обнаруженных уязвимостей безопасности.

Продолжение таблицы Б3

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
1	2	3	4
Выполнение	Злоумышленник осуществил выполнение произвольного кода, применив уязвимости в системных службах (T1569), с вовлечением пользователя (T1204) и через интерпретаторы командной строки и скриптов (T1059). Были зафиксированы попытки эксплуатации уязвимости CVE-2025-21375, CVE-2023-40037, CVE-2023-33225, CVE-2025-1080, CVE-2023-31169, CVE-2024-30103,CVE-2024-10914, CVE-2024-10915 и CVE-2024-50572.	1. Ограничили доступ к уязвимым службам и устройствам, заблокировав внешнее подключение. 2. Запретили применение устаревших версий ПО и отключили функции. 3. Выполнили проверку журналов безопасности для обнаружения подозрительной деятельности.	1. Внедрили новые патчи и обновление для уязвимых элементов. 2. Восстановили конфигурацию служб и баз данных из проверенных резервных копий. 3. Провели углубленное тестирование всей инфраструктуры на предмет скрытых уязвимостей.
Повышение привилегий	Злоумышленник успешно повысил свои права на взломанных системах, применив уязвимости CVE-2025-24073 (Microsoft DWM Core Library), CVE-2025-29811 (Windows Mobile Broadband Driver) и CVE-2025-26647 (Kerberos в Windows), что дало возможность обойти механизмы контроля доступа (T1548). Дополнительно для закрепления доступа и запуска вредоносного кода применялись техники выполнения по событию (T1546) с использованием уязвимостей CVE-2024-54158 (JetBrains YouTrack), CVE-2024-20278 (Cisco IOS XE NETCONF) и CVE-2024-47565 (Siemens SINEC Security Monitor). Также злоумышленник создавал и изменял системные процессы (T1543), используя уязвимости CVE-2024-12350 (Jfinal CMS), CVE-2025-24446 (ColdFusion) и	1. Ограничили доступ к уязвимым узлам и системам. 2. Осуществили углубленный анализ журнала событий для выявления следов проникновения. 3. Применили доступные исправления и обновили ПО до последней версии. 4. Сформировали правила брандмауэра для блокировки конкретных запросов и уязвимых путей.	1. Устранили повреждения и гарантировали штатное функционирование систем. 2. Восстановили системы из проверенных резервных копий. 3. Улучшили способы мониторинга и журналирования для оперативного обнаружения угроз. 4. Пересмотрели полномочия пользователей и настроить более строгие политики.

Продолжение таблицы Б3

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
1	2	3	4
	CVE-2025-27489 (Microsoft Azure Stack HCI), что дало возможность получить удалённый произвольный код и увеличить привилегии до уровня администратора.		
Предотвращение обнаружения	Злоумышленник осуществил комплексную атаку, применив уязвимости CVE-2024-50340, CVE-2024-11124, CVE-2024-11234, CVE-2025-24074, CVE-2025-24060, CVE-2025-24062, CVE-2025-31477 и CVE-2025-1736. Данные уязвимости позволили ему ослабить защитные механизмы (T1562), перехватить поток исполнения (T1574) и исполнить произвольный код (T1620). В итоге атаки злоумышленник сумел получить доступ к критически важным системам и выполнить произвольные команды, что повлекло за собой снижение производительности и отказ отдельных сервисов.	1. Изолировали все элементы, показавшие признаки атаки, включая базы данных и прикладные системы. 2. Перекрыли каналы обмена информацией между сегментами сети, чтобы остановить распространение атаки. 3. Увеличили глубину мониторинга и аналитику сетевого трафика для выявления скрытых каналов связи. 4. Активизировали процедуры EDR (Endpoint Detection & Response) и оперативно отреагировали на новые инциденты.	1. Осуществили полную ревизию всех установленных пакетов и библиотек, обновили до последних версий. 2. Проверили и откорректировали параметры безопасности базовых корпоративных решений (PHP, SQL-серверы, платформы Symfony и Umbraco). 3. Сформировали инструкции по работе с обнаруженными механизмами защиты от отражённой загрузки кода и модификации HTTP-заголовков. 4. Рассмотрели возможность внедрения автоматизированных систем блокировки попыток эксплойта.
Получение учетных данных	Злоумышленник получил несанкционированный доступ к аккаунтам, применяя уязвимости CVE-2025-24058 (Microsoft DWM Core Library), CVE-2025-27110 (библиотека Libmodsecurity3 для ModSecurity) и CVE-2025-29822 (Microsoft Office и 365 Apps for Enterprise). Использование этих уязвимостей позволило обойти ограничения защиты и получить доступ к открытым данным аккаунтов (T1552), что ставит под угрозу конфиденциальность и целостность систем.	1. Произвели анализ журналов и метаданных для обнаружения точного масштаба вторжения. 2. Активировали превентивные меры и усиленную фильтрацию сетевого трафика.	1. Использовали патчи и обновления. 2. Усилили шифрование и двухфакторную аутентификацию для всех учетных записей. 3. Проконтролировали функционирование и настройку файерволов и иных способов защиты.

Продолжение таблицы Б3

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
1	2	3	4
Сбор данных	Злоумышленник произвёл сбор данных с локальных систем, применяя уязвимости CVE-2025-29821 (Microsoft Dynamics 365 Business Central), CVE-2025-24514 (контроллер входящего трафика Kubernetes ingress-nginx) и CVE-2025-20227 (панель инструментов Splunk Dashboard Studio). Использование данных уязвимостей дало возможность получить несанкционированный доступ к информации и выполнить произвольный код, что привело к раскрытию конфиденциальных данных (T1005).	1. Ограничили доступ к серверам и приложения. 2. Установили масштабы собранной информации и проверили, какие конкретно данные были украдены. 3. Задействовали дополнительные меры мониторинга и анализа для обнаружения повторной активности злоумышленника.	1. Внедрили новые патчи и обновление для уязвимых элементов. 2. Проконтролировали сохранность копий данных и восстановили требуемую информацию из проверенных источников. 3. Усовершенствовали механизмы идентификации и авторизации, настроили многоуровневую защиту данных. 4. Обеспечили обучение сотрудников правилам безопасной работы с конфиденциальной информацией и реагирования на угрозы.
Организация управления	Злоумышленник осуществил организацию управления атакой, применяя протоколы прикладного уровня (T1071) для удалённого взаимодействия с инфраструктурой. В ходе атаки были использованы уязвимости CVE-2024-12966 (обход аутентификации в командной строке Skupper Red Hat Service Interconnect), CVE-2024-12965 (удалённое исполнение произвольного кода через сценарий update_ex_detail.php в Portfolio Management System) и CVE-2023-23844 (удалённое исполнение произвольного кода с правами SYSTEM в SolarWinds Orion Platform). Эксплуатация указанных уязвимостей дала возможность злоумышленнику	1. Немедленно изолировали все активные процессы и отключили уязвимые узлы от общей сети. 2. Собрали все логи и провели глубокий анализ для определения точной картины происходящего. 3. Увеличили интенсивность наблюдения за сетевыми подключениями и поведением систем.	1. Внедрили новые патчи и обновление для уязвимых элементов. 2. Необходима замена всех паролей и ключей доступа для любых учетных записей. 3. Выполнили полное резервное копирование всей важной информации. 4. Пересмотрели стратегию безопасности и усовершенствовали способы контроля доступа и аутентификации.

Продолжение таблицы Б3

Этапность реализации кибератак, рекомендованная MITRE ATT&CK	В соответствии с MITRE этапностью регистрируемые инциденты	Меры реагирования на регистрируемые инциденты	Меры ликвидации последствий инцидентов
1	2	3	4
	получить несанкционированный доступ к защищаемой информации, изменить данные и вызвать отказ в обслуживании.		
Деструктивное воздействие	Злоумышленник инициировал точечные атаки отказа в обслуживании (T1499) на важные инфраструктурные элементы, применяя уязвимости CVE-2024-56717 (функция ocelot_ifh_set_basic() в ядре Linux), CVE-2025-20146 и CVE-2025-20142 (операционная система Cisco IOS XR на маршрутизаторах Cisco ASR 9000). Использование указанных уязвимостей позволило злоумышленнику, действующему дистанционно, инициировать отказ в обслуживании, что вызвало уменьшение доступности сетевых служб и ухудшение производительности инфраструктуры.	1. Ограничили доступ к роутерам Cisco ASR 9000 и серверам Linux. 2. Активировали дополнительные средства контроля сетевого трафика для выявления попыток эксплуатации уязвимостей. 3. Подготовили резервные пути и ресурсы для обхода возможных сбоев. 4. Заблокировали отправителей вредоносных пакетов на уровне сетевых фильтров.	1. Оперативно установили патчи и обновления для устранения уязвимостей. 2. Оценили убытки и удостоверились в стабильности работы сервисов и маршрутов. 3. Повысили устойчивость инфраструктуры путём улучшения процессов мониторинга и реагирования.